

Apuntes de **SEGURIDAD de la INFORMACIÓN**

Antonio Ocón Carreras
Carlos Rosa Remedios

© del texto:

Antonio Ocón Carreras

Carlos Rosa Remedios

Depósito Legal: GC-130-2011

Primera edición, 2011

Segunda edición, 2019

Tercera edición, 2023

Queda rigurosamente prohibida, sin la autorización escrita de los titulares del «Copyright», bajo las sanciones establecidas por las leyes, la reproducción parcial o total de esta obra por cualquier medio o procedimiento, comprendidos la reprografía y el tratamiento informático.

ÍNDICE	3
INTRODUCCIÓN A LOS CONTENIDOS	11
PRESENTACIÓN	11
OBJETIVOS	11
ESQUEMA DE CONTENIDOS DE LOS APUNTES.....	12
UA 1. SEGURIDAD DE LA INFORMACIÓN: UNA VISIÓN INTEGRAL.....	13
PRESENTACIÓN	13
OBJETIVOS	13
ESQUEMA DE CONTENIDOS	14
EXPOSICIÓN DE LOS CONTENIDOS	14
1. Contextualización. Sociedad de la información.....	14
1.1. Situación actual: cambio constante	14
1.2. Impulsores del cambio: estándares y tecnologías de bajo coste.....	14
1.3. Factores tecnológicos.....	15
1.4. Factores de tipo humano y social.....	15
1.5. Factores económicos y políticos.....	16
1.6. Industria 4.0 - la cuarta revolución industrial	16
2. seguridad de la información. Definiciones y conceptos básicos	17
2.1. De seguridad informática a seguridad de la información.....	17
2.2. Principios básicos de la seguridad	20
2.3. Preguntas clave: qué proteger, contra quien, cómo y hasta donde.....	22
2.4. Diferentes enfoques de la seguridad de la información	23
2.5. Seguridad vs privacidad: en busca del equilibrio.....	23
2.6. Seguridad a través de la oscuridad o del conocimiento.....	25
3. Visión integral de la Seguridad	26
3.1. El factor humano: Seguridad en el Personal.....	26
3.2. Seguridad física y del entorno	27
3.3. Seguridad Lógica.....	27
3.4. Seguridad organizativa: políticas de seguridad.....	28

4. Identidad digital y legal. Firma electrónica y certificados.....	28
4.1. Identificación y autenticación	28
4.2. Identidad y rastro digitales.....	29
4.3. Firma electrónica.....	30
4.4. Hacia una identidad legal: certificados digitales y DNLe.....	30
4.4.1. Certificados digitales.....	30
4.4.2. DNI electrónico.....	31
4.4.3. DNI 3.0.....	32
5. Un futuro cambiante. Nuevos desafíos de Seguridad.....	32
ACTIVIDADES DE APRENDIZAJE	35
BIBLIOGRAFÍA.....	36
EJERCICIOS DE AUTOEVALUACIÓN	37
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN	38
GLOSARIO	39

UA 2. FUNDAMENTOS EN SEGURIDAD DIGITAL..... 41

PRESENTACIÓN	41
OBJETIVOS	41
ESQUEMA DE CONTENIDOS.....	42
EXPOSICIÓN DE LOS CONTENIDOS	42
1. Criptografía	42
1.1. Conceptos básicos	42
1.2. Confidencialidad: clave simétrica.....	43
1.3. Compartición de secretos: clave asimétrica.....	45
1.4. Integridad: algoritmos de Resumen.....	47
1.5. Autenticación y No repudio. Firma digital: cifrado de resúmenes	48
1.6. Sistemas criptográficos: horizontales y verticales.....	48
1.7. Sistemas Horizontales	48
1.8. Sistemas Verticales: Infraestructuras de clave pública.....	49
1.8.1. Certificados digitales X.509.....	49
1.8.2. Autoridades de certificación. Niveles de autoridad	50
1.8.3. Tipos de Autoridades: oficiales, comerciales y gratuitas.....	51
1.8.4. Generación segura de certificados digitales	52
2. Seguridad Digital en Entorno Local.....	53
2.1. Conceptos básicos de seguridad digital en equipos de usuario	53
2.2. Cifrado de discos, volúmenes y ficheros	54

3. Seguridad Digital en Redes. LAN y WAN	55
3.1. Internet como red global, sencillez frente a seguridad.....	55
3.2. Redes de Área Local (LAN).....	56
3.2.1. Seguridad en redes inalámbricas (Wifi). De WEP a WPA3	56
3.3. Entorno extendido (WAN)	57
3.3.1. Aplicaciones de los Sistemas Horizontales.....	57
3.3.2. Aplicaciones de los sistemas verticales.....	59
4. Herramientas adicionales en seguridad digital: biometría y esteganografía	64
4.1. Biometría.....	64
4.2. Esteganografía.....	65
ACTIVIDADES	67
BIBLIOGRAFÍA	68
EJERCICIOS DE AUTOEVALUACIÓN	69
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN	70
GLOSARIO	71
UA 3. AMENAZAS A LOS SISTEMAS DE INFORMACIÓN	73
PRESENTACIÓN	73
OBJETIVOS	73
ESQUEMA DE CONTENIDOS	74
EXPOSICIÓN DE LOS CONTENIDOS	74
1. Tipos de amenazas	74
1.1. Efectos de un ataque	74
1.2. Principales motivaciones de los atacantes.....	75
1.3. Perfiles clásicos del atacante informático. Subculturas	76
1.4. Vulnerabilidades y Exploits.....	77
2. Amenazas en entorno doméstico y estaciones cliente.....	79
2.1. Ordenador Personal. Sistema Operativo.....	79
2.2. Redes domésticas. Wifi. ADSL. Internet por cable	80
3. Software Malicioso o Malware	81
3.1. Mecanismos de propagación del malware.....	82
3.1.1. Virus	82
3.1.2. Gusanos (Worms)	83
3.1.3. Troyanos o Caballos de Troya (Trojan Horses).....	83
3.1.4. Combinación de mecanismos de propagación.....	83
3.2. Tipos de Software Malicioso.....	84

3.2.1.	Instalación y ocultación. Downloaders. Backdoors. Rootkits.....	84
3.2.2.	Captura de información. Spyware. PWStealers. Keyloggers	85
3.2.3.	Captura de recursos. Bots. Botnets.....	85
3.2.4.	Publicidad. Adware. Clickers. Secuestradores de web.....	86
3.2.5.	Secuestro de información. Rogues. Ransomware	86
3.2.6.	Destrucción de información. Killers. Bombas lógicas	87
3.2.7.	Otro software no recomendable	88
3.2.8.	Profesionalización del hacking. Malware a la Carta.....	88
4.	Amenazas a la seguridad en el correo electrónico	89
4.1.	Privacidad.....	89
4.2.	Spam o correo no deseado	90
4.3.	Bulos (<i>Hoaxes</i>)	90
5.	Amenazas a la seguridad en la web y el comercio electrónico.....	90
5.1.	Navegadores web.....	91
5.2.	Privacidad. Cookies	91
5.3.	Web Hacking.....	92
5.3.1.	Phishing. Estafas por Internet.....	92
5.3.2.	Pharming. Envenenamiento del DNS (DNS Poisoning)	93
5.4.	Cross-Site Scripting (XSS)	94
6.	Nuevas amenazas. Redes sociales y Cloud Computing	94
6.1.	Redes Sociales.....	94
6.2.	Computación en la Nube (Cloud Computing)	96
7.	Ataques elaborados a los sistemas de información	96
7.1.	Recopilación de información	97
7.1.1.	Escaneo de Puertos (Port Scanning).....	97
7.1.2.	Escuchas	98
7.1.3.	Google Hacking.....	98
7.1.4.	El punto más débil. Ingeniería social (social engineering).....	98
7.2.	Identificación de vulnerabilidades	99
7.3.	Ataque. Explotación de vulnerabilidades	99
7.3.1.	Suplantación. IP, DNS y Web spoofing.....	100
7.3.2.	Inyección de código SQL.....	100
7.3.3.	Denegación de servicio (DOS y DDOS).....	100
7.4.	Continuación del Ataque	101
7.5.	Amenaza avanzada y persistente (APT)	101
	ACTIVIDADES.....	103

BIBLIOGRAFÍA	104
EJERCICIOS DE AUTOEVALUACIÓN	105
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN	106
GLOSARIO	107
UA 4. MECANISMOS DE DEFENSA	109
PRESENTACIÓN	109
OBJETIVOS	109
ESQUEMA DE CONTENIDOS	110
EXPOSICIÓN DE LOS CONTENIDOS	110
1. Desde la perspectiva doméstica	110
1.1. Recomendaciones básicas de empleo del sistema.....	110
1.1.1. Protección física.....	110
1.1.2. Configuración básica del sistema y de las aplicaciones	110
1.1.3. Políticas de cuentas de usuario, contraseñas y copias de seguridad	111
1.1.4. Actualizaciones del sistema y de las aplicaciones.....	111
1.2. Conexión a Internet. Fibra, Cable, ADSL y Redes Wifi	111
1.2.1. Recomendaciones de configuración de un router	112
1.2.2. Configuración básica de una Wifi doméstica o de Pyme.....	113
1.3. Protección contra el malware. Suites de seguridad	114
1.4. Recomendaciones en el empleo de dispositivos móviles.....	115
2. Seguridad en el uso del correo electrónico	117
2.1. Recomendaciones generales.....	117
2.2. Recomendaciones específicas para la recepción	118
2.3. Recomendaciones específicas para el envío.....	119
3. Navegación segura	119
3.1. Recomendaciones relativas a la web y el comercio electrónico	119
3.2. Uso racional de la privacidad en redes sociales	121
4. Protegiendo la organización: defensa perimetral.....	123
4.1. Frontera de contención: Firewalls	123
4.1.1. Intranet corporativa	123
4.1.2. Zona desmilitarizada: DMZ.....	124
4.2. Acceso seguro a la organización: Redes Privadas Virtuales (VPN).....	124
4.3. Detección de intrusiones: IDS e IPS	124
4.4. Hacking ético, análisis de seguridad y pruebas de penetración.....	125
5. Protección desde la perspectiva gubernamental.....	126

5.1. Agencia Europea de Seguridad de las redes de la información (ENISA).....	126
5.2. Mando Conjunto de Ciberdefensa	127
5.3. SOC's, CERT y CSIRT	127
5.3.1. Security Operation Center (SOC)	127
5.3.2. Centros de Respuesta ante incidentes: CERTs y CSIRTs	127
5.3.3. CERTs y CSIRTs en España	128
5.3.4. CERTs en el ámbito internacional.....	128
5.4. Centro Criptológico Nacional (CCN).....	129
5.4.1. CCN-CERT.....	129
5.5. Centro Nacional de Protección de Infraestructuras Críticas (CNPIC).....	130
5.6. Instituto Nacional de Ciberseguridad (INCIBE)	130
5.6.1. Incibe-CERT	131
5.6.2. OSI – Oficina de Seguridad del Internauta	131
5.7. Agencia Española de Protección de Datos (AEPD).....	131
ACTIVIDADES.....	133
BIBLIOGRAFÍA.....	134
EJERCICIOS DE AUTOEVALUACIÓN	135
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN	136
GLOSARIO	137
UA 5. INSTRUMENTOS PARA LA GESTIÓN DE LA SEGURIDAD	139
PRESENTACIÓN	139
OBJETIVOS	139
ESQUEMA DE CONTENIDOS.....	140
EXPOSICIÓN DE LOS CONTENIDOS	140
1. Buenas prácticas en TIs. La visión de ITIL.....	140
1.1. La biblioteca ITIL.....	141
1.2. Terminología básica.....	141
1.3. El enfoque de ITIL v3 2011. El ciclo de vida del servicio	142
1.4. ITIL v4 y la Industria 4.0.....	144
2. Análisis de Riesgos	144
2.1. Terminología básica.....	145
2.2. Definición de riesgo	145
2.3. Tipos de riesgos.....	146
2.4. ¿Qué esperamos del análisis de riesgos?	146
2.5. Desarrollo.....	146

2.6. Metodologías para la implementación	149
2.7. Tipología de los análisis de riesgos.....	150
3. Auditoría de seguridad.....	151
3.1. Definición	151
3.2. Alcance	152
3.3. Objetivos.....	152
3.4. Tipos de auditoría	152
3.5. Desarrollo y ejecución.....	153
4. Plan director de seguridad.....	153
4.1. Objetivos.....	154
4.2. Factores clave para el éxito.....	154
4.3. Desarrollo y resultados	155
5. Plan de respuesta ante incidentes.....	155
6. Plan de continuidad del negocio	156
6.1. Objetivos.....	156
6.2. Fases para el desarrollo de un PCN	157
ACTIVIDADES	159
BIBLIOGRAFÍA	160
EJERCICIOS DE AUTOEVALUACIÓN	161
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN	162
GLOSARIO	163
UA 6. LEGISLACIÓN Y NORMATIVA EN SEGURIDAD DE LA INFORMACIÓN.....	165
PRESENTACIÓN	165
OBJETIVOS	165
ESQUEMA DE CONTENIDOS	166
EXPOSICIÓN DE LOS CONTENIDOS	166
1. Legislación.....	166
1.1. Infraestructuras críticas.....	166
1.2. Protección de datos personales.....	167
1.3. Ciberseguridad.....	167
1.4. Comunicaciones y administración electrónica.....	168
1.5. Directiva NIS	170
1.6. Reglamento Europeo de Protección de Datos.....	171
2. Esquema Nacional de Seguridad	172
2.1. Introducción	172

2.2. Ámbito Legal y de Aplicación.....	172
2.3. Elementos Básicos del ENS.....	173
2.4. Esquema general de implantación.....	173
2.5. Declaración de conformidad.....	174
3. Normativa ISO 27000 en el ámbito de la seguridad de la información.....	175
3.1. Introducción.....	175
3.2. La norma ISO 27.001.....	175
3.3. La norma ISO 27002.....	177
3.4. El SGSI como eje del proceso de implantación de la ISO 27001.....	177
3.4.1. Documentación relativa a un SGSI.....	178
3.4.2. Etapas o fases para el establecimiento de un SGSI.....	178
3.5. Adecuación de la gestión según ISO 27000 al ENS.....	183
ACTIVIDADES.....	185
BIBLIOGRAFÍA.....	186
EJERCICIOS DE AUTOEVALUACIÓN.....	187
SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN.....	188
GLOSARIO.....	189

Introducción a los contenidos

PRESENTACIÓN

Estos apuntes deben entenderse dentro de un enfoque basado en la seguridad de la información como aspecto básico de la seguridad de individuos, organizaciones y estados, en la situación de cambio constante provocada por la irrupción de las tecnologías de la información en todos los aspectos de la actividad humana, motivando el desarrollo de la denominada sociedad de la información o del conocimiento.

Así se estudian los conceptos y definiciones básicas relativas a la seguridad de la información, los fundamentos de la seguridad digital, las amenazas a los sistemas de información y sus mecanismos de defensa; así como los instrumentos para la gestión de esta seguridad, junto a las buenas prácticas, legislación y normativa existente en seguridad de la información. Todos estos conocimientos, técnicas y metodologías tienen aplicación en múltiples entornos, desde el personal y doméstico hasta el de grandes organizaciones y administraciones públicas, y cubren diferentes aspectos, desde el tecnológico hasta el de cumplimiento legal y de normativa, pasando por la necesaria concienciación de que el factor humano es crítico en la consecución de condiciones seguras para el desarrollo de todos los aspectos de la actividad privada, pública, profesional y social.

Por tanto, representa una oportunidad para que el estudiante, ya formado en diferentes aspectos de la ingeniería informática, se desenvuelva con soltura en aspectos tecnológicos, legales, metodológicos y normativos, específicos de la seguridad de la información.

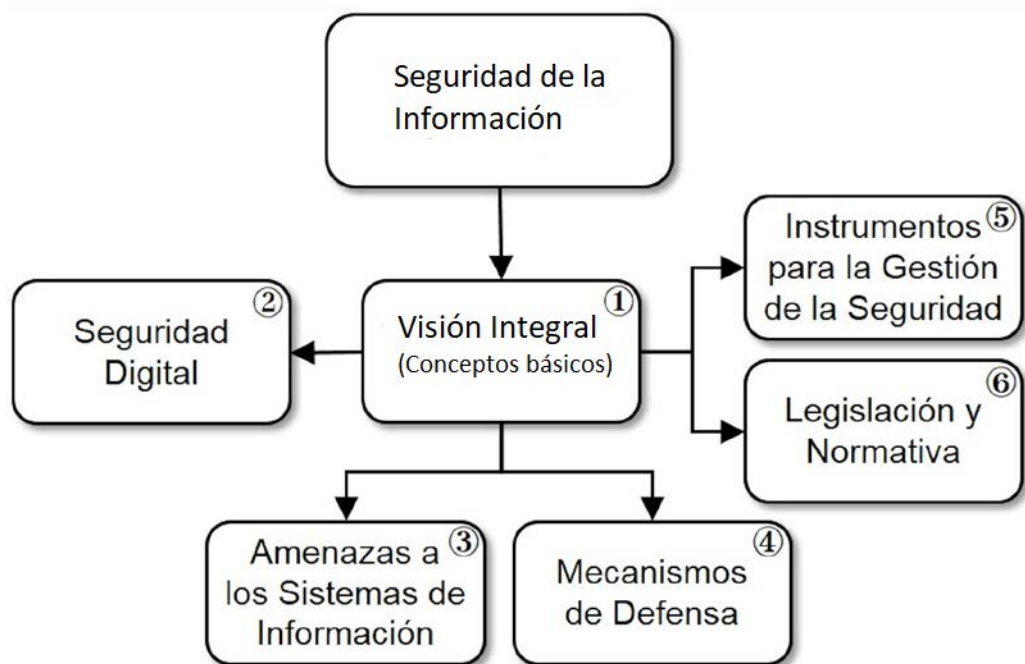
OBJETIVOS

Los objetivos didácticos que se plantean en este texto son los siguientes:

- Conocer los principios básicos de la seguridad de la información a partir de la seguridad informática, la seguridad en TIs y la ciberseguridad
- Conocer los principios básicos de la criptografía, sus herramientas más importantes y su integración en criptosistemas horizontales y verticales
- Garantizar las propiedades de la seguridad, como son la integridad, confidencialidad, autenticación y no repudio de sistemas informáticos integrados en red
- Conocer las amenazas más importantes a los sistemas de información
- Conocer y aplicar los mecanismos de defensa ante las amenazas estudiadas anteriormente
- Conocer los instrumentos básicos para la gestión de la seguridad de la información

- Conocer las buenas prácticas, normativa voluntaria y legislación de obligado cumplimiento en materia de seguridad de la información
- Aplicar los conocimientos adquiridos al desarrollo de análisis de riesgos, auditorías de seguridad, planes directores o estratégicos de seguridad, planes de respuesta ante incidentes y de continuidad del negocio, como fases del desarrollo de un sistema de gestión de la seguridad de la información en supuestos de organizaciones reales

ESQUEMA DE LAS UNIDADES DE APRENDIZAJE



UA 1. Seguridad de la información: una visión integral

PRESENTACIÓN

Comienza esta unidad de aprendizaje con una contextualización en la que se explica cómo el advenimiento de la Sociedad de la Información ha provocado cambios radicales en todos los aspectos de la sociedad. A continuación se desarrolla la evolución de los conceptos de seguridad informática, seguridad en TIs y ciberseguridad, hacia un concepto integral de **seguridad de la información**, objeto principal de este manual, de la que se enuncian sus principios y conceptos básicos.

Se discute acerca del necesario equilibrio entre seguridad y privacidad, a través de una reflexión de la evolución que ha sufrido la interpretación de dicho equilibrio en los últimos años, y de las amenazas que esto puede resultar para la privacidad de los ciudadanos. Igualmente se enuncian las dos visiones antagónicas de la seguridad, la clásica de conseguir la seguridad a través de la oscuridad y la moderna de conseguirla a través del conocimiento.

Se continúa con una necesaria visión integral de la seguridad, para indicar que las políticas de seguridad han de ir encaminadas a conseguir que se refuercen de manera homogénea los "eslabones más débiles" de la cadena que compone la seguridad integral, de cara a conseguir el necesario equilibrio del conjunto.

Posteriormente, se introducen los conceptos de identificación y autenticación, se estudia la identidad digital y las propuestas de conseguir identidades legales en la red, a través del empleo de certificados digitales, como es el caso del DNI electrónico en nuestro país.

Finaliza la unidad con una exposición de los nuevos retos a los que nos enfrentamos, derivados de este nuevo modelo de sociedad globalizada en la que el constante desarrollo de nuevas tecnologías modela un cambio cultural que presenta nuevos retos, nuevas amenazas y nuevas oportunidades.

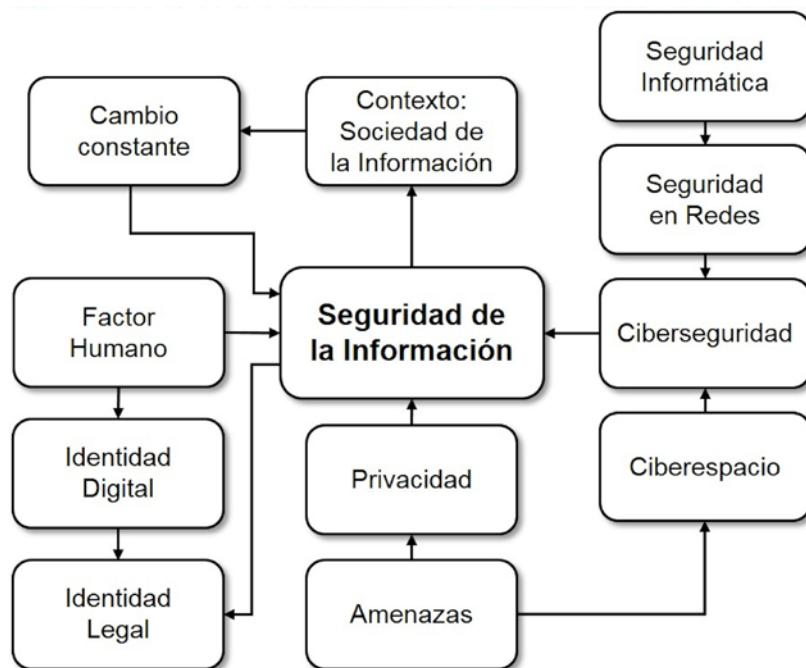
OBJETIVOS

Los objetivos didácticos de esta unidad son:

- Conocer los aspectos básicos e impulsores de la situación de cambio provocada por la irrupción de las tecnologías de la información en todos los ámbitos de la sociedad.
- Conocer y entender los principios básicos, definiciones y conceptos relativos a la seguridad de la información, la seguridad informática, la seguridad en TIs y la ciberseguridad.

- Conocer los elementos que configuran la identidad y el rastro digitales, y los fundamentos de la firma electrónica y el empleo de certificados digitales y el DNI electrónico.
- Reflexionar acerca de las principales amenazas y desafíos en relación con el advenimiento de la Sociedad de la Información y su repercusión en los diferentes ámbitos de la actividad humana.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. CONTEXTUALIZACIÓN. SOCIEDAD DE LA INFORMACIÓN

1.1. Situación actual: cambio constante

En los últimos años los avances tecnológicos y muy especialmente, el establecimiento de Internet como red global y ubicua están provocando una transformación sin precedentes en todos los ámbitos de la actividad humana. Ya nadie duda que estamos inmersos en la sociedad de la información o del conocimiento. El trabajo, el ocio, las relaciones personales, el turismo, el transporte, la sanidad, la educación, el entretenimiento, la política, la defensa nacional y en general, todas las facetas de la actividad humana se han visto enormemente afectadas por la irrupción de las tecnologías de la información y las comunicaciones a nivel planetario. En este mundo actual, lo único constante es el cambio.

1.2. Impulsores del cambio: estándares y tecnologías de bajo coste

El cambio tecnológico, que induce a su vez el cambio cultural en la sociedad, se sustenta sobre dos aspectos denominados **impulsores**: las tecnologías de bajo coste y los estándares.

- **Tecnologías de bajo coste:** La revolución microelectrónica de finales del siglo pasado ha motivado el desarrollo de sistemas digitales de capacidad creciente y coste decreciente. Es conocida la *Ley de Moore* que indica que aproximadamente cada dos años, la capacidad de los sistemas electrónicos de computación, captura, almacenamiento y comunicación de datos se duplica, a precio constante.
- **Estándares:** La primera etapa de la informática (años 70 y 80 del siglo pasado) se caracterizó porque los fabricantes (IBM, Unisys, Bull, etc.) producían sistemas no compatibles entre sí. Ni las pantallas ni los teclados de un fabricante servían para otro. Afortunadamente, organismos como ANSI, ISO, IEEE, la ITU y otros, han ido estableciendo estándares que han permitido la interoperabilidad de los sistemas y redes hasta llegar a la situación actual, marcada por el **software libre** como el sustrato básico de los servicios en Internet.

1.3. Factores tecnológicos

Así, hoy en día podemos citar como **factores tecnológicos** del cambio más importantes:

1. **Internet como red global y ubicua:** despliegue universal de redes móviles de capacidad creciente (3G, 4G, 5G...) y tecnologías de banda ancha urbana, Wifi a nivel doméstico, empleando los protocolos de Internet y sus servicios basados en estándares y software libre.
2. **Polarización de los entornos software:** prácticamente en la actualidad se emplean tres sistemas operativos en equipos fijos, Unix/Linux, Windows y Apple OS (basado a su vez en Unix). En equipos móviles, tan sólo dos entornos (Android e IOS, ambos basados en Unix/Linux) copan la práctica totalidad del mercado.
3. **Evolución hacia la computación móvil:** cada año se venden menos PCs y más equipos portátiles y Tablets, pero *todos los ciudadanos* disponen de un teléfono móvil de altas capacidades (acceso a Internet por Wifi y redes móviles, navegador incorporado, geolocalización por GPS, cámara de fotos y video, todo tipo de Apps, etc.). Cada vez más ciudadanos utilizan el móvil para todo tipo de actividades: compra por Internet, Apps bancarias, específicas para el puesto de trabajo, etc.
4. **La nube, sistemas conectados e Internet de las cosas (IoT):** *Todo* se conecta a Internet. Empresas, administraciones, gobiernos, hospitales, infraestructuras críticas (energía, transporte, comunicaciones, semáforos, tráfico aéreo, etc.), electrodomésticos, TVs inteligentes, cámaras de vigilancia, etc.
5. **Big Data, inteligencia artificial y robótica:** En los últimos años se ha producido un avance en técnicas de inteligencia artificial (aprendizaje autónomo, reconocimiento de patrones, etc.) a la vez que la actividad continua en la red de miles de millones de personas configura inmensas bases de datos con todo tipo de información. Vehículos autónomos, máquinas capaces de tomar decisiones complejas, etc.

1.4. Factores de tipo humano y social

Los factores de tipo humano y social más característicos de esta época son las nuevas formas de interacción motivadas por los factores tecnológicos y especialmente, por la irrupción de la web 2.0 y las redes sociales:

1. **Nuevos entornos de comunicación:** El empleo masivo de sistemas de mensajería como Whatsapp (propiedad de Facebook) y sus facilidades para realizar llamadas y videollamadas gratuitas, la creación de grupos, etc.; están cambiando la forma de comunicarnos a nivel global, sin diferencias de edad ni condición social.

2. **Redes sociales y plataformas digitales como fuente de (des)información:** más del 70% de los europeos utilizan las redes sociales como principal fuente de información. La prensa y las cadenas de televisión tradicionales se están volviendo minoritarias y se orientan hacia la población de mayor edad. Esta ausencia de control en los sistemas de información de la ciudadanía está facilitando lo que se conoce como desinformación, es decir, ataques orientados a alterar la opinión pública. La polarización de los ciudadanos hacia el tipo de noticias adaptadas a su perfil de pensamiento, las *fake news*, las cuentas falsas en RRSS robotizadas, están provocando cambios profundos en la opinión pública de los países democráticos.

1.5. Factores económicos y políticos

Y por último, citaremos algunos factores de índole económica y política:

1. **Industria del Cibercrimen:** entendido como una industria, el delito por medios tecnológicos a nivel mundial supera al tráfico de drogas, al tráfico de armas o a la trata de personas, a nivel mundial, y las cifras siguen en constante crecimiento.
2. **Polarización de los gigantes tecnológicos:** nueve corporaciones o *gigantes tecnológicos*, radicados en sólo dos países del planeta, controlan una gran parte de la actividad mundial en estos nuevos sectores. Cinco son estadounidenses, conocidos por sus siglas **GAFAM** (Google, Amazon, Facebook, Apple y Microsoft) y cuatro de China, identificados como **BATX** (Baidu, Alibaba, Tencent y Xiaomi)
3. **Globalización de la economía y precarización del empleo:** La globalización de los mercados y la respuesta de los gobiernos occidentales a la crisis mundial del período 2007-2014 están aumentando la desigualdad. En muchos países, se precariza el empleo, los ricos se hacen más ricos y los pobres, más pobres, con el estrechamiento de lo que se consideran clases medias.
4. **Guerra fría tecnológica:** situación de conflicto casi permanente a nivel comercial entre EEUU y China, con la supremacía mundial en juego. Todos los expertos indican que en la próxima década China será la primera potencia mundial, económica y muy probablemente militar. Tratándose de un estado que no respeta los derechos humanos (acceso a Internet filtrado y limitado, sin libertad de expresión ni de reunión, derechos civiles,...), el futuro no se presenta especialmente halagüeño en este contexto.
5. **Ciberespacio, ciberguerra y conflictos híbridos:** En esta nueva situación, el ciberespacio, entendido como el conjunto de sistemas, dispositivos y personas conectadas a Internet, se configura como el denominado quinto dominio de la guerra, después de la tierra, el mar, el aire y el espacio. Hoy en día los estados hacen la guerra sin declararla, a través del ciberespacio.

1.6. Industria 4.0 - la cuarta revolución industrial

Una posible respuesta a la pregunta de *hacia dónde nos lleva* esta situación de cambio, se plantea en el concepto de **cuarta revolución industrial**, acuñado por Klaus Schwab, fundador y presidente ejecutivo del *Foro Económico Mundial*. En su libro homónimo, Schwab sostiene que hasta la fecha se habían producido tres revoluciones industriales:

1. La **primera revolución industrial**, se origina en el siglo XVIII y dura hasta finales del XIX, con la revolución de la máquina de vapor como impulsora de las primeras fábricas y la transformación progresiva de la sociedad agraria y rural en industrial y urbana. Desarrollo de la industria textil y del hierro.

2. La **segunda**, entre finales del XIX y la primera guerra mundial (inicios del XX). En esta, las industrias existentes crecen y se desarrollan otras como el acero, el petróleo y la electricidad, lo que lleva a la producción en masa. Característico de esta época es el desarrollo del teléfono, el alumbrado eléctrico, el fonógrafo y el motor de combustión interna.
3. La **tercera** está marcada por la revolución digital, producto de la irrupción de la microelectrónica de bajo coste en la fabricación de todo tipo de sistemas y los avances en tecnologías mecánicas y ópticas (y los estándares, como ya hemos comentado), se inició alrededor de los años ochenta del siglo pasado y ha generado el ordenador personal, la expansión de Internet como red global, las tecnologías móviles, web 2.0, redes sociales, la computación en la nube, etc.

Así, llegamos a la **cuarta revolución industrial**, basada en la revolución digital producida por la anterior, que representa nuevas formas de integración de la tecnología en las sociedades e incluso en el ser humano, está marcada por avances emergentes en campos como la robótica, la inteligencia artificial, nanotecnología, computación cuántica, Internet de las Cosas (IoT), el blockchain, la impresión 3D y los vehículos autónomos.

Entre las **necesidades** planteadas por esta nueva revolución, citamos alguna de las más significativas en el entorno que nos ocupa, relativo a la seguridad de la información:

- Ciberseguridad en todo componente o sistema productivo integrado en la red.
- Fiabilidad en las comunicaciones para establecer la comunicación crítica entre máquinas (M2M)
- Mantenimiento de la integridad en los procesos de producción.
- Evitar interrupciones costosas en la producción.
- Proteger el conocimiento industrial, crítico en esta nueva era.
- Integrar los departamentos tradicionales de TIs en los sistemas de producción.

Después de esta introducción, en esta unidad realizaremos una aproximación al concepto de seguridad de la información, plantearemos los conceptos más importantes relativos a la misma, e identificaremos algunos de los retos, oportunidades y desafíos más importantes que plantea esta situación de cambio global, que serán desarrollados en las siguientes unidades de este manual.

2. SEGURIDAD DE LA INFORMACIÓN. DEFINICIONES Y CONCEPTOS BÁSICOS

2.1. De seguridad informática a seguridad de la información

Comenzamos con la primera definición formal de Seguridad Informática:

Seguridad Informática es la disciplina que se ocupa de diseñar las normas, procedimientos, métodos y técnicas orientados a proveer condiciones seguras y confiables para el procesamiento de datos en sistemas informáticos.

La definición anterior no explicita el concepto de transmisión de la información entre sistemas informáticos. Así, entendiendo las tecnologías de la información (TIs) como la integración de tecnologías informáticas y de comunicaciones, podemos definir la seguridad en TIs como:

Seguridad en TIs es la disciplina que se ocupa de diseñar las normas, procedimientos, métodos y técnicas orientados a proveer condiciones seguras y confiables para el procesamiento y la transmisión de datos entre sistemas informáticos.

No olvidemos que *tecnologías de la información (TI o TIs)* y *tecnologías de la información y las comunicaciones (TIC)* son términos equivalentes. En literatura inglesa, existen las mismas variantes: *Information Technologies (IT)* equivale a *Information and Communication Technologies (ICT)*

Hace años que se emplea el término *ciberseguridad* para indicar la seguridad a nivel global de los sistemas integrados en lo que se conoce como *ciberspacio*. De entre las muchas definiciones de este término escogeremos la indicada por el Centro Criptológico Nacional (CNN) en su glosario de términos:

Ciberseguridad es el conjunto de actuaciones orientadas a asegurar, en la medida de lo posible, las redes y sistemas que constituyen el **ciberspacio**. Y a su vez, define el ciberspacio como:

Ciberspacio es el espacio virtual que engloba todos los sistemas TIC, tanto sistemas de información como de control industrial.

Así, la mayoría de las definiciones de ciberseguridad son muy similares a las de seguridad en TIs, pero con carácter global, no restringido a una organización sino referido al ciberspacio, y muy especialmente, incorpora todo tipo de sistemas industriales, comerciales, gubernamentales, etc. Una organización puede hablar de seguridad en TIs pero a nivel nacional o supranacional, el concepto adecuado será ciberseguridad. La ciberseguridad contempla hogares, empresas, industrias, administraciones, infraestructuras críticas, defensa, etc.

En los últimos años, el concepto de Seguridad en TIs, asociado al ámbito meramente tecnológico, se ha ampliado con la aparición de un concepto más integral: La Seguridad de la Información (Information Security). Así, en la Metodología de análisis y gestión de riesgos de los sistemas de información de las Administraciones Públicas, MAGERIT, se define la Seguridad de la Información como:

Seguridad de la Información es la capacidad de las redes o de los sistemas de información para resistir, con un determinado nivel de confianza, los accidentes o acciones ilícitas o malintencionadas que comprometan la disponibilidad, integridad y confidencialidad de los datos almacenados o transmitidos y de los servicios que dichas redes y sistemas ofrecen o hacen accesibles.

En esta definición las primeras **dimensiones** de la seguridad de la información, o conceptos básicos relativos a la misma, identificando las características establecidas en su definición:

- **Disponibilidad:** sin duda, la característica más importante. La información debe estar disponible cuando sea necesario y por quien esté autorizado a ello.
- **Integridad:** es la característica de la información relativa a su fiabilidad. Se trata de evitar que la información sea alterada o modificada sin autorización.
- **Confidencialidad:** la información sólo debe ser accesible por las personas, programas o sistemas autorizados a ello, evitando accesos no autorizados, bien sea de forma casual o intencionada.

Otra definición que nos parece más completa es la que se encuentra en los estándares internacionales ISO 27000 sobre buenas prácticas y gestión de la seguridad, que además amplía las dimensiones establecidas en la anterior:

La **Seguridad de la Información** se ocupa de garantizar la disponibilidad, integridad, confidencialidad, el no repudio y la autenticación de la información, con independencia del medio físico en que se almacene o transporte: digital, impreso, etc.

Aparecen aquí dos nuevas dimensiones, especialmente importantes cuando se pretenda conferir **validez legal** a la información:

- **No repudio:** característica vinculada a la transmisión de información entre dos o más agentes. Establece la imposibilidad de que alguno de estos agentes pueda negar que haya participado en dicha transmisión. Se distinguen dos variedades:
 - No repudio de **origen:** garantiza que el receptor tenga pruebas suficientes para que el emisor no pueda negar el envío.
 - No repudio en **destino:** en este caso, el emisor debe tener pruebas de que el mensaje ha sido entregado a quien corresponde.
- **Autenticación:** Permite garantizar que el autor de cierta información sea quién dice ser.

En la figura 1.1 se intentan describir los ámbitos de cada uno de los tipos de seguridad definidos, entendiéndose que las definiciones no son estrictas y que muchas veces se podrán interpretar en sentido más amplio.

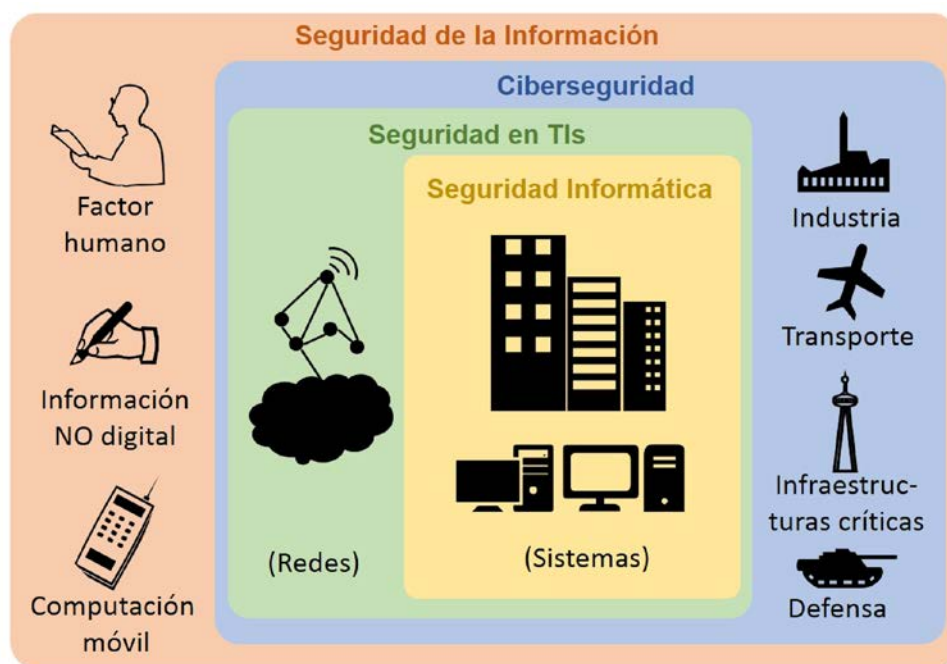


Figura 1.1.- Tipos de seguridad

Veamos a continuación las definiciones de dos conceptos básicos como son datos e información:

- **Datos:** Son los símbolos que representan hechos, situaciones, condiciones o valores. Suponen la materia prima para la producción de información.
- **Información:** Es el resultado de procesar, transformar o interpretar datos. Se considera el **activo más valioso** de cualquier organización.

La información usualmente se almacena (en forma de datos) y se procesa en ordenadores, tanto en equipos autónomos (usuarios individuales) como transmitiéndose entre equipos conectados a redes informáticas (organización). En virtud de su naturaleza, cierto tipo de información puede ser de carácter confidencial y su empleo ha de estar restringido a determinadas personas u organizaciones.

Como consecuencia, en función del valor de la misma, puede ocurrir que la información:

- Sea utilizada con fines poco éticos.
- Pueda divulgarse sin autorización de sus propietarios.

- Pueda verse amenazada por robos, fraudes o alteraciones.
- Pueda ser destruida, parcial o totalmente.

Lo que nos permite definir algunos conceptos directamente relacionados con la Seguridad:

- **Daño:** Perjuicio que se produce a consecuencia de un fallo en el sistema, bien sea fortuito o provocado.
- **Ataque:** Acción de provocar un daño a un sistema de forma intencionada.
- **Riesgo:** Relación entre la magnitud del daño y la probabilidad de que dicho daño ocurra.
- **Amenaza:** situación de daño cuyo riesgo de producirse es significativo.
- **Salvaguarda:** elemento de defensa contra una determinada amenaza.
- **Vulnerabilidad:** deficiencia de un sistema susceptible de producir, fortuita o intencionadamente, un fallo en el mismo.
- **Activo:** Cualquier elemento de valor para la organización.

Tradicionalmente, el ámbito de la seguridad informática y la seguridad en TIs han puesto su énfasis en la respuesta ante amenazas debidas a los ataques por explotación de vulnerabilidades. Posteriormente, se incorporó como disciplina el análisis de riesgos, determinando los diferentes riesgos en función de tres ejes principales: los **activos**, las **vulnerabilidades** y las **amenazas**.

La extensión de los conceptos anteriores hacia la seguridad de la información conlleva una visión más amplia en el proceso de análisis de riesgos. Se integran aquí, además de los ejes tradicionales (activos, vulnerabilidades y amenazas), los riesgos propios de la organización (organizacionales, operacionales, físicos y de TIs). En particular, es destacable la aparición del **factor humano**, ya que el establecimiento de este concepto extendido de seguridad involucra, junto a los cambios tecnológicos, cambios de comportamiento, de actitudes y en los procedimientos, que podrán suponer un primer escalón de resistencia a su implantación en la organización.

Pero también debemos concretar el concepto de Seguridad de la Información en el ámbito empresarial donde, además, aparecen una serie de problemas intrínsecos al valor de la información. Así, desde la perspectiva del negocio se podría realizar una última definición:

La seguridad de la información es la protección de la información de un rango amplio de amenazas para garantizar la continuidad del negocio, minimizar el riesgo comercial y maximizar el retorno de la inversión.

2.2. Principios básicos de la seguridad

Cuando se trata de cualquier tipo de seguridad, aparecen tres principios básicos de gran importancia que han de ser tenidos en cuenta desde el principio, y que se enuncian a continuación.

La seguridad no es un producto. Es un proceso



Figura 1.2.- Estructura cíclica de las políticas de seguridad

Esto implica que debe ser tomada en cuenta en cada etapa del ciclo de vida de un servicio:

- Diseño.
- Transición (puesta en marcha)
- Operación (día a día)
- Actualización y optimización (procesos de mejora del servicio)

En la figura 1.2 se ilustra este proceso continuo de evolución y mejora de las políticas de seguridad, enmarcado por necesaria y continua formación de los recursos humanos.

La Seguridad plena es una utopía

Por definición, todo sistema es inseguro. Por tanto, el objetivo será minimizar los efectos (el impacto) de la falta de seguridad. Veamos algunas acciones a desarrollar en cada una de las etapas del ciclo de vida de los servicios:

- En el **diseño**: minimizando la *superficie de ataque*, es decir, minimizando los riesgos inherentes a la exposición (el acceso) de la información. En general, esto se traduce en la máxima que indica: “*todo lo que no está explícitamente permitido, está prohibido*”.
- En el **desarrollo y puesta en explotación**: respondiendo a las posibles vulnerabilidades y amenazas, con salvaguardas o defensas que *mantengan a un nivel razonable* todas las dimensiones (disponibilidad, integridad, confidencialidad, no repudio y autenticación) de la información.
- En los **procedimientos y normas de uso**: concretando lo que se puede hacer y lo que no. Identificando los elementos críticos y monitorizando su adecuado funcionamiento.
- En el **uso diario**: mediante el establecimiento y revisión de políticas de seguridad.

La seguridad es una cadena y, como tal, romperá por el eslabón más débil

Con esto queremos reflejar que la gestión de la seguridad debe cubrir todos sus ámbitos, pues la mejora de una parte del sistema no producirá ninguna mejora en la seguridad global del conjunto, siempre que éste sea accesible por otra parte, más vulnerable.



Figura 1.3. La seguridad como cadena rompe por el eslabón más débil.

Como es habitual en el estudio de aspectos de seguridad en entornos tecnológicos, el factor humano (fallos debidos a negligencias o desconocimiento) resulta ser, con demasiada frecuencia, el elemento más débil del conjunto.

2.3. Preguntas clave: qué proteger, contra quien, cómo y hasta donde

Cuando en una organización se plantea la seguridad de su información, uno de los primeros aspectos que se tiene en cuenta es la fortaleza de sus entornos tecnológico y humano. Para ello, se deben analizar y tener en cuenta todos los aspectos que lo conforman.

Una de las técnicas más utilizadas es realizar una aproximación, cada vez más precisa, a través de cuatro preguntas fundamentales:

¿Qué queremos proteger?

Esta pregunta sustenta uno de los pilares básicos de todo el sistema. Identificar aquello que se quiere proteger obliga no sólo a identificar los elementos críticos, sino las relaciones entre ellos, sus dependencias y, en general, cualquier elemento físico o lógico que se quiera proteger. Este proceso se denomina “inventario de activos”, donde **activo** será todo elemento físico, lógico o humano que conforma el sistema que queremos proteger y que posee valor para la organización. Por otra parte, los activos se clasificarán principalmente por su valor económico, permitiendo cuantificar el impacto en el negocio de cada incidente de seguridad, en función de su riesgo. Con ello se introducen elementos de valor objetivo (cuantificables) que facilitan la toma de decisiones.

En la unidad de aprendizaje 5 se estudia el proceso de análisis de riesgos, cuya primera etapa es siempre la identificación y valoración de los activos de la organización, y que es una de las primeras etapas de cualquier proceso de gestión de la seguridad de la información, como los estudiados en la unidad 6.

¿Contra quién nos queremos proteger?

Entra aquí en juego el análisis de los perfiles de los posibles atacantes, su posible relación con nuestro sistema y las motivaciones que pueden tener para realizar el ataque. De hecho, en el análisis de este apartado aparece una cuestión interesante: ¿debemos protegernos de nosotros mismos? la respuesta, evidentemente, será afirmativa. Lo que llevará a garantizar que nuestra forma de actuar en el día a día respecto al manejo de información es la adecuada.

Este aspecto se estudiará con más detalle en la unidad 3, dedicada a las amenazas a los sistemas de información.

¿Cómo lo vamos a proteger?

En esta etapa, se identificarán los elementos, tecnologías, pautas, normas, procedimientos y buenas prácticas que han de ser aplicados para garantizar los principios de la seguridad de la información. Para concretar dicha elección será necesario identificar previamente las amenazas y los mecanismos de defensa, contenido que desarrollaremos en detalle en las unidades 3 y 4 de este manual.

¿Hasta dónde?

Cuestión fundamental, especialmente para una organización que busca el máximo rendimiento de sus inversiones: ¿Cuánto invertir en la gestión de la seguridad? Cualquier propuesta conlleva, al menos, una inversión económica que debe abarcar la compra de equipamiento (hardware o software), la puesta en funcionamiento de los servicios adquiridos, la definición (o modificación) de políticas de seguridad, la formación del personal y su administración y mantenimiento.

Los métodos modernos de **evaluación cuantitativa de riesgos**, descritos en las unidades 5 y 6, permiten establecer el punto de compromiso adecuado entre el valor de lo que se desea proteger y el coste total de la inversión necesaria para conseguir un adecuado nivel de protección de dicha infraestructura.

2.4. Diferentes enfoques de la seguridad de la información

Cuando se estudia la Seguridad de la Información, existen varias alternativas, compatibles entre sí para enfocar el trabajo a desarrollar:

- Centrado en la **normativa** y legislación que la organización ha de cumplir.
- Enfocado hacia las **amenazas tecnológicas**: Hacking, malware, fuga de información, ingeniería social, etc.
- Centrado en el **negocio**: Obtención de un nivel adecuado de seguridad en la organización, que permita gestionar eficazmente las relaciones con clientes, proveedores, administración, etc.; respondiendo adecuadamente a cualquier amenaza y garantizando la continuidad en el servicio.

En la práctica, para lograr una **concepción integral de la seguridad** será necesario considerar estas tres vertientes, plasmando el resultado en la política de seguridad de la Organización. En las unidades 5 y 6 se estudiarán instrumentos, buenas prácticas, legislación y normativa en seguridad de la información.

2.5. Seguridad vs privacidad: en busca del equilibrio

El 10 de diciembre de 1948, la Asamblea General de las Naciones Unidas aprobó la Declaración universal de Derechos Humanos, acogiendo en su artículo 12 el derecho a la **privacidad**. Posteriormente este derecho se ha integrado en la legislación de muchos estados, con mayor o menor grado de desarrollo. Así, la Constitución Española de 1978, en su Artículo 18.4 establece: "La ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos". Sin duda, el amplio espectro ideológico y las vivencias personales de muchos de nuestros *padres constituyentes* (y el ejemplo de la constitución portuguesa, aprobada dos años antes, que incluye un artículo similar) propiciaron un artículo tan garantista, casi futurista, si atendemos al escasísimo nivel de *informatización* de nuestro país en esa época.

A lo largo de los años siguientes, diversas leyes (LORTAD, LOPD, LOPDyGDD, etc.) han desarrollado este principio constitucional, protegiendo a los ciudadanos de los posibles atentados contra su privacidad. En la unidad 6 se explica la legislación española y europea relativa a los diferentes ámbitos de la seguridad de la información,

La Real Academia Española (RAE) define la **privacidad** como el "ámbito de la vida privada que se tiene derecho a proteger de cualquier intromisión". En el mundo digital, la utilización de técnicas criptográficas, especialmente los sistemas de cifrado simétrico y de intercambio de claves asimétrico, junto a los algoritmos de resumen y las operaciones de firma digital, que estudiaremos en la unidad 2, configuran hoy en día las herramientas que permiten garantizar las características de la información que entendemos asociadas a la privacidad en sentido amplio,

como son la integridad, la autenticación, la confidencialidad y el no repudio. Resumiendo, la privacidad en sistemas digitales, exige el empleo de la criptografía.

No obstante, a pesar de la cobertura legal, el excesivo celo por la seguridad, llevado en ocasiones a extremos de emergencia nacional tras la globalización del terrorismo de los últimos años, junto a los avances tecnológicos que dotan a los gobiernos de unas capacidades de registro y escrutinio de información sin precedentes, ha provocado en ocasiones que gobiernos de naturaleza tan poco sospechosa como las democracias occidentales, encabezadas por los Estados Unidos, tengan la tentación de limitar un derecho tan fundamental como la privacidad. La historia de los últimos años está llena de acontecimientos en este sentido.

En 1991, el gobierno de EEUU, propuso la utilización de un chip, el Clipper, que utilizaba una técnica de cifrado con “puerta trasera” a la que tendrían acceso las agencias gubernamentales autorizadas a intervenir las comunicaciones. El algoritmo de cifrado sería secreto y la clave quedaría al 50% en manos de dos agencias estatales. Al mismo tiempo la comisión europea debatía un proyecto de directiva que impondría a sus países miembros la adopción de medidas similares. Esto y una propuesta de Ley elevada al Senado para limitar el uso civil de la criptografía, impulsó al ingeniero de software Phil Zimmermann, a desarrollar el software gratuito PGP, un sistema de cifrado de alta calidad y robustez. Por primera vez en la historia, el gran público podía intercambiar libremente información que no podía ser descifrada por las agencias de seguridad de las grandes potencias.

Dado que, por aquel entonces, los sistemas criptográficos tenían la consideración de armamento y que estaban sometidos a control de exportación por el Gobierno, Zimmermann, por el simple hecho de publicar en Internet el código fuente del PGP, se vio inmerso en un proceso judicial, acusado de *facilitar* la exportación ilegal de armamento militar. Se enfrentaba a la misma pena que si hubiese vendido armamento prohibido a una potencia extranjera. El revuelo ocasionado por el caso y la creciente utilización del PGP por grupos de defensa de los derechos humanos en todo el mundo, motivaron que finalmente, en 1996, se desestimara el caso contra Zimmermann y casi al mismo tiempo, se flexibilizó la regulación de la exportación de material criptográfico.

Finalmente, la necesidad de disponer de sistemas de transmisión segura de información para la realización de actividades de banca, administración y comercio electrónicos, ha ido configurando el panorama actual, en el que prima el derecho a la privacidad y a las comunicaciones seguras. Podríamos decir que la sociedad civil ha ganado la batalla del derecho a la privacidad, en cuanto que la criptografía fuerte no está prohibida, de hecho, hoy en día es obligatorio por ley su empleo en la protección de datos personales. Pero no terminan aquí las posibles amenazas gubernamentales a la privacidad de sus ciudadanos.

La creciente capacidad de proceso y de almacenamiento de los sistemas electrónicos actuales brinda y seguirá brindando, cada día con más calidad y a menos coste, a cualquier gobierno, democrático o no, la posibilidad de controlar y registrar un número creciente de conversaciones simultáneas, de correos electrónicos o de identificar los rostros de los ciudadanos, según pasen cerca de una cámara de vídeo. Por citar sólo dos ejemplos, el gobierno chino ha desplegado más de un millón de cámaras con reconocimiento facial en las calles, y Rusia planifica la creación de una Internet propia con controles estrictos, algo que China ha establecido desde el principio (no olvidemos que Google está censurado en ese país)

La combinación de estas posibilidades con una cierta actitud, casi paranoica, de defensa ante una amenaza global tan grave como el terrorismo, puede motivar que determinados gobiernos implanten sistemas que, de forma oficial u oficiosa, posibiliten la creación de auténticos estados policiales. Un estado democrático puede dejar de serlo. Hitler accedió democráticamente al poder en Alemania, por citar solo un ejemplo. Un sistema que permita escudriñar todas las actividades, las conversaciones, la correspondencia y los movimientos de sus ciudadanos, diseñado para operar bajo riguroso control judicial, podría ser utilizado al día siguiente, como *la*

herramienta perfecta de identificación y arresto de cualquier opositor al sistema, si por algún motivo el estado deja de ser democrático.

La ciudadanía tiene la obligación moral de defender su intimidad y su privacidad ante cualquier intento de restricción, incluso limitada en el tiempo, que planteen sus gobernantes, por muy acorde a la legalidad que pueda parecer la iniciativa, y por muy loables que puedan parecer sus motivos. El gobierno que le suceda (y más en esta época de fake news, Brexit y elecciones manipuladas por potencias extranjeras) podrá ser *muy diferente*.

2.6. Seguridad a través de la oscuridad o del conocimiento

Seguridad a través de la oscuridad

La vinculación entre criptografía (escritura oculta) e informática ha sido una constante. Muchos años después de finalizada la Segunda Guerra Mundial, en 1965, se desclasificaron unos documentos secretos del gobierno británico que indicaban que el primer computador digital programable (Colossus) fue construido en 1942 en Bletchley Park (la base secreta británica de descifrado durante la guerra) para ayudar en el criptoanálisis (rotura de las claves) de la máquina de cifrado Enigma, utilizada por los alemanes para el envío de información cifrada a su flota de submarinos.

Todos los sistemas de cifrado anteriores a la introducción de la informática basaban su eficacia en que el **propio método de cifrado fuese secreto**. Por tanto, criptografía y secreto eran términos recurrentes. Las comunicaciones militares, la diplomacia (comunicación entre gobiernos y sus embajadas) y la inteligencia (comunicación con agentes secretos) hacían uso de estas técnicas y contaban con el secreto como aliado.

En la primera era de la informática comercial (años 70) los costosísimos *mainframes* y *miniordenadores* no se vendían en el sentido que todos entendemos. Se *alquilaba* el derecho a utilizarlos, pero el *comprador* se comprometía a no “levantar la tapa” del *cerebro electrónico*, ni siquiera ante una avería grave. Algo tan inocente como los mapas de memoria, tenían la categoría de “secreto de estado” y su revelación podía suponer años de cárcel, según las leyes del país de origen del equipo. En estas condiciones, es fácil imaginar qué se entendía por seguridad informática: los sistemas no eran *seguros*. Eran *secretos*. Pocas personas en el mundo sabían ni siquiera manejarlos, y los sistemas de protección eran de una sencillez rayana en la inocencia. En resumidas cuentas, la seguridad consistía en el desconocimiento.

Este ambiente fue el caldo de cultivo de la primera generación *hacker*. Los pocos que llegaban a adquirir esos conocimientos *arcanos*, tenían a las grandes corporaciones, a los grandes bancos, a cualquier corporación capaz de sufragar el coste y el mantenimiento de esos *mainframes*, literalmente *a sus pies*. Al cabo del tiempo, se demostró que esa “oscuridad” informativa no sólo no aportaba mayor seguridad al sistema, sino que impedía la adopción de medidas proactivas ante posibles ataques. Si no se sabe dónde están las debilidades ni a qué se deben, es imposible mejorar la seguridad.

Formalmente, la **seguridad a través de la oscuridad** es la filosofía en base a la que se considera que una aplicación informática será segura en la medida en que su código interno no sea difundido. Este modelo oscurantista también tuvo su reflejo en los primeros sistemas criptográficos digitales. Los primeros algoritmos de cifrado medían su seguridad por el grado de desconocimiento que se tenía acerca de su funcionamiento. No es difícil imaginar la forma de pensar de los responsables de la NSA (Agencia de Seguridad Americana) en aquella época. *Secreto, secreto y más secreto*. Sin embargo, la experiencia ha demostrado que este tipo de sistemas han cedido repetidamente a los ataques, sin que el grado de ocultación de sus vulnerabilidades pudiese disminuir o frenar el éxito de los mismos. La lección aprendida de este tipo de errores se resume en: “todo lo que un sólo hombre sea capaz de esconder, otro lo desvelará”.

Seguridad a través del conocimiento

La solución al problema que plantea la conclusión anterior, parece paradójica a primera vista, ya que consiste exactamente en lo contrario: divulgar todo lo posible la información de los sistemas y mecanismos de seguridad, en particular sus vulnerabilidades. Cuanto más grande sea el grupo de personas que disponga de dicha información, más pronto se detectarán las vulnerabilidades y consecuentemente, más rápidamente se evolucionará hacia mayores niveles de seguridad.

En el caso de la criptografía, lo opuesto a la seguridad a través de la oscuridad es el denominado principio de Kerckhoff, propuesto a finales de 1.880: “*un criptosistema debe ser seguro, incluso si todo lo relacionado con el funcionamiento del sistema, excepto la clave, es de conocimiento público*”. Los algoritmos criptográficos modernos son de carácter público y se someten al escrutinio de todo aquel que desee revisarlos, y por supuesto, criptoanalizarlos (es decir, atacarlos). Así, el sucesor del algoritmo de cifrado DES (Data Encryption Standard) propuesto por la NSA en 1976 en condiciones de *oscuridad* (contratando expertos que trabajaban bajo estricta confidencialidad) fue sustituido en 2001 por el AES (Advanced Encryption Standard), elegido entre una serie de candidatos presentados a concurso internacional y abierto. Su código fuente es público y quién tenga dudas sobre su fiabilidad, puede revisarlo línea a línea y buscar vulnerabilidades. Precisamente por eso, porque cualquiera puede estudiarlo y criptoanalizarlo, todos lo consideramos seguro.

3. VISIÓN INTEGRAL DE LA SEGURIDAD

Hasta el momento hemos tratado distintos aspectos de forma independiente que, de una forma u otra, nos ayudan a perfilar el concepto de seguridad en la información y sus implicaciones. En este apartado realizaremos una visión integradora de lo visto hasta el momento, tratando de *encajar las piezas del rompecabezas* hasta conseguir una **visión integral de la seguridad** que, volviendo a la analogía de la seguridad como cadena, nos proporcione la mejor cadena posible, formada por eslabones de similar resistencia, o en su equivalente real, por el correcto énfasis en cada uno de los aspectos de la seguridad que veremos a continuación.

3.1. El factor humano: Seguridad en el Personal

El factor humano, como ya hemos indicado, frecuentemente resulta ser el **eslabón más débil** en la cadena de seguridad. Hasta el sistema más seguro puede verse comprometido por relajación de las políticas, falta de rigor en los procedimientos, desconocimiento de las normas y también por la simple intención de causar daño. Según varias consultoras especializadas, **más del 70%** de los incidentes de seguridad se originan **dentro** de la propia organización. Bien sea por accidente, descuido o despiste, por uso inadecuado de las herramientas de trabajo o por acciones intencionadas.

En el origen de los incidentes no intencionados se encuentra casi siempre un denominador común: ausencia o escasa cultura de seguridad. Otro factor muy importante es la manipulación de las personas con el objetivo de obtener información mediante el empleo de técnicas de lo que se conoce como **ingeniería social**, que veremos en la unidad 3.

Ante esta situación es fundamental desarrollar un plan de trabajo que permita llevar a cabo tres objetivos principales:

1. Difundir y formar al personal en las líneas generales de la política de seguridad corporativa.
2. Asegurarse de que el personal toma conciencia de las amenazas y riesgos en el ámbito de la seguridad de la información.
3. Minimizar el impacto provocado por las incidencias de seguridad.

Para ello, las medidas a adoptar en relación al personal son:

- Formación: en todos los aspectos, tanto normativos como procedimentales.
- Establecimiento de acuerdos de confidencialidad.
- Seguimiento del personal que gestiona tareas críticas.

Como antes se ha dicho, si la seguridad en el personal resulta ser la más débil de la cadena, debería ser la más potenciada, a fin de conseguir una *cadena* de seguridad más resistente.

3.2. Seguridad física y del entorno

La seguridad física hace referencia a la protección mediante barreras físicas y mecanismos de control, de los elementos tangibles del sistema de información. Se trata de considerar tanto las amenazas provocadas por personas, como por aquellas que tienen su origen en fenómenos naturales.

En este ámbito se consideran, por ejemplo, los siguientes aspectos:

- Inventario y etiquetado de activos.
- Control de soportes móviles de almacenamiento de datos.
- Protección contra fallos del suministro eléctrico.
- Controles de acceso a instalaciones.
- Protección contra factores ambientales (inundaciones, tormentas, etc.)

En relación con la seguridad física de los equipos informáticos y de comunicaciones, es de extrema importancia que todo el personal de la organización sea plenamente consciente de la existencia de un principio básico: *todo atacante que disponga de unos minutos físicamente delante de un equipo, podrá tomar control absoluto sobre el mismo*. Este principio no sólo es de aplicación a los servidores centrales de la organización, sino a cualquier equipo de sobremesa conectado a una red segura y muy especialmente, a los routers, switches y puntos de acceso Wifi.

3.3. Seguridad Lógica

La Seguridad lógica consiste en la “aplicación de barreras y procedimientos que protejan el acceso a los datos de forma que sólo sean accesibles por las personas autorizadas”.

Este ámbito de la seguridad lógica contempla una serie de objetivos fundamentales:

- Delimitar el acceso a las aplicaciones y archivos de datos.
- Disponer caminos alternativos para la transmisión de la información.
- Garantizar que la información recibida sea la misma que la enviada.
- Garantizar que sólo el destinatario de la información puede recibirla y no otros.
- Verificar que el uso de la información se ajusta a los procedimientos establecidos.

Pese a que parece obvio que la definición de las políticas conducentes a la obtención de elevados niveles de seguridad lógica será responsabilidad de los expertos en TIs, como veremos en el apartado siguiente, para que dichas políticas sean efectivas en su aplicación, deben elaborarse en total alineación con la política general de seguridad de la organización. En resumen, tendrán que conjugar el cumplimiento de los objetivos antes citados, con un adecuado equilibrio entre fortaleza y usabilidad, entre coste y complejidad, entre la utilización de las últimas tecnologías o la disponibilidad de material didáctico para formar rápidamente al personal. La responsabilidad en la toma de estas decisiones, por su elevado impacto en la propia misión de la organización, ha de ser asumida por la alta dirección de la organización.

3.4. Seguridad organizativa: políticas de seguridad

Ya hemos visto que no todo el trabajo a realizar es de tipo técnico. Por tanto, se deberá documentar todo el proceso, evitando así incoherencias en la gestión y la indefinición de los criterios básicos de actuación. Fruto de esta necesidad de formalizar el marco de trabajo relativo a la Seguridad de la Información, aparece el concepto de política de seguridad de la Organización, definida por el IETF Site Security Handbook como “Un conjunto de normas que deben cumplirse por todas las personas que tengan acceso a cualquier información y/o tecnología de una organización”. Esta política reflejará la filosofía de seguridad de la organización, teniendo como características principales las siguientes:

- **Abarcable:** debe poder implantarse de forma efectiva.
- **Inteligible:** tanto a nivel de conceptos como de las implicaciones de no cumplir sus directrices.
- **Obligado cumplimiento:** incluirá procesos de auditoría para detectar posibles desviaciones.
- **Concreción de responsabilidades:** delimitará los roles necesarios y sus responsabilidades.
- **Asequible:** no debe entorpecer el trabajo.
- **Mejorable:** incorporará mecanismos de autoevaluación y actualización.

No obstante, con la política de seguridad no culmina la gestión de la seguridad de la información. En las unidades 5 y 6 entraremos en detalle en las pautas, procedimientos, estándares y buenas prácticas conducentes al establecimiento de un completo sistema de gestión de la seguridad de la información.

4. IDENTIDAD DIGITAL Y LEGAL. FIRMA ELECTRÓNICA Y CERTIFICADOS

4.1. Identificación y autenticación

Anteriormente hemos definido la autenticación como la *dimensión* o propiedad de la información que permite garantizar que el autor de cierta información sea quién dice ser. Por su parte, el diccionario de la RAE (Real Academia Española) define la identificación como el hecho de reconocer que una persona o cosa es la misma que se supone o busca. Así, la autenticación se podría entender como una identificación *exenta de dudas*. En el mundo físico, todos los países cuentan con procedimientos bien documentados para obtener un pasaporte, tarjeta de identidad o similar, que permita demostrar fehacientemente la identidad de sus titulares, lo que se entiende como autenticación física.

Factores de autenticación: algo que se sabe, algo que se tiene y algo que se es

Antes de definir conceptos como la identidad digital y una extensión del concepto de identificación legal (o autenticación personal) en la red, veremos los denominados factores de autenticación. Estos factores permiten *autenticar* tanto en el mundo físico como en el virtual, y son tres:

1. Factor de **conocimiento**: algo que *se sabe* (nombre, apellidos, DNI, fecha de nacimiento, nombre de usuario, contraseña, PIN, etc.)
2. Factor de **posesión**: algo que *se tiene* (DNI, pasaporte, teléfono móvil, correo electrónico, número de teléfono, tarjeta criptográfica, claves criptográficas, etc.)
3. Factor de **existencia**: algo que *se es* (algún rasgo *biométrico* que nos identifique unívocamente, como el iris, la huella dactilar, rasgos faciales, ADN, etc.)

Así, en el mundo físico, nos identificaremos con uno o más factores de conocimiento y nos autenticaremos con la combinación de dos o más factores de autenticación. A su vez, la autenticación no tiene por qué ser universal. Una tarjeta bancaria, en combinación con un PIN nos autentifica como usuarios de un servicio bancario, pero no tiene capacidad para identificarnos ante la policía, por ejemplo. Nos identificamos por nuestro nombre (conocimiento) y nos autenticamos a efectos administrativos y legales mostrando el DNI físico (posesión), cuya fotografía será contrastada con nuestro aspecto real (existencia)

En el mundo digital, estamos acostumbrados al empleo de parejas de distintos tipos de cuentas de usuario y contraseñas como métodos de identificación. La autenticación requerirá igualmente la combinación de diferentes factores de los antes descritos (posesión o existencia además de conocimiento). Así, cada vez más las operaciones bancarias *online* que involucran transferencia de fondos se realizan con mecanismos de autenticación de dos factores: conocimiento de la cuenta de usuario y su contraseña asociada *combinado con* la posesión de (o el acceso a, en este caso) un teléfono móvil en el que se recibe una clave que autentifica la operación. Cada vez más la **autenticación de dos factores** es una herramienta imprescindible en seguridad de la información y por citar un ejemplo, su empleo es obligatorio en sistemas de información considerados de nivel de seguridad alto, en la administración pública española.

Estudiaremos ahora los conceptos de identidad y rastro digitales, y los mecanismos oficiales y legales de autenticación en nuestro entorno digital.

4.2. Identidad y rastro digitales

Todos los seres humanos, en la realización de actividades personales o profesionales en la red, acumulan multitud de elementos que los definen como *seres digitales* y que en su conjunto, configuran el denominado **rastro digital**:

- Cuentas de correo electrónico.
- Perfiles en redes sociales (Facebook, Instagram, LinkedIn, etc.)
- Web personal o de nuestra empresa.
- Opiniones vertidas en blogs, foros, grupos de Whatsapp, redes sociales, etc. (incluyendo los *likes*)
- Búsquedas realizadas con diferentes plataformas (Google, Bing, etc.)
- Relación de compras realizadas (libros, tecnología, medicinas, ropa, etc.) en diferentes tiendas electrónicas.
- Páginas web visitadas.
- Direcciones IP desde las que se conectan y si es desde móviles, posición geográfica en cada momento (Google almacena la geolocalización o coordenadas geográficas, aunque explícitamente se le indique lo contrario)

Así, varios autores definen la **identidad digital** como la agregación del rastro digital, aunque otros especifican que todos tenemos identidades múltiples, en virtud del rastro digital percibido por otros usuarios.

En general y salvo que se utilicen diferentes cuentas de acceso a los servicios de la red, con diferentes identidades, el rastro digital confluirá en una identidad digital coherente, con independencia de que la información esté dispersa entre muchos servidores, con sus respectivas cuentas de acceso.

Metadatos

En general, se definen los metadatos como los “datos que describen otros datos” y es un concepto muy utilizado en tecnologías de la información. Así, al realizar una fotografía con una cámara digital o un teléfono móvil, además de la propia imagen, se almacenan datos relativos a la velocidad de disparo, la fecha y hora en que se realizó, etc. Igualmente, al crear un documento de Office (Word, Excel, etc.) o un fichero PDF, se suelen almacenar metadatos relativos a su autor o a la empresa en la que trabaja, por citar algunos ejemplos.

Así, aparece un nuevo concepto de rastro digital que suele pasar inadvertido, pero que puede ser fuente de problemas en determinadas ocasiones. Es muy importante conocer su existencia y controlar los metadatos asociados a toda fuente de información o documento que se publique o entregue a cualquier destinatario. Estos metadatos pueden ser archivados por Google y otros buscadores, podrían indicar falta de originalidad en determinados documentos, y en general, se trata de información no controlada por quién la emite.

4.3. Firma electrónica

La Firma electrónica es un sistema de autenticación que permite verificar la identidad de las personas con el mismo valor que la firma manuscrita, validando las comunicaciones generadas por el firmante.

En particular, la Ley 59/2003 de 19 de diciembre, de Firma Electrónica, define la misma como “el conjunto de datos en forma electrónica, consignados a otros o asociados con ellos, que pueden ser utilizados como medios de identificación del firmante”.

La firma electrónica permite que tanto el receptor como el emisor de un contenido puedan identificarse mutuamente con la *certeza* de que son ellos los que están interactuando (**autenticación**), evita que la comunicación sea interceptada (**confidencialidad**) y alterada por terceros (**integridad**) y garantiza el “**no repudio**” a través de las disposiciones legales.

Dentro de la ley se distinguen dos tipos de firma electrónica:

- **Firma electrónica avanzada:** es aquella que permite identificar al firmante y detectar cualquier cambio ulterior de los datos firmados, que está vinculada al firmante de manera única y a los datos a que se refiere y que ha sido creada por medios que el firmante puede mantener bajo su exclusivo control.
- **Firma electrónica reconocida:** se considera como tal a la firma electrónica avanzada basada en un certificado digital reconocido y generada mediante un dispositivo seguro de creación de firma. Este tipo de firma tendrá respecto a los datos consignados en forma electrónica el mismo valor que la firma manuscrita en relación con los consignados en papel.

Veremos a continuación dos soluciones basadas en estos conceptos, de amplio uso en nuestro país para la realización de firmas electrónicas: los certificados digitales y el DNI electrónico.

4.4. Hacia una identidad legal: certificados digitales y DNIE

4.4.1. Certificados digitales

En la unidad de aprendizaje 2 se desarrollan los conceptos más importantes en relación con los certificados digitales y autoridades de certificación. Nos limitaremos aquí a reseñar la existencia de los denominados certificados digitales, que son estructuras de datos que contienen información relativa al usuario, información relativa a la autenticación del mismo (su clave pública) y la firma electrónica de la autoridad que certifica el certificado.

En España existen varias autoridades de certificación digital reconocidas legalmente, la Fábrica Nacional de Moneda y Timbre (FNMT) es la responsable de la emisión de los

certificados digitales de software más utilizados por la ciudadanía para identificarse de forma electrónica ante la Administración y firmar documentos. Estos certificados se obtienen accediendo a la página web de la sede electrónica, rellenando la solicitud y después de recibir el código de solicitud, habrá que presentarse en alguna oficina de entidad pública reconocida (delegaciones de hacienda, ayuntamientos, administraciones universitarias, etc.) donde un funcionario, después de acreditar la identidad del solicitante, activará el proceso para que se pueda acceder de nuevo a la sede electrónica y recibir en el mismo ordenador donde se realizó la solicitud, el certificado completo.

Este certificado es técnicamente un documento electrónico que contiene los datos identificativos y sobre todo, las claves criptográficas que permitirán realizar operaciones de autenticación del usuario y de firma digital. Las operaciones criptográficas de cifrado y firma de información se realizarán en el ordenador en el que esté instalado. Este ordenador será en general utilizado para múltiples actividades (podría estar infectado por virus, por ejemplo) y en general **no cumplirá** las condiciones para ser considerado un **dispositivo seguro de creación de firma**. Por este motivo, las firmas electrónicas efectuadas con certificados digitales *de software*, como los emitidos por la FNMT y entidades similares (Asociación de cámaras de comercio, etc.) solamente tendrán categoría de **firma electrónica avanzada**, según define la Ley de firma electrónica indicada anteriormente.

Una alternativa mucho más robusta al empleo de certificados digitales de software consiste en el empleo de tarjetas criptográficas, dotadas de memoria para almacenar certificados digitales pero sobre todo, con un procesador capaz de realizar las operaciones de cifrado y firma de forma autónoma, en la propia tarjeta, sin peligro de que las claves sean capturadas en el ordenador que las utilice. El DNI electrónico es un claro ejemplo de este tipo de sistemas con categoría de **firma electrónica reconocida**, como veremos a continuación.

4.4.2. DNI electrónico

España ha sido pionera en la implantación de un verdadero sistema nacional de identidad digital, dotando a todos sus ciudadanos de un sistema de identificación con capacidades de firma electrónica **reconocida** (mediante el uso de un dispositivo seguro de creación de firma) y cifrado de documentos. Se trata del DNI electrónico o DNIE, cuya implantación comenzó en 2006.

El concepto de DNI electrónico surge como respuesta a tres objetivos fundamentales planteados desde la Administración para el diseño de un documento que permita:

- Identidad digital.
- Firma electrónica avanzada.
- Mejora en el servicio al ciudadano: entrega inmediata.

De forma más amplia, en el diseño del nuevo DNI se ha partido de los siguientes objetivos:

- Creación de un documento que certifique la identidad del ciudadano, no sólo en el mundo físico sino en las transacciones telemáticas.
- Expedición en un solo acto administrativo, pues el ciudadano lo recoge el mismo día de su solicitud.
- Interoperabilidad con los proyectos europeos de identificación digital.
- Aceptación por parte de todas las Administraciones Públicas y Entidades de Derecho Público, vinculadas o dependientes de las mismas, del uso del DNIE.

El DNIE, además de la identificación física del titular, tal y como lo hacía el DNI tradicional, permite:

- **Autenticación:** Capacidad de identificación en medios telemáticos a través de los certificados digitales.
- **Integridad de la información:** a través del uso de la firma digital.
- **Confidencialidad:** mediante el cifrado de datos.
- **No repudio:** con el uso conjunto de los certificados digitales y la firma digital.

Para todo ello se rodea de una serie de medidas de seguridad entre las cuales merece especial atención el **chip criptográfico**, que permite la identificación digital del poseedor del documento, además de operaciones de autenticación, firma digital y envío de documentación cifrada utilizando el certificado digital incluido, expedido por la Autoridad de Certificación del Ministerio del Interior.

Además, dispone de la versión digital de la imagen del titular y un fichero de datos biométricos, obtenidos a partir de la huella dactilar, que permiten la identificación del titular, por ejemplo, para poder cambiar la contraseña de acceso a la clave privada del certificado, necesaria para las operaciones de firma electrónica.

4.4.3. DNI 3.0

A partir de 2015 la Dirección General de la Policía lanzó el DNI 3.0, nueva versión del DNI electrónico. La principal diferencia con su antecesor es que el chip criptográfico ahora dispone de un interfaz dual que permite además de la conexión mediante hardware, típica del DNLe, el empleo de la tecnología NFC (Near Field Communication), ya presente en la mayoría de smartphones y ampliamente utilizada en tarjetas de crédito y débito.

Tanto el DNLe como el DNI 3.0, al estar dotados de un chip criptográfico que realiza las operaciones críticas durante la firma (manipulación de la clave privada) sin necesidad de que esos datos sensibles del certificado digital sean enviados al ordenador para que este último sea el que realice la firma, son intrínsecamente más seguros que el empleo de certificados digitales de software expedidos por la FNMT y otras autoridades. Al realizarse la firma en el interior del **chip criptográfico**, que es un **dispositivo seguro de creación de firma**, será una **firma electrónica reconocida** según establece la Ley de firma electrónica y en consecuencia tendrá, a todos los efectos, el mismo valor legal que la manuscrita.

Sin embargo, las directivas europeas al respecto no son tan exigentes en la consideración de firma electrónica avanzada o reconocida. Esto y la relativa facilidad de uso de los certificados de software frente al DNI electrónico, ha motivado que, en la mayoría de los casos, la administración española confiera igual fiabilidad a las operaciones realizadas con DNI electrónico a las realizadas con certificados de software, como los emitidos por la FNMT.

5. UN FUTURO CAMBIANTE. NUEVOS DESAFÍOS DE SEGURIDAD

Si algo caracteriza a Internet es su capacidad de transformación. Empezó siendo un proyecto militar destinado a proveer a EEUU de un mecanismo de respuesta ante un ataque nuclear masivo por parte de la Unión Soviética, en los últimos años de la guerra fría. Con la incorporación de universidades y centros de investigación, pasó a ser un punto de encuentro de ámbito académico. Pocos años después, su uso se ha generalizado a la práctica totalidad de habitantes del planeta con renta superior al umbral de pobreza extrema, siendo una de las comodidades más importantes del ciudadano medio y un recurso imprescindible en la sociedad actual. El cambio tecnológico está provocando enormes cambios sociales.

Integradas las personas, la red continúa su avidez expansiva. Aparece el concepto de Internet de las cosas (Internet of Things o IoT), en referencia a la integración de objetos físicos en la red. El ejemplo más cercano es la conexión de objetos domésticos: TV, altavoces, alarmas, cámaras de vigilancia, etc.; pero sobre todo, comprende la integración de todo tipo de sistemas

industriales, y muy especialmente, de **infraestructuras críticas**: redes eléctricas y sus centrales de producción, redes de abastecimiento de agua, sistemas de control de tráfico aéreo, marítimo y terrestre, hospitales, etc. Esto define la extensión de Internet hacia el concepto de **ciberspacio**, y configura la **ciberseguridad** como factor crítico de supervivencia en esta nueva era de la Industria 4.0. Las consecuencias que traerá, por poner solo un ejemplo, esta interconexión de empresas cada vez más robotizadas en el mercado del trabajo, aún están por determinar pero serán muy importantes, sin duda alguna.

Todo esto obliga a revisar el concepto de seguridad de la información, a ampliar las dimensiones existentes y a reorientar buenas prácticas, políticas y estándares. Pero, sobre todo, afecta de manera especial a un elemento básico en la libertad de los ciudadanos: su privacidad. En este mundo digital, unos (gobiernos) y otros (corporaciones) tienen la tentación de **romper el equilibrio entre seguridad y privacidad**.

La red ha llegado a tal punto de complejidad que no es sencillo detectar el uso indebido de nuestros datos. La facilidad de concentración y análisis de los datos dispersos por toda la red, con técnicas de Big Data, maximiza el riesgo de abuso de la privacidad. Actualmente, la preocupación no sólo se centra en el posible abuso por parte de gobiernos e instituciones públicas, sino cada vez más en las empresas y corporaciones del sector privado, ávido de información para explotar sus objetivos de negocio.

Así, la frase “**tú eres el producto**” resume de forma brillante la estrategia de negocio que impera actualmente en este ámbito. Disfrutamos *sin coste* de todo tipo de servicios de correo electrónico, de geolocalización, de plataformas de red social, de Apps para nuestro móvil, etc., cuando realmente estamos pagando más de lo que imaginamos, al poner literalmente todas las actividades que realizamos diariamente en conocimiento de estas organizaciones, para que trafiquen con nuestros datos y obtengan nuestro *perfil*. Basta realizar una búsqueda en Google de cualquier servicio o producto para que, a partir de ese momento, aparezca publicidad relativa a dicho concepto en cualquier página que visitemos. Es conocida la relación entre Facebook y *extraños* resultados electorales. Algunos vaticinan que la distinción entre manipulación y marketing se difuminará de tal forma en los próximos años, que los internautas estaremos completamente “dirigidos” consciente o inconscientemente.

En este sentido, la **desinformación**, entendida como la manipulación intencionada de información para influir en la opinión de los ciudadanos, se está constituyendo como una amenaza que afecta a todos los estamentos de la sociedad actual, y muy especialmente a uno de los elementos básicos en una democracia moderna: **la opinión pública**. Estamos viendo como países no democráticos hacen uso de estas técnicas para minar la confianza de los ciudadanos de países democráticos en las instituciones públicas y sigue en debate su influencia en todo tipo de elecciones y consultas a la ciudadanía, así como en el ascenso de ideologías políticas de corte populista y nacionalista. En este sentido, recomendamos encarecidamente la lectura del documento CCN-CERT BP/13 “Desinformación en el ciberspacio” elaborado por el Centro Criptológico Nacional (CNN) y que se reseña en la bibliografía.

Otro desafío amenaza a la propia *esencia* de Internet. Se ha desatado una profunda controversia en diferentes sectores políticos y económicos sobre la necesidad o no de que el tráfico de la red se mantenga *neutral*, es decir, que todos los equipos conectados operen en igualdad de condiciones y no se priorice el tráfico en base a intereses comerciales ni gubernamentales. Como hemos visto, las aspiraciones de control por parte de estados, democráticos o no, han sido una constante en la evolución de Internet. Por si esto fuera poco, los intereses comerciales están intentando, ahora más que nunca, romper las reglas del juego. El hecho de que Google se haya plegado a las exigencias del gobierno chino, ofreciendo una versión censurada de su buscador al país con más habitantes del planeta (y próxima *primera potencia mundial*), o que los EEUU hayan derogado la ley que imponía la neutralidad en Internet,

son dos claros exponentes del peligro de que Internet, tal y como la conocemos, desaparezca en breve plazo y sea sustituida por *otro tipo* de Internet.

Como conclusión y adoptando una perspectiva optimista (como no podría ser de otra forma), las tecnologías de la información han demostrado a lo largo del tiempo su capacidad para ofrecer respuestas que solucionan muchos de los problemas generados por su propia implantación. La red (entendida como conjunto de personas inteligentes que se comunican entre sí) es la primera línea de defensa contra los ataques a la red (entendida como la infraestructura que permite tal comunicación a nivel planetario). Los usuarios de una red social como Facebook constituyen actualmente lo que sería el primer país del planeta en número de habitantes (unos dos mil millones de habitantes que saben leer, escribir y comunicarse), y ejemplos como este indican que estamos en las primeras etapas de una humanidad *hiperconectada*. En este proceso, a medida que aprendamos a desarrollar políticas de empleo seguro de la red, la propia red será más segura y sabia.

Desconocemos las posibilidades y los desafíos que nos planteará la constante evolución del sistema global de comunicaciones, pero hemos de confiar que serán superados por una humanidad cada vez más segura, unida y vertebrada a través de dicho sistema. Son muchos los analistas que piensan que, una vez superada la etapa inicial de desconcierto, incertidumbre y pecados de juventud, esta humanidad *hiperconectada* avanzará, lógicamente con pequeños titubeos y retrocesos, pero de forma decidida, hacia un nuevo modelo de sociedad, mejor y más justa. La inteligencia colectiva no ha hecho sino empezar. Esto se pone realmente interesante.

ACTIVIDADES DE APRENDIZAJE

1. Realizar una atenta lectura del documento CCN-CERT BP/13 - Desinformación en el Ciberespacio, reseñado en la bibliografía, e identificar al menos cinco mensajes recibidos en redes sociales, grupos de Whatsapp y similares, que puedan ser calificados como elementos de desinformación.
2. Realizar una búsqueda de noticias en prensa digital relativas a ciberataques contra infraestructuras nacionales. Seleccionar los cinco más importantes atendiendo a su impacto y número de ciudadanos afectados.
3. Realizar una búsqueda exhaustiva de nuestro rastro digital en diferentes buscadores de Internet y en las principales plataformas de red social. Reflexionar sobre los resultados.
4. Recopilar noticias de prensa digital relativas a conflictos entre la seguridad y la privacidad. Realizar un análisis de los motivos más habituales por los que se sacrifica la privacidad de los ciudadanos en favor de la seguridad.
5. Realizar una búsqueda en Internet de herramientas y técnicas para localizar los metadatos asociados a documentos de Office o en formato PDF y utilizarlas para rastrear los metadatos de los documentos de este tipo creados últimamente, en el ámbito de nuestra actividad docente o profesional.

BIBLIOGRAFÍA

Díaz Orueta, G., Mur Pérez, F. Sancristobal Ruiz, E. Castro Gil, M. Peire Arroba, J. (2004). Seguridad en las comunicaciones y en la información. Madrid: Universidad Nacional de Educación a Distancia.

Gómez Vieites, A. (2011). Enciclopedia de la seguridad informática (2ª edición). Madrid Ra-Ma.

Schwab, K. (2016). La cuarta revolución industrial. Madrid. Editorial Debate.

Documentos electrónicos

CCN-CERT BP/13 - Desinformación en el Ciberespacio. Centro Criptológico Nacional.
<https://www.ccn-cert.cni.es/informes/informes-ccn-cert-publicos/3552-ccn-cert-bp-13-desinformacion-en-el-ciberespacio-1/file.html>

Estrategia Nacional de Ciberseguridad. Boletín oficial del Estado (BOE).
https://www.boe.es/diario_boe/txt.php?id=BOE-A-2019-6347

Sitios en Internet

Centro Criptológico Nacional: <https://www.ccn-cert.cni.es>

Sede electrónica de la Fábrica Nacional de Moneda y Timbre: <https://www.sede.fnmt.gob.es>

Instituto Nacional de Ciberseguridad: <https://www.incibe.es>

EJERCICIOS DE AUTOEVALUACIÓN

A continuación seleccione en cada pregunta la respuesta que considere más correcta.

1. La disponibilidad supone:
 - a. Que la información sólo debe ser accesible por las personas autorizadas.
 - b. Evitar que la información sea alterada o modificada sin autorización.
 - c. Que la información esté disponible cuando sea necesario y por quien esté autorizado a ello.
 - d. Acceder a la información siempre que sea posible.
2. La diferencia entre datos e información radica en:
 - a. No hay diferencias.
 - b. Los datos son la materia prima de la información.
 - c. Los datos son un tipo específico de información.
 - d. La información es la materia prima de los datos.
3. A la hora de analizar la seguridad de la información debemos plantearnos las siguientes preguntas básicas:
 - a. Qué proteger, contra quién, cómo y hasta donde.
 - b. Qué proteger, de qué manera y hasta cuándo.
 - c. Qué proteger, contra quién y cómo.
 - d. Cuando, cómo y dónde proteger.
4. Según la Ley de Firma Electrónica, las firmas efectuadas con un certificado de software FNMT o con el DNLe:
 - a. Ambas son exclusivamente firmas electrónicas reconocidas.
 - b. La firma con DNLe es avanzada y con certificado FNMT es reconocida.
 - c. La firma con DNLe es reconocida y con certificado FNMT es avanzada.
 - d. Ambas son exclusivamente firmas electrónicas avanzadas.
- 5.Cuál de estos elementos se considera generalmente el eslabón más débil de la cadena que configura la visión integral de la seguridad:
 - a. La seguridad física.
 - b. La seguridad lógica.
 - c. La seguridad en comunicaciones.
 - d. La seguridad en el personal.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	c
2	b
3	a
4	c
5	d

GLOSARIO

Big Data: Tecnologías de análisis del comportamiento del usuario, que extraen valor de grandes conjuntos de datos almacenados y formulan predicciones a través de los datos observados.

Blockchain: Tecnología basada en la organización de información en una cadena de bloques que con la incorporación de técnicas criptográficas, permite la creación de un histórico irrefutable de información, sin necesidad de una entidad de confianza que centralice la información. Se emplea en criptomonedas como el Bitcoin.

Criptomonedas: Medio digital de intercambio que utiliza criptografía fuerte para constituir una divisa alternativa a las convencionales.

Desinformación: Empleo de información falsa (por ejemplo, *Fake news*) con el objetivo de manipular la opinión pública.

IEEE: Institute of Electrical and Electronics Engineers. Instituto de ingeniería eléctrica y electrónica. Asociación internacional de ingenieros dedicada a la normalización y desarrollo en áreas técnicas.

IETF: Internet Engineering Task Force. Grupo de trabajo de ingeniería en Internet. Organización internacional que regula las propuestas y los estándares en Internet.

Infraestructura crítica: Toda instalación, red o servicio cuya interrupción o destrucción suponga un impacto importante en la salud, la seguridad o el bienestar económico de los ciudadanos o en el eficaz funcionamiento del Estado y de sus administraciones públicas.

ISO: International Standards Organization. Organización Internacional de Estándares. Organismo internacional independiente y no gubernamental formada por las organizaciones de estandarización de sus 163 países miembros.

ITU: International Telecommunications Union. Unión internacional de comunicaciones. Organismo de la ONU encargado de regular las telecomunicaciones a nivel internacional.

Software libre: Todo programa informático cuyo código fuente puede ser estudiado. Modificado y utilizado libremente con cualquier fin.

UA 2. Fundamentos en seguridad digital

PRESENTACIÓN

En este capítulo se estudian los fundamentos de la seguridad electrónica, comenzando por la criptografía. Así, se describen los métodos básicos de cifrado, tanto simétrico como asimétrico, que junto a los sistemas de generación de resúmenes, confieren las características básicas de la seguridad específicas de la privacidad, como son la confidencialidad (cifrado), autenticación, integridad y no repudio (firma digital). El problema de transmisión segura de las claves, se resuelve con dos aproximaciones diferentes, el sistema horizontal o “anillo de confianza” y el sistema vertical, basado en el concepto de autoridad y certificados digitales.

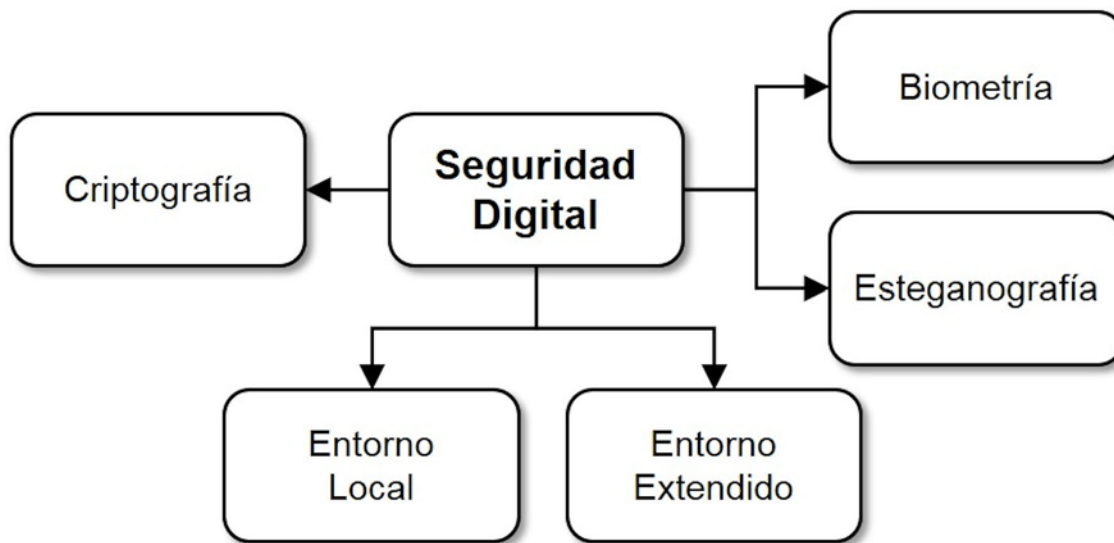
Posteriormente se estudian las aplicaciones prácticas de la criptografía, primero en un entorno local, con equipos de usuario final, continuando con su integración en redes de área local (con especial atención a los entornos inalámbricos Wifi) y finalmente en redes de área extensa (Internet). Se desarrollan por separado las aplicaciones basadas en sistemas horizontales, como PGP y GnuPG o SSH; de las basadas en sistemas verticales, con especial atención al correo electrónico S/MIME, el estándar TLS de comunicaciones seguras y su aplicación a la web segura. A continuación se describen las técnicas de cifrado de redes, como las redes privadas virtuales y los túneles cifrados.

Por último, se explican dos técnicas complementarias a la criptografía en ámbitos de seguridad digital, como son la biometría y la esteganografía.

OBJETIVOS

- Conocer los métodos de cifrado simétrico, asimétrico y de generación de resúmenes más utilizados en la actualidad.
- Conocer las aplicaciones básicas de la criptografía en la seguridad de sistemas informáticos.
- Conocer los sistemas criptográficos más utilizados en la actualidad y sus aplicaciones para asegurar correo electrónico, conexiones entre máquinas y navegación segura.
- Conocer los conceptos de redes privadas virtuales y las aplicaciones básicas de la biometría y la esteganografía.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. CRIPTOGRAFÍA

La criptografía es el método más empleado en la actualidad para la obtención de privacidad, elemento básico en la seguridad de los sistemas basados en las tecnologías de la información. Estudiaremos seguidamente los conceptos básicos que permiten aprovechar técnicas de *escritura oculta* en el proceso, transmisión y almacenamiento de la información.

1.1. Conceptos básicos

Siendo una de las actividades más antiguas del ser humano (existen pruebas de su empleo en el antiguo Egipto, Babilonia, etc.), la **criptografía** o “escritura oculta” ha estado tradicionalmente vinculada a un empleo preferente en aplicaciones militares y por tanto, ha sido necesaria una toma de conciencia muy importante por parte de la sociedad civil, hasta llevar a sus respectivos gobiernos a permitir su empleo de forma generalizada. Así, cabe resaltar la labor de personas como Philip Zimmermann, que pusieron en peligro su propia libertad para conseguir que los métodos modernos de cifrado pudiesen ser utilizados por la sociedad civil. Afortunadamente, la irrupción de Internet en nuestra sociedad y muy especialmente, el desarrollo del comercio y la banca electrónicos, ha venido a facilitar el desarrollo y la expansión de sistemas de cifrado, hasta hace pocos años restringidos a los entornos gubernamentales y militares, y por tanto lejos del alcance del público en general.

Aunque formalmente la criptografía está definida en la RAE como el “Arte de escribir con clave secreta o de un modo enigmático”, es mucho más adecuada su definición técnica, como la aplicación práctica de la **criptología**, entendida a su vez como la “ciencia que se ocupa de garantizar la **privacidad** en el almacenamiento y la transmisión de información”. La criptología tiene su necesaria contrapartida en el **criptoanálisis**, definido como el conjunto de técnicas destinadas a restituir la información cifrada a su estado original, desconociendo la clave o método de cifrado. Por su parte, se define un **criptosistema** como un conjunto de procedimientos (algoritmos, claves, etc.) que garantizan la seguridad de la información mediante el empleo de técnicas criptográficas.

Formalmente, la criptografía tiene como objetivo proporcionar las dimensiones de la seguridad que configuran la **privacidad**, que son todas las conocidas, exceptuando la **disponibilidad**:

- **Autenticación:** capacidad de identificar con seguridad al emisor de un mensaje.
- **Confidencialidad:** capacidad de mantener los datos ocultos para los agentes externos.
- **Integridad:** capacidad de mantener los datos sin alteración.
- **No Repudio:** imposibilidad del emisor (o receptor) de un mensaje de negar que lo ha emitido (o recibido)
- **Trazabilidad:** capacidad de reproducir íntegramente y sin ambigüedad el conjunto de operaciones o de elementos que han afectado a un determinado mensaje.
- **Temporalidad:** capacidad de verificar que determinada información existe o ha sido enviada en un determinado momento, almacenando de forma segura la fecha exacta del evento.

Recordemos que la información se almacena en los ordenadores en formato binario (los bits son números) y, por tanto, se organizan, de cara a su almacenamiento y visualización, en los denominados sistemas de codificación de la información. Así, en todo momento se podrán considerar los bits de una determinada información como si fuesen números (y jugar con ellos, hacer operaciones aritméticas) o como parte de caracteres o símbolos (y permutarlos, alterarlos, etc.). Como veremos de aquí en adelante, los sistemas de cifrado harán uso de estas dos alternativas, a la vez que se utilizarán sistemas específicos de codificación de la información para su transporte y almacenamiento. También debemos recordar que las palabras *encriptar* y *desencriptar* derivan de los verbos ingleses *encrypt* y *decrypt*. Es más correcto y elegante emplear nuestros verbos **cifrar** y **descifrar**.

1.2. Confidencialidad: clave simétrica

La criptografía de clave simétrica se refiere al conjunto de métodos que aseguran la **confidencialidad**, ya que son capaces de cifrar cualquier elemento de información (documento, mensaje, disco, etc.) con una determinada clave. Esto permite tanto el almacenamiento confidencial de dicho elemento, como la transmisión segura de dicha información entre varios agentes, siempre y cuando dichos agentes conozcan la clave correspondiente, que denominaremos **clave simétrica**. La simetría se refiere a que se utiliza la misma clave, tanto para cifrar como para descifrar, como muestra la Figura 2.1. Así, este tipo de algoritmos se basan en el empleo de una clave de cifrado (generada aleatoriamente o a partir de una *contraseña*) que realiza una transformación sobre los datos de entrada, típicamente a base de permutaciones y sustituciones de bits y caracteres, convirtiendo el mensaje o documento original en su versión cifrada, imposible de interpretar a primera vista, pero que, no obstante, podrá ser susceptible de criptoanálisis, para intentar recuperar el mensaje original sin conocer la clave.

Se denomina **texto claro** (*plaintext* en inglés) a la versión original y **texto cifrado** o **criptograma** (*ciphertext*) al resultado de cifrar dicho texto claro. La palabra “texto” no indica que el documento a cifrar sea textual, y podrá ser cualquier tipo de documento electrónico. La **potencia** de este tipo de criptosistemas simétricos viene determinada básicamente por dos aspectos:

- La **calidad** del algoritmo (complejidad de las transformaciones que realiza)
- El **tamaño de la clave** (cantidad de las transformaciones)



Figura 2.1.- Algoritmos de clave simétrica

En la Figura 2.2 se indica, a modo de ejemplo, cómo dos agentes (Ana y Berto) pueden intercambiar información cifrada utilizando este tipo de sistemas de clave simétrica, denominados también de **clave privada**. Siempre que Ana y Berto sean los únicos que conocen la clave privada, cualquier mensaje cifrado por uno de ellos podrá viajar por una red insegura y alcanzar al otro, que lo descifrará con la misma clave, de forma que cualquier agente que intercepte el mensaje (Eva en este caso) lo encontrará ilegible, salvo que el método utilizado sea lo bastante débil como para ser susceptible de criptoanálisis.

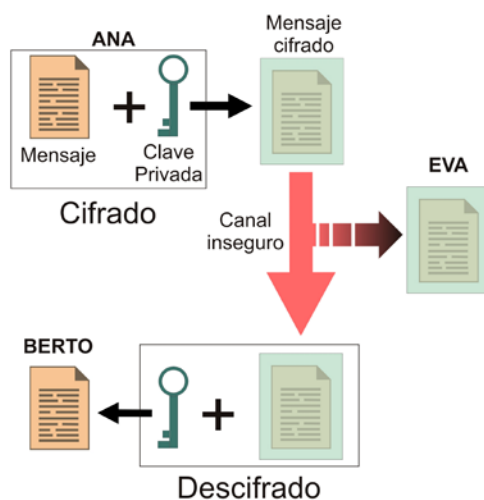


Figura 2.2. Criptografía de clave privada.

Es sabido que los primeros computadores digitales nacieron de la necesidad de *criptoanalizar* los mensajes cifrados con métodos clásicos, como las máquinas Enigma y Purple, utilizadas respectivamente por los alemanes y los japoneses, durante la Segunda Guerra Mundial. La constante evolución y mejora de estos ordenadores, permitió en los años siguientes el desarrollo de sistemas sofisticados de cifrado, dando lugar a lo que se conoce como la criptografía moderna.

El más conocido de estos sistemas es el algoritmo DES (Data Encryption Standard) promovido por la Agencia de Seguridad Americana (NSA) en los años 70, actualmente en desuso, debido a su relativa “debilidad”, ya que, al tener una clave de sólo 56 bits, los sistemas actuales pueden afrontar su criptoanálisis o *ataque* mediante *fuerza bruta*, es decir, probando todas las claves posibles, en pocas horas de cálculo. Aun así, una variante de este algoritmo denominada Triple DES o TDES, consistente en la aplicación sucesiva de tres cifrados mediante DES al mismo documento, se sigue empleando actualmente. En estos últimos años, se han

desarrollado una gran cantidad de algoritmos de este tipo, dentro de iniciativas como el AES (Advanced Encryption Standard) bajo una concepción mucho más abierta, con mayor tamaño de clave (entre 128 y 256 bits) y por lo tanto, mucho más seguros.

Mediante el uso de este tipo de criptosistemas, se resuelven la mayor parte de las necesidades de confidencialidad, tanto en el almacenamiento (ficheros y discos cifrados) como en la transmisión de información. No obstante, en este caso, se plantea un problema: podemos transmitir un mensaje cifrado con una clave a cualquier destinatario, pero ¿cómo le hacemos llegar la clave utilizada? la solución a este problema se consiguió con el desarrollo de los algoritmos de clave pública o asimétrica, que veremos a continuación

1.3. Compartición de secretos: clave asimétrica

El desarrollo de la criptografía asimétrica se inicia con Diffie y Hellman, que describieron en 1976 el modelo teórico de su funcionamiento. Sin embargo, no fue hasta 1978 cuando Rivest, Shamir y Adleman, investigadores del MIT (Instituto Tecnológico de Massachusetts), desarrollaron el algoritmo RSA (acrónimo de sus iniciales), consiguiendo el primer sistema práctico de criptografía asimétrica.

Este tipo de algoritmos se basa en la existencia de **dos claves apareadas**, de tal forma que un texto cifrado con una de ellas sólo puede ser descifrado con la otra y viceversa. Este concepto, que se ilustra en la Figura 2.3, se inicia con la generación de un par de claves que cumplen la propiedad antes citada. De esta forma, una de estas claves se hace **pública**, y todos los restantes usuarios la deben conocer, mientras que la otra, denominada clave **privada**, será tan sólo conocida por el usuario, lo que genera dos aplicaciones básicas, que se intentan explicar en dicho gráfico:

1. Cualquier usuario que conozca la clave pública de otro podrá cifrar mensajes “sólo para los ojos” del titular de dicha clave pública, que sólo podrán ser descifrados con la clave privada, a la que únicamente este tiene acceso (**confidencialidad**)
2. Cualquier mensaje cifrado con la clave privada de un usuario podrá ser descifrado por cualquier otro agente que posea la clave pública de dicho usuario. Esto permite garantizar que dicho mensaje fue cifrado por el único conocedor de la clave privada (autenticación y no repudio, características básicas de la **firma digital**)

Principios de funcionamiento

El funcionamiento del criptosistema RSA está basado en la dificultad computacional de factorizar números enteros muy grandes. Así, las claves pública y privada son dos números realmente grandes (de más de cien cifras decimales) generados a partir de combinaciones de dos números primos, de forma que una determinada transformación matemática del texto claro con uno de ellos sólo puede ser revertida con el otro, y viceversa. Resumiendo, los algoritmos de clave simétrica realizan sustituciones y permutaciones en los datos de entrada para construir el criptograma, mientras que los algoritmos de clave pública realizan operaciones matemáticas, haciendo uso de las propiedades de la aritmética modular, sobre el texto claro y una de las claves para obtener el criptograma y posteriormente, con otra transformación matemática y la otra clave, para reconstruir el texto claro.

Posteriormente, se han desarrollado diferentes criptosistemas asimétricos basados en otras propiedades matemáticas. Así, los algoritmos Diffie-Hellman (DH) de intercambio de claves y el estándar DSA (*Digital Signature Agreement*) de firma digital aprovechan el denominado “problema del logaritmo discreto” (PLD), o la dificultad de encontrar la potencia a la que hay que elevar un número para obtener otro. Una tercera familia basa su seguridad en el concepto de PLD aplicado a las denominadas curvas elípticas, que ha dado lugar a diferentes esquemas, tanto de intercambio de claves como de firma digital, como ElGamal, DHE, y MQV, entre

otros. La principal ventaja de los sistemas de curva elíptica es que reducen el tamaño de sus claves asimétricas, frente a las convencionales.

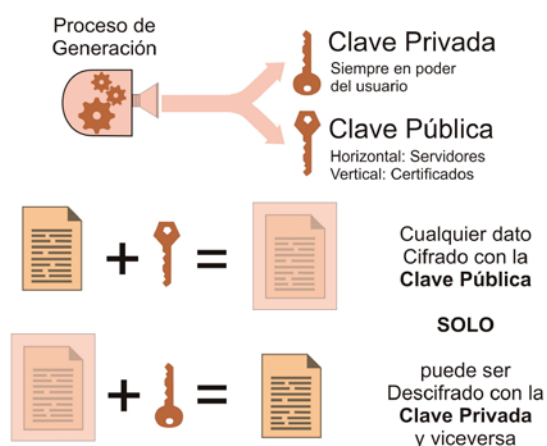


Figura 2.3.- Algoritmos de clave asimétrica o pública

Coste Computacional. Sistemas Mixtos

El mayor inconveniente de estos sistemas es el llamado **coste computacional**: el tamaño de la clave es mucho mayor (entre 512 y 4096 bits, frente a 256 bits como máximo en los simétricos) y las operaciones son más más complejas. Así, el cifrado de un documento con una clave asimétrica es cerca de mil veces más costoso (y por tanto, más lento) que si se emplea una clave simétrica.

La solución adoptada es el empleo de **criptosistemas mixtos**, que usan claves simétricas (TDES, IDEA, RC5, AES, etc.) para cifrar la información y claves asimétricas (RSA, ElGamal, DH, etc.) para cifrar la clave simétrica utilizada, permitiendo su envío hasta el receptor de forma segura. Todos los criptosistemas modernos de clave pública, utilizan este modelo mixto.

Problema del “Man in the middle”. Firma digital de claves

El segundo inconveniente de los sistemas de clave pública afecta a la necesidad de que los agentes, antes de poder cifrar la comunicación, necesitan intercambiar sus claves públicas a través de un medio de comunicaciones, que podrá no ser seguro.

Aparece entonces la denominada amenaza del “agente intermedio” conocido en literatura inglesa como “Man in the middle”. Esta expresión indica la posibilidad de que dos agentes que intercambian sus claves públicas y a continuación cifran la comunicación en ambos sentidos con la clave pública del otro agente, sean engañados por un tercero, que intercepta la transmisión y engaña a ambos, sustituyendo su clave pública propia por la que se transmite en ambas direcciones. De esta forma, este tercer agente podrá descifrar la transmisión en ambos sentidos, y cifrarla de nuevo, sin que los intervinientes se den cuenta.

En la Figura 2.4 se describe este curioso mecanismo de ataque a los criptosistemas de clave pública. En este ejemplo, dos agentes, Ana y Berto, intercambian sus claves públicas, pero existe un tercer agente malicioso, denominado Carlos, que intercepta todas las comunicaciones y manipula los mensajes, sustituyendo las claves durante el intercambio inicial por la suya propia.

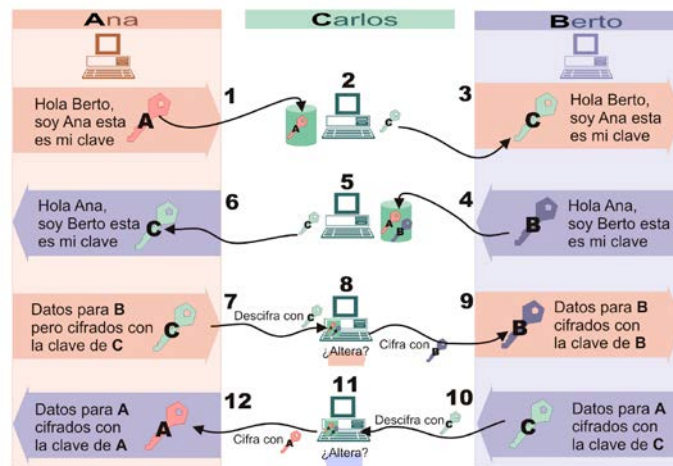


Figura 2.4.- Problema del hombre en medio (Man in the middle)

De esta forma, Carlos se convierte en un intermediario que puede descifrar los dos sentidos de la transmisión y volver a cifrarlos con la clave correcta (que él conserva), de forma que no sólo intercepta el flujo de comunicación secreta, sino que, además, podrá manipular el contenido de los mensajes que intercambian Ana y Berto a su antojo, sin que ninguno de ellos pueda darse cuenta de que toda la seguridad está siendo comprometida. Este mecanismo constituye un claro ejemplo de cuán peligrosa puede ser la falsa sensación de seguridad.

La solución a esta amenaza requiere **confianza en el intercambio de las claves públicas**, es decir, que las claves se transmitan con **integridad** y **autenticación**. Esto se consigue mediante la **firma digital de claves**, que describiremos más adelante.

1.4. Integridad: algoritmos de Resumen

Cuando se desea garantizar la integridad de los datos enviados, es muy conveniente disponer de un método que permita, a través de una serie de cálculos sobre todo su contenido, generar el equivalente de un *extracto de tamaño fijo* o *resumen irreversible* del mensaje, mediante las *funciones de resumen* (*hash* en inglés). Así, cualquier modificación del mensaje original provocará que el resumen obtenido sea diferente del calculado inicialmente, lo que permite comprobar la integridad del mismo. Este tipo de algoritmos, por tanto, generan lo que se conoce como **resumen** o **huella digital** del mensaje (*digest* en inglés).

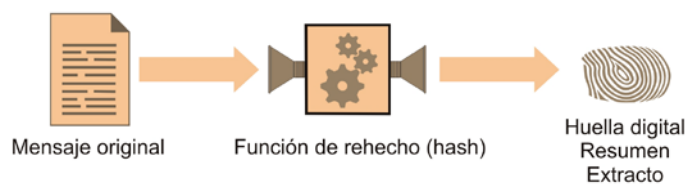


Figura 2.5.- Algoritmos de generación de resúmenes

Este resumen o huella del mensaje, tiene un tamaño fijo, dependiendo del algoritmo utilizado. Además, es imposible reconstruir el mensaje original a partir del resumen y la probabilidad de encontrar otro mensaje distinto que produzca la misma huella es prácticamente nula. Los algoritmos más conocidos son los denominados de la familia MD (MD2, MD3, MD4 y MD5), actualmente considerados poco seguros y las familias SHA-1, SHA-2 y SHA-3, con mayor tamaño y robustez.

Estos algoritmos de resumen son utilizados, no sólo en todo tipo de sistemas criptográficos, sino también para la **gestión de las contraseñas de acceso** a los sistemas informáticos, de forma que no se almacenan las contraseñas, sino sus resúmenes.

1.5. Autenticación y No repudio. Firma digital: cifrado de resúmenes

La aplicación combinada de los algoritmos de resumen con los sistemas de cifrado vistos anteriormente, presenta dos aplicaciones inmediatas:

1. Un mensaje, bien sea transmitido en texto claro o cifrado, puede ir acompañado de un resumen del mismo, que a su vez se cifra con la clave privada del autor. Aquellos que lo reciban, podrán descifrar el resumen utilizando la clave pública del firmante, lo que indica que efectivamente fue cifrado con su clave privada, es decir, que sólo él pudo hacerlo (**autenticación y no repudio**). Una vez descifrado el resumen, se podrá comparar con el resumen que se obtiene aplicando el mismo algoritmo al documento recibido. Si ambos coinciden, el documento no ha sufrido ningún cambio en la transmisión (**integridad**). Esta es la base del concepto de **firma digital**, que es **el resumen de un documento cifrado con la clave privada del agente firmante**.
2. Al igual que se puede firmar cualquier documento, también se pueden firmar las **claves públicas** de los agentes. Este mecanismo de firma de claves permite solventar el problema antes citado del *Man in the middle*, y se aplica de forma práctica en los dos tipos de sistemas criptográficos que describiremos a continuación.

1.6. Sistemas criptográficos: horizontales y verticales

Una vez establecidos los algoritmos criptográficos que se utilizan para la transmisión segura de información, el problema radica en el método que se utilizará para distribuir de forma abierta pero segura, las claves públicas de los diferentes agentes. Las dos soluciones básicas a este problema se denominan sistemas horizontales y verticales. En los primeros, cada agente será responsable de confiar o no en las claves de los demás agentes y en los segundos, se establece el concepto de autoridad o tercera parte segura que firma las claves de todos los agentes participantes.

1.7. Sistemas Horizontales

Los sistemas criptográficos horizontales asumen que todos los participantes tienen el mismo nivel de confianza intrínseca. Así, cada agente genera su par de claves asimétricas, almacenando de forma segura la clave privada y firmando la clave pública con su propia clave privada. Esta clave *autofirmada* estará protegida contra alteraciones. Además, otro agente que esté seguro de que dicha clave pública es realmente la indicada (por ejemplo, porque lo ha comprobado fehacientemente, en persona o de alguna otra forma) podrá también firmar dicha clave. Estas firmas de clave se realizan en los “llaveros digitales” o repositorios de cada usuario, pero, además, pueden ser publicadas en los denominados “servidores de claves”, de forma que los demás agentes podrán descargar no sólo la clave pública de un agente con el que desean tener una comunicación segura, sino también las firmas digitales que acompañan a dicha clave.

Confianza entre agentes. Transitividad.

De esta forma, todos los agentes del sistema podrán acceder a dichos servidores, identificar la clave pública asociada a un agente con el que desean establecer algún tipo de comunicación segura, y en virtud de otros agentes que hayan *firmado dicha clave*, validar la fiabilidad de la misma, en función de la confianza que les merezcan dichos firmantes. En la Figura 2.6 se muestra como cada agente podrá *fiarse* o no de una determinada clave, aplicando la propiedad transitiva (si A se fía de B y B se fía de C y C se fía de D...)

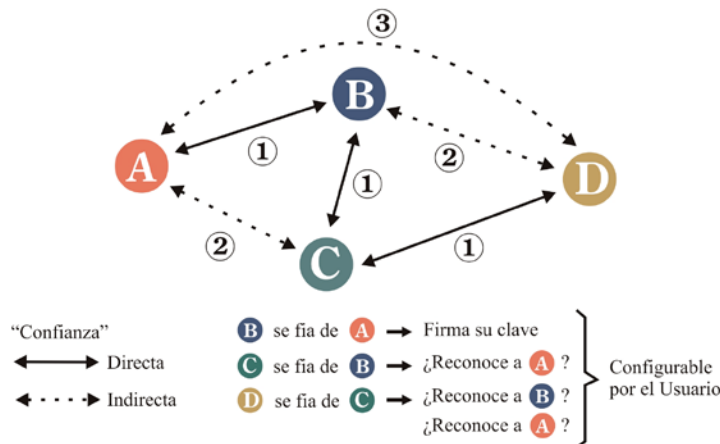


Figura 2.6.- Sistema Horizontal (PGP y GnuPG)

Telaraña de confianza (Web of Trust)

A medida que el número de agentes crece, se establece lo que se denomina una *telaraña de confianza* o *web of trust*, modelo que ha demostrado ser de gran utilidad cuando pequeñas organizaciones o grupos de individuos necesitan intercambiar correo electrónico seguro y documentos cifrados en general, muy especialmente en estados que no respetan los derechos humanos.

El mayor inconveniente que presentan estos sistemas es que el concepto subyacente de *firma entre amigos* no es el más adecuado para la distribución de claves públicas en un entorno global, como el de los negocios en la Internet actual. Cuando los agentes no se conocen previamente, es más eficaz la existencia de *autoridades de confianza*, características de los sistemas verticales, que aseguran la autenticidad de las claves para todos los agentes.

1.8. Sistemas Verticales: Infraestructuras de clave pública

Así, los sistemas criptográficos verticales se basan en la existencia de **Autoridades de Certificación** (AC, también denominadas CA por abreviatura de Certification Authority), que, al firmar electrónicamente las claves públicas de todos los agentes de un sistema, garantizan la validez y autenticidad de dichas claves. Este es el mecanismo más empleado en la actualidad, y se usa en entornos tan universales como la web segura (HTTPS) o el correo electrónico seguro S/MIME, por citar solo dos ejemplos.

Así, se define como **Infraestructura de clave pública** (Public Key Infrastructure o PKI) el conjunto de autoridades de certificación, los agentes certificados que intervienen en el sistema vertical (personas, programas, dispositivos, etc.) y el conjunto de criptosistemas que de manera integrada, permiten el cifrado y descifrado de mensajes, la firma digital de información, el no repudio de un envío, y en general, todas las operaciones conducentes a la obtención de privacidad.

1.8.1. Certificados digitales X.509

Un **certificado digital** es una estructura de datos que engloba los datos más relevantes de cada uno de los agentes de una infraestructura de clave pública o PKI, basada en el concepto de **sistema vertical** de intercambio seguro de claves asimétricas. En estos sistemas, una Autoridad de Certificación o tercera parte segura (Trusted Third Party o TTP), como entidad responsable de la administración de las claves públicas de todos los agentes implicados en el sistema, firma digitalmente, uno a uno, los certificados de cada uno de estos agentes. A su vez, un agente podrá ser una persona física, una persona jurídica (empresa, sociedad, etc.), un servidor de Internet, un programa informático, un componente hardware o, en general, cualquier elemento susceptible de establecer comunicaciones seguras.

Las cuatro partes más importantes de un certificado digital son:

1. La clave pública del agente titular del certificado
2. La identidad de dicho titular: nombre y datos generales
3. Las operaciones que puede realizar el titular (firma de determinados documentos, cifrado con determinados algoritmos, etc.)
4. La firma digital de todo el certificado, realizada con la clave privada de la autoridad de certificación, que asegura la integridad y autenticación de los datos.

En la actualidad, casi todas las aplicaciones de comercio electrónico y transacciones seguras se basan en el empleo de certificados digitales, cuyo formato estándar más utilizado es el conocido como X509, con estructura básica indicada en la tabla 2.1.

Tabla 2.1. Datos más importantes de un certificado X.509

Versión de protocolo:
Número de serie:
Emisor del certificado (nombre de la Autoridad):
Identificador del algoritmo usado en la firma (RSA, DSA, etc.):
Periodo de validez del certificado:
Nombre e información adicional del sujeto:
Clave pública, longitud, y demás parámetros:
Algunos datos opcionales (por ejemplo, claves adicionales, operaciones autorizadas para cada clave, autoridad delegada de firma o registro, etc.):
Firma de la autoridad certificadora:

Así, cualquier agente que quiera transmitir información cifrada, necesitará conocer la clave pública de su interlocutor. Para ello se habrá de efectuar un **intercambio de certificados** previo a la transmisión segura, de tal forma que cada uno de los agentes podrá verificar la acreditación efectuada por la Autoridad de Certificación sobre la clave pública del otro.

1.8.2. Autoridades de certificación. Niveles de autoridad

Un valor añadido en el empleo de los sistemas verticales es la posibilidad de que el concepto de autoridad de certificación o CA se distribuya en niveles, de forma que aparecen autoridades de certificación **delegadas**, con capacidad para firmar certificados. De esta manera, se puede distribuir por todo un país la emisión y generación de certificados, como se realiza en el caso del DNIe, con los diferentes equipos de expedición repartidos por la geografía nacional.

El papel de la **autoridad de certificación** (CA) consiste en firmar los certificados digitales de los usuarios, y mantener el status correcto de dichos certificados. Como veremos, hoy en día es práctica habitual que la generación de la pareja de claves pública y privada se realice en el ordenador del usuario y que se envíe, junto con los datos del mismo, la clave pública para que esta sea certificada por la CA. Si se consideran niveles de autoridad, la CA será la responsable, como mínimo, de emitir los certificados de las autoridades que de ella dependan.

Las **autoridades delegadas** (equipos de expedición del DNIe, por ejemplo) podrán ser a su vez emisoras de certificados, cuyo ámbito de aplicación suele ser más restringido que los certificados que firma la autoridad de certificación. En cualquier caso, la verificación de todo certificado conlleva al menos dos pasos: la verificación de la firma de la autoridad en el certificado del agente y la verificación del **certificado raíz** de la autoridad, que ha de estar autofirmado. Si como se muestra en la figura 2.7, existen autoridades delegadas o intermedias, aparece el concepto de **cadena de verificación**, de forma que se tendrá que comprobar también cada uno de los certificados de estas autoridades delegadas.

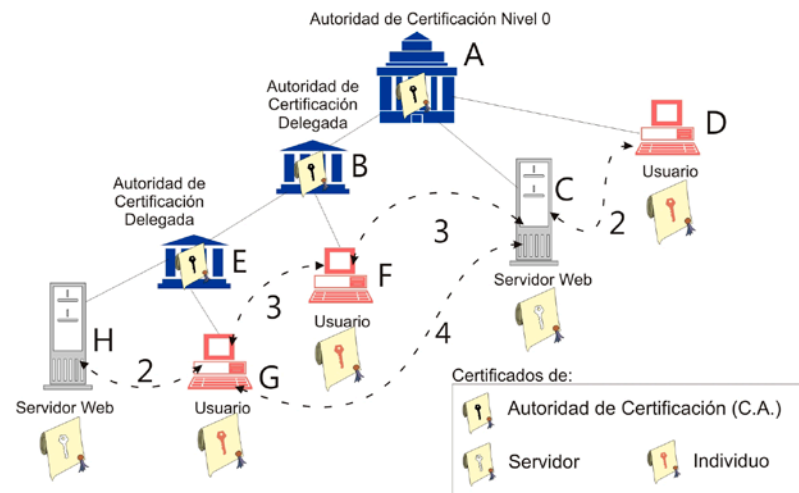


Figura 2.7.- Esquema de certificación en modelo vertical con autoridades delegadas

Renovación y Revocación de Certificados

Además de disponer de un **período de validez** fijado con antelación y que podrá ser **renovado** si la CA lo autoriza (emitiendo un certificado idéntico al anterior, con la misma clave y un nuevo plazo de validez), un certificado cuya seguridad se haya visto comprometida, podrá ser **revocado** por el usuario. Entonces, los demás agentes tendrán que disponer de acceso a la denominada *lista de revocación de certificados* o CRL, ya que, sin la consulta a esta lista, un certificado ha de considerarse como válido mientras lo indique su período de validez. Por ello, las aplicaciones que manejan certificados X.509 suelen utilizar el protocolo OCSP (*Online Certificate Status Protocol*) para consultar en línea la validez de los certificados que procesan. En el caso de que la clave privada de una autoridad sea comprometida, será necesaria la revocación automática de todos los certificados emitidos por la misma, sean de agente o de autoridad. Este es otro argumento a favor de la descentralización de autoridades.

1.8.3. Tipos de Autoridades: oficiales, comerciales y gratuitas

Como se ha explicado en apartados anteriores, los sistemas criptográficos verticales permiten la realización de operaciones criptográficas (cifrado simétrico, cifrado asimétrico, firma digital, etc.) entre diferentes agentes, de forma que la autenticación de los mismos se produce cuando un agente verifica la firma del certificado de otro agente, firma efectuada con la clave privada de una tercera parte segura o autoridad de certificación.

En la práctica, la verificación de dicha firma exige el conocimiento, por parte del agente que realiza la verificación, de la clave pública de la autoridad certificadora, que a su vez se distribuye en un certificado de autoridad o **certificado raíz**. Los equipos informáticos actuales cuentan con **almacenes de certificados** en sus sistemas operativos y en algunos navegadores, en los que se almacenan los certificados propios y de otros agentes, y en los que se introducen los certificados de determinadas **autoridades reconocidas**, es decir, que cumplen determinados criterios en la emisión y el control de los certificados que emiten.

Esto lleva a la primera clasificación de autoridades, según su reconocimiento:

- **Autoridades reconocidas:** cumplen determinados criterios de emisión y control de sus certificados y figuran en los almacenes de certificados raíz de Microsoft, Apple, Android, etc.
- **Autoridades no reconocidas:** Su certificado raíz no figura en estos almacenes y ha de ser cargado previamente por los usuarios.

Otra clasificación atiende al ámbito de funcionamiento de las autoridades, citaremos aquí como ejemplos de autoridades reconocidas:

- **Autoridades oficiales:** Organismos gubernamentales y grandes organizaciones. Ejemplos: FNMT, DNIe, Asociaciones de Cámaras de Comercio, etc.
- **Autoridades comerciales:** Empresas que prestan servicios de emisión de certificados para su uso comercial. Ejemplos: Thawte, Verisign, etc.
- **Autoridades gratuitas:** Iniciativas como Let's Encrypt (cifremos en español) ofrecen certificados reconocidos de servidores web sin coste, con el objetivo de conseguir que el tráfico web mundial sea mayoritariamente seguro.

1.8.4. Generación segura de certificados digitales

Aunque en las primeras implantaciones de este tipo de sistemas, la autoridad de certificación generaba las parejas de clave pública y privada de sus agentes, previamente a la emisión de los certificados, hoy en día, los navegadores de Internet más conocidos, disponen de mecanismos para generar internamente la pareja de claves pública y privada, transmitir la clave pública a la CA y recoger el certificado firmado por dicha CA. Mediante este proceso, se asegura que la **clave privada** se genera de **forma segura** en un entorno local al ordenador y ni siquiera la CA puede conocerla. Como ya vimos, la *generación segura* de los certificados es un **requisito** para la **validez legal** de un certificado a efectos de firma electrónica aceptada por la legislación española, tratándose en este caso de una firma electrónica **avanzada**.

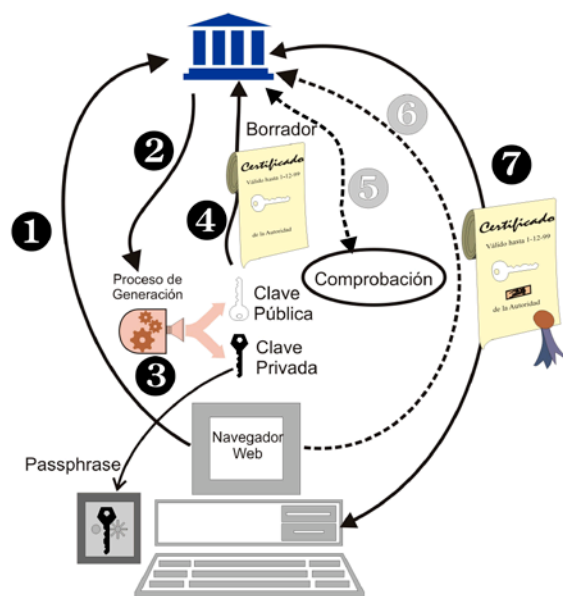


Figura 2.8. Mecanismo de creación segura de un certificado digital

Así, como se observa en la Figura 2.8, mediante la serie de pasos indicada, el navegador del ordenador conecta con el servidor de la autoridad de certificación (1) y recibe la orden de generar una pareja de claves pública y privada. La clave privada se almacena de forma segura en el ordenador y la clave pública se envía en el paso (3) junto con la información solicitada al usuario, formando parte del borrador de certificado. Llegados a este punto, la CA realizará la comprobación de que el usuario es quien dice ser, en un proceso que podrá ser diferido, como cuando se requiere que el usuario se presente en una oficina (caso del certificado de la FNMT), aunque en ocasiones este procedimiento no es tan estricto y se realiza instantáneamente, como ocurre en los certificados gratuitos que expiden algunas autoridades como openca.org o CAcert.org. Finalmente, la autoridad envía al usuario el certificado válidamente firmado (5) para

su almacenamiento en el ordenador del usuario y se procede al registro en la base de datos del servidor de certificados de la autoridad.

Finalizado el proceso, el poseedor del certificado dispone de la **clave privada** que le permitirá realizar las operaciones de descifrado de información, típicamente cifrada por otro agente con su clave pública (es decir, *sólo para sus ojos*), y de cifrado con dicha clave privada de resúmenes de documentos que podrán ser descifrados por cualquier otro agente, utilizando su clave pública (firma digital). **Esta clave privada, por tanto, ha de ser protegida** de forma que no sea accesible a ningún otro agente. Para ello, se aplican a su vez técnicas de cifrado de esta clave privada, almacenándose siempre cifrada a su vez, con claves simétricas consistentes en contraseñas de mayor longitud y robustez que las habituales (en terminología inglesa, se las conoce como **passphrases** o frases clave, en contraposición con las habituales **passwords** o palabras clave).

Tarjetas criptográficas. DNIE

En cualquier caso, por muy seguro que sea su almacenamiento, cuando sea necesario utilizar la clave privada, será descifrada y estará desprotegida mientras se utilice en la memoria del ordenador, posibilitando que otro programa de carácter malicioso tenga acceso a ese espacio de memoria y pueda comprometer gravemente la seguridad de dicha clave.

La alternativa a los problemas planteados por el empleo de estos certificados *de software*, consiste en la utilización de tarjetas con un **chip criptográfico**, dotado de memoria en la que se almacena tanto el certificado como la clave privada y de un procesador capaz de realizar las operaciones de cifrado y descifrado con la clave privada, a solicitud del procesador principal del ordenador. De esta forma que se consigue introducir toda la “lógica de trabajo” en la propia unidad lectora de las tarjetas inteligentes. En este caso, la creación del certificado también es segura, ya que la generación de las dos claves se realiza internamente. Como ya se dijo, España ha sido pionera en el despliegue universal de este tipo de sistemas, incorporando un chip criptográfico en el DNIE. Recordemos que en la unidad 1 se explicó que las firmas realizadas con certificados de software son **avanzadas** y con el DNIE son **reconocidas**, aunque ambas tienen plena validez legal.

2. SEGURIDAD DIGITAL EN ENTORNO LOCAL

Estudiada la criptografía como el conjunto de técnicas que confieren privacidad a los datos almacenados o en tránsito, se estudia ahora la aplicación de estas técnicas en el funcionamiento básico de los equipos informáticos, para asegurar la autenticación, la integridad y la confidencialidad de los datos almacenados en dichos equipos, que podrán ser fijos, portátiles o móviles, y estar integrados o no en alguna red de comunicaciones.

Se verán por tanto a continuación las técnicas que confieren seguridad digital a los equipos de usuario en un entorno local, sin contemplar el empleo de redes de comunicaciones; y en apartados siguientes se desarrollarán las técnicas de protección de la información en su tránsito por redes de comunicaciones, tanto en ámbito local como extendido.

2.1. Conceptos básicos de seguridad digital en equipos de usuario

Es sabido que desde el mismo momento en que se accede un sistema informático, con independencia de que sea un ordenador de sobremesa, portátil, tablet o smartphone, se emplean herramientas criptográficas. Así, las contraseñas de acceso al sistema usualmente se almacenan *resumidas* mediante funciones de hash, otras contraseñas denominadas *passphrases* a su vez se utilizan como clave de cifrado para proteger claves asimétricas almacenadas en los certificados, etc. En ocasiones, sobre todo en equipos móviles, se emplean herramientas biométricas, descritas más adelante, como la identificación de la huella dactilar o el reconocimiento facial o

del iris. En todo caso, el sustrato básico de seguridad en el acceso a los equipos de usuario serán las herramientas criptográficas estudiadas anteriormente.

2.2. Cifrado de discos, volúmenes y ficheros

Cuando se almacena información en un disco duro, en un pendrive, se sube a la nube, etc., estará almacenada en ficheros legibles por cualquiera que tenga acceso a ellos. En ocasiones se podrá comprometer la privacidad (documentos personales, fotos, correos), en otras, información de carácter profesional cuyo contenido puede ser de gran utilidad a la competencia o a posibles rivales. Muchas veces, existirá un imperativo legal a tomar medidas de protección (Ley orgánica de protección de datos personales, etc.). En todas estas situaciones, será necesario emplear medidas de protección destinadas a:

1. Evitar que cualquiera tenga acceso a la información almacenada en los discos internos de los equipos personales o de trabajo, incluyendo los móviles.
2. Garantizar un intercambio seguro de datos cuando se comparte información a través de pendrives, CDs, discos externos o a través del envío por medios digitales (almacenamiento en servidores web, sistemas en la nube, etc.)

Actualmente el cifrado de discos, volúmenes o ficheros individuales es una opción sencilla, muchas veces sin coste y que proporciona el grado de seguridad requerido para cada situación.

Veamos primero algunas definiciones básicas:

- **Unidad de almacenamiento** es un dispositivo físico (disco, pendrive, DVD, etc.) que, alojado interna o externamente en el ordenador, permite almacenar información, bien sean documentos, fotos, videos, correos, etc. Como tal, una unidad puede dividirse en varias **particiones** o bien se podrá generar una única partición con todo el espacio disponible en la unidad.
- Posteriormente, cuando una partición es incorporada, mediante la operación conocida como montaje, al sistema de ficheros, y por tanto es accesible desde el sistema operativo, se crea un **volumen** a nivel lógico. Un volumen podrá ocupar una o varias particiones, de una o varias unidades de almacenamiento.
- Por último, es posible generar **volúmenes virtuales**, formados por la recursión del concepto de volumen asociado a partición, considerando un **fichero de un volumen ya montado** como si fuese una nueva partición independiente. En este caso, el sistema operativo detectará la aparición de un nuevo disco virtual, como resultado de montar, como si fuese una partición más, el contenido de dicho fichero como un nuevo volumen.

Por tanto, es necesario disponer de mecanismos que permitan cifrar la información almacenada, tanto en volúmenes asociados a particiones reales de las unidades de almacenamiento, como en volúmenes asociados a particiones virtuales (creadas sobre ficheros), como en ficheros individuales.

Veamos tres alternativas que permiten trabajar con volúmenes cifrados:

1. La primera consiste en el uso de discos externos o pendrives que incorporan de fábrica hardware que permite cifrar el contenido de los mismos. La mayoría de las marcas que fabrican este tipo de dispositivos incorporan algún modelo con estas capacidades. El algoritmo más habitual es el cifrado AES de 128 o 256 bits. Actualmente el uso de estos equipos se limita a aplicaciones de alta seguridad y se emplean cada vez más las dos opciones siguientes.

2. La segunda, más interesante por las posibilidades que ofrece, consiste en el cifrado mediante herramientas software, o aplicaciones que se intercalan en los servicios básicos del sistema operativo relativos a la gestión de los sistemas de ficheros, de forma que permiten el cifrado y descifrado de la información que se guarda o se recupera. Este tipo de cifrado se denomina *On the Fly* (en vuelo) por realizarse en tiempo real, mientras se está accediendo al disco. Muchos pendrives y discos externos ofrecen este tipo de herramientas incorporadas de fábrica y existen diversos productos, tanto en versiones comerciales como gratuitas.
3. La tercera es una extensión de la segunda y consiste en cifrar todos los discos del sistema, incluido el disco de arranque. De esta manera, el sistema solicitará la contraseña antes de arrancar y no podrá ser analizado desde otro sistema con técnicas forenses si no se conoce la contraseña. Esto es especialmente útil en equipos móviles

Cada vez más son utilizadas las dos últimas opciones, junto con el cifrado individual de ficheros, que en ocasiones se realiza desde los programas de edición (Microsoft Office, etc.)

3. SEGURIDAD DIGITAL EN REDES. LAN Y WAN

Es sabido que los protocolos de Internet permiten el intercambio de información en una red global, a través del concepto de *internetwork* o red formada por integración de distintas redes que utilizan el mismo conjunto de protocolos básicos de funcionamiento (la familia de protocolos TCP/IP). De hecho, el mismo nombre propio de la red Internet (con mayúsculas) procede de la abreviatura inglesa de *internetwork* a *internet* (con minúsculas).

Así, desde el punto de vista del usuario, se considera que un equipo está conectado a Internet, con independencia de que lo haga desde una conexión de cable Ethernet, una red inalámbrica Wifi o por acceso a una red de datos móviles. Se estudian a continuación los elementos básicos de seguridad digital, tanto en redes de área local (Local Area Networks o LAN) como en redes de área extensa (Wide Area Networks o WAN), entendiendo este caso Internet como una red de área extensa o WAN a nivel planetario.

3.1. Internet como red global, sencillez frente a seguridad

Una de las razones que explican el crecimiento explosivo de Internet se basa en el empleo de estándares de comunicación como los protocolos básicos de funcionamiento de Internet, descritos como la familia TCP/IP, cuya naturaleza está orientada a su facilidad de uso. Es decir, **Internet nació como una red global con énfasis en la funcionalidad, a expensas de la seguridad.**

Así, el sustrato básico de Internet es el denominado paquete IP, que es una estructura de datos sencilla que contiene la información básica de origen y destino, junto al contenido de la información que se desea transmitir. Estos paquetes se entregan a las máquinas intermediarias o routers que, a base de saltos, consiguen que lleguen a la dirección de destino.

Estos paquetes IP circulan por determinadas arquitecturas de red física, como las redes de cable Ethernet, redes inalámbricas Wifi, conexiones punto a punto ADSL, cable y fibra, sobre sistemas de cable submarino, de satélite, etc. La existencia de este concepto de “paquetes dentro de paquetes” es precisamente la que permite unificar múltiples sistemas de transmisión en una red de alcance planetario, como es Internet.

Así, en el denominado nivel de red, las comunicaciones no son fiables (los paquetes pueden no llegar a su destino). Sobre este nivel de red, se configuran los denominados protocolos de transporte, uno de los cuales (TCP) organiza el control del envío de paquetes entre las máquinas, constituyendo conexiones fiables y orientadas a conexión sobre el sustrato anterior. Aun así, este protocolo no contempla ningún nivel de privacidad en la comunicación.

De esta forma, el nivel de aplicación, donde realmente se establece el intercambio de información útil para los usuarios, adolece de los mismos problemas. Así, como hemos visto en ejemplos anteriores, muchas aplicaciones, como el correo electrónico y la navegación web *originales*, se transmiten de forma tal que cualquier equipo que pueda interceptar los paquetes en su viaje a través de las distintas conexiones, podrá *leer* todo su contenido e incluso modificarlo con fines maliciosos.

A continuación, se estudian las técnicas básicas que permiten el empleo de herramientas criptográficas para conferir privacidad a las conexiones en red, tanto en área local como extendida.

3.2. Redes de Área Local (LAN)

En el denominado entorno de redes de área local (LAN), se estudia la problemática de seguridad inherente a la tecnología de bajo nivel que sustenta el tráfico de paquetes IP. La más extendidas en la actualidad son las tecnologías Ethernet (sobre cable de diferente tipo) y muy especialmente la tecnología inalámbrica o Wifi, basada en radiofrecuencias.

3.2.1. Seguridad en redes inalámbricas (Wifi). De WEP a WPA3

Últimamente, las tecnologías de red inalámbrica conocida como Wifi (Wireless Fidelity) está sustituyendo, tanto en el entorno doméstico (gracias a la irrupción de la banda ancha en los hogares) como en todo tipo de lugares públicos, a conexiones a la red establecidas sobre circuitos inherentemente más seguros (cable Ethernet, conexiones punto a punto, etc.)

Las tecnologías de red local, con Ethernet a la cabeza, ha mejorado a lo largo de los años, con la adopción de mejoras en los equipos repetidores (sustitución de repetidores o *hubs* por conmutadores o *switches*) que, en su conjunto, garantizan que por cada cable sólo circulen los paquetes de información necesarios, evitando así la posibilidad de que otro ordenador de la red local escuche paquetes de información que en principio debería ignorar.

En este sentido, la tecnología de transmisión inalámbrica conocida como Wifi, que se basa en la adaptación de los protocolos Ethernet a frecuencias de radio, supone en cierto sentido una *marcha atrás* en la seguridad en redes locales, ya que se ve afectada por la naturaleza promiscua de sus transmisiones de radiofrecuencia. Debido a esta circunstancia, desde el primer momento de la definición de los estándares Wifi, se desarrollaron aplicaciones que intentan asegurar la privacidad en la transmisión de información a través de estos sistemas, inherentemente inseguros, mediante el empleo de técnicas criptográficas.

Así, las diferentes versiones de este protocolo de comunicaciones inalámbricas han intentado mejorar no sólo la velocidad y la interoperabilidad de las comunicaciones, sino muy especialmente su privacidad. Por tanto, al configurar redes Wifi, se podrá elegir una comunicación sin protección (muy desaconsejable) o con diferentes sistemas de cifrado:

- **WEP** (*Wired Equivalent Privacy*, o privacidad equivalente al cableado): actualmente obsoleto, aunque lamentablemente siguen existiendo redes con esta protección. Desarrollado en 1.999, utiliza el algoritmo RC4 para cifrado. Errores en su concepción permiten que cualquier equipo conectado a la red pueda descubrir la clave de protección pasados unos minutos. Hoy en día, el empleo de este protocolo es casi tan peligroso como no utilizar ninguna protección.
- **WPA** (*Wifi Protected Access*, o Acceso protegido a Wifi): este protocolo se desarrolló en 2003 para mitigar las deficiencias de seguridad del anterior. WPA diferencia entre dos modos de uso: personal y empresarial. En el personal, se usa una autenticación simple a través de contraseña contra el punto de acceso. En el empresarial, se emplea un servidor RADIUS para la autenticación.

- **WPA2:** vulnerabilidades descubiertas en el cifrado RC4 motivaron el 2004 la segunda versión de WPA, que lo sustituye por AES, mucho más seguro. Incorpora también los dos modos de autenticación, al igual que WPA: personal y empresarial. Tiene como su antecesor un mecanismo de conexión automática a la red denominado WPS (*Wifi Protected Setup*) con muchas vulnerabilidades y también permite en su modo de uso personal los ataques a la clave de cifrado mediante diccionarios, haciendo los cálculos sin necesidad de estar conectado.
- **WPA3:** Introducido en 2018, este nuevo sistema presenta un cambio sustancial sobre los anteriores, mejora la negociación de las claves, dificultando su ataque mediante fuerza bruta e incorpora opciones para mejorar la integración de dispositivos IoT (Internet de las cosas: TVs, cámaras, sensores, altavoces, etc.) sin pantalla ni teclado de configuración.

Además del cifrado de la transmisión entre agentes en una red Wifi, existen otras alternativas que permiten mejorar la privacidad en este tipo de comunicaciones y que serán estudiados en la unidad 4 de este manual. Como conclusión, se puede decir que el abanico de posibilidades de utilización de entornos seguros en las comunicaciones inalámbricas, permite establecer un equilibrio razonable entre facilidad de uso y seguridad (entendida como privacidad) en las comunicaciones.

3.3. Entorno extendido (WAN)

Se estudian a continuación los diferentes sistemas basados en el empleo de aplicaciones criptográficas más utilizados en la actualidad para incorporar privacidad a las comunicaciones con carácter global, características de la Internet actual.

3.3.1. Aplicaciones de los Sistemas Horizontales

La simplicidad de su esquema básico de funcionamiento y el modelo de igualdad entre todos sus agentes, característicos de la filosofía “peer-to-peer” (igual a igual) imperante en los sistemas de distribución de claves públicas basados en un modelo horizontal, ha permitido que tanto el software PGP, como su encarnación en software libre, denominada GnuPG, han sido y siguen siendo extensivamente utilizados por ciudadanos y organizaciones no gubernamentales para garantizar la privacidad en sus comunicaciones.

PGP, OpenPGP y GnuPG. Servidores de firma de claves

El software **PGP** fue la primera aplicación informática capaz de proporcionar *privacidad a las masas*, entre otras razones, debido a su carácter gratuito. No obstante, una vez resueltos sus problemas con la justicia, su autor, Phil Zimmermann, creó una empresa para su explotación paralela, bajo filosofía comercial, de modo que durante años existieron dos versiones del PGP, una comercial y otra gratuita para uso individual. El propio Zimmermann propuso la creación de un estándar internacional denominado **OpenPGP** y la Free Software Foundation desarrolló el software *GNU Privacy Guard*, también denominado **GnuPG** o GPG, que se integra en la práctica totalidad de las distribuciones de Linux y Unix, con equivalentes en todos los sistemas operativos de computación de sobremesa y móvil (Windows, MacOS, IOS, Android, etc.)

Las aplicaciones básicas de los sistemas OpenPGP son el cifrado simétrico y asimétrico y la firma digital de ficheros, así como el correo electrónico seguro. Igualmente, una serie de servidores de claves PGP, almacenan miles de claves públicas de usuarios, firmadas por otros usuarios. Lamentablemente, la inexistencia del equivalente de autoridades de certificación permite la existencia de muchas claves falsas, con firmas igualmente falsas. De alguna forma, vienen a ser la constatación de las carencias del sistema horizontal en el entorno global.

Cifrado de documentos y Correo electrónico seguro PGP

Desde su desarrollo, el software PGP adoptó la dirección de correo electrónico de sus usuarios como identidad digital, de forma que se asociaba la pareja de claves asimétricas a cada dirección de correo. Incorporó funciones de cifrado simétrico, envío seguro de claves y firma digital de documentos. Además, se desarrolló un estándar de codificación de información binaria en formato de texto, lo que permitió la incorporación de mensajes de correo electrónico con información segura en su interior, cuando el estándar de correo electrónico sólo permitía mensajes de texto ASCII sin caracteres específicos de lenguaje (como la ñe en nuestro país), es decir, antes del desarrollo del estándar MIME de codificación de mensajes con diferentes formatos y juegos de caracteres.

Actualmente existen versiones de GnuPG para la práctica totalidad de los sistemas operativos de equipos fijos y móviles, y programas de correo como Thunderbird integran extensiones que permiten utilizar correo electrónico seguro, tanto en modo *inline*, con los mensajes codificados en texto, como mediante el estándar PGP/MIME, incorporando las diferentes partes de un correo seguro de manera muy similar a la que explicaremos con detalle en el apartado equivalente de los sistemas verticales. Como caso práctico que explica la importancia de este sistema, los correos electrónicos de comunicación de incidentes de seguridad a los denominados CERTs gubernamentales españoles (que estudiaremos en la unidad 4) deben enviarse cifrados con clave PGP.

La diferencia sustancial entre el modelo PGP y el empleo de certificados digitales es que en PGP, el control de las claves públicas y privadas se gestiona mediante *llaveros* o almacenes de claves propias y en el modelo vertical los certificados digitales se gestionan mediante almacenes de certificados. La gestión de la confianza es totalmente manual en PGP y automática en lo relativo a la confianza en las autoridades de certificación ya reconocidas, en los sistemas verticales basados en certificados digitales.

Firma de distribuciones de software abierto (Linux, FreeBSD y sus aplicaciones)

Otra aplicación muy extendida de las claves públicas PGP es su utilización por la práctica totalidad de desarrolladores de código de fuente abierta, para la firma electrónica de sus desarrollos, proporcionando autenticación e integridad a toda esta familia de productos. Así, mientras que empresas como Microsoft utilizan un esquema vertical, con certificados digitales y autoridad de certificación propia, para verificar la autenticidad de sus actualizaciones, todos los productos desarrollados bajo filosofía de software abierto, como las distribuciones de Linux y los programas que utilizan los principales servidores de Internet, hacen uso de claves PGP para asegurar la autenticidad e integridad de sus productos.

Cifrado de conexiones entre máquinas a través de Internet. SSH

Los primeros servicios de aplicación desarrollados sobre Internet fueron, además del correo electrónico, la emulación de terminal remoto *telnet* y la transferencia de ficheros *ftp*. Téngase en cuenta que la inmensa mayoría de los servidores de Internet han de ser accedidos remotamente para su configuración y carga de contenidos.

Así, los servicios *telnet* y *ftp* hacían uso del concepto de identificación de sus usuarios, mediante el envío de contraseñas *sin cifrar* a través de la red. La propia naturaleza de Internet, formada por la interconexión de redes de diferente tecnología, permitía que determinados equipos *escuchasen* los paquetes que circulaban por las redes a las que estaban conectados, generándose toda una familia de programas “sniffers” encaminados a desvelar contraseñas de usuarios que hacían uso de estos servicios.

Esto motivó a Tatu Ylonen, investigador de la Universidad de Helsinki, a desarrollar la primera versión del protocolo **SSH**, encaminado a reemplazar los servicios *telnet* y sus variantes

rlogin y *rsh*, con versiones similares, pero cuya comunicación está protegida por un sistema criptográfico de clave pública, con su esquema propio de reconocimiento de claves, basado en una aproximación característica de sistemas horizontales, es decir, en el que la confianza se establece de forma explícita, mediante el intercambio de claves que autorizan los administradores las máquinas implicadas.

De forma casi idéntica a lo ocurrido con el PGP, a medida que la popularidad de este sistema aumentó, SSH evolucionó hacia una filosofía propietaria, lo que motivó el desarrollo bajo software libre de una nueva implementación de este sistema, conocida como **OpenSSH**.

De esta forma, programas como *ssh*, *putty*, *scp* y similares, con versiones cliente disponibles para todo tipo de ordenadores personales, permiten la conexión con servidores utilizando métodos criptográficos que garantizan la privacidad en las comunicaciones.

3.3.2. Aplicaciones de los sistemas verticales

Seguridad en el software. Firmado de distribuciones y actualizaciones propietarias

Análogamente a la utilización del sistema PGP para la firma de todo tipo de distribuciones de software abierto, los fabricantes de sistemas operativos y distribuciones de software propietario emplean métodos criptográficos de clave pública para garantizar su integridad.

Evidentemente, así como el modelo horizontal y participativo de desarrollo de software libre se adapta perfectamente al sistema de distribución horizontal de claves, el modelo jerárquico y centralizado de las distribuciones propietarias se presta al empleo de certificados digitales, firmados por la empresa responsable de la integridad del sistema operativo.

De esta forma, los principales fabricantes mundiales de software, como Microsoft, Apple, Google y otros, han desarrollado sus propias autoridades de certificación encargadas de emitir los certificados, tanto propios como de los productos desarrollados por terceras partes.

Correo electrónico seguro. S/MIME

MIME (Multipurpose Internet Message Extensions) es un estándar de codificación de información, inicialmente desarrollado para el correo electrónico, que permite la estructuración de mensajes en código textual, formados por diferentes tipos de información en diferentes formatos. Así, un mensaje de correo electrónico estructurado según las reglas MIME puede ser de tipo multimedia, con partes en texto normal, imágenes, vídeo digital, archivos de sonido y un largo etcétera. Mediante el lenguaje propuesto por MIME, se organiza cada una de las partes del documento, indicando el tipo de contenido y la forma en que la información binaria de ese contenido se codifica, de manera que pueda ser transmitido por la red y recuperado en el otro extremo.

Este sistema adquirió un notable impulso con el desarrollo, a principios de la década de los noventa, de la World Wide Web, combinando las prestaciones de un sencillo protocolo de comunicaciones (HTTP), un lenguaje de descripción de páginas (HTML) y el estándar MIME, encargado de identificar el tipo de información que obtenemos a través de la web.

La proliferación en el uso de sistemas criptográficos impulsó el desarrollo de una variante del estándar MIME, orientada a la incorporación de información relativa a la privacidad en los mensajes electrónicos. De esta forma, se definieron nuevos identificadores de contenido y nuevos sistemas de codificación de este contenido, permitiendo incorporar a los mensajes de correo electrónico toda la información necesaria para transmitir documentos cifrados, firmas, certificados de usuario, etc.

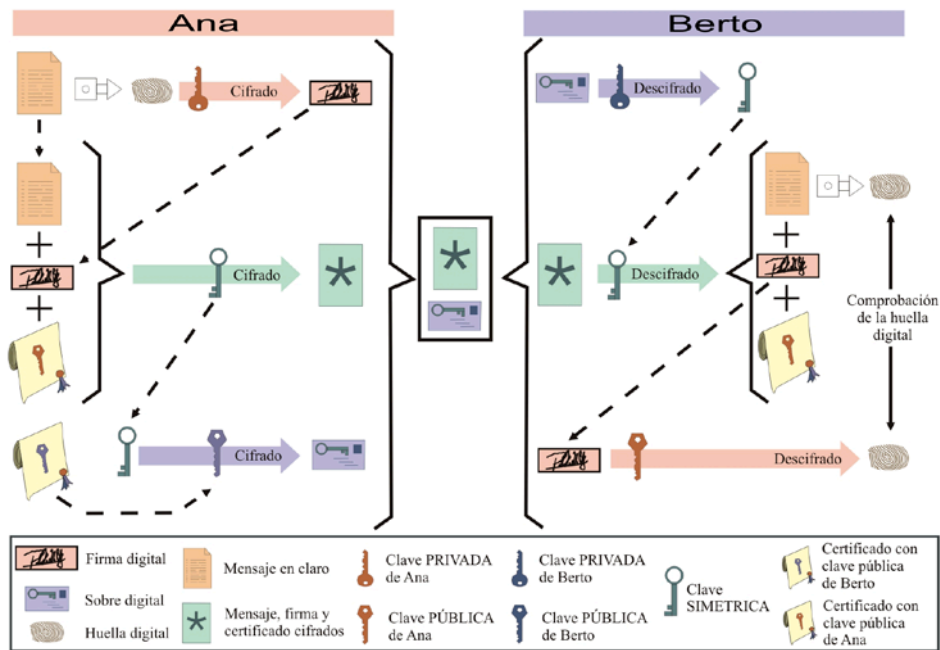


Figura 2.9.- Correo electrónico S/MIME cifrado y firmado

Así, en la Figura 2.9 se describe la utilización de S/MIME para el envío de un mensaje de correo electrónico en un sistema vertical (basado en certificados digitales) y la estructuración de dicho mensaje en diferentes partes, que contendrán los respectivos elementos necesarios para la transmisión segura del correo electrónico.

En el ejemplo descrito, supongamos que intervienen dos agentes (Ana y Berto) y que la primera desea enviar al segundo un mensaje cifrado, es decir, que sólo Berto pueda leer su contenido (confidencialidad) y firmado, es decir, que Berto pueda por una parte estar seguro de que el contenido del mensaje no ha sido alterado (integridad) a la vez que haya garantías de que ha sido Ana, y no otro agente, el autor del mismo (No repudio).

En este caso, el programa de correo electrónico de Ana ha de tener acceso al certificado de Berto, firmado por una autoridad reconocida por ambos, que contendrá su clave pública. Típicamente, lo tendrá almacenado por haber recibido con anterioridad correspondencia cifrada o firmada de Berto, o bien lo podrá obtener de algún servicio de directorio.

Igualmente, Ana ha de acceder a su propia clave privada. Esta podrá estar almacenada (protegida con una clave) en el disco duro, asociada a su certificado, o mejor aún, puede estar almacenada en una tarjeta criptográfica, de forma que todo el proceso *sensible* se realice fuera del ordenador, y, por tanto, de forma más segura.

Una vez que Ana ha redactado el mensaje y que ha indicado que desea enviarlo cifrado y con firma digital, el proceso que realiza el programa de correo es el siguiente:

1. Obtiene un resumen (huella digital) del mensaje, cifrándolo a continuación con la propia clave privada de Ana, obteniendo una “firma digital”. Así, cualquier otro agente que tenga acceso a su certificado (es decir, a su clave pública) podrá descifrarlo y verificar si el documento recibido produce la misma huella (integridad y no repudio)
2. El certificado digital de Ana debe especificar uno o varios métodos de cifrado simétrico permitidos. Escogido uno de estos métodos, genera aleatoriamente una clave simétrica (denominada “secreto”) y cifra con ella el conjunto formado por el texto del mensaje, la firma digital previamente obtenida y su propio certificado.

3. Cifra a su vez, el secreto generado en el paso anterior, con la clave pública de Berto, construyendo el llamado “sobre digital”, de forma que sólo podrá ser descifrado con la clave privada equivalente, y por lo tanto sólo Berto podrá obtener el secreto y utilizarlo para descifrar el antedicho sobre digital.
4. Finalmente, introduce las tres partes antes descritas, en un mensaje multiparte, según el estándar S/MIME y dicho mensaje se envía a la dirección electrónica de Berto

Cómo se observa en la misma figura, el programa de correo electrónico de Berto podrá realizar las operaciones pertinentes para:

1. Descifrar el “sobre digital” con su propia clave privada, obteniendo el conjunto de texto, firma y certificado de Ana.
2. Además de obtener el texto descifrado y presentárselo a Berto para su lectura, puede obtener una huella (resumen digital) de dicho texto y compararla con el resultado de descifrar la “firma” de Ana con su clave pública (presente en el Certificado). Así, se comprobaría que el texto y el autor del mensaje son los adecuados.

Evidentemente, este proceso se puede simplificar, considerando por ejemplo en el caso en que el documento enviado por Ana no fuese de carácter confidencial, se podría omitir el proceso de cifrado del documento, pero mantener el envío de la firma electrónica. En este caso, sin existir confidencialidad, se garantizaría la integridad, la autenticación y el no repudio.

Como se indicó anteriormente, en el caso del empleo de correo electrónico en sistema horizontal con productos como GnuPG, el único cambio con respecto a lo indicado será la sustitución de los certificados digitales de Ana y Berto por las claves de ambos, almacenadas en los “llaveros” de sus respectivas aplicaciones PGP; y que el mecanismo de codificación de los mensajes será PGP/MIME (muy similar a S/MIME) o mensajes PGP con cabecera embebidos en el texto del mensaje.

SSL y TLS. Cifrado de conexiones Internet

El estándar denominado SSL (*Secure Sockets Layer*) fue desarrollado por Netscape Communications y consiste en un conjunto de protocolos criptográficos que permiten la privacidad en las comunicaciones por Internet (emulación de terminal, transferencia de ficheros, navegación segura en la Web, etc.), bajo un sistema de distribución Vertical de Claves. La versión 3.0 de este estándar, aprobada en 1996, fue reconocida internacionalmente y adaptada en el sistema **TLS** (*Transport Level Security*) versión 1.0. A partir de 2015, SSL se considera obsoleto y el estándar oficial es TLS.

A diferencia del sistema SSH, orientado a proporcionar comunicación segura entre determinados componentes de software, y basado en el modelo horizontal de distribución de claves, la filosofía modular del modelo TLS permite su utilización como una “capa segura” entre los protocolos de transporte y de aplicación en Internet. **Por ello, cualquier protocolo que ofrezca servicios en Internet y que utilice el sistema de transporte estándar, denominado TCP, podrá ser implementado de forma segura utilizando TLS.**

El empleo del estándar TLS implica tres operaciones básicas:

1. Negociar entre las partes los algoritmos criptográficos que se usarán.
2. Intercambio de claves públicas y autenticación basada en certificados digitales.
3. Cifrado del tráfico basado en cifrado simétrico.

Durante la primera fase, el cliente y el servidor negocian qué algoritmos criptográficos se van a usar. Las implementaciones actuales proporcionan las siguientes opciones:

- Para criptografía de clave pública: RSA, Diffie-Hellman (DH), DSA o Fortezza.
- Para cifrado simétrico: IDEA, Triple DES o AES.
- Funciones de resumen: SHA-1 y SHA-2.

Una característica muy importante es que este sistema permite su utilización en dos modos de funcionamiento diferentes:

1. Cuando sólo una de las partes posee certificado digital (típicamente el servidor). De esta forma, cualquier cliente podrá autenticar que el servidor es el adecuado, y mantener una comunicación segura con el mismo (autenticación de servidor y confidencialidad)
2. Cuando ambas partes poseen certificados digitales. En este caso, la autenticación es mutua, lo que permite que la comunicación sea absolutamente segura, y lo más importante, permite eliminar la necesidad de que el cliente tenga que identificarse ante el servidor (típicamente enviando una contraseña) una vez establecida la comunicación.

TLS sobre HTTP. Web Segura S-HTTP con certificados de servidor

En este caso, explicaremos como el mecanismo denominado TLS antes descrito, permite el uso de privacidad en una transacción web, suponiendo que sólo el servidor dispone de certificado digital. Este proceso, mostrado en la Figura 2.10, es el típico que se produce cuando un navegador web, desde cualquier tipo de equipo informático, accede a un servidor seguro utilizando el protocolo *https*.

1. El cliente accede al servidor utilizando el protocolo de conexión segura *https*.
2. Como respuesta al intento de conexión del cliente, el servidor presenta su certificado digital.
3. El cliente busca en su base de datos local el certificado raíz de dicha autoridad. Si lo encuentra y puede verificar la firma de la autoridad en el certificado recibido, cumple condiciones de validez temporal y no está marcado en su base de datos como revocado, continuará con el proceso. En caso contrario, indicará al usuario si desea interrumpir la conexión o aceptar, para esta sesión o definitivamente, la validez del certificado recibido.
4. Dado que es el cliente quién dispone de la clave pública del servidor, será quién genere el secreto o clave simétrica de cifrado para el resto de la sesión. Para ello, escoge uno de los algoritmos de cifrado válidos en el certificado y genera el secreto como una clave aleatoria válida para el algoritmo escogido.
5. Cifra el secreto con la clave pública del servidor (presente en el certificado que recibió en el paso 2)
6. Envía dicho secreto cifrado al servidor.
7. El servidor descifra dicho secreto con su clave privada.
8. A partir de ese momento, toda la comunicación entre cliente y servidor será cifrada con el secreto, y por tanto, será confidencial.

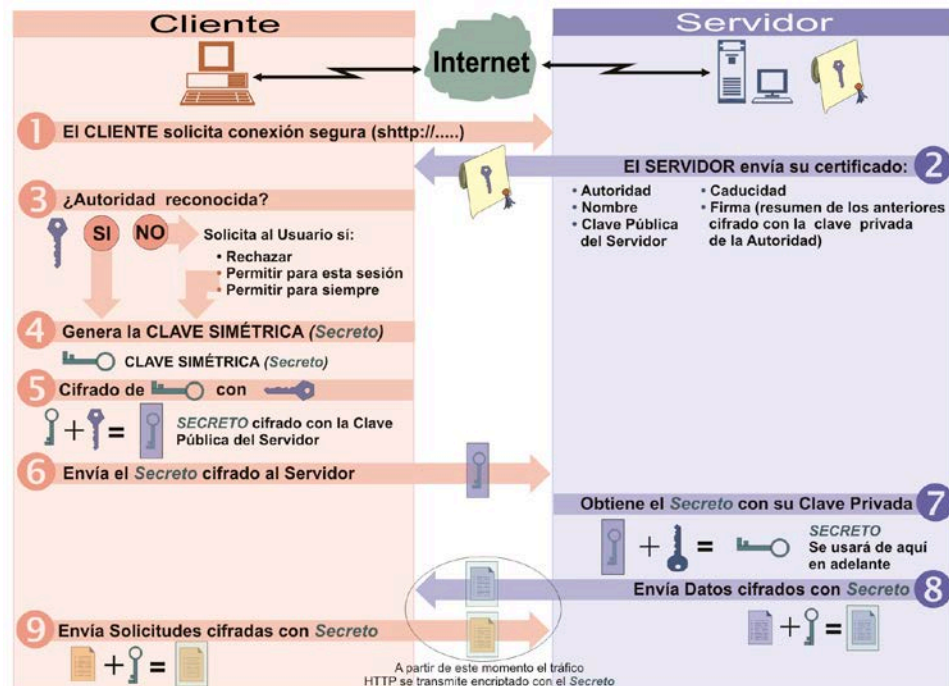


Figura 2.10.- Web segura https con certificados de servidor

Aunque el proceso indicado en la figura describe el proceso de una transacción web segura (desde el punto de vista del usuario, todo este proceso tiene lugar cuando se activa el icono con el *candado* presente en su navegador), cualquier otro tipo de transmisión segura mediante TLS, como, por ejemplo, la transferencia de correos electrónicos (*SMTP* e *IMAP* seguros), se efectuará según el mismo esquema básico.

Doble autenticación en conexiones web. Https con certificados de cliente

En el caso descrito en el apartado anterior se desarrolló el empleo de TLS en la variante de “autenticación de servidor”, es decir, sólo el servidor dispone de certificado y por tanto, el cliente forma parte de la conexión segura, pero sin posibilidad de autenticarse ante el servidor. Este esquema es universalmente utilizado cuando es crítico que el servidor sea quién dice ser, y los clientes se identifiquen ante dicho servidor una vez iniciada la transmisión segura de información, habitualmente mediante una combinación de usuario y contraseña.

La segunda modalidad de funcionamiento del estándar TLS permite que tanto el cliente como el servidor dispongan de un certificado, que intercambian previamente en el paso 2 del proceso antes descrito. Esto permite el concepto de “doble autenticación”, ya que tanto cliente como servidor podrán verificar que la otra parte es quién dice ser, pues verifican su certificado (comprobando la firma de la autoridad de certificación)

La aplicación de este principio permite la autenticación, es decir, la *identificación segura* de agentes en una red insegura como es Internet. Si el certificado del equipo cliente resulta ser un certificado personal, el servidor podrá identificar al usuario que se ha conectado, sin necesidad de solicitarle ninguna otra información. Por ejemplo, si el servidor ofrece servicios de banca por Internet, tendrá un mayor nivel de certeza de que el usuario es quién dice ser, que si se limita a solicitarle un nombre de usuario y una contraseña.

La posibilidad de sustituir los sistemas clásicos de protección de servicios web, basados en nombres de usuario y contraseñas, por este método, basado en sistemas criptográficos mucho más seguros, está siendo aprovechada de forma creciente por la administración española, que a través de diversas leyes (como veremos en la última unidad), establece las condiciones de acceso de los ciudadanos a los servicios públicos mediante su identificación a través de certificados

digitales, tanto de software (certificados emitidos por la FNMT) como mediante tarjetas criptográficas (DNIe).

Otras aplicaciones. IP segura y túneles cifrados. Redes Privadas virtuales (VPN)

La tercera familia de aplicaciones de estos sistemas consiste en cifrar no un mensaje electrónico, ni siquiera el flujo de una “transacción web”, sino cifrar el contenido de todos y cada uno de los “paquetes de red” que intercambien dos equipos cualesquiera. Esto se puede hacer básicamente de dos formas:

1. Después de intercambiar sus respectivos certificados y “acordar” el secreto que cifrará las transmisiones, el contenido de los paquetes se cifra con este secreto y es transmitido así a través de Internet. Esta aproximación es utilizada por el protocolo IPsec, y básicamente consiste en cifrar la “carga útil” de los paquetes IP que se intercambien entre dos equipos cualesquiera. De esta forma, los paquetes circularán con su cabecera (con la información de origen y destino) en texto claro, pero con su contenido cifrado y por tanto, no visible por los equipos intermedios.
2. Una variante más sofisticada es la utilización de “túneles seguros” dentro de la propia Internet. En este caso, se pueden transmitir todos los paquetes correspondientes a varias comunicaciones entre dos subredes, estableciendo una comunicación segura entre dos equipos que hagan de “concentradores seguros” de ambas subredes. Esto permite la utilización de Internet (básicamente insegura) en la transmisión segura de datos entre dos o más delegaciones, funcionalidad conocida como el establecimiento de una red privada virtual o VPN.

4. HERRAMIENTAS ADICIONALES EN SEGURIDAD DIGITAL: BIOMETRÍA Y ESTEGANOGRAFÍA

Además de la criptografía, existen otros sistemas de seguridad digital, que pueden ser utilizados de manera autónoma o, más comúnmente, combinados con ésta, para cumplir determinados objetivos de seguridad, como veremos a continuación.

4.1. Biometría

Por biometría se entiende el conjunto de métodos para el reconocimiento automático de seres vivos (normalmente, seres humanos) mediante el análisis de rasgos fisiológicos o rasgos de conducta. Se trata de una rama del conocimiento reciente y donde muchos de los métodos aún están en fase experimental. Normalmente la biometría se utiliza principalmente en la identificación de usuarios (en el control de acceso a una institución, edificio o estancia en general con acceso restringido), o bien, para poder utilizar o consultar algún tipo de servicio o información protegida, proporcionada por un sistema informático. Así, cada vez está más extendida la alternativa a la introducción del PIN en equipos móviles y portátiles por la lectura de la huella dactilar o el reconocimiento facial. Desde el punto de vista de la seguridad, la biometría es una **herramienta de apoyo a la autenticación**.

Los métodos de identificación biométrica más utilizados en la actualidad se basan en rasgos fisiológicos propios del individuo a identificar, como los que se muestran en la Figura 2.11. Así, existen métodos tanto en operación como desarrollo basados en el reconocimiento automático de huellas dactilares, reconocimiento facial, geometría de la mano y sus vasos sanguíneos, reconocimiento del iris, reconocimiento de la retina e incluso por el olor o esencias corporales (feromonas, etc.). Estos métodos intentan identificar a una persona de manera inequívoca, pero es sabido que los rasgos fisiológicos cambian en mayor o menor medida con el paso del tiempo. Por tanto, estos sistemas deben utilizarse sabiendo que, con la posible excepción de la secuenciación completa del ADN (operación que actualmente requiere grandes recursos

técnicos y de computación y por tanto es imposible de realizar de manera rutinaria), **ningún sistema de detección biométrica será infalible**. La mayor parte de los productos biométricos disponibles están basados en huellas dactilares, palma de la mano y reconocimiento facial o del iris.

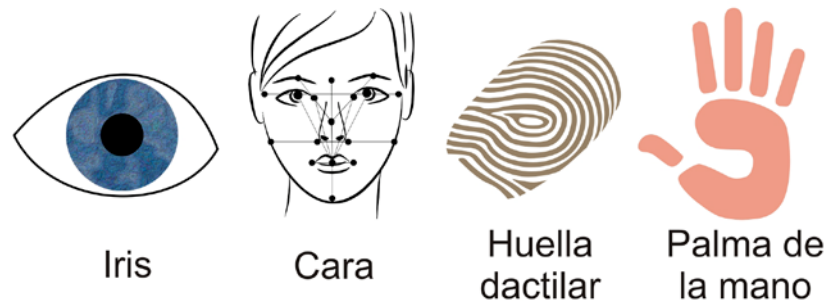


Figura 2.11. Biometría. Características Fisiológicas para la Identificación de Usuarios.

Como aplicación de la biometría en seguridad digital, uno de los ejemplos más destacados es la implantación de **rasgos biométricos en el DNI electrónico**, como soporte a la recuperación de la contraseña que protege las claves privadas de los certificados digitales de firma y autenticación que contiene. Uno de los detalles característicos del DNIE es que además de los certificados digitales, almacena los datos “típicos” del DNI convencional, con la particularidad de que las **huellas dactilares** se almacenan también en un **formato numérico que identifica los patrones característicos de cada huella**, lo que permite su clasificación y comparación mediante técnicas biométricas.

Así, cuando un usuario del DNI electrónico olvida la contraseña que protege sus certificados, puede acudir a uno de los “kioscos del DNIE” disponibles en las oficinas de expedición del DNI y otros organismos. Al solicitar la opción de recuperación de contraseña, se le solicita que coloque su dedo en el lector correspondiente. En este momento el programa del kiosco obtiene una “versión numérica” de la huella dactilar que será comparada con la almacenada en el DNI electrónico. Si se cumplen los criterios de similitud establecidos, se podrá suponer que el usuario es el verdadero titular del DNIE y por tanto, se le solicitará que introduzca una nueva contraseña de protección de los certificados.

Como se indicó en la unidad 1, los factores de autenticación son tres: algo que se *sabe*, algo que se *tiene* o algo que se *es*. Típicamente, lo que se *sabe* es una contraseña, lo que se *tiene* puede ser una clave, una herramienta criptográfica (DNIE), un teléfono móvil, etc.; y lo que se *es*, algún rasgo fisiológico susceptible de ser identificado por aplicación de una técnica biométrica.

4.2. Esteganografía

La Esteganografía es la ciencia o rama del conocimiento que estudia mecanismos para la transmisión de mensajes o el registro de información de manera que pase inadvertida y oculta a todos, excepto a los agentes involucrados en la comunicación, esto es, el emisor y el receptor del mensaje. Su nombre procede de la combinación de las palabras griegas *steganos* (ocultación u oculto) y *graphos* (escritura)

A efectos prácticos, las técnicas esteganográficas se utilizan para **ocultar** información en **un soporte con otro tipo de información**, denominado **portador**, de manera que dicha información que se desea ocultar **pase desapercibida**. En esteganografía digital (cuando tanto la información a ocultar como el portador se encuentran en formato digital) es posible ocultar información en archivos de imágenes, de vídeo, documentos de texto o presentaciones, audio e incluso en programas ejecutables. Estos portadores podrán ser enviados sin sospecha a través de sistemas de comunicación sometidos a control de los contenidos, como ocurre en países con regímenes totalitarios.

Además, la información a ocultar suele cifrarse previamente, de modo que las técnicas esteganográficas se centran en la ocultación del mensaje propiamente dicho, de forma que pase inadvertido dentro de cualquier otro tipo de información, y las técnicas criptográficas garantizarán la confidencialidad de su contenido, en caso de ser detectado.

Una característica exclusiva de la esteganografía, frente a las restantes técnicas que confieren seguridad digital, como la criptografía, es que está **basada en la seguridad a través de la oscuridad** frente a la seguridad a través del conocimiento. Si se conoce la forma exacta en que se la información oculta se “reparte” dentro del portador, la esteganografía pierde su utilidad. **No cabe hablar de estándares** en este campo. El receptor de la información ha de utilizar el mismo programa, para restituir la información escondida en el portador, que el empleado por el emisor para esconderla.

Una de las técnicas esteganográficas más usuales consiste en la **sustitución de los bits menos significativos** de un archivo de imagen, sonido o video por bits de la información a ser ocultada. Por ejemplo, si un archivo de imagen contiene los valores de luminosidad y color de cada píxel de dicha imagen, se puede alterar mínimamente estos valores para cada píxel reemplazando sus últimos bits de información por bits del texto que se desea transmitir de forma oculta. La nueva imagen no tendrá diferencias apreciables para el ojo humano, no debe despertar sospechas entre quienes la revisen, y un programa igual al que hizo el trabajo de ocultación podrá reconstruir sin problema el texto *esteganografiado* de esta forma.

Por último, otra aplicación de la esteganografía consiste en la inclusión de información oculta en algún tipo de documento digital (libro, imagen, vídeo, programa, etc.) que permita autenticar su origen, a fin de salvaguardar los derechos de sus autores originales, de proteger dicho documento de la copia no autorizada del mismo, o bien de garantizar una licencia o licencias de uso para un software específico a su comprador. Así, las **marcas de agua** se ocultan en documentos, de manera que, si son copiados, esta información oculta estará en la copia y podrá ser detectada por sus autores.

ACTIVIDADES

1. Establecer diferencias y similitudes entre criptografía simétrica y criptografía asimétrica.
2. Definir qué es un certificado digital con nuestras propias palabras, incluyendo una analogía con la vida real no comentada en el texto.
3. Obtener un certificado digital de una autoridad gratuita, instalarlo en un programa de correo electrónico (Mozilla Thunderbird, Apple Mail, etc.) y utilizarlo para el envío de un correo electrónico firmado.
4. Instalar el software GnuPG y utilizarlo para el envío de correo electrónico seguro mediante el programa Mozilla Thunderbird o Apple Mail.
5. Crear y utilizar un disco cifrado, empleando alguna herramienta de software libre.

BIBLIOGRAFÍA

Caballero Gil, P. (2002). Introducción a la Criptografía 2ª ed. actualizada. Madrid. Ra-Ma.

Durán Díaz, R., Hernández Encinas, L., Muñoz Masqué, J. (2005). El criptosistema RSA. Madrid. Ra-Ma.

Gómez Vieites, A. (2006). Enciclopedia de la Seguridad Informática. Madrid. Ra-Ma.

Pastor Franco, J., Sarasa López, M.A., Salazar Riaño, J.L. (2010) Criptografía digital. Fundamentos y aplicaciones (2ª Ed.). Zaragoza. Prensas Universitarias de Zaragoza.

Bradley, T.; Carvey, H. (2007). Protección del PC y Seguridad Informática. Madrid. Anaya Multimedia.

Recursos en Internet

Wikipedia. La enciclopedia libre. “Criptografía”. <https://es.wikipedia.org/wiki/Criptografía>

Wikipedia. La enciclopedia libre. “Biometría”. <https://es.wikipedia.org/wiki/Biometría>

Wikipedia. La enciclopedia libre. “Esteganografía”.
<https://es.wikipedia.org/wiki/Esteganografía>

EJERCICIOS DE AUTOEVALUACIÓN

1. Los sistemas de clave simétrica
 - a. Aseguran la integridad.
 - b. Aseguran la disponibilidad.
 - c. Aseguran la confidencialidad.
 - d. Aseguran el No repudio.
2. El mecanismo de firma digital
 - a. Se realiza mediante el cifrado simétrico de resúmenes.
 - b. Se realiza mediante el cifrado asimétrico de resúmenes.
 - c. Se realiza mediante el cifrado simétrico de claves públicas.
 - d. Se realiza mediante el cifrado asimétrico de claves privadas.
3. El software PGP
 - a. Se basa en un modelo horizontal.
 - b. Se basa en un modelo vertical.
 - c. Se basa en el empleo de SSH.
 - d. Se basa en el empleo de TLS.
4. Un certificado digital
 - a. Contiene la clave privada del usuario.
 - b. Contiene la clave pública del usuario.
 - c. Contiene la clave privada de la Autoridad Certificadora.
 - d. Contiene la clave pública de la Autoridad Certificadora.
5. Las técnicas biométricas
 - a. Aseguran la disponibilidad.
 - b. Aseguran el No repudio.
 - c. Aseguran la autenticación.
 - d. Aseguran la trazabilidad.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	c
2	b
3	a
4	b
5	c

GLOSARIO

ADN: Ácido desoxirribonucleico. Sustancia que lleva las instrucciones genéticas para el desarrollo biológico de todas las formas celulares de vida y algunos virus.

ASCII: American Standard Code for Information Interchange (Código estándar estadounidense para el intercambio de información). Código de caracteres basado en el alfabeto latino. Emplea un código fijo de 128 caracteres internacionales y tiene extensiones para caracteres especiales adaptados a diferentes lenguajes.

HTTP: HyperText Transfer Protocol. Protocolo de transferencia de hipertexto. Protocolo de comunicaciones que regula la transferencia de información entre clientes y servidores web.

HTTPS: HyperText Transfer Protocol Secure. Protocolo seguro de transferencia de hipertexto. Protocolo de aplicación basado en HTTP que utiliza una comunicación segura entre cliente y servidor, haciendo uso de certificados digitales.

IEEE: Institute of Electrical and Electronics Engineers. Instituto de ingeniería eléctrica y electrónica. Asociación internacional de ingenieros dedicada a la normalización y desarrollo en áreas técnicas.

IETF: Internet Engineering Task Force. Grupo de trabajo de ingeniería en Internet. Organización internacional que regula las propuestas y los estándares en Internet.

IMAP: Internet Message Access Protocol. Protocolo de acceso a mensajes de Internet. Protocolo de aplicación que permite el acceso a mensajes almacenados en un servidor de Internet.

Protocolo de comunicaciones: Conjunto de reglas y estándares que controlan la comunicación entre agentes conectados a una red.

SMTP: Simple Message Transfer Protocol. Protocolo sencillo para la transferencia de mensajes. Protocolo de Internet que regula el envío de mensajes de correo electrónico.

UA 3. Amenazas a los sistemas de información

PRESENTACIÓN

Una vez analizado el conjunto de herramientas tecnológicas cuyo empleo racional permite mantener las dimensiones de la seguridad digital, en esta unidad se discuten las amenazas a la seguridad de los sistemas de información, incorporando el factor humano. El estudio comienza con las amenazas características del entorno doméstico y de pequeñas empresas, el empleo de ordenadores personales, portátiles y teléfonos móviles y su integración en red. A continuación se analiza una amenaza muy característica como es el software malicioso o *malware*, sus mecanismos de transmisión, sus tipologías y los efectos que produce.

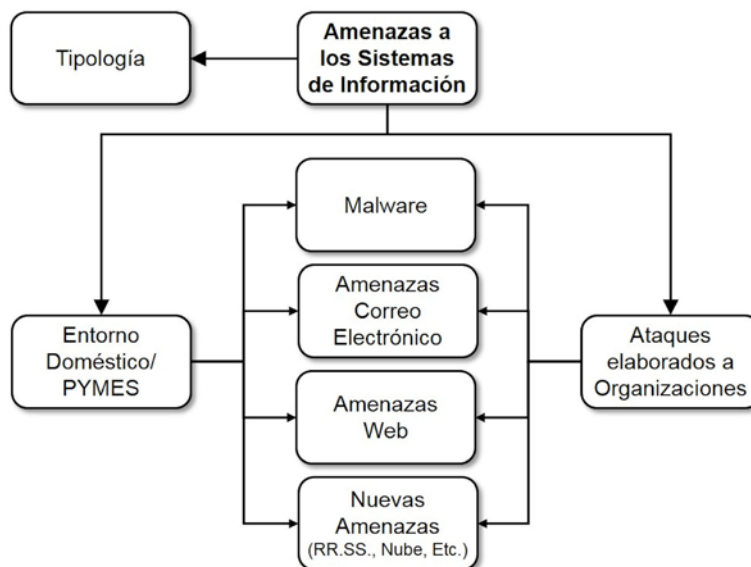
Posteriormente, se contemplan las amenazas inherentes al empleo de los sistemas básicos de intercambio de información actuales, como son el correo electrónico, la navegación web y las nuevas amenazas asociadas a la irrupción de la web 2.0 y las plataformas de red social, con especial atención al factor humano como punto débil de la cadena.

Por último, se estudia la estrategia y la operativa principal de los ataques a los sistemas de información, tanto en la vertiente clásica como en la moderna, basada en un nuevo modelo de cibercrimen altamente profesionalizado, capaz de generar en la unión europea pérdidas cercanas al billón de euros anuales.

OBJETIVOS

- Conocer y distinguir entre los tres tipos de amenazas: ataques, accidentes y negligencias.
- Conocer las amenazas básicas a los sistemas de información en el entorno doméstico y de pequeñas empresas.
- Conocer los tipos de malware existente y su nivel de peligrosidad.
- Conocer las amenazas relativas al empleo del correo electrónico, la navegación web y las plataformas de red social, tanto desde equipos fijos como portátiles y móviles.
- Conocer las técnicas básicas de ataque a los sistemas de información organizacionales.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. TIPOS DE AMENAZAS

Las **amenazas** básicas a la seguridad de sistemas de información pueden ser de tres tipos: ataques, accidentes y negligencias.

- **Ataques** son las amenazas que provienen de terceros que deliberadamente tratan de comprometer la seguridad del sistema. Estos ataques podrán ser específicos, es decir, planificados y organizados con una organización como objetivo, o indiscriminados, en los que se pretende ocasionar un daño generalizado conducente, en la mayoría de las ocasiones, a la obtención ulterior de algún tipo de beneficio económico.
- **Accidentes** son sucesos eventuales o acciones que involuntariamente producen un daño en los sistemas de información. Las causas pueden ser de lo más variado: desastres naturales, rotura o deterioro de cables, interrupciones en el suministro eléctrico, averías en equipos informáticos, de acondicionamiento de aire, etc.
- **Negligencias** son daños producidos por un mal uso de los equipos, redes y sistemas auxiliares, de forma no intencionada, por parte de personal de la propia organización o responsable de la provisión de algún servicio. Las causas más comunes de este tipo de incidentes son el descuido, la escasa formación y en general, alguna deficiencia en la definición o aplicación de las políticas de seguridad de la organización.

A su vez, se define una **vulnerabilidad** como la debilidad o **incapacidad de respuesta** ante una determinada **amenaza**. De esto se deduce que la seguridad de la información requiere la adecuada reducción de las vulnerabilidades ante cualquier tipo de amenaza, ya se trate de ataques, accidentes o negligencias.

1.1. Efectos de un ataque

Con independencia del ámbito en el que se produzca un ataque, del alcance del mismo y de la gravedad de sus consecuencias, los efectos más importantes serán:

- **Destrucción de información.** Es una de las consecuencias más obvias y temibles. Ante la inexistencia de una política de gestión de la información que permita recuperar todos los sistemas a un estado consistente previo al ataque, las consecuencias de la destrucción pueden ser catastróficas para la organización, al afectar los activos más importantes de la misma, como es la información relativa a sus proveedores, clientes, productos, proyectos, diseños, estudios, análisis, pedidos, nóminas, facturación, contabilidad, etc.
- **Pérdida de disponibilidad de los servicios.** Un ataque que tenga como consecuencia la parada de un servicio. Por muy inocuo que sea el ataque, el personal técnico tendrá que verificar que los sistemas están intactos y que no se ha introducido software malicioso, tendrán que restablecer los datos a su estado original, comprobar que se ha corregido la vulnerabilidad que permitió ese ataque, etc. Todo ello muy probablemente requerirá la parada de alguno de los servicios de la organización durante un cierto tiempo, con el consiguiente perjuicio para la organización y sus usuarios.
- **Daños a la propiedad.** La revelación no autorizada de material confidencial, como pueden ser documentos que afecten a la estrategia o a la operativa de la organización (planes de negocio, patentes, grandes contratos en prospectiva, etc.). Junto a todas las variantes modernas del espionaje industrial, puede ocasionar gravísimas consecuencias.
- **Violación de la intimidad.** Si se revelan de forma no autorizada datos personales, se está atentando contra la intimidad de las personas. Esta violación de la intimidad puede ocasionar graves consecuencias y cuantiosas sanciones, especialmente en nuestro entorno, caracterizado por una legislación de fuerte carácter garantista en la protección de datos personales. El hecho de que la revelación haya sido consecuencia de un ataque no exime de las consecuencias legales.
- **Daños a la reputación de la empresa.** Este es uno de los efectos más sutiles y a la vez más temidos de las intrusiones informáticas, y más aún en grandes corporaciones, especialmente vulnerables a los daños a su imagen. La difusión de información relativa a cualquier tipo de ataque muestra las debilidades de la organización y afecta muy negativamente a su credibilidad. Esto es especialmente crítico para entidades bancarias, servicios de información, prensa digital, plataformas de red social, etc.

Aunque hablamos de efectos de un ataque, no cabe duda que **estos mismos efectos podrán ser resultado de determinados accidentes, negligencias** o combinación de amenazas.

1.2. Principales motivaciones de los atacantes

Las motivaciones que llevan a una persona o grupo de personas, a desarrollar un ataque contra la seguridad de un sistema pueden ser muy diversas. La bibliografía clásica encuadra dichas motivaciones en cuatro categorías principales:

- **Obtención de beneficio económico (Money).** Sin duda, esta es la principal motivación. robo de información con valor económico (datos bancarios, tarjetas de crédito), estafas, extorsiones, ocupación de equipos que posteriormente ejecutarán ataques distribuidos, etc. Detrás de estos ataques se podrán encontrar tanto individuos como asociaciones delictivas más o menos organizadas. Las técnicas típicas son el phishing, la instalación de software malicioso en los equipos de la empresa, etc.

- **Motivación política (Ideology).** Detrás de un ataque puede haber un objetivo de carácter político o social, que podrá ir desde el “activismo en red” o **hacktivismo** de algunas organizaciones pro derechos humanos, ecologistas, antisistema, etc.; hasta el ciberterrorismo patrocinado por gobiernos totalitarios y antidemocráticos. Su objetivo final es dañar de alguna forma a un adversario político: una empresa, una organización política o todo un estado. El resultado esperado de dicho ataque podrá ser meramente publicitario, el sabotaje, o encuadrado en acciones de espionaje, dirigidas únicamente a la obtención de información.
- **Intención de hacer daño (Compromise).** Antiguos empleados descontentos, exparejas vengativas, clientes maltratados o pura actitud vandálica. Todos estos atacantes tienen en común el deseo de provocar un daño, sin esperar más beneficio directo que el perjuicio a la persona u organización. Los ataques más comunes consisten en la destrucción de archivos, la revelación de información sensible y comprometedor, la parada de servicios o la intrusión y manipulación de las webs corporativas. Este tipo de ataques son menos frecuentes que los encuadrados en la anterior categoría, pero no por ello sus efectos son menos devastadores.
- **Prestigio y autoestima (Ego).** Muchos hackers se plantean la entrada ilícita en un sistema como un reto personal, como un desafío que les hará aumentar su autoestima y prestigio en su entorno social. Es la motivación menos frecuente y la de consecuencias más inocuas, ya este tipo de ataques suele limitarse a la penetración en el sistema y dejar algún rastro que constate de la superación de su reto.

Estas cuatro grandes motivaciones se abrevian en el acrónimo inglés MICE (literalmente, “ratones”), procedente de las siglas de Money, Ideology, Compromise and Ego. Como ya se ha dicho, la primera motivación (el beneficio económico) es la predominante en la sociedad actual.

1.3. Perfiles clásicos del atacante informático. Subculturas

Existen varios perfiles de ciberatacantes clásicos, asociados por la literatura en seguridad informática al concepto de “subculturas”, con un cierto nivel de subjetividad e incluso de confusión en la terminología empleada:

- **Hacker.** El término hacker se refiere a una persona que domina una tecnología informática hasta el punto de que es capaz de manipularla para que funcione más allá de su comportamiento natural. En el ámbito de la seguridad en TIC, se suele calificar como hacker al intruso con alta cualificación técnica que aprovecha sus conocimientos para comprometer la seguridad de un sistema, como reto personal o por pura diversión, sin que exista mala fe ni intención de hacer daño al sistema vulnerado. No olvidemos que todo buen hacker ha de comportarse como cracker tentativo de sus propios equipos, realizando *tests* de penetración, precisamente para garantizar la seguridad del sistema ante intentos de ataque.
- **Cracker.** Este término tiene dos interpretaciones diferentes. Una se refiere a una persona con la cualificación técnica de un hacker, pero que actúa con mala fe y ataca los sistemas con mala intención, con alguna de las motivaciones antes descritas. Este tipo de cracker se refiere a los denominados *black hat hackers*, o simplemente *black hats*. La segunda acepción del término cracker sirve para designar a los hackers que utilizan su conocimiento informático para desproteger, es decir, desbloquear la protección de todo tipo de programas. En la literatura especializada, es esta la acepción más común de la palabra cracker, es decir, aquel que produce *cracks* o elimina los sistemas de protección del software comercial.

- **Script kiddie.** Persona no experta en tecnología que ataca sistemas informáticos utilizando “kits de ataque” o colecciones de programas e instrucciones básicas de manejo, cada vez más frecuentes en Internet, que no requieren especial cualificación técnica para su ejecución. Este tipo de atacantes combina el acceso a herramientas sofisticadas de ataque, con un desconocimiento de las posibles consecuencias reales de su utilización indiscriminada. Son el equivalente informático de “niños jugando con explosivos”.
- **Phreaker.** Término, ya en desuso, utilizado tradicionalmente para referirse a los hackers especializados en las redes telefónicas. Muchos de los gurús, (término que representa el máximo escalón de la escala de un hacker) actuales comenzaron sus andaduras como phreakers.
- **Carder.** Expertos en sistemas de sistemas criptográficos y tarjetas inteligentes (en especial tarjetas bancarias) capaces de producir réplicas, alterar su funcionamiento o aprovechar sus vulnerabilidades.

Por último, en ocasiones se puede incluir con perfil propio, a los **empleados descontentos y ex-empleados**, no tanto por su dominio de la tecnología, sino por su conocimiento de la organización y de las políticas de seguridad, especialmente de medidas concretas (contraseñas, debilidades y vulnerabilidades de la red, de los sistemas de protección contra intrusiones, etc.). Este conocimiento de la organización, actuando en solitario o con otro tipo de atacantes, les confiere un nivel de peligrosidad que muy difícilmente se podría alcanzar con una aproximación puramente tecnológica.

1.4. Vulnerabilidades y Exploits

Al inicio de esta unidad definimos la vulnerabilidad como la incapacidad de respuesta ante una determinada amenaza, que podrá ser un ataque, un accidente o una negligencia. Nos centraremos ahora en las vulnerabilidades de los programas informáticos.

Todo programa informático es susceptible de fallo, es decir, de no realizar las acciones previstas. Cuando este mal funcionamiento, bien por error de diseño o por introducción de datos erróneos que no estaban previstos, afecta a las funciones relativas a los controles de seguridad del programa, es decir, que permite su utilización fuera del ambiente inicialmente previsto, será susceptible de un ataque, y por tanto presenta una vulnerabilidad, y al ataque específico para esta vulnerabilidad se le denomina **exploit**.

Los sistemas operativos actuales están formados por miles de programas y archivos que actúan de forma entrelazada para proporcionar entornos de computación multiusuario y multitarea. Todos los aspectos relativos a la autorización para ejecutar determinados programas, las comprobaciones de identidad, de permisos de los usuarios para acceder a determinados recursos, de establecimiento de conexiones en red, y un larguísimo etcétera, están condicionados por el hecho de que *ninguno de estos programas falle*. Por ejemplo, un fallo en un programa encargado de gestionar un sistema de ficheros en red puede permitir a cualquier usuario el acceso e incluso el borrado de los ficheros, una solicitud mal configurada a un servidor web puede provocar que accedamos a operaciones restringidas en principio al administrador del sistema, etc.

Del mismo modo, cualquier aplicación informática, y muy especialmente las complejas herramientas de comunicación actuales, como los entornos de correo electrónico, de mensajería instantánea y muy especialmente, los navegadores web, por su propia naturaleza, pueden presentar vulnerabilidades que les hagan susceptibles ante determinados ataques o *exploits*.

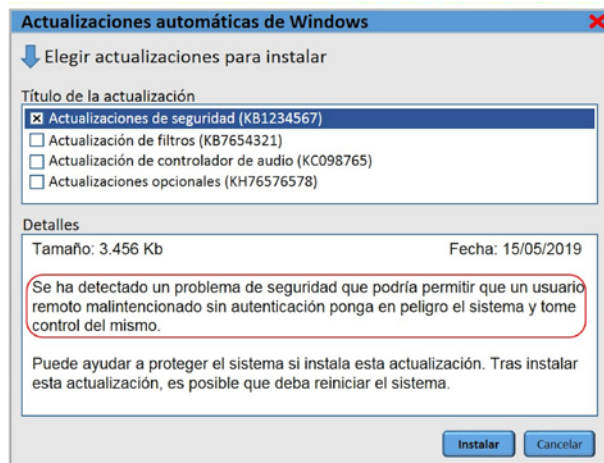


Figura 3.1. Mensaje de actualización de Windows

En resumen, podemos identificar dos tipos de fallos informáticos: los que afectan tan sólo a la disponibilidad del recurso o servicio y los que, además, comprometen las restantes dimensiones de la seguridad, como son la confidencialidad, la autenticación, la integridad, etc. Aunque de forma estricta, ambos son vulnerabilidades que comprometen alguna dimensión de la seguridad, la **capacidad de que el fallo sea explotado** activamente para comprometer alguna de las **restantes dimensiones**, es lo que **diferencia un simple fallo informático de una vulnerabilidad**. Ambos tipos de fallo deben ser identificados y resueltos, pero las implicaciones de las vulnerabilidades a los *exploits* exigen una actuación mucho más rápida y sobre todo, efectiva en su distribución y alcance.

Esto lleva al concepto de identificación de vulnerabilidades y reparación de las mismas, usualmente a través de actualizaciones, parches u “hotfixes” que resuelven dichas vulnerabilidades. Así, todos estamos familiarizados con el concepto de instalación de actualizaciones en nuestros equipos. No tan conocido es el efecto de este ciclo de identificación de vulnerabilidades, desarrollo de la solución y distribución a la base de usuarios.

Suponiendo que una determinada vulnerabilidad sea descubierta por la propia empresa que desarrolla el software, por algún cliente que lo notifica o por algún tipo de *white hat hacker*, aparece el problema relativo al tiempo efectivo que tardará, no en corregirse esta vulnerabilidad, sino en distribuirse a todos los usuarios registrados del producto. La mayoría de los *exploits* se dan a conocer tan pronto se desarrolla la corrección y a partir de ese momento, el tiempo de actualización de todos los usuarios se convierte en factor crítico.

Peor aún es cuando alguien descubre una vulnerabilidad importante de algún producto de uso masivo y no lo comunica a sus autores, sino que mantiene el secreto y desarrolla lo que se conoce como “**virus de día cero**”, o programa que explota esta vulnerabilidad. Como el fabricante no tiene noticia de la vulnerabilidad, no puede tomar medidas contra ella. Se sabe que algunos virus de día cero de entornos Windows, con capacidades de tomar el control como administrador del sistema, han sido vendidos en el mercado negro por millones de euros, y lo que es peor, que gobiernos democráticos (caso de EEUU) los han comprado.

En cualquier caso, el aprovechamiento de estas vulnerabilidades conocidas o *exploits* son uno de los principales mecanismos de intrusión y ataque a los sistemas informáticos, y esto justifica **la necesidad de tener actualizados los sistemas**, actualización que será tanto más crítica cuanto más expuesto se encuentre el sistema al acceso desde el exterior en virtud del *exploit*.

Nuevas tecnologías, nuevas amenazas. Cibercrimen

La evolución de las tecnologías de comunicación global, la universalización de Internet como plataforma sobre la que se sustenta todo tipo de actividad (de carácter económico, laboral, social, de ocio, etc.), la creciente incorporación de todo tipo de dispositivos a esta llamada *Internet de las Cosas* o IoT (TVs, altavoces, cámaras de vigilancia, sistemas de control de tráfico, etc.) y muy especialmente, la ausencia de una cultura de uso seguro de Internet, está promoviendo el desarrollo de lo que se conoce como **industria del cibercrimen**, en el que organizaciones delictivas de carácter transnacional, promueven y organizan a gran escala todo tipo de actividades encaminadas a la obtención de beneficio económico, mediante la comisión de delitos a través de la Red.

De esta forma, las estrategias de ataque cambian radicalmente. No se trata de obtener notoriedad, sino muy al contrario, de acceder de forma silenciosa a los recursos de información, de instalar programas espía que transmitan cualquier información susceptible de ser vendida o utilizada para perpetrar robos o estafas. El software malicioso o malware ya no se dedica a destruir información, sino a capturarla y utilizarla con intención de obtener beneficio económico, directo o indirecto.

2. AMENAZAS EN ENTORNO DOMÉSTICO Y ESTACIONES CLIENTE

Como se ha indicado anteriormente, las amenazas en entornos informáticos vienen determinadas por las vulnerabilidades que presenta el conjunto de elementos que compone el sistema, vulnerabilidades que podrán ser explotadas por atacantes humanos o por simples programas (caso de los programas maliciosos o malware que estudiaremos más adelante).

Sin ningún lugar a dudas, el **factor humano** representará en la mayoría de las ocasiones, como en todo entorno tecnológico, el **punto más débil**. Se describen a continuación las amenazas más significativas en entornos domésticos, y por extensión, también en las pequeñas organizaciones y empresas que no disponen de políticas de formación de personal y seguridad en el empleo de las TIs.

2.1. Ordenador Personal. Sistema Operativo

La mayor amenaza relativa a la informática personal radica en los propios usuarios. A diferencia de los ordenadores corporativos, casi siempre sometidos a políticas de empleo seguro, de actualización del sistema y de control de aplicaciones instaladas; los ordenadores domésticos habitualmente son compartidos por los diferentes miembros de la unidad familiar, con distintas habilidades, intereses y prioridades. Dicho de otra forma, en el entorno doméstico (y lamentablemente, en muchas pequeñas empresas) es donde se muestra con más claridad la **ausencia de políticas de seguridad** en el empleo de las TIs. Casi todas las amenazas aquí indicadas se extienden a los teléfonos móviles o *smartphones* actuales.

El usuario como administrador

Desde un punto de vista técnico esta carencia de políticas se traduce en que muchos ordenadores domésticos y ubicados en pequeñas empresas son utilizados por usuarios que en la mayor parte de las ocasiones, asumen el papel de administradores de los mismos, dándose en ocasiones el caso de que sólo exista una cuenta de trabajo, con privilegios completos. De esta forma, se confunde la operación con la configuración de un sistema operativo. La cuenta de Administrador dispone de privilegios que le permiten modificar tanto la configuración misma del equipo o modificar los programas que le permiten realizar todo tipo de funciones. Aunque a través de la explotación de determinadas vulnerabilidades, se puede conseguir que un usuario sin privilegios modifique el propio sistema operativo, cuando se utiliza el equipo como administrador, cualquier pieza de software malicioso que se ejecute de forma involuntaria,

tomará **control absoluto de los recursos del sistema**, dificultando su eliminación e incluso, como veremos más adelante, su detección.

Amenazas inherentes al sistema operativo y las aplicaciones

Una de las mayores amenazas es la debida a las propias vulnerabilidades del sistema operativo, que como hemos visto, pueden generar exploits o modos de explotar estas debilidades. La continua **actualización** del sistema operativo y las aplicaciones instaladas se vuelve imprescindible.

Configuración del sistema. Contraseñas

La adecuada configuración de los servicios del sistema operativo es crítica de cara a conseguir que el equipo informático tenga abiertos (y por tanto, susceptibles de ataque) el menor número de puertos, asociados a los servicios típicos de compartición de recursos en red local y a la mayoría de los servicios de Internet.

Otro aspecto de gran importancia son las contraseñas utilizadas para proteger las cuentas de trabajo en el equipo, y también en la práctica totalidad de los servicios de Internet. La vulnerabilidad de una contraseña vendrá determinada por su posibilidad de ser usurpada, bien por ser susceptible a los denominados ataques de diccionario (palabras con significado) o de fuerza bruta (lo que depende de su tamaño). Si tiene menos de ocho caracteres será susceptible de ser comprometida en cuestión de horas de cómputo.

Sistemas de almacenamiento. Discos removibles, pendrives y nube

Tanto en entornos domésticos como corporativos, el almacenamiento de información y su posibilidad de ser transferida de forma masiva con los modernos sistemas de almacenamiento basados en discos portátiles, pendrives o subida a Internet es una de las amenazas principales, asociados a la transmisión de software malicioso y al simple robo de información

Uso compartido de ordenadores personales

Antes de la irrupción de Internet en los hogares, el peligro de compartir el PC estaba casi exclusivamente limitado a la infección por virus o a la destrucción accidental de información sensible. Hoy en día, las amenazas se multiplican cuando un mismo equipo es usado por usuarios con diferentes intereses y sensibilidades, en operaciones de muy distinto nivel de riesgo, en un entorno tan universal y lleno de amenazas como la Red. Considerando la seguridad como una cadena, se entiende que en estas condiciones, cualquier negligencia que implique una deficiencia en la seguridad del sistema, afectará por igual a todos los usuarios.

2.2. Redes domésticas. Wifi. ADSL. Internet por cable

La mayoría de los hogares y pequeñas empresas en nuestro entorno disponen de conexiones a Internet de banda ancha, mediante ADSL, cable o fibra metropolitana. Igualmente, la tecnología Wifi (Wireless Fidelity) de comunicaciones inalámbricas se integra en los equipos de acceso a Internet, configurando una LAN (red de área local) doméstica que permite el intercambio de información entre ordenadores, el empleo compartido de recursos como impresoras, etc.

Aunque la configuración básica de estos *routers* domésticos y de Pymes es mucho más segura que en los antiguos sistemas de comunicación a través de modem, ya que un router solo por tener direcciones privadas en la red local, se comporta como una membrana semipermeable gracias al mecanismo denominado NAT, permitiendo las conexiones salientes, desde los equipos domésticos hacia Internet e impidiendo las conexiones iniciadas en la Red destinadas a los equipos domésticos; pero no por ello deja de presentar vulnerabilidades, sobre todo ante el

acceso de usuarios no autorizados. Explicamos brevemente las principales amenazas a la seguridad en este tipo de redes domésticas.

Acceso al equipo de comunicaciones (router)

Habitualmente, el usuario y contraseña de acceso a la configuración del equipo de comunicaciones es o bien compartido por el usuario y la empresa de comunicaciones, o esta última tiene su propia cuenta de acceso. En resumidas cuentas, no se conoce con precisión quién puede acceder a dicho equipo. No olvidemos, además, que es demasiado frecuente por parte de las empresas de comunicación la utilización de subcontratas y empleo temporal para la realización de estas actividades de instalación de nuevas conexiones domésticas.

Configuración de seguridad de la red Wifi. Identificación y métodos de cifrado

En la unidad anterior vimos las diferentes opciones de cifrado de las comunicaciones a través de Wifi y algunas herramientas de seguridad adicional. Las amenazas principales a la seguridad de una red doméstica con Wifi vendrán determinadas por la posibilidad de que usuarios no autorizados accedan a la red. En este sentido, la adecuada configuración de seguridad de la Wifi, el empleo de la última versión disponible del protocolo WPA, la asignación una contraseña fuerte y la desactivación de opciones que puedan ser peligrosas, como explicaremos en el siguiente módulo, son medidas críticas de seguridad.

De esta forma, aunque los entornos Wifi actuales permiten sistemas más avanzados (y también más sofisticados, y por tanto, más complejos de instalar y mantener) de cifrado de las comunicaciones, así como herramientas de seguridad adicional cuyo empleo recomendaremos en la unidad siguiente, la realidad actual es que todavía cierta parte de las redes Wifi domésticas pueden ser, y de hecho son, accedidas ilícitamente por usuarios que en el mejor de los casos se limitarán a aprovechar la conexión a Internet, y en ocasiones realizarán acciones maliciosas contra otros equipos de la red interna.

3. SOFTWARE MALICIOSO O MALWARE

Aunque tradicionalmente se ha utilizado el término “virus” para referirse genéricamente a todos los programas que pueden introducirse de manera no deseada en un ordenador, produciendo resultados también indeseables; se considera a los virus un tipo específico de lo que se denomina en lengua inglesa **malware** (de malicious software), y que es el término genérico para designar cualquier pieza de *software malicioso* cuyo objetivo sea comprometer la seguridad de un sistema informático.

Orientación hacia el beneficio económico. Crimeware

Como ya se ha dicho, los creadores de software malicioso actúan mayoritariamente con una motivación económica y desarrollan productos de malware con la intención de que se extiendan por toda la red, infectando el mayor número posible de ordenadores y actuando sin ser detectados para poder desarrollar sus actividades maliciosas durante el mayor tiempo posible. Esta variedad de malware se denomina *crimeware*.

Dentro del enorme abanico de posibilidades que ofrece la creación de software malicioso para la obtención de beneficio económico o *crimeware*, las más comunes son las encaminadas a instalar de forma oculta una determinada pieza de malware que al ejecutarse realizará alguna de estas actividades:

- Recopilar información sensible del ordenador infectado, como datos personales, contraseñas, credenciales de acceso a entidades bancarias, que podrá ser enviada de distintas formas a los atacantes (creadores del malware), para su posterior aprovechamiento.

- Obedecer instrucciones remotas (bot o zombie), de tal forma que los atacantes organizan redes de estos ordenadores infectados (botnets), y su vez alquilan estos servicios a entidades sin escrúpulos para perpetrar acciones ilegítimas, como el envío masivo de *spam*, de mensajes de *phishing*, organizar ataques masivos de denegación de servicio, minería de *criptomonedas*, etc.
- Comportarse como un “falso antivirus” que muestra mensajes con publicidad informando de que el ordenador está infectado, cuando en realidad no es así, la infección que tiene el usuario es el propio falso antivirus.
- Cifrar el contenido de los ficheros del ordenador y solicitar un *rescate* al usuario del equipo para recuperar la información, como hacen los criptovirus o *ransomware*.

Los programas maliciosos pueden afectar a cualquier dispositivo basado en un procesador digital y conexión de red, como ordenadores personales, servidores, teléfonos móviles, tablets, videoconsolas, routers, TVs inteligentes, cámaras de vigilancia, etc.

La gran variedad de software malicioso que existe en la actualidad se puede clasificar en función de diferentes criterios, siendo los más comunes:

1. Atendiendo a su **mecanismo de propagación** (cómo accede al sistema anfitrión)
2. Atendiendo a su funcionalidad (acciones que realizan en el equipo infectado)

Algunos programas maliciosos serán fáciles de categorizar de acuerdo a ambos criterios, mientras que otros presentarán alternativas, tanto en su propagación como en su funcionalidad, lo que dificultará su clasificación.

3.1. Mecanismos de propagación del malware

Atendiendo a su mecanismo de propagación, podemos considerar tres tipos de código malicioso: los **virus**, los **gusanos** y los **troyanos** o caballos de Troya.

3.1.1. Virus

Un virus informático es un programa que es capaz de copiarse a sí mismo y propagarse dentro de un sistema informático o una red, sin conocimiento de los usuarios del sistema. Probablemente es el tipo de software malicioso más popular, aunque su utilización en los últimos años ha ido disminuyendo en favor de los troyanos.

El nombre de virus proviene de su analogía con los virus biológicos: estos penetran en un organismo anfitrión, insertan su código genético y se reproducen a sí mismos, provocando efectos nocivos en dicho anfitrión. Análogamente, el virus informático infecta un equipo gracias a algún agente externo, y desde el momento en que logra ejecutarse al menos una vez consigue introducir su código maligno en el sistema. El código contiene instrucciones que replican el virus en otros lugares (por ejemplo, adosándolo a otros ejecutables) y además provoca algún efecto permanente en el ordenador, más o menos fácil de detectar.

Los virus se introducen en un sistema a través de una fuente externa, como puede ser cualquier soporte que transporte ficheros ejecutables: disquetes, CD-ROM, memorias USB, documentos adjuntos en correos electrónicos, carpetas compartidas en red, ficheros descargables en programas P2P, etc. Una vez dentro, infectan otros archivos. Los ficheros infectados generalmente son ejecutables: .exe, .src, o en versiones antiguas .com, .bat; pero también pueden infectar otros archivos, por ejemplo, un virus de macro infectará programas que utilicen macros, como los productos Office. Si el fichero que infectan se encuentra dentro de un dispositivo extraíble o una unidad de red, cada vez que un nuevo usuario acceda al fichero infectado, su equipo también se verá comprometido. Una característica principal de los virus es que requieren de la **intervención humana** para provocar la infección.

3.1.2. Gusanos (Worms)

Un gusano (worm) es, al igual que un virus, un programa capaz de reproducirse. Pero a diferencia del anterior, se propaga de forma **automática** por las redes, sin requerir intervención humana. De ahí la analogía con un gusano o lombriz, que serpentea por la red, reproduciéndose en cada bifurcación, multiplicándose continuamente. Su mecanismo de acceso al ordenador es a través de alguna debilidad del sistema operativo o algún servicio de red defectuoso (exploit) y una vez dentro, desarrollan su capacidad maliciosa e intentan acceder a otros anfitriones.

Dada su capacidad de infección autónoma, los gusanos tienen una altísima peligrosidad potencial. Sirva como ejemplo el gusano Blaster, que contaminó millones de equipos en 2003, aprovechando una vulnerabilidad en el servicio RPC del sistema operativo Windows. Más famoso aún fue uno de sus precursores, el “gusano Morris” en 1998, iniciado como un experimento de carácter científico que *se le fue de las manos* a su autor y provocó la mayor caída de servicio de Internet ocurrida hasta el momento. De hecho, este incidente propició la creación del primer CERT (Computer Emergency Response Team), o equipo de respuesta ante emergencias informáticas, de los que hablaremos en las unidades siguientes.

3.1.3. Troyanos o Caballos de Troya (Trojan Horses)

Los troyanos o caballos de Troya son componentes de software que, emulando el mito homónimo citado en la literatura clásica, bajo una apariencia inofensiva esconden código que ejecuta acciones no deseadas por el usuario. Por tanto, la diferencia con las anteriores variedades de malware (virus y gusanos) es que un **troyano siempre irá acompañado de un “señuelo” para que el usuario haga lo que el atacante desea**, que típicamente será la instalación de malware que, una vez dentro del sistema, capturará información confidencial y la enviará a un destino controlado por el atacante, o realizará cualquier otra acción de interés para el intruso. Los troyanos son muy difíciles de combatir, porque juegan con la apreciación subjetiva del usuario, que no los reconoce como amenazas.

Al carecer de sistema de propagación, pueden llegar al sistema de diferentes formas, las más comunes son:

- Descargado como parte de alguna aplicación instalada por el usuario (las *Apps* de móviles son grandes fuentes de troyanos)
- Como adjunto en un mensaje de correo electrónico, que podrá ser cualquier tipo de documento (Word, Excel, PDF, etc.)
- Descargado, con o sin autorización del usuario, al visitar una página web maliciosa o una red social.
- Dentro de otro programa, inofensivo en apariencia, obtenido de cualquier forma (versiones gratuitas de productos de pago, de cracks de productos, etc.)

3.1.4. Combinación de mecanismos de propagación

Muchas veces, la distinción entre virus, gusano y troyano es confusa, y no es raro encontrar bibliografía, incluso especializada, que define como gusano o como virus un troyano. Más aún, una pieza de malware que accede automáticamente a un equipo en forma de gusano, se podrá replicar en forma de troyano, enviando correos electrónicos con copias de su mismo código malicioso adaptadas al nuevo método de propagación, o incluso infectar archivos como un auténtico virus. *Wannacry*, el *ransomware* que afectó a Telefónica en 2017 penetró como troyano y una vez dentro, se replicaba como gusano e infectaba soportes como virus.

3.2. Tipos de Software Malicioso

Con independencia de su método de acceso al sistema y de su ulterior propagación, el software malicioso puede ser clasificado de acuerdo a las acciones que realiza. Al igual que en el apartado anterior, un mismo componente de malware podrá comportarse de forma diversa, realizando acciones encuadradas en una o varias de las categorías siguientes.

3.2.1. Instalación y ocultación. Downloaders. Backdoors. Rootkits

El crimeware o malware moderno basa su filosofía de funcionamiento en la ocultación. Así, después de acceder a cualquier ordenador, en forma de virus, gusano o troyano, el código malicioso realizará funciones que le permitan trabajar de forma autónoma y en segundo plano, e intentará esconderse o dificultar su localización y si es posible, garantizar accesos al sistema en el futuro. Por lo tanto, en este apartado describimos funcionalidades del malware que no son especialmente nocivas en sí mismas, sino encaminadas a facilitar la realización de acciones maliciosas.

Downloader

En este caso, el malware que produce la infección en el sistema es muy pequeño, consistiendo en una pequeña porción de código que al ejecutarse, descargará de forma silenciosa el resto de los componentes, usando los servicios de red, e instalando dichos componentes en el sistema operativo. Los downloaders modernos exploran previamente el equipo anfitrión y podrán elegir los restantes módulos en función de lo que se encuentren.

Backdoor

Puede ser el resultado de la ejecución de un determinado malware o bien una serie de acciones realizadas a mano por un atacante de un sistema informático. Consiste en dejar “puertas traseras” en el sistema, típicamente cuentas de usuario con privilegios o servicios de Internet modificados, que permitirán al atacante acceder al sistema, incluso después de que hayan sido detectados y corregidos los efectos del ataque.

Rootkit

Este tipo de infección es especialmente peligrosa. Dado que todo sistema operativo se basa en una serie de programas que realizan determinadas acciones y que proporcionan información a los usuarios de lo que está ocurriendo, se conoce como “rootkit” el software malicioso que **sustituye determinados programas del sistema operativo**, de forma que puede esconder todos sus componentes, así como las acciones que realiza. Deben su nombre a que son el equivalente de un kit de administrador (la cuenta *root* es equivalente al administrador en sistemas Unix/Linux). En resumen, un ordenador que tenga instalado un rootkit no mostrará los ficheros que contienen el malware, ni los procesos de red que esté realizando, ni las conexiones establecidas, de forma que podrá engañar a cualquier sistema de antivirus local, impidiendo que detecte el código malicioso ni sus consecuencias.

La existencia de rootkits es lo que motiva que la única forma de estar seguro de que un sistema no está contaminado es escanear con antivirus los discos del sistema, arrancando desde otra fuente (típicamente un pendrive) ya que, si el sistema está infectado por un rootkit, el software de detección no podrá localizarlo, ya que el propio sistema, al estar infectado, ocultará los ficheros implicados.

3.2.2. Captura de información. Spyware. PWStealers. Keyloggers

Spyware

Se conoce con este nombre al software que se instala de forma no consentida en el equipo de un usuario para registrar su actividad y enviar los datos a algún destino controlado por el atacante original. Los datos registrados pueden ser de todo tipo, dependiendo de las intenciones del atacante: contraseñas y datos personales: sitios web visitados; horarios de actividad, etc. Al igual que en los demás casos, la vía de acceso de un spyware puede ser un virus (por ejemplo, dentro de un ejecutable), un troyano (podría ser un vídeo falso bajado de una red P2P), un gusano que se instaló en el sistema por una vulnerabilidad de algún servicio de red, o bien pudo ser descargado de Internet e instalado en el ordenador por un *downloader* que accedió al sistema por alguno de los métodos antes citados.

PWStealers (Ladrones de contraseñas)

Consisten en variantes de spyware especializadas en el robo de contraseñas almacenadas en el ordenador. Puede tratarse de las contraseñas de acceso al sistema, pero típicamente se trata de contraseñas de acceso a servidores web con información sensible, servicios de pago o peor aún, de entidades bancarias, que se almacenan de una forma particular en ficheros específicos del sistema. Se trata por tanto de malware muy específico, diseñado para obtener información de acceso a determinados recursos en la red.

Keyloggers (capturadores de teclado)

Constituyen un caso particular y extremadamente sofisticado de spyware. Son dispositivos de software o hardware que realizan un registro completo de las actividades de navegación del usuario, registrando y enviando a los atacantes toda la información introducida por el usuario en dichas páginas web, llegando incluso a registrar las pulsaciones del teclado de la víctima. Como es fácil de entender, la peligrosidad de este tipo de malware es extrema, ya que proporcionan a sus creadores todo lo necesario para actuar en nombre del propietario del equipo infectado (sus nombres de usuario, las contraseñas y en general, toda la información de autenticación que no haga uso de avanzados sistemas criptográficos). Dado el empleo creciente de los sistemas de banca online, de pago en la red y de criptomonedas, se entiende perfectamente las posibilidades de este tipo de código malicioso para la obtención inmediata de grandes beneficios económicos.

La contramedida dispuesta a la primera generación de keyloggers, basada en el empleo de herramientas de “teclado virtual” por las entidades de banca electrónica en red, que evitan la necesidad de introducir contraseñas a través del teclado, ha sido neutralizada por una segunda generación de keyloggers, capaces de capturar y almacenar porciones de la imagen en pantalla alrededor del puntero cuando el usuario está utilizando estos teclados virtuales, de forma que enviando dichas imágenes a los responsables del malware, se vulnera totalmente la eficacia de estos sistemas de protección de las contraseñas.

3.2.3. Captura de recursos. Bots. Botnets.

Este tipo de software malicioso es extremadamente peligroso. Se trata de malware que se instala de forma silenciosa en el equipo anfitrión y utilizando algún servicio público de información en Internet (foros de noticias, páginas web maliciosas, etc.) acceden a las órdenes que allí publica el hacker responsable de su propagación.

A medida que la infección se extiende, este hacker podrá disponer de un elevado número de ordenadores que, sin conocimiento de sus propietarios, efectuarán todo tipo de tareas en segundo plano. Al ordenador infectado con este tipo de software malicioso, se le denomina

zombie o bot (abreviatura de robot) y al conjunto de bots infectados se le llama red de zombies o botnet. Se han identificado *Botnets* con millones de equipos *zombies*.

Las tareas más comunes que puede desarrollar una botnet son:

1. **envío masivo de spam** (ya que cada zombie es un ordenador que usualmente, tendrá configurado uno o más servidores de correo fiables, que aceptarán sus envíos de correo)
2. **plataforma de ataques** distribuidos de denegación de servicio o **DDoS**, que se explicará más adelante.
3. **minería de criptomonedas** aprovechando la potencia combinada de los procesadores de toda la red de zombies.

En este sentido, la organización de estas botnets está demostrando ser un *negocio* muy rentable, ya que se pueden contratar sus servicios anónimamente a través de Internet, tanto para la organización de ataques DDos (la práctica totalidad de grandes empresas y organizaciones han sufrido serios ataques de estas características) como para el envío de spam (se estima que en la actualidad, más del 50% del spam es producido por bots) y también para otras actividades más específicas, como el aprovechamiento del procesador de cada equipo infectado para el minado de criptomonedas.

3.2.4. Publicidad. Adware. Clickers. Secuestradores de web

Adware

Esta expresión procede de la expresión en inglés coloquial “ad”, abreviatura de *advertisement* o anuncio publicitario. Bajo esta denominación se conoce a los programas que sirven para mostrar publicidad de manera forzada al usuario. Es práctica común hoy en día que existan versiones gratuitas de programas de pago, que muestran publicidad diversa mientras son utilizadas, algo que será legal, siempre que el usuario conozca y explícitamente acepte, con anterioridad a su instalación, esta característica.

Lo que típicamente se conoce como *adware* es, en cambio, un malware que mayoritariamente accede mediante un troyano de forma que, acompañando a cualquier software inocuo, instala en el equipo algún ejecutable que muestra la publicidad no deseada. El ejecutable suele instalarse de manera que sea difícil de eliminar para un usuario no experto.

Clicker

Este tipo de malware redirecciona las páginas de Internet a las que intenta acceder el usuario, de este modo logra aumentar el número de visitas a la página redireccionada, realizar ataques de Denegación de Servicio a una página víctima o engañar al usuario sobre la página que está visitando, por ejemplo, creyendo que está accediendo a una página legítima de un banco cuando en realidad está accediendo a una dirección falsa, aunque esta actividad se explicará con más detalle cuando se muestren las técnicas de phishing y pharming en apartados siguientes.

En ocasiones se comporta como un *secuestrador del navegador*, modificando de la página de inicio del navegador de la máquina infectada, la página de búsquedas por defecto o las pestañas de navegación. También pueden añadir barras de herramientas, con propósito más o menos malicioso, en el navegador o incluir enlaces en la carpeta de “Favoritos”. La idea es que el usuario acceda a sitios web diferentes de los inicialmente previstos.

3.2.5. Secuestro de información. Rogues. Ransomware

Troyanos y webs fraudulentos (*rogue trojan and web*):

Este tipo de malware *simula un comportamiento anormal* del sistema y propone la compra en línea de algún programa para solucionarlo. Los más comunes son los *falsos antivirus*, que informan de

que el ordenador está infectado, cuando en realidad el principal programa malicioso que tiene es precisamente el indicador de que está infectado. También existen páginas web *rogue* o falsas (usualmente a las que se accede mediante técnicas de *adware*) que realizan la misma función, es decir, realizan un presunto análisis o escaneo del equipo del usuario, cuando lo que hacen en realidad es instalar un troyano, y le informarán de que necesita contratar su servicio de antivirus. En ambos casos, lo habitual es que si el usuario accede e instala el presunto antivirus, luego de realizar el pago de alguna forma, lo único que obtendrá será la instalación adicional de malware de diversa funcionalidad.

Criptovirus (ransomware)

Este tipo de software malicioso, una vez instalado en el sistema, convierte en inaccesibles (utilizando técnicas de cifrado criptográfico) determinados ficheros del ordenador, y coacciona al usuario para que solicite la clave que le permita descifrar la información, a cambio del pago de una cantidad en concepto de “rescate” (*ransom* en inglés), generalmente en criptomonedas. Lo que hacen es cifrar todos los documentos de trabajo existentes en los discos del ordenador, como documentos de texto, hojas de cálculo, imágenes, etc.

En los últimos años, distintas variantes de criptovirus (*cryptolocker*, *wannacry*) están ocasionando pérdidas muy importantes, especialmente en Pymes con políticas de seguridad débiles. Dos factores se combinan para hacer que estos ataques sean muy destructivos: 1.- pagar el rescate casi nunca resuelve el problema, ya que es muy difícil que el atacante responda con la clave de cifrado utilizada y 2.- si las copias de seguridad están en línea en algún dispositivo de la red, el malware las cifrará también.

3.2.6. Destrucción de información. Killers. Bombas lógicas

Killers

Se conoce con esta denominación genérica cualquier pieza de malware que en un momento determinado destruye parte o la totalidad de la información contenida en el sistema infectado. En particular, las primeras generaciones de virus, creados por hackers con pretensiones de notoriedad, frecuentemente actuaban como killers. En cambio, el crimeware de nueva generación tiende a la utilización de técnicas mucho más insidiosas, intentando pasar desapercibido mientras realiza acciones encaminadas a la obtención directa de beneficio económico por sus creadores. Aun así, siguen apareciendo nuevas versiones de malware con clara vocación destructiva.

Bombas lógicas

Una bomba lógica es un componente maligno dentro de una aplicación de software que está programado para activarse en determinadas circunstancias, como puede ser una fecha determinada, un contador (al ejecutar la aplicación que la contiene un número determinado de veces) o un disparador, como puede ser la ausencia o la existencia de un determinado fichero en el sistema, o el contenido de cualquier información en la Red. Por ejemplo, uno de los virus más tristemente famosos de la historia, el *Jerusalem*, era también una bomba lógica que se activaba si la fecha era un viernes y 13.

Las bombas lógicas son a veces utilizadas como recurso por desarrolladores de software desaprensivos, que las insertan en las aplicaciones que crean para sus clientes o empleadores, con ánimo de activarlas si les dejan de pagar o les despiden; o también para simular problemas de mantenimiento, que podrán corregir a cambio de dinero.

3.2.7. Otro software no recomendable

Además del denominado malware, existen algunos programas informáticos que, sin realizar directamente ninguna acción dañina en el equipo, se consideran maliciosos o ilegales, como son los siguientes.

Generadores de claves (keygens)

Muchas aplicaciones comerciales están protegidas mediante claves que el usuario tiene que introducir en el momento de su instalación. Esto permite que el kit de instalación del producto pueda ser distribuido libremente y bien para poder ser instalado, o bien para aprovechar todas sus funcionalidades, el usuario accede a la página web del fabricante y después de introducir sus datos y proceder al pago, recibe la clave que desprotege el producto.

Cuando un programador sin escrúpulos descubre (usualmente, mediante técnicas de criptoanálisis) el método de generación de las claves a partir de los datos del usuario, puede construir un pequeño programa que generará claves para cualquier usuario, sin necesidad de que se registre en la web del fabricante y proceda al pago de la licencia de uso. Estos programas son los denominados generadores de claves o *keygens*.

Crack (desprotección de Kits de instalación)

Un crack en lenguaje informático es una modificación o “parche” que se aplica a un determinado programa de pago para que funcione de forma gratuita. A diferencia de los generadores de claves, aquí lo que se hace es modificar el código del programa de pago, de forma que este deja de ejecutar las operaciones que comprueban su autenticidad.

En cualquier caso, la utilización de keygens y cracks no sólo es una actividad ilegal, sino además muy peligrosa. Las dos razones principales son la imposibilidad de actualizar oficialmente los productos *crackeados* y muy especialmente, la frecuente simbiosis de ambos productos con malware de tipo troyano y muy variada peligrosidad. Las páginas web de crackers y sus buscadores especializados son en su mayoría ejemplos de *webs tóxicas*, dispuestas a infectar todo equipo que las visite.

Herramientas de creación de malware (constructores)

Desde la aparición de los primeros virus de ordenador, se ha desarrollado un floreciente mercado ilegal de programas que permiten confeccionar malware a medida. Cuando aparece un nuevo tipo de malware, es común que se desarrollen *programas constructores* que permiten a usuarios sin escrúpulos el desarrollo de variantes de dicho malware, adaptadas a necesidades específicas. Por decirlo de alguna forma, el malware genérico constituye el vector que se introduce en el ordenador de la víctima, y la adaptación del usuario realizará las acciones deseadas por este, una vez dentro de la víctima. Por ejemplo, un determinado generador producirá un código de tipo troyano, capaz de descargarse en una página web maliciosa e instalarse silenciosamente en cualquier huésped, y el usuario decidirá qué ficheros quiere que el troyano localice y le envíe de forma silenciosa.

3.2.8. Profesionalización del hacking. Malware a la Carta

Fruto de la criminalización del malware y su empleo creciente como vehículo de obtención de beneficio económico, se está popularizando una serie de tendencias que marcan un antes y un después en el malware. Por un lado, la aparición de mafias organizadas que con elevados recursos económicos y organizativos, que gestionan redes de cobro de las cantidades sustraídas mediante fraude bancario y que contratan los servicios de hackers que elaboran software malicioso con las más modernas técnicas de ingeniería del software.

Esto está promoviendo también el efecto inverso. Ya no se trata sólo de grandes organizaciones delictivas con centenares de personas en varios países, sino que existen kits de malware, fácilmente accesibles a través de la red, diseñados de forma totalmente modular. Básicamente una pieza de malware de estas características se comporta como un vehículo (se suele hacer la analogía con un proyectil) en tres etapas:

1. **Downloader:** Se trata de una pieza de código extremadamente pequeña, dotada de características de mutación de código que lo hacen muy difícilmente detectable por los antivirus. Nada más instalarse en el sistema mediante alguna de las opciones ofrecidas (típicamente, a través de un enlace colocado en una red social o enviado en forma de spam), procede a la descarga de las siguientes etapas.
2. **Rootkit:** Esta pieza, descargada desde el equipo infectado con el downloader, modifica el sistema de forma que el componente activo (carga útil) será indetectable, hasta que el usuario reinstale el sistema o consiga detectarlo por medios indirectos.
3. **Malware propiamente dicho.** Normalmente, esta es la parte “a la carta” del kit. Puede tratarse de un Bot, o programa “zombie” que responderá a los comandos de su dueño o *herder*, puede tener capacidad de infección a equipos próximos con versiones “gusano” del downloader que lo instaló, puede ser un componente de “pharming local” que modifique la configuración del DNS de la máquina de forma que acceda a webs bancarias falsas, etc.

En particular, se conocen multitud de sitios web en los que un candidato a “phisher” puede encargar malware específico destinado a pequeños grupos de usuarios de webs bancarias. Otros sitios más o menos clandestinos ofrecen listas de correo para spammers, listas de direcciones de usuarios con cuenta en determinado banco y un larguísimo etcétera.

4. AMENAZAS A LA SEGURIDAD EN EL CORREO ELECTRÓNICO

El correo electrónico es uno de los servicios de Internet más empleados, siendo el primero en desarrollarse. Por ello, es un excelente vector para vulnerar la seguridad de los sistemas informáticos. Además, la evolución del correo electrónico, desde su primera época basada en el intercambio de textos simples, hasta los mensajes actuales, escritos en lenguaje HTML y con incorporación de multimedia, con ficheros adjuntos de todo tipo como documentos, imágenes, vídeos, ficheros de audio, ficheros ejecutables, etc., ha posicionado este sistema como una de las **principales vías de transmisión de malware**.

Sin embargo, esta no es la única amenaza que se nos presenta en el correo electrónico. Otros problemas y riesgos habituales son descritos en los apartados siguientes.

4.1. Privacidad

Sin duda alguna, después de su peligrosidad como vehículo de transmisión de malware, la principal amenaza del correo electrónico es relativa a la privacidad. Las opciones básicas asociadas al reenvío de correos (campos CC: y CCO:) facilitan que un mensaje inicialmente destinado a un interlocutor cualquiera, sea redistribuido a un número indeterminado de receptores. Muchos de nosotros hemos cometido, alguna vez, el error de enviar un mensaje al destinatario *erróneo*, con diversas consecuencias.

Otro factor a tener muy en cuenta es la persistencia de los mensajes de correo electrónico. Un mensaje que enviemos hoy en día puede ser conservado por su destinatario y utilizado, quizás en nuestra contra, dentro de varios años.

4.2. Spam o correo no deseado

El tráfico de correos no deseados representa una amenaza grave a los sistemas, por el elevadísimo volumen de tráfico que genera y las molestias que ocasiona a administradores y usuarios en general. El spam es el nombre genérico en inglés para los correos no deseados, que hoy día pueden representar hasta el 90% del correo entrante de un usuario típico. La mayoría del spam son correos publicitarios que se difunden automáticamente a miles de usuarios, cuyas direcciones electrónicas han sido recolectadas utilizando spyware, con buscadores web, en redes sociales, etc. Se dice que, en promedio, puede pasar menos de un minuto desde que alguien hace pública de alguna forma su dirección de correo en Internet, hasta que comienza a recibir mensajes de **spam**.

En los primeros años, los *spammers* o responsables de envíos masivos de spam, se aprovechaban de la escasa o nula seguridad de las estafetas de correo o servidores organizativos, que aceptaban mensajes de cualquier procedencia, hacia cualquier destino. Con la incorporación de medidas de seguridad a estas estafetas, la estrategia se ha orientado hacia la utilización de las citadas botnets, o conjuntos de ordenadores infectados con malware que les convierte en bots o zombies a las órdenes de estos spammers, de forma que cada ordenador infectado retransmitirá multitud de mensajes de spam a su estafeta organizativa.

Además, entre el spam pueden encontrarse mensajes maliciosos, con técnicas de phishing o incluso “sondas” que lo único que pretenden es asegurarse de que la dirección a la que se ha hecho el envío está activa, con vistas a un posterior ataque más serio. En este sentido, es importantísimo **no responder nunca a un mensaje de spam**. Lo único que conseguiremos será demostrar al spammer que leemos sus mensajes, es decir, nos convertiremos en “objetivo ideal” de futuros envíos.

4.3. Bulos (*Hoaxes*)

Son mensajes de correo electrónico (o de otro tipo) que intentan hacer creer al destinatario algo que es falso, como alertar de virus inexistentes o noticias con contenido engañoso, que usualmente solicitan ser reenviados a todos los contactos del destinatario. Algunos de estos mensajes pueden ser peligrosos por la alarma innecesaria que generan y las acciones que, en ocasiones, solicitan realizar al usuario. Por ejemplo, que elimine por peligrosos determinados ficheros del ordenador que son necesarios para el correcto funcionamiento del equipo. En otras ocasiones, son parte de campañas de desinformación con objetivos más siniestros, como vimos en la primera unidad.

Técnicamente, estos bulos que se diseminan por Internet, y que cada vez más utilizan sistemas de mensajería como *Whatsapp* y redes sociales, son un tipo particular de spam que se propaga gracias a la ingeniería social: un mensaje alertando sobre la aparición de un nuevo virus es propagado por usuarios bienintencionados que quieren ayudar a sus contactos; un mensaje anunciando mala suerte para quien no lo reenvíe a diez contactos hará mella en las personas más supersticiosas, etc. En resumidas cuentas, sin necesidad de utilizar sofisticados programas informáticos, se crea una difusión vírica de información no deseada, con una mayor repercusión en la productividad (ya que usualmente este tipo de mensajes, al proceder de personas conocidas, son leídos con más atención) que el spam convencional.

5. AMENAZAS A LA SEGURIDAD EN LA WEB Y EL COMERCIO ELECTRÓNICO

La principal razón por la que la web produjo la mayor revolución en Internet desde su creación, es el énfasis en la facilidad de uso del servicio, no en la seguridad. Posteriormente, el empleo de este sistema como sustrato básico para todo tipo de actividades en la Red y la necesidad de comunicaciones seguras en comercio electrónico, banca en red, etc., motivó el

desarrollo de los protocolos SSL y TLS de web segura. Estudiaremos a continuación las principales amenazas a la seguridad de la navegación en web.

5.1. Navegadores web

El desplazamiento de todo tipo de actividades en Internet hacia su uso a través de la web, lleva a considerar el **navegador como sistema operativo de la Red**, especialmente en ordenadores fijos y portátiles, en los que muchos de los programas son aplicaciones web.

De esta forma, el navegador pasa a ser el entorno en el que se realizan todas las actividades de proceso, almacenamiento y transmisión de la información. Entendiendo la seguridad como una cadena, ya no es tan importante la robustez y la fiabilidad del sistema operativo, sino la de un componente, antes utilizado de forma esporádica, que ahora gestiona todas las operaciones en red. Si a esto añadimos que, precisamente para satisfacer estas demandas crecientes de funcionalidad, la complejidad de estos programas los ha convertido en auténticos entornos capaces de ejecutar código y acceder a la práctica totalidad de recursos del sistema operativo, se entiende que una gran parte de los ataques sufridos por ordenadores personales en la actualidad tengan su origen en debilidades propias del software del navegador, en una configuración inadecuada de parámetros que afectan a la seguridad o finalmente, en su empleo inadecuado por parte de los usuarios.

Así, una de las amenazas más importantes a los navegadores web es el empleo de **enlaces tóxicos**, es decir, de enlaces confeccionados de forma que consiguen vulnerar los criterios de seguridad del navegador, lo que conducirá a resultados siempre no deseados, como el envío de información confidencial, la infección con algún tipo de malware, etc..

En relación específica con el comercio electrónico y las operaciones de manejo de información bancaria a través de la web, además de las amenazas que estudiaremos a continuación, es fundamental el conocimiento de los principios básicos de la utilización de web segura, mediante la comprobación de que se conecta con el dominio correcto y la verificación del certificado digital que presente el sitio web.

5.2. Privacidad. Cookies

Las cookies son pequeños ficheros de texto que son creados a petición del servidor web y se almacenan en los navegadores al visitar sus páginas. Su empleo básico consiste por tanto en almacenar información que, por lo general, facilitará la navegación del usuario por el sitio web que se está visitando. Esta información puede ser de identificación (algunas cookies de carácter persistente permiten mantenernos conectados a un sitio web durante más tiempo que lo que dura una sesión), de navegación (son utilizadas por muchas tiendas virtuales como almacén de lo que se conoce como “carrito de la compra”), o de preferencias del usuario (pueden almacenar el idioma seleccionado, colores en pantalla, etc.)

Dicho de otra forma, una cookie es una pieza de información que un servidor web envía al navegador y que posteriormente podrá solicitar para de alguna forma, mejorar la experiencia del usuario.

Aunque como medida básica de seguridad, las cookies sólo pueden ser consultadas por servidores en el mismo dominio (parte principal del nombre del sitio web en un URL, como google.com) la complejidad actual de las páginas web, que insertan elementos de otros sitios web, como “banners” publicitarios o ventanas de acceso a redes sociales, algunas versiones antiguas de los navegadores web permiten lo que se conoce como **cookies espía**, de forma que los responsables de estos sitios web consiguen el acceso de información en principio restringida al sitio web principal. La peligrosidad aumenta cuando estas “cookies espía” consiguen obtener información, no sólo de hábitos o costumbres de navegación del usuario, sino que se accede a información de autenticación almacenada, convirtiéndose en auténticas **cookies maliciosas**.

5.3. Web Hacking

Una estrategia, utilizada desde hace tiempo por los hackers para **conseguir las credenciales de acceso** de otros usuarios (típicamente, conjuntos de usuario y contraseña) a todo tipo de servidores web, consiste en la creación de *falsas réplicas* de estas webs, con idéntica apariencia a las auténticas, de forma que si consiguen que los usuarios accedan sin saberlo a la web falsa, introducirán sus credenciales de acceso. Acto seguido, la web falsa puede generar un mensaje de error indicando que el servicio está temporalmente desactivado y el usuario no sospechará que ha sido víctima de que a partir de ese momento, sus claves de acceso están en poder de usuarios maliciosos.

Por tanto, lo que necesita el hacker es conseguir que los usuarios no accedan a la web auténtica, sino a su réplica maliciosa. Evidentemente, esta réplica estará instalada en un servidor diferente del original, con distinta dirección IP, de forma que asociará a un nombre de dominio escogido de forma que pueda ser confundido con el original (www.goooogle.com en vez de www.google.com, o bien www.cualquierbanco.net en vez de www.cualquierbanco.com).

Existen dos estrategias básicas para conseguir que los usuarios de la web original accedan sin saberlo a la versión maliciosa:

- **Phishing:** conseguir que el usuario acceda mediante un enlace falseado, que *aparentemente* conduce a la web auténtica, pero que realmente conduce a la réplica maliciosa.
- **Pharming:** falsear el propio sistema de nombres de dominio (DNS) para que, aunque el enlace sea correcto, el ordenador sustituya erróneamente el nombre por la dirección IP maliciosa, de forma que se conecte con la web falsa.

5.3.1. Phishing. Estafas por Internet

La variante más común del phishing se indica en la figura 3.2 y consiste en que el hacker que ha creado una copia maliciosa de un sitio web, envía a los usuarios de dicho sitio web un mensaje de correo electrónico para conseguir que accedan (mediante un enlace también malicioso) al citado sitio web. Esto conlleva el uso de **técnicas de ingeniería social** encaminadas a conseguir que los usuarios, bien para evitar cualquier perjuicio como la caducidad de sus cuentas, o para recoger algún tipo de premio, eviten la regla básica que consiste en **evitar el uso de enlaces externos para acceder a los sitios web con información sensible**.

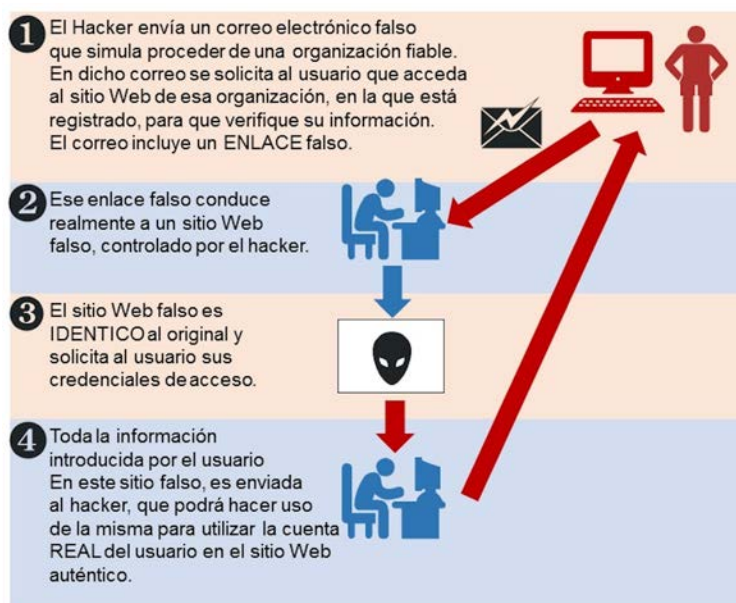


Figura 3.2.- Cómo funciona el phishing

Usualmente, estos mensajes de correo electrónico se envían de forma masiva, utilizando técnicas de spam. No obstante, es creciente el uso del denominado **spear phishing** o phishing *con arpón*, dirigido a usuarios específicos, con el contenido del mensaje adaptado a las características de víctimas concretas. Se puede decir que la práctica totalidad de los sitios web con cierto número de usuarios sufre periódicamente ataques de phishing.

Como en todas las amenazas que se apoyan en la **ingeniería social**, su mejor y casi única defensa es la **formación** de los usuarios. Si se consigue concienciar a los usuarios de que nunca accedan a servicios web sensibles a través de enlaces en correos electrónicos, redes sociales o *WhatsApp* y que ningún sitio web va a solicitar a los usuarios sus credenciales de acceso, se conseguirá mitigar esta gran amenaza a la seguridad en servicios web.

5.3.2. Pharming. Envenenamiento del DNS (DNS Poisoning)

La segunda estrategia de aprovechamiento del web hacking consiste, no en conseguir que los usuarios accedan a enlaces falsos, sino precisamente en falsear la sustitución del nombre del servicio web original, de forma que **el enlace correcto nos conduzca a la dirección IP falsa**. Dicho de otra forma, se trata de falsear la información de los servidores de nombres de dominio. Esta técnica es más compleja que la anterior pero mucho más efectiva y difícil de evitar.

El servicio de nombres de dominio (Domain Name System o DNS) es uno de los servicios más importantes (y desconocidos) de Internet. Gracias al DNS, asociamos servidores con nombres, cuando realmente su dirección de acceso es en un conjunto de números. El DNS es por tanto, un equivalente de la “guía telefónica” de Internet, en la que se sustituye cualquier “nombre de dominio” por su dirección IP equivalente. Todos los servicios básicos de comercio electrónico e información en la Red dependan del DNS, comenzando por los protocolos TLS que son sustrato de la web segura, garantizada por certificados digitales que protegen el nombre de los sitios, no su dirección IP.

Así, un ataque global a los servidores principales del DNS (actualmente existen trece *servidores de la raíz*) es una de las máximas amenazas de carácter global. Esto explica la implantación del sistema *Secure DNS* en los servidores principales, con empleo de sistemas criptográficos en el intercambio de datos sensibles entre estos servidores.

Intoxicación de la caché del servidor DNS de la organización

El DNS es un conjunto formado por centenares de miles de servidores trabajando conjuntamente, de forma que cada servidor mantiene las tablas que permiten asociar números IP a nombres de dominio de las zonas bajo su responsabilidad, y a su vez mantiene una memoria temporal o caché de la información correspondiente a otras zonas fuera de su autoridad.

Así, el primer método de pharming consiste en enviar información falsa al servidor DNS de una organización o de un proveedor ISP, aprovechando vulnerabilidades de versiones antiguas de software, para falsear la dirección IP de la web objetivo. A partir de ese momento, cualquier equipo de la organización que intente acceder al servidor web, solicitará a ese servidor que le resuelva dicha dirección, obteniendo la IP maliciosa. Al conectar con dicha web, el resultado será que conecta con la web falsa en vez de la auténtica. Consiguientemente, este sistema de pharming es extremadamente peligroso, ya que intoxicando a un sólo servidor, se pueden conseguir muchos accesos, de diversos ordenadores, a la web falsa.

Modificación del fichero HOSTS del equipo local

Todo equipo (fijo, móvil, portátil, etc.) conectado a Internet dispone de una tabla que le permite asignar la conversión de números a nombres. Esta tabla se almacena en un fichero denominado HOSTS, de forma que la configuración estándar de todo ordenador en red es consultar este fichero antes que enviar la pregunta al servidor DNS local. Así, el segundo método

de pharming consiste en modificar este fichero HOSTS, de forma que se especifique la dirección IP maliciosa como asociada al nombre del servidor web objetivo.

Esta técnica, debido a su relativa sencillez, ya que sólo requiere disponer de permiso de administrador, es utilizada por muchos componentes de malware.

5.4. Cross-Site Scripting (XSS)

Esta sofisticada técnica de ataque, que se podría traducir como “código de ejecución cruzada” se basa en la explotación de vulnerabilidades en un servidor web por parte de un atacante, que consigue **introducir código malicioso en dicho servidor web**, con la intención de que ese código sea ejecutado por los navegadores de otros clientes, afectando por tanto a la seguridad de los datos de los usuarios, no del servidor.

El fundamento de esta vulnerabilidad es similar al de la inyección de SQL, descrita más adelante. La inyección de SQL se basa en la inserción de código malicioso en los datos que se envían a un servidor, mientras que XSS se basa en la **inserción de código malicioso en el propio enlace** o link (URL) que apunta a un servidor determinado, de forma que un usuario registrado que acceda a dicho enlace, además de acceder a dicho servidor, ejecutará el código malicioso en su propio navegador, estando conectado al servidor de destino. Por decirlo de alguna forma, el atacante consigue que un cliente conectado a un servidor actúe en dicho servidor siguiendo sus dictados, pudiendo recibir a su vez los resultados de las acciones realizadas. Típicamente un ataque XSS culmina con la captura por parte del atacante de la “cookie de sesión” de la víctima, de forma que puede acceder al servidor con las credenciales de dicha víctima.

Existen dos modalidades de XSS, denominadas no persistente y persistente. En la primera, el ataque depende de que la víctima ejecute una versión “modificada” de un enlace que apunte al servidor. Para ello, el atacante puede utilizar técnicas de phishing.

La segunda modalidad de XSS denominada persistente, es menos frecuente, pero mucho más peligrosa. Para que un servidor web sea susceptible a esta amenaza, deberá mostrar a sus usuarios información directamente proporcionada por otros usuarios, sin ningún tipo de control o filtrado, como puede suceder en redes sociales, en foros de Internet, etc. Este tipo de ataque requiere que el servidor “publique” el código malicioso. Dado que las técnicas para evitarlo son sencillas, hoy en día la gran mayoría de los ataques XSS conocidos son de tipo no persistente. En cualquier caso, plataformas de red social tan conocidas como Twitter o Facebook han sufrido en el pasado ataques XSS de enorme repercusión.

6. NUEVAS AMENAZAS. REDES SOCIALES Y CLOUD COMPUTING

6.1. Redes Sociales

Después del advenimiento a principio de la década del 2000 de la llamada web 2.0, formada por la integración en servidores web de contenido generado por los usuarios, las redes sociales se han convertido en una de las últimas revoluciones en el mundo de Internet. Han superado el concepto de comunicación, pasando al siguiente nivel, el de la participación, la colaboración o el de compartir todo aquello que tiene que ver con nuestras vidas personales o nuestra actividad profesional.

Una de las consecuencias de este cambio en la clase de información que publicamos ha sido el tipo de incidentes de seguridad, puesto que como ya se ha comentado, la información personal es enormemente atractiva para los grupos criminales organizados y los ciberdelincuentes o personas sin escrúpulos que buscan venganza, difamación o daño de imagen.

El uso de estas plataformas de red social implica tres grandes **amenazas**:

1. De tipo **técnico**. Se trata de plataformas web 2.0 altamente integradas con todo tipo de sitios web de terceros. El empleo de *mashups* o ventanas de interacción con una red social dentro de otros sitios web, abre todo un espectro de nuevas amenazas relacionadas con *web hacking* y empleo de *enlaces tóxicos*.
2. La **Incertidumbre**, ya que éstas son gestionadas y controladas por empresas que, podrían hacer un uso inadecuado de los datos y la información publicada en estas redes.
3. La **Intimidad y la Privacidad**, se publica todo tipo de información de carácter personal, y en ocasiones, datos muy íntimos, como pueden ser aspectos de salud, de ideología, de creencias, de hábitos sexuales, etc.

Así, los **riesgos de carácter humano** que se encuentran en las redes sociales son muy variados y pueden traer consecuencias insospechadas. Veamos algunos ejemplos.

- **Daños o perjuicios a terceros.** Publicar información o fotografías sin permiso, o sin valorar los riesgos, puede suponer perder una amistad o dañar una relación de pareja. Este tipo de errores comunes pueden ser causa de venganzas o incluso de denuncias por parte de los afectados.
- **Repercusiones en la vida laboral.** Las redes sociales son utilizadas para buscar información sobre los candidatos a cualquier puesto de trabajo, y también sobre los empleados de una organización para conocer sus hábitos, lo que piensan de su empresa, sus comentarios, etc. Cada vez más, lo que publicamos en estas redes será determinante para nuestro futuro profesional, tanto a la hora de encontrar empleo como de mantenerlo.
- **Difamaciones y calumnias.** Las redes sociales son usadas para llevar a cabo campañas de difamación y calumnias. Una vez que algo es publicado y difundido, es realmente difícil hacer que desaparezca. La velocidad a la que se puede propagar un rumor, una fotografía comprometedor o una mentira es enorme.
- **Menores en la red.** Las redes sociales se han convertido en un lugar perfecto para los delincuentes sexuales que se hacen pasar por amigos o jóvenes con perfiles falsos, con el objetivo de engañar o acosar a menores. Los menores son un grupo de riesgo en este sentido, puesto que son mucho más influenciables que otro tipo de usuarios.

Por su parte, los **riesgos de carácter tecnológico** más importantes son:

- **Difusión de Malware.** Muchas versiones de malware utilizan cuentas de usuarios ya comprometidas para propagarse, colocando enlaces infectados que serán accedidos por los contactos del usuario víctima.
- **Social Spamming y Scamming.** El uso de estas plataformas es una oportunidad para el envío de correos electrónicos no deseados, tanto si la finalidad es meramente publicitaria (spam), como si implica fraude o lucro indebido (scam)
- **Tabnabbing.** Esta técnica aprovecha el sistema de navegación por pestañas o tabs. Cuando el usuario va de una pestaña a otra, la que permanece en segundo plano se transforma en una página de acceso a servicios y plataformas (como Gmail, YouTube, Facebook, etc.). El usuario, al no percatarse, introduce los datos de acceso a estos servicios, y por tanto, está facilitando estos datos al propietario de la página falsa.

- **Clickjacking.** En este caso, al hacer click en “Me gusta” (botones para compartir opiniones sobre un contenido), se actualizan en el estado del usuario frases que redirigen hacia webs de spam o malware. También se pueden encontrar mensajes que enlazan hacia webs fraudulentas, en este sentido, se debe tener cuidado con los acortadores de URL que enlazan a páginas web maliciosas.

Éstos son sólo algunos de los riesgos que nos podemos encontrar en las redes sociales. Combatirlos es una tarea fundamental y muy necesaria puesto que este tipo de incidentes pueden tener consecuencias directas tanto para nuestro entorno personal como profesional.

6.2. Computación en la Nube (Cloud Computing)

Internet no ha dejado de evolucionar desde sus inicios y aún continúa haciéndolo. Prueba de ello es un nuevo paradigma que está provocando importantes y profundos cambios en el mundo de Internet y en el ámbito de las tecnologías de la información: el *cloud computing*.

Cloud computing significa “**computación en la nube**” y tiene que ver con el hecho de que muchas empresas y organizaciones **externalizan** una gran parte de sus infraestructuras TIC. Además, el aumento de velocidad de Internet y los avances en tecnologías web y los navegadores posibilitan que la mayoría de las aplicaciones empleadas habitualmente ya no necesiten estar instaladas en los ordenadores, sino que se utilizan a través de un navegador.

Pero la principal consecuencia del cloud computing es que las organizaciones externalizan no sólo aplicaciones u otro tipo de recursos, como ya se hacía con recursos humanos, instalaciones o infraestructura informática, sino también la **información**. Las ventajas de este enfoque son enormes, pero el problema radica en que un recurso tan importante se encuentre fuera de la organización, incluso fuera de su país, con la problemática legal asociada.

La información es el activo más importante que posee cualquier organización. Si ésta ya no está físicamente almacenada en sus sistemas internos, mantener los niveles de seguridad se vuelve una tarea compleja. Ya no depende únicamente de sus recursos, infraestructuras, políticas y normativas, sino que todo esto ha de ser adaptado a un escenario en el que la gestión de estos recursos críticos se encuentra en manos de terceros. Esto plantea nuevos riesgos y amenazas a la seguridad de la información.

Así, es necesario establecer los mecanismos que conduzcan a garantizar todas las dimensiones de la seguridad de la información corporativa, en virtud de acuerdos con los proveedores de estos servicios en la nube. Aparecen nuevos aspectos, de legislación nacional e internacional, de cláusulas de privacidad y de responsabilidad delegada en el mantenimiento de la seguridad.

7. ATAQUES ELABORADOS A LOS SISTEMAS DE INFORMACIÓN

Una vez desarrolladas las amenazas más frecuentes relativas a los sistemas de información, tanto en el uso doméstico como en los equipos o estaciones cliente de las organizaciones, estudiaremos las técnicas de ataque básicas contra las infraestructuras de información de grandes organizaciones, entendidas como el conjunto de servidores, bases de datos, redes de comunicaciones y en general, los elementos que sustentan los principales activos de información de las mismas.

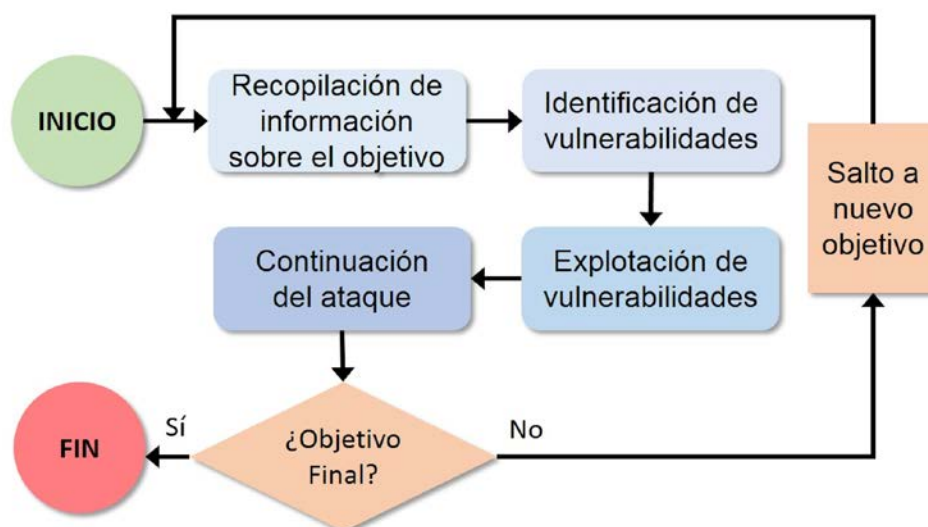


Figura 3.3. Etapas de un ataque informático

Un ataque informático a una gran organización se suele realizar en una serie de etapas como las descritas en la Figura 3.3, en las cuales el atacante comienza por recopilar información, conducente a la identificación de vulnerabilidades de todo tipo en el objetivo: A continuación, se realiza el ataque propiamente dicho, por explotación de estas vulnerabilidades para acceder al sistema (**acceso**) y realizar las acciones deseadas, a la vez que se establecen medidas que permitan eliminar las huellas (**ocultación**) y garantizar la posibilidad de mantener el acceso o el control sobre el objetivo (**aseguramiento**). Muy frecuentemente, el objetivo inicialmente atacado no es el deseado, sino cualquier equipo o sistema dentro de la organización (equipo de comunicaciones, PC de un empleado sin privilegios, etc.), de forma se repetirá el proceso descrito para poder acceder (**salto**) a otro objetivo más cercano al deseado, hasta llegar al objetivo final.

7.1. Recopilación de información

Consiste en obtener cualquier información, de cualquier manera posible (con medios informáticos o no) que permita identificar vulnerabilidades en un sentido amplio. Esto engloba desde obtener la contraseña de administrador del sistema, por descuido de su propietario, hasta identificar la marca y modelo o la dirección IP de un equipo de comunicaciones en una visita casual a un centro de proceso de datos o rebuscando en la basura del departamento de TIs.

Usualmente, en esta etapa, se emplean, entre otras, técnicas de sniffing (escucha de paquetes en la red), google hacking (búsqueda de información involuntariamente filtrada a través de buscadores), ingeniería social (manipulación de las personas para obtener información que en condiciones normales no estarían dispuestas a dar), escaneo de puertos en red (para identificar servicios de red con exploits conocidos), etc. Veamos a continuación algunas de las técnicas más características en esta fase.

7.1.1. Escaneo de Puertos (Port Scanning)

La comunicación entre máquinas en Internet se establece mediante conexiones entre procesos, identificadas por el concepto de puertos. Así, los servicios de red más importantes se conocen por el puerto que ha de utilizar el servidor. Por ejemplo, 80 es el puerto que usa un servidor web para aceptar conexiones normales, 443 para las conexiones seguras, 25 para recibir mensajes de correo electrónico, y así sucesivamente. Detrás de cada uno de estos puertos, el sistema operativo conecta un proceso o programa en memoria, que utilizando un lenguaje particular, intercambia información con el programa equivalente del cliente que ha solicitado la conexión.

El término escáner de puertos o escaneo de puertos se emplea para designar la acción de analizar el estado de los puertos de una máquina conectada a una red de comunicaciones, desde otra máquina que ejecuta un programa que intenta acceder a todos sus puertos. Por lo tanto, detecta si un puerto está abierto, cerrado, o protegido por un cortafuego. Se utiliza para detectar qué servicios comunes está ofreciendo la máquina y posibles vulnerabilidades de seguridad, según los puertos que tenga abiertos.

7.1.2. Escuchas

Bajo este término se engloban todas las actividades encaminadas a interceptar información transmitida por la organización objetivo del ataque. Básicamente se consideran dos tipos: las escuchas de voz y las de datos.

Eavesdropping o interceptación de comunicaciones de voz

Mediante estas técnicas, se puede obtener todo tipo de información, de aspectos organizativos, de políticas de seguridad, de horarios, etc. Pensemos por ejemplo en la posibilidad de escuchar las llamadas al departamento de informática. Muy probablemente, se pueda recopilar información valiosísima de cuentas de usuario y contraseñas, de equipos con problemas de seguridad y un larguísimo etcétera.

Sniffing o escucha de comunicaciones de datos

Consiste en aprovechar la naturaleza promiscua de los sistemas de comunicaciones de datos (redes locales Ethernet, redes inalámbricas Wifi) para colocar equipos con software específico (sniffers de paquetes) que almacenan la información relevante contenida en los mismos. Con los modernos sistemas de voz por IP, estas técnicas están reemplazando a las anteriores para la escucha de comunicaciones de voz.

7.1.3. Google Hacking

Evidentemente, la obtención de información de un objetivo incluye una búsqueda exhaustiva de información en buscadores de Internet, como *Google Search*. Sin embargo, el término *Google Hacking* hace referencia a una amenaza mucho más peligrosa. Los buscadores como Google funcionan en base a una serie de navegadores automáticos o *arañas* que recorren la web enlace a enlace, almacenando los contenidos de los millones de páginas que encuentran y organizando índices de acceso a los contenidos de estas páginas palabra a palabra. Por decirlo brevemente, permiten buscar en *todo* lo que encuentran. Mediante opciones de búsqueda avanzada, puede localizarse información relativa a aspectos que pueden ser reveladores para cualquier usuario malicioso, por ejemplo:

- Localización de versiones específicas (de las que se conozca algún exploit) de servidores web, de bases de datos, de cámaras web, etc.
- Localización de mensajes de error específicos de software conocido, incluso cuando el responsable ha ocultado los mensajes que permitan identificarlo directamente.
- Páginas erróneamente generadas, con filtración de información sensible, por servidores en respuesta a URLs tóxicas.

7.1.4. El punto más débil. Ingeniería social (social engineering)

Por muy fiable y robusto que sea un sistema informático, estará administrado por personas. Y las personas somos propensas a confiar en otras personas por motivos emocionales y no racionales, a devolver favores a quienes nos ayudan, a tener descuidos y despistes, etc. Un atacante con *habilidades sociales* puede aprovechar **las debilidades de la condición humana** para **engañar** y obtener acceso a un sistema. Según Kevin Mitnick, un famoso hacker y

ciberdelincuente, hoy reformado y convertido en asesor de seguridad (samurái), la ingeniería social se apoya en cuatro principios básicos:

- Todos queremos ayudar.
- El primer movimiento siempre es de confianza hacia el otro.
- No nos gusta decir no.
- A todos nos gusta que nos halaguen.

Como puede apreciarse en esta lista, lo que hacen los atacantes es seguir las técnicas básicas del engaño y la persuasión: manejo del poder, utilización del miedo, control de la reactancia ante situaciones provocadas por ellos, etc.

La única forma de combatir la ingeniería social es la organización **de planes de formación específica de todo el personal de la organización**. Dado que el factor humano es el eslabón más débil en la cadena de la seguridad, el conocimiento de estas técnicas y de sus contramedidas es de importancia extrema.

7.2. Identificación de vulnerabilidades

Esta segunda etapa consiste en la identificación, mediante el análisis de toda la información recopilada en el paso anterior, de una o varias vulnerabilidades del sistema objetivo que permita el acceso al mismo. Muchas vulnerabilidades son el resultado lógico de bugs o fallos en el diseño de una versión específica de sistema operativo o software en particular. Como ya indicamos, estas vulnerabilidades, una vez identificadas, suelen solucionarse con parches, hotfixes o con cambios en la versión.

Entendido que el aprovechamiento de estos exploits es una de las formas básicas de conseguir penetrar en un sistema, una de las actividades típicas en la fase de obtención de información consistirá en averiguar qué programas y qué versiones de estos programas se utilizan los sistemas de la organización seleccionada como objetivo.

Una vez obtenida la información, el atacante decidirá la estrategia del ataque. Básicamente, los ataques de tipo clásico se basan en aprovechar vulnerabilidades o exploits de los equipos de comunicación (routers, switches, repetidores Wifi), de los servidores de la organización accesibles desde el exterior, con el objetivo final de alcanzar un equipo en la Intranet de la organización que les proporcione acceso al origen de los datos buscados.

En ocasiones, será la conjunción de varias vulnerabilidades la que permita, en su conjunto, el acceso al sistema. Por ejemplo, la debilidad en la contraseña de un usuario sin privilegios permite al atacante acceder al sistema, y una vez dentro, aprovechará otra debilidad, en algún servicio del sistema operativo, que le permita adquirir propiedades de administrador. Desde dicha cuenta privilegiada, explotará otras debilidades que le permitan instalar una puerta trasera o *backdoor* que garanticen su acceso al sistema, incluso después de que la cuenta que utilizó para acceder sea identificada y eliminada.

7.3. Ataque. Explotación de vulnerabilidades

Esta fase representa la puesta en práctica del plan concebido en la etapa anterior, y consiste en el ataque propiamente dicho. Puede tratarse de una simple intrusión sin afán malicioso, de la instalación de programas espía que capturen determinada información, de la destrucción total de la información almacenada, de la instalación de software que permita controlar remotamente la máquina, o simplemente de la utilización del equipo invadido como plataforma para la realización de otros ataques.

La diferencia entre un ataque dirigido a un determinado objetivo y un ataque genérico, como el que usualmente se realiza a través de mecanismos de infección masiva, como los troyanos, consistirá en la presencia o no de las fases anteriores.

Las técnicas básicas de ataque consisten en provocar que el ordenador objetivo sufra un error de tipo lógico que “rompa” el sistema de seguridad interno. Se trata de estrategias de desbordamiento de buffer, errores en la validación de los datos de entrada como la inyección SQL, ejecución de código remoto en servidores web (XSS), etc.

Tampoco olvidemos que un ataque dirigido consistirá en una combinación de todas las técnicas aquí descritas, por ejemplo, un equipo invadido mediante un exploit, puede ser objeto a continuación de una infección voluntaria de malware encaminada a ocultar las huellas (rootkit), de modificaciones en su configuración para dejar puertas traseras (backdoors), etc.

7.3.1. Suplantación. IP, DNS y Web spoofing

Las técnicas de suplantación de identidad se basan en la inyección de un flujo de comunicaciones falso que haga pensar al destinatario de los mensajes que el intruso es otra entidad de confianza. Esta estrategia está detrás de delitos como el phishing (que combina técnicas de suplantación o *spoofing* con empleo de ingeniería social para conseguir finalmente un ataque de web hacking), y en sus versiones más sofisticadas utiliza técnicas como el IP Spoofing y el DNS Spoofing, que consiste en modificar los paquetes de datos enviados a un sistema informático para simular que provienen de un equipo diferente al original.

Una variante muy utilizada de la suplantación es el ataque del tipo *Man in the Middle*, explicado anteriormente, y que tiene aplicación en la práctica totalidad de los sistemas de comunicación, correo electrónico, web, transferencia de ficheros y un larguísimo etcétera. En términos generales, se puede decir que todo sistema de comunicación que no tenga un mecanismo fuerte de autenticación (como el empleo de criptografía de clave pública, y aun así, muchos de ellos lo son por defectos en la implantación del mecanismo) es susceptible a este tipo de ataques en los que un intermediario realiza una doble suplantación.

7.3.2. Inyección de código SQL

Es una técnica de ataque a servidores web, mediante la cual un usuario malicioso interacciona con un servidor web, alterando los datos que se envían a dicho servidor (típicamente, los datos de identificación de entrada al servidor, usuario y contraseña), de forma que, en lugar de datos, lo que realmente envía son instrucciones que, al ser ejecutadas por el servidor, comprometen la seguridad de su base de datos.

Este tipo de vulnerabilidad es conocida hace mucho tiempo y está suficientemente documentada. Se evita con técnicas básicas de supervisión y filtrado de todos los datos de entrada al servidor web. Lamentablemente, sigue siendo utilizada con éxito, lo que demuestra que aún queda mucho por hacer en el establecimiento de políticas básicas de seguridad.

7.3.3. Denegación de servicio (DOS y DDOS)

Los ataques de denegación de servicio (DoS, de “Denial of Service”) son un caso particular de ataques que se ha popularizado en los últimos años. Un ataque DoS tiene como objetivo anular la capacidad de operar de los equipos informáticos y las redes de datos de una organización, para que no pueda prestar sus servicios. Por tanto, constituyen una amenaza a la **disponibilidad** de la información. Aunque se han identificado muchos tipos de ataque de denegación de servicio, todos ellos responden a dos estrategias básicas:

- **Aprovechamiento de exploits (DoS):** Mediante este tipo de ataque, se consigue la saturación de los procesadores o de la memoria del servidor, forzando la ejecución de determinados programas con vulnerabilidades conocidas (exploits), que les llevan a consumir una gran cantidad de recursos del sistema. De esta forma, una sola máquina o un reducido grupo de máquinas atacantes, conseguirá bloquear el servidor.
- **Denegación de Servicio Distribuido (DDoS):** Cuando no se conocen exploits en el objetivo del ataque, se puede provocar un colapso de la capacidad operativa del servidor, a base de solicitar una ingente cantidad de conexiones. Por ejemplo, enviando miles o millones de peticiones simultáneas a un servidor web, de forma que se satura y no es capaz de atender las peticiones legítimas (fuerza bruta). La técnica básica de DoS mediante fuerza bruta es el ataque de denegación de servicio distribuido (DDoS). Esta técnica consiste en utilizar miles de ordenadores infectados con malware de tipo Botnet ya descrito, para realizar las peticiones simultáneas al mismo servidor.

7.4. Continuación del Ataque

Como ya indicamos, estas técnicas se utilizan en ocasiones en cadena, es decir, el atacante alcanza su objetivo mediante una serie de saltos entre máquinas, cada vez más cercanas al objetivo. Es muy importante entender que cuando se desea atacar contra la seguridad de la información de cualquier organización desde el exterior de la misma, será necesario burlar los sistemas de protección de la misma en su totalidad, comenzando por los cortafuegos (firewalls) o elementos encargados de impedir dichos accesos, que se describen en el capítulo siguiente. De esta forma, un ataque de estas características muchas veces requiere una penetración por etapas, accediendo a algún sistema de la denominada DMZ o zona neutra, donde se ubican los servidores encargados de interactuar con el exterior, para a continuación, una vez dentro del perímetro exterior de la organización, disponer de un rango más amplio de objetivos que le conduzcan al sistema que contenga la información cuya seguridad se desea comprometer.

Por tanto, un ataque elaborado combinará las cuatro etapas básicas del ataque: Recopilación de información, identificación de vulnerabilidades, ataque y mantenimiento del ataque con las técnicas indicadas de acceso, ocultación, aseguramiento y salto a otro objetivo.

7.5. Amenaza avanzada y persistente (APT)

Una amenaza avanzada y persistente (*Advanced Persistent Threat* o APT) es una variedad de ciberataque especialmente peligroso, en la que un atacante con elevados conocimientos y amplios recursos, realiza un ataque elaborado a otra organización o estado mediante el cual consigue acceso a un objetivo y permanece oculto durante mucho tiempo, empleando las técnicas ya descritas de acceso, ocultación, aseguramiento y salto por sus sistemas, estableciendo un canal de comando y control que le permite acceder de forma continuada a información estratégica de su objetivo. Este tipo de ataques busca obtener a lo largo del tiempo información valiosa, con otros fines que los meramente económicos.

Habitualmente, este tipo de ataques son llevados a cabo bajo el auspicio o la dirección de un país, aunque en ocasiones pueden ser llevados a cabo por organizaciones delictivas o terroristas. Los tres aspectos básicos de una APT son:

1. El atacante se infiltra en la organización objetivo por un largo período de tiempo.
2. Se adapta a los mecanismos de defensa y consigue superarlos.
3. Mantiene el nivel de interacción para conseguir los objetivos finales.

Es importante entender que no todas las APTs son muy avanzadas y sofisticadas, del mismo modo que no todos los ataques selectivos, complejos y bien estructurados constituyen una

amenaza persistente avanzada. La motivación del adversario (el ciberespionaje y actividades afines) y el empleo de técnicas de persistencia es su principal característica.

ACTIVIDADES

1. Escanear nuestro ordenador personal con dos antivirus diferentes, gratuitos o de pago, y comparar los resultados de la exploración. ¿conducen? Aparte de las “cookies maliciosas”, ¿alguna de estos análisis ha detectado código malicioso? Comparar los resultados.
2. Escanear nuestro teléfono móvil con un antivirus, gratuito o de pago, analizar los resultados y en su caso, realizar las acciones aconsejadas.
3. Realizar una revisión exhaustiva de los permisos de cada aplicación instalada manualmente en nuestro teléfono móvil. Detectar (y revocar en su caso) los permisos excesivos (p.e. una App de linterna con acceso a la agenda de contactos). Repetir el proceso con las Apps preinstaladas en el móvil.
4. Mediante una búsqueda en prensa digital, identificar todas las noticias relacionadas con las amenazas indicadas en este capítulo: phishing, filtraciones de datos, malware en móviles, etc. ¿Qué tipo de amenaza es la más frecuente y cuál es la de mayor impacto?
5. Durante una semana, prestar atención a la carpeta de correo no deseado de nuestras cuentas de correo electrónico e identificar intentos de phishing, de venta ilegal de medicamentos y de estafa mediante loterías o herencias sin destinatario. ¿Cuál de estas amenazas es la más frecuente?

BIBLIOGRAFÍA

- Aceituno Canal, V. (2004). Seguridad de la información: expectativas, riesgos y técnicas. Madrid. Creaciones Copyright.
- Areitio Bertolín, J. (2008). Seguridad de la información: redes, informática y sistemas de información. Madrid. Paraninfo.
- Costas Santos, J. (2011). Seguridad y alta disponibilidad. Madrid. Ra-Ma.
- Gómez López, J. (2010). Guía de campo de Hackers. Aprende a atacar y a defenderte. Madrid. Ra-Ma.
- Gómez Vieites, Á. (2006). Enciclopedia de la seguridad informática. Madrid. Ra-Ma.
- Mitnick, K. (2006). El arte de la intrusión: la verdadera historia de las hazañas de hackers, intrusos e impostores. Madrid. Ra-Ma.
- Rovira del Canto, E. (2002). Delincuencia informática y fraudes informáticos. Granada. Comares.
- Shinder, D. L. (2003). Prevención y detección de delitos informáticos. Madrid. Anaya Multimedia.
- Tynan, D. (2006). Privacidad informática: problemas y soluciones. Madrid. Anaya Multimedia.

Recursos en Internet

- Guía de seguridad y privacidad en Internet. Oficina de Seguridad del Internauta.
<https://www.osi.es/es/guia-de-privacidad-y-seguridad-en-internet>

EJERCICIOS DE AUTOEVALUACIÓN

1. Una vulnerabilidad es un tipo de:
 - a. Amenaza.
 - b. Incidente.
 - c. Riesgo.
 - d. Debilidad.

2. La persona que compromete la seguridad de un sistema informático haciendo uso de sus conocimientos técnicos, pero sin la intención de cometer daños, se llama:
 - a. Hacker.
 - b. Cracker.
 - c. Phreaker.
 - d. Carder.

3. Un ataque de denegación de servicio distribuido se caracteriza porque:
 - a. El intruso deniega el servicio distribuyendo contraseñas por la Red.
 - b. Se emplea a un conjunto de máquinas para saturar al sistema víctima.
 - c. Se distribuye el trabajo entre varios hackers.
 - d. Se aprovechan exploits para saturar al sistema objetivo desde una máquina.

4. Una diferencia entre un gusano y un virus es que...
 - a. El virus es un software malicioso y el gusano no lo es.
 - b. Son términos sinónimos, se refieren al mismo tipo de software.
 - c. El gusano se propaga automáticamente, mientras que el virus necesita intervención humana.
 - d. El gusano puede ser un troyano y el virus no.

5. La intoxicación del DNS a fin de dirigir un equipo a una web maliciosa se denomina:
 - a. Spoofing.
 - b. Phishing.
 - c. Pharming.
 - d. Rootkit.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	D
2	A
3	B
4	C
5	C

GLOSARIO

Antivirus: programa de ordenador que permite detectar y eliminar virus informáticos.

Cookie: paquete de datos enviado por un servidor web a un navegador que le visita con información sobre el uso que ha realizado dicho navegador sobre las páginas alojadas en el servidor. Esta información se almacena en el ordenador del usuario para su uso en visitas posteriores a la misma web.

Criptomoneda: Medio digital de intercambio que utiliza criptografía fuerte para constituir una divisa alternativa a las convencionales.

Firewall o Cortafuegos: Sistema de seguridad que permite controlar las comunicaciones entre redes informáticas.

Network Address Translation (NAT): Mecanismo de traducción automática entre las direcciones IP privadas de una red interna y la dirección pública del router o firewall. Esto proporciona seguridad a la red interna, ya que salvo configuración expresa del router/firewall, ningún equipo interno será directamente accesible desde el exterior.

Spam: Correo electrónico, generalmente de carácter publicitario, que se envía de forma masiva.

Uniform Resource Locator (URL): Un localizador de recursos uniforme o URL es una cadena de caracteres con la que se asigna una dirección única a cada uno de los recursos de información accesibles en Internet. Típicamente tiene cuatro partes: el protocolo, el anfitrión, el puerto y la ruta al recurso.

UA 4. Mecanismos de defensa

PRESENTACIÓN

Desarrolladas en la unidad anterior las amenazas más importantes a los sistemas de información, corresponde a esta unidad la descripción de los mecanismos de defensa ante dichas amenazas. Así, el desarrollo de la unidad se realiza de forma paralela a la anterior, planteando inicialmente las soluciones a las amenazas desde la perspectiva del usuario en un entorno doméstico y de pequeñas empresas, contemplando las medidas de seguridad más importantes en el empleo de equipos de usuario final integrados en pequeñas redes, típicamente de cable o fibra urbana, con recomendaciones específicas de empleo seguro de dispositivos móviles.

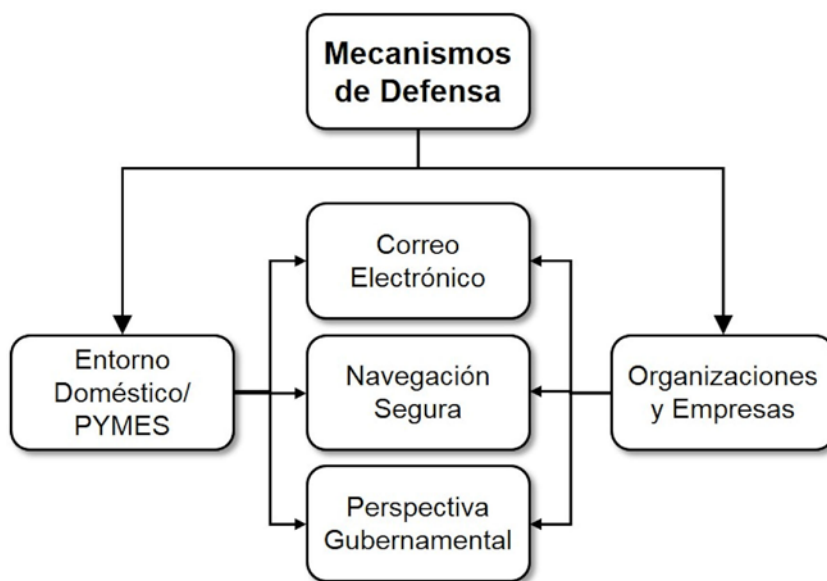
A continuación, se detallan las medidas de defensa transversales a todo tipo de usuarios con independencia del tamaño de su organización, como son las que aseguran el empleo del correo electrónico, la navegación segura por la web, el uso racional de la privacidad en redes sociales y otros sistemas de información característicos de la web 2.0.

Se continúa con la descripción de las medidas básicas de seguridad en las organizaciones y empresas de mayor tamaño, dotadas de mecanismos y políticas de seguridad activas, finalizando con aspectos de protección desde la perspectiva gubernamental, describiendo los organismos encargados de colaborar con empresas, administraciones y ciudadanos en el mantenimiento de la seguridad de la información.

OBJETIVOS

- Conocer y aplicar las medidas básicas de protección en entornos domésticos.
- Conocer y aplicar las medidas que mejoran la seguridad en el uso del correo electrónico.
- Conocer y aplicar técnicas básicas de utilización segura de teléfonos móviles.
- Conocer y aplicar técnicas básicas de navegación segura.
- Conocer y aplicar las técnicas de preservación de la privacidad en redes sociales.
- Conocer los organismos de protección desde la perspectiva gubernamental.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. DESDE LA PERSPECTIVA DOMÉSTICA

1.1. Recomendaciones básicas de empleo del sistema

De acuerdo con la secuencia de amenazas descritas en el módulo anterior, dedicaremos este apartado a enunciar una serie de recomendaciones básicas de interés general centradas en el ámbito de los ordenadores personales y extensibles a la computación móvil (que tendrá recomendaciones específicas en otro apartado), tanto para usuarios de equipos domésticos como en pequeñas empresas. A su vez, la práctica totalidad de estas recomendaciones formará parte de las políticas de seguridad de las grandes organizaciones y administraciones.

1.1.1. Protección física

La primera recomendación atañe a un principio general de la seguridad informática: todo sistema físicamente accesible es vulnerable. Todos los sistemas operativos de los ordenadores personales, equipos de comunicaciones, dispositivos móviles y cualquier sistema de proceso de información, disponen de **procedimientos de recuperación** basados en el acceso físico al mismo. En unos pocos minutos, una persona con ciertos conocimientos puede penetrar en un sistema sin conocer sus contraseñas de acceso, mediante el empleo de estos procedimientos acceder como administrador al equipo, modificar lo que estime oportuno y además, asegurar el acceso para futuras intrusiones.

1.1.2. Configuración básica del sistema y de las aplicaciones

Garantizada la seguridad en el acceso físico al sistema, corresponde garantizar la adecuada instalación del sistema operativo y la configuración de los sistemas de almacenamiento, la eliminación de todos los servicios de red que no sean imprescindibles, la instalación de las aplicaciones desde fuentes fiables, y en general todas las operaciones encaminadas a conseguir que el equipo de trabajo disponga de las herramientas adecuadas con una configuración correcta.

Aunque habitualmente estas operaciones son llevadas a cabo por profesionales o al menos, por usuarios avanzados, con ciertas capacidades de administración; es demasiado frecuente comprobar como el desconocimiento y la tendencia a evitar procesos repetitivos, suele conducir

a sistemas deficientemente configurados y con opciones de instalación *por defecto*, que pueden ser muy peligrosas.

1.1.3. Políticas de cuentas de usuario, contraseñas y copias de seguridad

Debemos asegurarnos de que los sistemas disponen de cuentas separadas de acceso para cada usuario, con los privilegios adecuados a sus necesidades, protegidas por contraseñas de longitud y complejidad adecuadas, que son modificadas cada cierto tiempo.

Igualmente, es fundamental el establecimiento de una política de copias de seguridad que preserve la disponibilidad de los datos ante cualquier eventualidad, como la avería en un soporte, el borrado accidental o cualquier tipo de ataque (malware, vandalismo, etc.). Es muy aconsejable el empleo de más de un sistema, por ejemplo, la realización de copias automáticas del sistema en otro dispositivo o en la nube y cada cierto tiempo, el volcado completo a una unidad removable, etc. En este sentido, extremar la precaución ante un ataque de criptovirus o ransomware, sabiendo que ningún sistema de copias en línea que se encuentre permanentemente accesible por un ordenador estará a salvo y las copias también se cifrarán y dejarán de estar disponibles. Es imprescindible que alguno de los sistemas de copia se encuentre normalmente offline y sólo se monte el dispositivo para realizar la copia.

1.1.4. Actualizaciones del sistema y de las aplicaciones

Una de las mayores amenazas de los sistemas actuales se debe a la existencia de vulnerabilidades o *exploits*, debidas a fallos en los programas que permiten soslayar las medidas básicas de seguridad, permitiendo todo tipo de intrusiones. Como sabemos, una vez que se corrige una vulnerabilidad por el fabricante, se hace pública la vulnerabilidad, lo que permite el desarrollo de exploits por usuarios maliciosos. Es fundamental por tanto reducir al máximo la “ventana de exposición” a dichos *exploits*.

Por tanto, es medida de seguridad básica la aplicación, si es posible de forma automática, de todas las actualizaciones de seguridad, tanto del sistema operativo como de las aplicaciones. Así, es muy peligroso el uso de software comercial sin licencia, ya que en muchas ocasiones no se tendrá acceso a este mecanismo de actualización; y peor aún el uso de sistemas operativos obsoletos cuyo ciclo de actualizaciones de seguridad haya finalizado (Windows XP, etc.)

Un claro ejemplo de la criticidad que supone este tipo de vulnerabilidades del sistema son los propios mensajes relativos a las distintas actualizaciones de seguridad de los productos de Microsoft. Una gran parte de estas actualizaciones, según indica el propio fabricante: “corrigen vulnerabilidades que permitirían a un atacante remoto tomar control de los recursos del sistema”. Poco más se puede decir al respecto.

1.2. Conexión a Internet. Fibra, Cable, ADSL y Redes Wifi

Indudablemente, el uso doméstico y de las pequeñas y medianas empresas de Internet ha sufrido una auténtica revolución gracias a la implantación, por parte de diferentes operadores de comunicaciones, de los denominados sistemas domésticos de banda ancha. Con independencia del operador escogido y la tecnología empleada, una vez instalado el equipo de conexión (*router*) se dispondrá de una red local doméstica (sobre tecnología Ethernet, Wifi o ambas) con direcciones IP privadas, que se conecta a Internet a través de un router con capacidades de firewall o cortafuegos.

El hecho de que el router sea el único elemento que dispone de una dirección IP pública, asignando direcciones privadas a los equipos domésticos, es un avance importantísimo en cuestiones de seguridad. Gracias a esto, los equipos internos podrán acceder a Internet con total libertad y comunicarse con cualquier protocolo, siempre que sean ellos los que originan la conexión, mientras que el router filtrará todos los intentos de conexión entrantes.

1.2.1. Recomendaciones de configuración de un router

No es objeto de este capítulo formar al lector en los conceptos necesarios para configurar todas las opciones de un router típico y, en la mayoría de las ocasiones, esta configuración es llevada a cabo por el personal del proveedor de servicios de Internet, después de consultar con el responsable de la instalación. No obstante, en la siguiente tabla resumimos una serie de recomendaciones en relación con la configuración de un router de fibra, cable o ADSL indicando el nivel de seguridad que proporcionan y que se describen a continuación.

Tabla 4.1. Configuración de un router doméstico o de Pyme

Nivel de Seguridad	Medidas a adoptar
Básico	Cambiar la contraseña de acceso e impedir su configuración desde Internet
Básico	Asegurarnos de que el router bloquea las conexiones entrantes (asigna IPs privadas a equipos internos)
Básico	Evitar el empleo de “DMZ” o “default workstation”
Medio	Configurar puertos entrantes (si es necesario)

Cambiar la contraseña de acceso e impedir su configuración desde Internet

Habitualmente, el personal de instalación nos proporcionará una contraseña para que podamos acceder al router. Es buena práctica cambiarla, de forma que evitemos que desde el operador de comunicaciones puedan acceder a nuestro router sin nuestro conocimiento. Además, es muy conveniente configurar el router para que no ofrezca ninguna posibilidad de acceso y configuración desde Internet. Por supuesto, si el equipo nos lo entregan con las contraseñas por defecto, es importantísimo cambiarlas.

Bloqueo de conexiones entrantes. Empleo de direcciones IP privadas y NAT

Como hemos dicho, la configuración estándar de un router doméstico es en modo cortafuegos o *firewall* con traslación de direcciones (*Network Address Translation* o NAT). De esta forma se consigue evitar que ningún intruso acceda a nuestra red, ya que el router tendrá cerrados todos los puertos, y sólo permitirá el flujo de datos habitual de Internet (en ambas direcciones) a las conexiones creadas desde el interior.

Hay dos formas básicas de comprobar esta característica: comprobando que está activa la opción NAT en la configuración del router o verificando que los equipos internos, una vez conectados al router, tienen direcciones privadas en alguno de los tres rangos asignados oficialmente: **192.168.X.X**, **172.26.X.X** o **10.X.X.X**; siendo X cualquier valor numérico.

Evitar el empleo de “DMZ” o “default workstation”

Especialmente peligrosa es la opción que tienen los routers de configurar lo que unos denominan “*default workstation*” y otros DMZ. En cualquier caso, se trata de que el router se comporte de forma transparente y que entregue todos los intentos de conexión a una determinada máquina de la red interna, en cualquier de sus puertos. Esto es peligrosísimo ya que dicha máquina dejará de estar protegida por el filtrado de conexiones entrantes.

Configurar puertos entrantes (si es necesario)

En caso de que se necesite que alguna máquina interna reciba conexiones directas desde el exterior, debe hacerse puerto a puerto y evitar la asignación completa indicada en el apartado anterior. Todos los routers tienen una opción de configuración a este efecto, y típicamente consiste en asignar uno a uno qué puerto de la dirección pública del router se asignará a qué puerto en qué dirección privada.

1.2.2. Configuración básica de una Wifi doméstica o de Pyme

Usualmente, el router dispondrá de red inalámbrica o Wifi. Al igual que en el caso anterior, se deben tomar ciertas medidas para reducir los riesgos de un incidente de seguridad; como puede ser que personas ajenas accedan a información privada, que utilicen dicha red con fines maliciosos (con las consideraciones legales que esto puede suponer) o simplemente que usuarios no autorizados consuman ancho de banda.

Como sabemos, los routers Wifi actuales ofrecen medidas que permiten disponer de un nivel de seguridad más que aceptable, si se configuran y utilizan correctamente los medios de protección disponibles. En la tabla 4.2 se resumen las medidas de acuerdo al nivel de seguridad que proporcionan, y que se describen a continuación.

Tabla 4.2. Configuración de la Wifi en un router doméstico o de Pyme

Nivel de seguridad	Medidas a adoptar
Básico	Configurar protocolo de seguridad WPA, WPA2 o WPA3 con contraseña propia
Básico	Desactivación del protocolo WPS (Wifi Protected Setup)
Medio	Ocultar el identificador de la red (SSID)
Medio	Utilizar la lista de control de acceso (ACL) por MAC
Medio	Desactivación del DHCP en el Router y utilización de IP estáticas
Avanzado	Empleo de protocolos de autenticación 802.1x

Configurar protocolo de seguridad WPA, WPA2 o WPA3 con contraseña propia

Como sabemos, una red Wifi puede funcionar sin cifrado en las conexiones, opción extremadamente peligrosa; utilizar el protocolo WEP, con vulnerabilidades que lo hacen totalmente inseguro hoy en día; o bien emplear alguna de las versiones del protocolo WPA. La opción escogida será la más avanzada que tenga el router, siempre que todos los clientes la contemplen también. Tanto o más importante es el empleo de una contraseña segura, diferente de la proporcionada por el instalador.

Desactivación del protocolo WPS (Wifi Protected Setup)

El protocolo WPS (Wifi Protected Setup) es una opción asociada a los protocolos WPA que permiten la negociación directa de la contraseña de protección de la Wifi entre un cliente y el router, de forma que pulsando un botón en el router se activa la negociación de este protocolo y durante un tiempo, cualquier cliente que tenga activo el cliente WPS obtendrá la contraseña de la Wifi. Está afectado por diferentes problemas de seguridad y por tanto, se considera imprescindible comprobar que el WPS esté totalmente desactivado.

Ocultar el identificador de la red (SSID).

Cuando un equipo intenta conectarse a una red, le aparecerán todas las que se encuentran a su alrededor, siempre que tengan habilitada la opción de “mostrar SSID” en los respectivos repetidores. Si se puede realizar, por el reducido número de usuarios en la red doméstica o de la organización, es bueno configurar la opción de “no mostrar SSID”. De esta manera, será necesario introducir a mano el nombre de la red antes de proceder a la conexión, y en primera instancia, la red Wifi no sea visible. Si bien esto no evita un posible ataque, en entornos domésticos, con multitud de redes Wifi en todo un edificio, ocultar el SSID constituye una buena medida, ya que cualquier *hacker* de Wifi buscará redes *débiles* y escogerá alguna de las visibles antes que las ocultas.

Utilizar la lista de control de acceso (ACL) por MAC

La lista de control de acceso, consiste en crear una lista con las direcciones MAC de los dispositivos que se desea que tengan acceso a la red. La dirección MAC es un identificador único de los dispositivos de red de cada equipo. De esta forma, cuando se solicita la conexión, si la dirección MAC está en la lista, se podrá acceder a la red, en caso contrario el router bloqueará dicha conexión.

Habitualmente, los routers Wifi que implementan esta característica disponen de una opción que activa y desactiva el bloqueo de MACs, con otra opción adicional que añade automáticamente las MAC de los equipos conectados en ese momento a la lista de MAC permitidas. Por tanto, el proceso para añadir un equipo en la red Wifi conlleva cuatro pasos:

1. Desactivar el control de acceso.
2. Conectar el nuevo equipo.
3. Pulsar la opción de añadir las MACs conectadas a la lista.
4. Activar el control de acceso.

Aunque no es infalible, ya que un *hacker* podrá usurpar la dirección física de algún equipo autorizado, el nivel de seguridad que proporciona en muchas ocasiones justifica la molestia de realizar los pasos indicados cada vez que se quiera incorporar un nuevo equipo a la red.

Desactivación del DHCP en el Router y utilización de IP estáticas

Para dificultar la conexión de terceros a la red se puede desactivar la asignación de IP dinámica por parte del router a los distintos dispositivos inalámbricos.

Cuando un equipo trata de conectarse a una red, ha de tener una dirección IP que pertenezca al rango de IPs de la red a la que queremos entrar. Habitualmente, el router Wifi se encarga de proporcionar una dirección IP adecuada, siempre y cuando el dispositivo esté configurado para obtenerla en modo dinámico mediante el protocolo DHCP (*Dynamic Host Configuration Protocol*). Al deshabilitar el DHCP en el router, cuando un nuevo dispositivo solicite una dirección IP, el router no se la proporcionará, por lo tanto, cualquier usuario malicioso que desee conectarse, deberá indicar una dirección IP, una máscara de subred y una dirección de la pasarela o *gateway* (dirección del Router) válidas. La combinación de este método con el empleo de una red interna con direcciones privadas poco habituales, ofrece un nivel más de seguridad ante intrusiones y en ocasiones, justifica el trabajo adicional que requiere.

Medidas avanzadas - Empleo de protocolos de autenticación 802.1X

La autenticación de usuarios es frecuentemente utilizada en entornos corporativos, donde la plantilla de personal es amplia, cambia con poca frecuencia y se desea el máximo nivel de seguridad en la red Wifi. El protocolo de autenticación más utilizado es el denominado 802.1x. Resulta complejo de implantar, pero es muy seguro. Su funcionamiento se basa en el intercambio de información entre el router y los clientes con autenticación a través de un servidor *Radius* y permite la incorporación de certificados digitales, lo que hace la negociación de la clave de cifrado de la comunicación lo más segura posible. No se contempla la incorporación de esta medida de seguridad en entornos domésticos o de Pymes.

1.3. Protección contra el malware. Suites de seguridad

Una estrategia básica para protegernos contra el malware es el uso de programas antivirus. Tal y como hemos comentado, un código malicioso nos puede llegar de múltiples formas: correo electrónico, navegando por la red, etc. Este tipo de software llamado originalmente antivirus, recibe hoy en día un nombre más general debido a que su funcionalidad es mayor que los

programas antivirus originales, teniendo incorporados herramientas de control de conexiones (cortafuegos o *firewall*), filtros antispam, filtros de contenido web, etc.; convirtiéndose en auténticas *suítes de seguridad*.

Las funciones de un firewall o cortafuegos de software son similares a los de sus equivalentes en hardware ya descritos. Impiden el tráfico entrante y saliente que no cumpla unos criterios previamente establecidos, aunque su funcionalidad suele ser más limitada, y están sometidos a una debilidad evidente: si el sistema llegase a estar comprometido, igualmente lo estará el componente software que constituye el firewall.

El funcionamiento de los componentes *antimalware* (que se siguen denominando antivirus por comodidad) puede ser **basado en firmas o heurístico**. En los sistemas basados en firmas, estos programas disponen de unos ficheros de configuración donde se almacenan una serie de patrones que sirven para identificar diferentes tipos de malware. El programa analiza cada uno de los correos entrantes en el sistema, ficheros que se copian al disco duro, que se descargan a través del navegador, etc., y busca dentro de ellos dichos patrones. Si el fichero o correo bajo análisis tiene alguno de los patrones, se activa el mecanismo de aviso. Dependiendo de la configuración predeterminada o de la elección del usuario, el fichero sospechoso será puesto en un directorio de cuarentena, será desinfectado (si es posible) o será eliminado. Por esta razón es muy importante que los ficheros de datos del antivirus estén permanentemente actualizados. En el caso del funcionamiento heurístico, el software identifica patrones de comportamiento del malware que conoce, y actúa de manera similar. Usualmente, los sistemas modernos utilizan una combinación de estas dos técnicas.

En general, los antivirus modernos se actualizan automáticamente a través de Internet. En cualquier caso y aunque tengamos antivirus, no debemos olvidar que en muchas ocasiones algunos virus nuevos no son detectados. Exactamente lo mismo pasa en medicina, la vacuna se obtiene después de conocido el virus.

Pese a la creencia general de que los buenos antivirus son productos comerciales y de precio relativamente elevado, la realidad es que se pueden encontrar **productos totalmente gratuitos con prestaciones muy elevadas**, y varios fabricantes de productos comerciales, incluyen licencia gratuita para su empleo doméstico. Por último, cada vez más sistemas operativos (Microsoft y varias distribuciones de Linux y de Android, por ejemplo) incorporan antivirus de buena calidad desde su instalación.

En este sentido, la configuración recomendada será la instalación y activación permanente de una buena suite de seguridad, bien la original del sistema (en su caso), bien gratuita o de pago, y la revisión periódica del sistema con otro producto ligero y sin coste adicional.

1.4. Recomendaciones en el empleo de dispositivos móviles

Se presentan a continuación una serie de recomendaciones específicas en el empleo de dispositivos móviles, Tablets y similares, que deben ser entendidas como adicionales al resto de recomendaciones genéricas de esta unidad, ya que cada vez más, los equipos móviles complementan e incluso, llegan a sustituir a los ordenadores personales, en el desarrollo de la actividad personal, profesional y corporativa de los ciudadanos utilizando las TIs.

Copias de seguridad

Se hace necesaria una política de copias de seguridad, tanto de la información del componente de teléfono móvil (contactos, agenda, tareas, correos, SMS, etc.) como de las posibles tarjetas de memoria extraíbles o internas al dispositivo, en las que se almacenan los restantes documentos.

Para esto, cada fabricante ofrece módulos de software que, instalados en un ordenador, permiten no sólo hacer copia de seguridad de estos datos sino también sincronizar la información entre el ordenador y el dispositivo móvil. Más extendido aún está el empleo de sistemas que permiten realizar copias en *la nube* (*Google Drive* en sistemas Android, *Apple Cloud* en dispositivos IOS, etc.).

Protección de la información almacenada

En los últimos tiempos, es frecuente la aparición de noticias en relación con la pérdida o la sustracción maliciosa de información sensible almacenada en dispositivos móviles. Tan sólo en los aeropuertos de todo el mundo, desaparecen diariamente centenares de equipos de altas prestaciones, que pueden contener desde fotos y vídeos de carácter privado, hasta información comercial estratégica, datos personales muy protegidos por ley, etc.

Para evitar este tipo de inconvenientes, la mejor solución consiste, además del establecimiento de contraseñas o PINs seguros, en el **cifrado de los sistemas de almacenamiento** del dispositivo. Tanto Android como IOS disponen de opciones para cifrar todos los sistemas de almacenamiento, tanto la unidad propia del sistema como otras particiones.

Recomendaciones relativas al protocolo Bluetooth

Se trata posiblemente de uno de los protocolos más controvertidos por los problemas de seguridad asociados a su empleo.

Además de las pautas básicas de uso (restringir su activación al tiempo en que resulta imprescindible, solicitar autorización para la conexión de nuevos dispositivos, o evitar su uso en espacios de gran concentración de personas), se pueden aprovechar algunas características intrínsecas a los sistemas *Bluetooth*. Una de las más útiles es ocultar la identidad de nuestro dispositivo al entorno que nos rodea. Otro principio básico es no utilizar el código por defecto para emparejar dispositivos, ya que son ampliamente conocidos y permitirían acceder a nuestra información de forma muy sencilla.

Protección contra el malware

El malware, especialmente en forma de troyanos, ya no está limitado a los PCs y servidores. Los *markets* de proveedores de software para dispositivos móviles más importantes, como *Apple Store* o *Android Play Store*, a pesar de sus esfuerzos por evitarlo, ofrecen multitud de productos (*Apps* para móviles) infectados con malware de todo tipo, desde *adware* en versiones gratuitas de muchas aplicaciones, hasta sofisticados sistemas de control y vigilancia remotos basados en *rootkits*.

Más peligroso aún es instalar *Apps* procedentes de otras fuentes que no son las oficiales del fabricante. Los sistemas operativos (Android, IOS) más importantes permiten controlar esta posibilidad y la tienen desactivada por defecto. Salvo que se necesite instalar algún producto del que se pueda garantizar la autenticidad y fiabilidad y haciéndolo siempre de forma puntual y controlada, esta opción de permitir otras fuentes debe estar siempre desactivada.

El uso creciente de estas *Apps* frente a las aplicaciones estándar en PCs, hace que cada vez más, la información almacenada en dispositivos móviles sea un activo muy valioso para cualquier organización, por lo que la utilización de software antivirus, propio del fabricante o específico, resulta imprescindible en todo *smartphone*. Especial atención habrá que prestar a las *Apps* que recopilan información relativa a la salud y a los dispositivos, como relojes inteligentes, que capturan información biométrica. El mal uso del Big Data que puede recopilar los fabricantes de estas *Apps* podría ser muy perjudicial para el usuario, si llegase a caer en manos de compañías aseguradoras, solo por poner un ejemplo.

Permisos de las aplicaciones

Uno de los problemas más importantes en relación con la seguridad en dispositivos móviles es la captura de información, generalmente con fines comerciales, que realizan muchas de las aplicaciones que se instalan o que están preinstaladas. Un ejemplo que ilustra este concepto es el de la aplicación de “linterna” en el móvil que, al instalarse, solicita permiso para acceder a los contactos del usuario. Evidentemente, una aplicación que se limita a encender la luz de flash no necesita ese acceso para cumplir su función.

Es muy importante efectuar una revisión de los permisos que tienen las aplicaciones instaladas y en su caso, denegar los que no sean necesarios o se consideren peligrosos. No olvidemos que cualquier equipo móvil tiene micrófono, cámara de fotos y video, localizador GPS y multitud de sensores que podrán ser activados por cualquier aplicación que tenga permisos para ello.

2. SEGURIDAD EN EL USO DEL CORREO ELECTRÓNICO

2.1. Recomendaciones generales

Utilización de varias cuentas de correo

Es recomendable utilizar más de una cuenta de correo. Muchas guías de seguridad aconsejan un mínimo de tres. Una para el trabajo (corporativa), otra de carácter personal y una tercera (con datos personales *inexactos*) para cuando nos soliciten una cuenta de correo en cualquier subscripción, registro en comercio electrónico o no, boletines, concursos, etc.

Consultar periódicamente la cuentas

Los correos que se reciben en una cuenta de correo serán almacenados por el servidor en el buzón hasta que se elimine ese mensaje o lo descargue localmente en su ordenador a través de su cliente de correo.

La mayoría de los proveedores de correo electrónico limitan el tamaño máximo del buzón. Esto significa que, si un buzón supera este límite, el servidor de correo, ante la imposibilidad de almacenar el mensaje, lo devolverá al remitente indicándole este inconveniente. Por lo tanto, la principal tarea a la hora de gestionar una cuenta de correo electrónico es descargar o eliminar el correo con una periodicidad frecuente, con el fin de evitar que el buzón se llene.

Configuración del Spam o correo no deseado

En relación con los correos no deseados (spam), los sistemas anti-spam suelen emplear alguna o una combinación de las siguientes técnicas:

- **“Listas Negras”:** consiste en tener un listado de las direcciones de correo falsas y de los servidores que generalmente envían este tipo de correo.
- **“Listas Blancas”:** en este caso se hace justo lo contrario que en el caso anterior; mantener un listado de direcciones y/o servidores de confianza.
- **Empleo de filtros** que analizan el asunto y el contenido de los mensajes de forma que a través de una serie de palabras clave son capaces de etiquetar un correo como spam con una cierta probabilidad.

La actuación cuando un mensaje es etiquetado como spam suele ser configurable, desde sistemas muy restrictivos que eliminan directamente los mensajes identificados como no deseados, hasta sistemas más flexibles que permiten etiquetarlos como spam e incluso almacenarlos en carpetas concretas de forma que sea el usuario el que toma la decisión final sobre la acción que realizará. Además, estos sistemas suelen realimentarse de las decisiones

tomadas por el usuario, de forma que pueden tener con el tiempo una mayor tasa de éxito al clasificar un correo como spam. Hay que tomar en cuenta que la clasificación de un correo como spam y por tanto su posible borrado, puede suponer la pérdida de un correo legítimo.

Por último, estos sistemas anti-spam pueden instalarse en los servidores de correo o en los sistemas finales de los usuarios o en ambos sitios. Una elección mixta suele ser una buena alternativa ya que se establece un filtro anti-spam en el servidor “básico” y ágil cuya función sería eliminar los correos que son claramente spam y dejar un sistema anti-spam que computacionalmente podría ser más costoso y personalizable en los computadores de los usuarios finales. En cualquier caso, para que se pueda disponer de las ventajas de un sistema anti-spam local, es necesario el empleo de un agente local de gestión de correo electrónico, como el Mozilla Thunderbird, el Outlook de Microsoft, el Apple Mail, etc.

Utilización de correo electrónico seguro (PGP o S/MIME)

El empleo de certificados digitales (S/MIME) o de PGP en el correo electrónico permite disponer de autenticación, integridad y no repudio (mediante firma digital) y confidencialidad (mediante el envío de mensajes cifrados). La utilización de este tipo de sistemas compensa con creces la dificultad de su puesta en marcha y configuración.

2.2. Recomendaciones específicas para la recepción

A continuación se detallan las normas básicas que debemos tener en cuenta en lo relativo a los correos electrónicos recibidos:

1. No abrir correos si no conocemos al remitente, si sospechamos que puede ser spam o puede contener malware. Y mucho menos contestar con información personal, si desconocemos a quién nos dirigimos.
2. No aceptar documentos ni archivos adjuntos provenientes de direcciones desconocidas o que contengan un asunto u origen poco fiable.
3. No asumir que un mensaje es válido porque el nombre del remitente es conocido. Los spammers falsean las direcciones de origen, escogiéndolas de la misma lista de víctimas que recibirán sus mensajes, así que podemos recibir spam incluso de nuestra propia dirección, sin que ello signifique necesariamente que estamos infectados.
4. Utilizar filtros anti-Spam. Aunque la mayoría de los proveedores de correo ya proporcionan este servicio, e incluyen opciones de control más avanzado.
5. No leer los correos de spam y muy especialmente, jamás se deben abrir sus ficheros adjuntos, por muy atractivo que parezca el contenido. Estos mensajes deben eliminarse sin ser leídos para evitar el aumento de la cantidad de correo basura en el buzón y sobre todo, para evitar la posibilidad de intrusión de virus en el sistema.
6. Analizar con antivirus cualquier documento adjunto antes de abrirlo directamente. Es mucho más seguro extraer previamente el adjunto a un directorio del ordenador y analizarlo con un buen antivirus.
7. No confiar en regalos y promociones de fácil obtención. En ocasiones la infección del equipo se puede producir tan sólo al visitar una página web facilitada en un correo aparentemente inofensivo.
8. Desconfiar especialmente de cualquier correo que incluya un enlace y nos pida que accedamos a dicho enlace e introduzcamos nuestras credenciales. Ninguna organización seria hará eso y con toda seguridad será un intento de *phishing*.

Es muy conveniente disminuir el tamaño de los mensajes con ficheros adjuntos utilizando herramientas de compresión de los archivos (*.rar, *.zip, etc.). Además, muchas estafetas de

correo rechazarán directamente mensajes con archivos ejecutables o documentos ofimáticos susceptibles de contener malware.

2.3. Recomendaciones específicas para el envío

1. Incluir un "Asunto" lo más descriptivo posible del contenido del mensaje. Esto facilita la lectura, clasificación y posterior recuperación del correo al destinatario y constituye una norma de cortesía hacia el destinatario.
2. Tengamos en cuenta que el uso de mayúsculas en Internet sugiere emociones fuertes. Evitemos emplear mayúsculas en el cuerpo de texto de sus correos, pues implica GRITAR. En la medida de lo posible, se debe hacer uso de elementos de formato como negrita, uso de colores o subrayados, etc.
3. No utilizar fondos prediseñados o con colores para los mensajes, ya que aumentan el tamaño del mismo y pueden provocar problemas de recepción en el destinatario (es más probable que sean filtrados por algún sistema antivirus o antisпам)
4. Jamás, bajo ningún concepto, se facilitarán datos personales o financieros a personas desconocidas, por muy fiable que parezca su mensaje.
5. No responder a correos no solicitados (spam), incluso aunque estemos interesados en el producto o servicio, ya que tan sólo aumentaremos la cantidad de correo basura recibido, y “aumentará el valor” de nuestra dirección para otros spammers, ya que le hemos indicado al remitente que la cuenta es leída por una persona.
6. No se debe participar en el reenvío de mensajes piramidales y de bulos (cadenas de mensajes, niños enfermos que necesitan ayuda, rumores, publicidad, etc.). Esta recomendación afecta por igual a los sistemas de mensajería privada, como *Whatsapp*, *Telegram*, mensajería en redes sociales, etc.
7. No es bueno activar funcionalidades como el "aviso de lectura", su eficacia es escasa y cuando se utiliza de manera indiscriminada o continuada, llegará a molestar al remitente y provocará el efecto contrario. Se debe activar sólo en los casos en los que sea estrictamente necesario.

3. NAVEGACIÓN SEGURA

3.1. Recomendaciones relativas a la web y el comercio electrónico

Actualización del navegador a los últimos parches de seguridad

Es quizás la recomendación más importante. Como ya se ha indicado, en la actualidad el navegador es la pieza más importante de nuestro equipo, nuestra conexión con el *exterior* y habitualmente la principal fuente de fallos de seguridad que son utilizados por los atacantes externos. De hecho, no sólo son un punto de entrada en los ordenadores personales, sino también en todo tipo de dispositivos móviles y *Tablets*, donde la navegación y la ejecución de Apps son frecuentemente lo más utilizado en el dispositivo.

Evitar la utilización de enlaces de origen no conocido y fiable

Al igual que en el caso del correo electrónico, un sitio web malicioso puede estar detrás de cada enlace ofrecido por páginas web de dudosa solvencia. Esta recomendación es especialmente crítica cuando se accede a sitios web que ofrecen oportunidades de cualquier tipo, bien de descargas de software gratis, de versiones *crackeadas* de software comercial, y como ya se ha indicado, es especialmente peligrosa en noticias publicadas en redes sociales.

En cualquier caso, al menor síntoma de que la página visitada está preparada para hacernos creer lo que realmente no es (textos incorrectamente escritos o a medio traducir, organismos que parecen oficiales pero que emplean estética dudosa, etc.) es muy recomendable cerrar la pestaña de navegación con la mayor celeridad posible.

Descargar software del desarrollador o de fuentes fiables

Cuando se descarga software desde Internet para instalarlo en el equipo local, estamos *abriendo la puerta* a todo tipo de malware. En este sentido, es de máxima importancia hacerlo directamente desde el servidor web del desarrollador, evitando sitios web que no sean de confianza.

Esta recomendación tiene mucha relación con la anterior, ya que es muy común, cuando se conoce la existencia de un determinado software, acceder a Google y teclear “descargar dicho software”. Evidentemente, muchos hackers habrán previsto esa eventualidad y estarán dispuestos a facilitarnos una copia de dicho software, acompañada de un troyano que, una vez en nuestro equipo, les proporcionará algún beneficio económico.

Evitar el uso de “recordar contraseñas”

Salvo en ordenadores estrictamente en poder de un sólo usuario, se debe evitar la opción de “recordar contraseñas”. Estas contraseñas son almacenadas de forma poco segura en el navegador. Por tanto, jamás se debe activar esta opción en ordenadores de uso compartido, aunque sea con personas conocidas y de confianza. Incluso en el caso de que el equipo sea utilizado por un único usuario, muchas piezas de malware recopilan y envían esta información a sus creadores.

Control de las “cookies”

Una *cookie* es un fragmento de información que se almacena en el disco duro del visitante de una página web a través de su navegador, a petición del servidor de la página. Esta información puede ser luego recuperada por el servidor en posteriores visitas. En ella se suele guardar información como el nombre de usuario y contraseña, lugares visitados, etc... También todos los navegadores permiten que el usuario pueda desactivar las cookies, aunque esto puede provocar que los servicios proporcionados por determinados servidores no funcionen. En cualquier caso, es conveniente si se permite el uso de cookies, que estas sean eliminadas al terminar la sesión con el servidor, o bien periódicamente. Todos estos aspectos pueden ser personalizados en las opciones de configuración del navegador. Todos los navegadores presentan, en sus opciones de configuración, una pestaña “Privacidad” o equivalente, con un apartado para cambiar parámetros sobre la configuración de las cookies.

Navegación segura. Comprobación de certificados digitales de servidor

La práctica totalidad de sitios web de empresas y organismos oficiales, y muy especialmente todos los orientados al manejo de información sensible, hacen uso de conexiones web seguras según el protocolo TLS ya descrito.

Por su parte, todos los navegadores actuales permiten comprobar que el servidor posee un certificado digital, así se puede verificar que el URL empieza por “https:” y acceder a toda la información relativa al certificado. En definitiva, se puede comprobar que el servidor al que nos conectamos es quien dice ser.

No enviar datos sensibles en conexiones web inseguras (no cifradas)

Como consecuencia de lo anterior, se debe evitar la introducción de datos sensibles, nombres de usuario, contraseñas, números de tarjetas de crédito, etc., en sitios web que no ofrezcan

conexiones seguras, ya que dicha información viajará por la red en forma de texto claro y podrá ser interceptada por terceros.

Hacer uso de la autenticación de dos factores siempre que sea posible

La práctica totalidad de los sitios web bancarios, de pago por internet, de intercambio de criptomonedas, y cada vez más los dedicados al comercio electrónico en general, ofrecen la posibilidad de incorporar un elemento más de seguridad al empleo del usuario y contraseña.

Por ejemplo, muchos bancos permiten el acceso mediante certificado digital o DNI electrónico. Otros sitios web emplean Apps para móviles para que el usuario obtenga un “ticket” o contraseña de un solo uso que deberá introducirse además de las credenciales habituales, o bien se le envía dicho *ticket* como SMS a su teléfono móvil, etc.

La autenticación mediante dos factores debe ser considerada **imprescindible** siempre que desde la cuenta de acceso se puedan realizar operaciones directas de **transferencia de fondos** y muy aconsejable en cualquier otro caso.

Evitación de código tóxico y control de pestañas en los navegadores

En el capítulo anterior se explicaron técnicas como el Cross-Site Scripting o XSS encaminadas a la captura de información mediante enlaces en los que se inserta código que será ejecutado en el servidor de acceso. La regla general es que de la misma forma que no debemos abrir correos electrónicos (y mucho menos los ficheros adjuntos) de origen no fiable, no deberíamos acceder a enlaces proporcionados por usuarios desconocidos a través de entornos como las plataformas de red social. Muy especialmente, se debe tener en cuenta que entre dos pestañas de un mismo navegador, la separación a efectos de seguridad es relativa. Dicho de otra forma, no se debe tener una red social en una pestaña y nuestra cuenta bancaria en otra. Es mucho más probable que un enlace tóxico en la primera pueda llevar a un robo de credenciales o a la captura de la segunda conexión.

3.2. Uso racional de la privacidad en redes sociales

Además de las medidas básicas de seguridad aplicables a su condición de sitios web altamente utilizados por todo tipo de usuarios, en el que el empleo de técnicas de web hacking, phishing y similares está muy extendido, las plataformas de red social presentan una serie de amenazas a la privacidad que fueron discutidas en el anterior capítulo.

Presentaremos a continuación una serie de recomendaciones encaminadas a facilitar un uso adecuado y racional de las redes sociales.

Política de uso y privacidad

Las redes incorporan una política de uso y privacidad que es fundamental conocer. Ésta se encuentra generalmente disponible a través de la página web de la red social, en un apartado con una denominación similar. Es muy importante conocer esta política, puesto que describe los usos y responsabilidades que tiene la empresa que gestiona la red social sobre la información publicada.

Nivel de privacidad

Cuando creamos una cuenta en una red social, el primer paso que debemos realizar, después de haber leído la política de privacidad, es configurar el nivel de privacidad. Éste permite controlar quién ve la información que publicamos en la red social. Configurar el nivel de privacidad es especialmente importante en el caso de los buscadores. Es decir, cuando publicamos información en una red social es posible que sea visible, no sólo para las personas

que pertenecen a esa red social, sino que incluso el contenido que publica el usuario puede ser indexado y utilizado por los buscadores de Internet que están fuera de la red social.

De esta forma, es posible buscar datos de una persona en Google y encontrar información que ha publicado en su red social. Para evitar estos y otros problemas de privacidad, lo ideal es que, al principio, sobre todo si desconocemos el funcionamiento, bloqueemos todos los permisos y, poco a poco, vayamos dando visibilidad a los contenidos que publiquemos, pero de forma controlada.

Amigos y conocidos

Uno de los mayores peligros de las redes sociales se deriva del hecho de que en una red social parece que todo el mundo puede ser amigo nuestro. Al igual que ocurre en la realidad, no es lo mismo un amigo, un conocido o un compañero de trabajo. Son conceptos completamente distintos y las implicaciones de cada uno de esos tipos de usuarios que nos podemos encontrar en una red social, también son totalmente distintas. En este sentido, es muy recomendable, establecer distintos grupos de usuarios, en los que podamos agrupar y diferenciar a nuestros amigos de otros que no lo son.

En particular, en redes de carácter generalista como Facebook, es de extrema importancia configurar el nivel de privacidad de nuestra información de forma que sea accesible a los *amigos*, pero no a los *amigos de los amigos*. La probabilidad de que bajo esta última condición se esconda alguna persona con fines maliciosos, es muy superior a cuando sólo se ha expuesto información potencialmente sensible a personas de nuestro círculo de confianza.

Información personal

La información que podemos publicar en una red social es muy variada, pero cuando se trata de datos personales, al igual que ocurre con los amigos y conocidos, es muy importante saber diferenciar. No es lo mismo publicar una fotografía tomando algo con los amigos, que una imagen con nuestra pareja o un comentario a un amigo. Por regla general, cuanto menos información personal publiquemos, mejor. No obstante, si vamos a publicarla es fundamental pensar antes qué tipo de información estamos publicando y cuáles pueden ser las consecuencias de hacerlo, sabiendo que desconocemos en qué manos puede caer.

Del mismo modo, debemos pensar que la información colocada en la red, no tiene fecha de caducidad. Una foto subida hoy, en el ámbito de una comunidad de amigos que disfrutan de una fiesta nocturna, podría ser utilizada con otros fines totalmente distintos dentro de varios años. Es sabido que hoy en día, la selección de personal en las empresas y la valoración de currículos, comienza por una búsqueda exhaustiva en las redes sociales, y que el resultado de esa búsqueda pueden ser argumentos *en contra* de la contratación.

Información de terceros

En las redes sociales es muy habitual publicar información e incluso imágenes de terceras personas, generalmente de fotos grupales. El problema de publicar información en la que aparecen terceros, que pueden ser amigos o no, es que no siempre pensamos en las consecuencias no deseadas que pueda traer. Por tanto, debemos tener en cuenta que la información que publicamos en una red social, en ocasiones, está relacionada no sólo con nosotros, sino también con muchas otras personas, con circunstancias personales y profesionales distintas a las nuestras, y, por tanto, con distinta percepción ante su exposición pública.

4. PROTEGIENDO LA ORGANIZACIÓN: DEFENSA PERIMETRAL

4.1. Frontera de contención: Firewalls

El esquema básico de seguridad informática de una organización se basa en el concepto de defensa perimetral, por analogía con la defensa física, tanto de las antiguas fortificaciones como de las modernas instalaciones. Así, la red interna de la organización se aísla del exterior mediante uno o varios dispositivos denominados cortafuegos o firewalls. Su funcionalidad es similar a la descrita en el caso de las instalaciones domésticas de ADSL, cable y fibra, aunque suele estar basado en sistemas más sofisticados de control de las comunicaciones.

Las tecnologías básicas de los firewalls modernos se encuadran en tres tipos:

1. **Filtrado de puertos** (port filtering): es el modelo más simple, opera a nivel de red, permitiendo conexiones entrantes o salientes de acuerdo a directivas preestablecidas.
2. **Pasarela a nivel de transporte** (transport level gateway): opera a nivel de las conexiones TCP, permitiendo filtrar con más precisión los flujos de información.
3. **Pasarela a nivel de aplicación** (application level gateway): opera a nivel de las comunicaciones entre cliente y servidor, pudiendo examinar el contenido del tráfico y el contexto en el que se producen.

Con independencia de la tecnología utilizada, la configuración típica de un firewall en una organización que ofrezca servicios sensibles hacia Internet se basa en el establecimiento de dos zonas claramente delimitadas en el interior de la organización: la Intranet corporativa o zona segura y la zona desmilitarizada o DMZ, como se observa en la Figura 4.1, cuyos elementos describiremos a continuación.

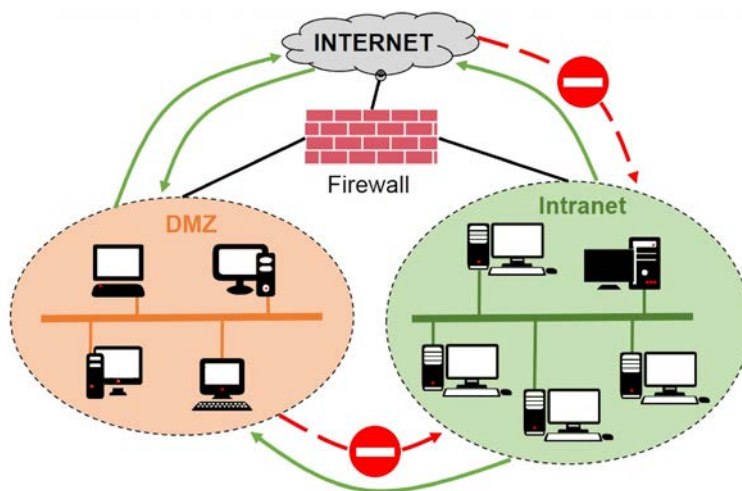


Figura 4.1. Firewall, DMZ e Intranet

4.1.1. Intranet corporativa

Constituye la zona considerada *segura* en el interior de la organización. En una misma red lógica, o en redes separadas (en virtud del tamaño y la complejidad del sistema de información organizativo), se ubicarán los diferentes equipos centrales, departamentales y de usuario final.

Todos los flujos de información entre la Intranet, el exterior (Internet) y la DMZ estarán filtrados por el firewall y en continua monitorización, a fin de evitar y detectar lo antes posible cualquier incidente de seguridad. Como medida básica, se impedirán todas las conexiones de red con inicio en Internet o la DMZ, y sólo se permitirá el flujo de paquetes *en respuesta* a

solicitudes iniciadas desde la Intranet (se establece una *membrana semipermeable*, como en los routers domésticos), que cumplan los requisitos establecidos.

Cuando las necesidades de protección de la organización son elevadas, se suele evitar e incluso prohibir el empleo de redes inalámbricas, debido a su vulnerabilidad, o en el mejor de los casos, se establecerán redes con elevados niveles de protección. En relación al uso de dispositivos de almacenamiento externo, se aplican también políticas restrictivas que permiten denegar o limitar la conexión de estos dispositivos a los equipos de usuario.

4.1.2. Zona desmilitarizada: DMZ

Se conoce con este nombre a la porción de la red interna a la organización en la que se ubican los **bastiones** o servidores que atenderán las aplicaciones accesibles desde el exterior. Se trata por tanto de una red típicamente sometida a todo tipo de ataques. El firewall deberá **impedir el acceso a cualquier servicio no explícitamente autorizado**, y los bastiones deben ser continuamente monitorizados, especialmente ante ataques con técnicas de rootkit.

De hecho, una práctica habitual consiste, pese a que se encuentran conectados a la misma red, en limitar la comunicación entre diferentes bastiones, salvo cuando sea imprescindible, en evitación de que un eventual atacante pueda invadir un equipo y tomarlo como plataforma para atacar a los restantes.

Habitualmente, los bastiones que ofrecen servicios de aplicación al exterior disponen de sus propios servidores de base de datos, que al estar accesibles desde el exterior podrán ser atacadas, por lo que estas bases de datos, siempre *bajo sospecha*, serán replicadas de forma segura desde los servidores corporativos ubicados en la Intranet.

4.2. Acceso seguro a la organización: Redes Privadas Virtuales (VPN)

Las tecnologías de red privada virtual permiten soslayar el problema que se plantea cuando una organización tiene sucursales, con necesidades de seguridad similares, accesibles a través de una red insegura como Internet, de igual forma que permiten a usuarios externos compartir los recursos sólo accesibles en la intranet corporativa.

Básicamente permiten unir varias intranets a través de Internet, o bien acceder desde Internet a los recursos de la intranet. Para conseguirlo, la estrategia consiste en que el punto de acceso a la intranet (en muchas ocasiones es el mismo Firewall que se comporta como un servidor de VPN) es capaz de encapsular, con técnicas de cifrado criptográfico, paquetes de información que circulan por la intranet para que viajen ocultos en paquetes que circulan por Internet.

De esta forma, un equipo doméstico podrá conectar a través de Internet y, después de presentar sus credenciales, ser admitido por el servidor de acceso, que a partir de ese momento le otorga una dirección privada y realizará ese proceso de encapsulado y cifrado de los paquetes con destino al equipo remoto y el proceso inverso a los paquetes que recibe desde la estación remota. A partir de ese momento, el equipo doméstico navegará, a todos los efectos, *desde dentro* de la Intranet. De igual forma, dos firewalls correspondientes a distintas sedes de una misma organización, podrán establecer un puente o túnel cifrado para el intercambio seguro de paquetes de información entre ambas Intranets.

4.3. Detección de intrusiones: IDS e IPS

Además de la seguridad proporcionada por la defensa perimetral establecida por el firewall, se hace necesario un control exhaustivo del tráfico interno a fin de detectar los ataques más peligrosos, que son precisamente aquellos que pretenden pasar inadvertidos. Igualmente, los servidores de la organización generarán *logs* de eventos en los que se registran todas sus actividades. Así, cuando un usuario accede a un servidor, se generará una entrada en el fichero de *log* correspondiente.

Se conoce como correlación de eventos a la actividad, típicamente realizada por programas automáticos, que recogen los *logs* de todos los servidores y del mismo firewall y los correlacionan, a partir de sus registros de tiempo, de forma que permitan seguir la traza de cualquier actividad sospechosa.

Por su parte, los sistemas de detección de intrusiones o IDS (*Intrusion Detection Systems*) son programas que, mediante una monitorización detallada de las actividades en el perímetro y en el interior de la red corporativa, son capaces de identificar patrones de tráfico sospechosos que indican bien un intento de ataque o bien el tráfico generado por el ataque.

Los sistemas más avanzados combinan ambas capacidades para realizar una correlación continua de todos los eventos y mediante el empleo de técnicas de inteligencia artificial, son capaces de combinar el análisis de la correlación con los patrones de tráfico sospechosos, aumentando las posibilidades de detección temprana de los ataques y disminuyendo los falsos positivos que podría generar alguno de estos subsistemas.

A su vez, los sistemas de prevención de intrusiones o IPS (*Intrusion Prevention Systems*) monitorizan el tráfico de red y correlacionan las actividades en un sistema, no sólo para detectar intrusiones, sino para evitarlas y prevenir que se repitan. Para ello, combinan funcionalidades de IDS (detección) con las de firewall (bloqueo y protección). Pueden ser autónomos o extensiones de IDS que configuran en tiempo real el Firewall organizativo.

4.4. Hacking ético, análisis de seguridad y pruebas de penetración

Es sabido que la única forma de garantizar que un sistema es seguro ante ataques es la realización controlada de intentos de ataque, y se comentó en la anterior unidad la evolución, natural o forzada, de hackers maliciosos hacia hackers “buenos” o samuráis. El hacking ético es el empleo controlado de técnicas de hacking para evaluar las vulnerabilidades de un sistema de información, en lo que se conoce como **análisis de seguridad de un sistema**.

Cada vez más organizaciones emplean estas técnicas para analizar la seguridad de sus sistemas de información. Así un buen análisis de seguridad conllevará las mismas etapas que se indicaron anteriormente: recopilación de información, identificación de vulnerabilidades y ataque o explotación controlada de las mismas, de cara a conseguir no el robo o la destrucción de información, sino a lo contrario, es decir, a subsanar todas las vulnerabilidades que se identifiquen. En este caso, el analista intentará utilizar las mismas herramientas que los posibles atacantes y su metodología será casi igual, evitando siempre la destrucción o la revelación de información sensible. La realización de estos ataques tentativos y controlados se conoce como *Pentesting* o **pruebas de penetración** de los sistemas. El resultado del análisis será, por tanto, las vulnerabilidades identificadas en todas las fases del mismo.

Antes de proceder al análisis de seguridad y los *pentests* correspondientes, se firmarán los acuerdos de confidencialidad pertinentes, y se establecerá el tipo de análisis de seguridad, que típicamente responderá a una de estas tres categorías:

- **Análisis de caja negra** (Black Box): El analista de seguridad solo conoce el nombre del sistema objetivo, no se le proporciona ninguna otra información, y tendrá que descubrirla por sí mismo para llevar a cabo su tarea. Es el que más tiempo conlleva, y el que más se asemeja a la realidad.
- **Análisis de caja blanca** (White Box): Se realiza con acceso a la información interna de la organización. El analista recibe las direcciones de los sistemas, la estructura de red y los detalles necesarios. La ventaja sobre el anterior es el ahorro de tiempo.

- **Análisis de caja gris** (Grey Box): Combinación de las dos anteriores, la organización solo proporciona información básica del sistema objetivo, y lo demás habrá de ser descubierto por el analista.

La recopilación de información se suele llevar a cabo con herramientas OSINT, acrónimo de la expresión Open Source Intelligence, que hace referencia a la obtención de información de fuentes públicas, utilizando programas de fuente abierta. Además, según el tipo de análisis que se contrate, el analista podrá emplear técnicas de ingeniería social, electrónicamente o en persona, para conseguir información estratégica, lo que ayudará a solucionar más vulnerabilidades, de origen humano en este caso.

Existen multitud de aplicaciones, tanto de software libre como propietarias, de apoyo a la realización de análisis de seguridad y pentesting, verdaderos entornos de ataque semiautomático como Metasploit. Se han creado distribuciones de Linux específicas para estos objetivos, que integran las herramientas de software libre, siendo Kali Linux la más utilizada a nivel mundial.

Cuando un análisis de seguridad se lleva a cabo sobre un sistema o equipo que ya ha sido atacado y sigue en funcionamiento, se conoce con el nombre de **análisis forense**, mientras que si por causa del ataque el sistema no está operativo, se utiliza la expresión de **análisis post-mortem**, por analogía con las técnicas forenses humanas.

5. PROTECCIÓN DESDE LA PERSPECTIVA GUBERNAMENTAL

En los apartados anteriores se han visto algunas medidas para contrarrestar las principales amenazas a los sistemas de la información. Se trata de recomendaciones de ámbito personal o corporativo.

La creciente preocupación por la ciberseguridad no ha pasado desapercibida tampoco en el ámbito gubernamental, siendo actualmente una prioridad para todos los países, especialmente en el contexto de los denominados **servicios esenciales**, definidos como los necesarios para el mantenimiento de las funciones sociales básicas, la salud, la seguridad, el bienestar social y económico de los ciudadanos, o el eficaz funcionamiento de las instituciones del Estado y las Administraciones Públicas, que dependan para su provisión de redes y sistemas de información

Desde la Unión Europea se ha creado un marco organizativo común para la ciberseguridad de los estados miembros, a través de la denominada Directiva NIS (Directiva (UE) 2016/1148 relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de información en la Unión), traspuesta al derecho español a través del Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información, que se estudiarán en la unidad siguiente.

En este contexto, es necesario conocer los actores que participan en este marco organizativo, comenzando con el ámbito europeo y repasando a continuación los organismos más relevantes a nivel español.

5.1. Agencia Europea de Seguridad de las redes de la información (ENISA)

La agencia ENISA (*European Union Agency for Network and Information Security*) fue creada mediante el Reglamento 460/2004, tiene su sede en Grecia y su objetivo fundamental es el desarrollo del conocimiento en ciberseguridad y la protección del territorio de la Unión Europea.

Esta agencia trabaja en coordinación con los Estados miembros y el sector privado, ofreciendo asesoramiento y soluciones técnicas. En 2018 reforzó su papel en el ámbito de la ciberseguridad de la UE, convirtiéndose en una agencia con mandato permanente para el apoyo de las capacidades de ciberseguridad a nivel europeo.

Dentro de sus actividades destacan:

- Desarrollo de estrategias nacionales de ciberseguridad.
- Estudios sobre aspectos vinculados al desarrollo tecnológico y la ciberseguridad.
- Organización de ciberejercicios para reforzar la capacidad de respuesta de la UE ante ciberataques a gran escala.

La ENISA también tiene previsto participar en el proceso de certificación que la UE está desarrollando para reforzar la seguridad de los dispositivos, como el caso de los elementos IOT o de las infraestructuras críticas.

5.2. Mando Conjunto de Ciberdefensa

La creación del Mando Conjunto de Ciberdefensa de las Fuerzas Armadas (MCCD) ha sido el resultado de un proceso gradual que culminó el 29 de febrero de 2014 con la Orden Ministerial 10/2013 por la que se crea el Mando Conjunto de Ciberdefensa.

Se trata de un organismo militar, auxiliar del Jefe del Estado Mayor de la Defensa (JEMAD), responsable del planeamiento y ejecución de la ciberdefensa en las redes, sistemas y telecomunicaciones del Ministerio de Defensa y de contribuir a la respuesta adecuada en el ciberespacio ante amenazas o agresiones que pudiesen afectar a la Defensa Nacional.

Entre sus cometidos se encuentra:

- Garantizar la disponibilidad, integridad y confidencialidad de la información, así como la integridad y disponibilidad de las redes y sistemas que la manejan y tenga encomendados.
- Garantizar el funcionamiento de los servicios críticos de los sistemas de información y telecomunicaciones de las Fuerzas Armadas.
- Obtener, analizar y explotar la información sobre ciberataques e incidentes en las redes y sistemas de su responsabilidad.

5.3. SOCs, CERT y CSIRT

5.3.1. Security Operation Center (SOC)

Se trata de centros cuya principal función es la monitorización de la seguridad con el objetivo de proteger todo tipo de organismos (públicos o privados) de forma ininterrumpida (24x7x365). Su gestión se enfoca al ámbito técnico, especialmente sobre equipos y elementos de seguridad, como firewall, antivirus, etc.

A partir del 2018, el CCN-CERT ha incorporado dentro de sus servicios un SOC dedicado en exclusiva al ámbito de la Administración, denominado “**Centro de Operaciones de Ciberseguridad AGE**”.

La finalidad del SOC AGE es prestar servicios de ciberseguridad de carácter horizontal para optimizar la monitorización y detección de amenazas en sistemas TIC de la Administración. El ámbito de actuación es la Administración General del Estado (AGE) y los organismos públicos vinculados a la misma.

5.3.2. Centros de Respuesta ante incidentes: CERTs y CSIRTs

Los Centros de respuesta ante incidentes son organismos con capacidad técnica y estructura adecuada para la lucha contra el amplio abanico de ciberamenazas. Analizan los riesgos y gestionan los incidentes.

Habitualmente se utilizan indistintamente los términos CSIRT (*Computer Security Incident Response Team*) y CERT (*Computer Emergency Response Team*) para definirlos. El término CERT está registrado como marca comercial en EEUU, por lo que muchos centros de estas características, especialmente en América, adoptan la denominación de CSIRT.

5.3.3. CERTs y CSIRTs en España

Dentro del ámbito nacional existen diversos centros de este tipo con funciones complementarias entre sí. El Real Decreto ley 12/2018, que traspone la Directiva NIS, vincula a los CSIRT de referencia previstos como el punto de entrada de las notificaciones de incidentes, que serán derivadas a la autoridad competente. Actualmente, los CSIRTs con competencias asignadas por esta ley son:

- **CCN-CERT:** adscrito al Centro Criptológico Nacional, tiene responsabilidades en ciberataques sobre sistemas clasificados, sistemas de la Administración General, Autonómica y Local y, en coordinación con el CNPIC, sobre sistemas que gestionen infraestructuras críticas. Es el CSIRT de referencia gubernamental y de la Administración, de coordinación de todos los restantes y proporciona información sobre ciberamenazas a Presidencia de Gobierno.
- **ESP DEF CERT:** es el Centro de Respuesta ante Incidentes del Ministerio de Defensa y se encuentra en el ámbito del Mando Conjunto de Ciberdefensa. CSIRT de referencia en organismos de Defensa.
- **INCIBE-CERT:** adscrito al Ministerio de Industria, Turismo y Comercio, es el CSIRT de referencia de ciudadanos, entidades privadas y la red académica, tiene responsabilidades en la respuesta ante incidentes de seguridad en los entornos de ciudadanos y PYMES.

Y también existen diversos CSIRTs de carácter público, cuyas funciones principales son actuar como primer escalón de atención a sus ámbitos de influencia y la coordinación de incidentes con los CSIRTs de referencia:

- En Comunidades Autónomas: CESICAT (Cataluña), CSIRT-CV (Comunidad Valenciana) y BCSC (País Vasco), entre otros.
- **IRIS-CERT:** el primer CERT creado en España. Adscrito al Ministerio de Industria, Turismo y Comercio, actúa como primer escalón en la solución de incidentes de seguridad en la red académica RedIRIS, de universidades y centros de investigación.

En el ámbito privado también se han creado algunos CERT de reconocido prestigio, como son S21Sec-CERT, que proporciona servicio de gestión de incidentes especialmente al sector bancario; Telefonica-CSIRT; ITS-CERT dedicado a ciberseguridad industrial, etc.

Todos estos CERT se coordinan a través del grupo de trabajo de CERT's nacionales, denominado CSIRT.es y a través del foro ABUSES.

5.3.4. CERTs en el ámbito internacional

Ante la necesidad de colaboración entre los distintos organismos responsables de ciberseguridad, a nivel internacional existen varios foros con este objetivo, donde destacan:

- **FIRST:** Forum de equipos de seguridad y respuesta a incidentes (*Forum of Incident Response and Security Teams*) se trata de organismo internacional que relaciona los CERTs reconocidos en cada país, siendo necesario un proceso de adscripción que finaliza con una auditoría del candidato.
- **TF-CSIRT.** Es el foro de CERTs y CSIRTs europeos.

- **NCIRC:** Centro de respuesta ante incidentes de la OTAN. El CCN-CERT participa en los ejercicios de ciberdefensa organizados por NCIRC.
- **Directorio MERIDIAN.** Se trata de un directorio internacional de organismos y agencias gubernamentales con responsabilidad en la protección de infraestructuras críticas.

5.4. Centro Criptológico Nacional (CCN)

El Centro Criptológico Nacional (CCN) es el Organismo responsable de coordinar la acción de los diferentes organismos de la Administración que utilicen medios o procedimientos de cifrado, garantizar la seguridad de las Tecnologías de la Información en ese ámbito, informar sobre la adquisición coordinada del material criptológico y formar al personal de la Administración especialista en este campo.

El CCN fue creado en el año 2004, a través del Real Decreto 421/2004, adscrito al Centro Nacional de Inteligencia (CNI). De hecho, en la Ley 11/2002, de 6 de mayo, reguladora del CNI, se encomienda a dicho Centro el ejercicio de las funciones relativas a la seguridad de las Tecnologías de la Información y de protección de la información clasificada, a la vez que se confiere a su director (Secretario de Estado) la responsabilidad de dirigir el Centro Criptológico Nacional. Por ello, el CCN comparte con el CNI medios, procedimientos, normativa y recursos

Ámbito de actuación

Por sus características y en base a las funciones atribuidas a través del marco regulatorio, el CCN actúa sobre cuatro sectores:

- Sistemas de la Administración Pública.
- Seguridad y Defensa.
- Infraestructuras críticas y Sectores Estratégicos.
- Ciudadanos y PYMES.

Funciones

De entre todas las funciones atribuidas al CCN, se indican a continuación las más representativas de su capacidad de actuación y de su importante papel en la seguridad de la información en el ámbito nacional.

- Elaborar y difundir normas, instrucciones, guías y recomendaciones para garantizar la seguridad de las TIC en la administración, empresas y ciudadanos.
- Formar al personal de la administración especialista en el campo de la seguridad de las TIC.
- Constituir el organismo de certificación del Esquema Nacional de Evaluación y Certificación de aplicación a productos y sistemas de su ámbito.
- Coordinar la promoción, desarrollo, obtención, adquisición y puesta en explotación y uso de la tecnología de seguridad vinculada a productos de cifrado y sistemas TIC.

Es muy de reseñar la labor formativa que realiza el CCN y el esfuerzo en la producción de guías y recomendaciones, de interés para todos los ámbitos de actuación indicados.

5.4.1. CCN-CERT

Una de las vertientes más importantes y críticas del CCN es su capacidad de actuación como centro de respuesta ante incidentes de referencia nacional a través del ya indicado CCN-CERT.

Su objetivo principal es la gestión de incidentes y contribuir a la mejora del nivel de seguridad de los sistemas de información de las Administraciones Públicas; de las infraestructuras críticas, en coordinación con el CNPIC, y la coordinación de todos los CSIRT's nacionales.

Servicios ofrecidos por el CCN-CERT

Servicios Reactivos: se engloban aquí los relativos a:

- Gestión de incidentes (tanto sobre sistemas clasificados como no clasificados)
- Gestión de alertas y avisos.
- Gestión de vulnerabilidades.
- Análisis de código malicioso.

Servicios proactivos: enfocados a proporcionar los medios y capacidades necesarios para la adopción de medidas preventivas:

- Anuncios y avisos a los usuarios autorizados.
- Realización de auditorías y evaluaciones de seguridad sobre los sistemas clasificados.
- Configuración y mantenimiento de elementos de seguridad.
- Detección de intrusiones.
- Certificación de Calidad.

Servicios de gestión: de carácter formativo y de consultoría incluyen, entre otros:

- Análisis de riesgos.
- Consultoría de seguridad informática.
- Formación.
- Evaluación y certificación de productos.

5.5. Centro Nacional de Protección de Infraestructuras Críticas (CNPIC)

El CNPIC fue creado en 2007 a través de Acuerdo de Consejo de Ministros de 2 de noviembre y sus competencias están reguladas por la Ley 8/2011 de 28 de abril, por el que se establecen medidas para la protección de infraestructuras críticas y el Real Decreto 704/2011, de 20 de mayo, por el que se aprueba el Reglamento de protección de infraestructuras críticas.

Es el órgano responsable del impulso, coordinación y supervisión de toda la actividad relativa a Infraestructuras Críticas españolas. En este ámbito, se encarga de proteger los doce sectores estratégicos recogidos en la normativa española (Administración, Alimentación, Industria Nuclear, Industria Química, Centros de Investigación, salud, Sistema Financiero y Tributario, TIC, Transporte, Agua, Energía y Espacio).

Entre sus principales objetivos están:

1. El desarrollo de los planes estratégicos de cada uno de los sectores anteriores.
2. La creación y custodia del Catálogo Nacional de Infraestructuras Críticas, que contiene información actualizada y contrastada de todas las infraestructuras estratégicas.

5.6. Instituto Nacional de Ciberseguridad (INCIBE)

El Instituto Nacional de Ciberseguridad (INCIBE) es una sociedad estatal dependiente del Ministerio de Economía y Empresa a través de la Secretaría de Estado para el Avance Digital.

Tiene su sede en León y es la principal referencia para el desarrollo de la ciberseguridad en el ámbito de los ciudadanos, redes académicas, profesionales y sector privado.

Las actividades principales de este organismo se centran en la investigación aplicada, la prestación de servicios, la promoción y detección de talento y en la coordinación con redes nacionales e internacionales para agilizar la respuesta ante un incidente de ciberseguridad.

La actividad de INCIBE se dirige a:

- Empresas y profesionales.
- Expertos en ciberseguridad.
- Ciudadanos.
- Menores, jóvenes, familias, educadores y profesionales en el ámbito de los menores.

5.6.1. Incibe-CERT

Como se ha indicado, el Incibe dispone del centro de respuesta a incidentes de seguridad de referencia para ciudadanos, empresas y red académica, cuyos objetivos son:

- Impulsar la confianza en las nuevas tecnologías.
- Minimizar los prejuicios ocasionados por incidentes de seguridad.
- Prevenir, informar, concienciar y formar a las entidades y al ciudadano.

Entre las misiones encomendadas, destacan cuatro servicios esenciales:

- Gestión y soporte de incidentes de seguridad.
- Gestión y soporte ante el fraude electrónico.
- Asesoría legal.
- Laboratorio de soluciones de seguridad.

5.6.2. OSI – Oficina de Seguridad del Internauta

Dependiente de Incibe, la OSI u Oficina de Seguridad del Internauta es un organismo cuya misión principal es reforzar la **confianza del ciudadano en el ámbito digital**, a través de la formación en materia de ciberseguridad. Así, se plantea tres objetivos:

- Ayudar al ciudadano a adoptar buenos hábitos en seguridad.
- Hacerle consciente de su propia responsabilidad en relación con la ciberseguridad.
- Contribuir a minimizar el número y la gravedad de incidentes de seguridad.

En su portal dispone de información general sobre seguridad en Internet (su *Guía de privacidad y seguridad en Internet* es un referente de lectura casi obligatoria) y herramientas de ayuda a la navegación segura. También dispone de canales de avisos de alertas de seguridad y de soporte técnico, con servicio telefónico de atención a los usuarios.

5.7. Agencia Española de Protección de Datos (AEPD)

Se trata de un Ente de Derecho Público con personalidad jurídica propia y plena capacidad pública y privada, que actúa con independencia de las Administraciones Públicas. Su creación data de 1.993 y su objetivo principal es **garantizar el cumplimiento de la legislación sobre protección de datos de carácter personal**. Sus decisiones sólo pueden ser recurridas ante la vía contencioso-administrativa.

Tiene su sede en Madrid y tiene competencias en todo el territorio nacional. No obstante, existen también agencias de protección de datos de carácter personal autonómicas, Concretamente en Madrid, Cataluña y País vasco, aunque su ámbito de actuación está restringido a las administraciones autonómicas y locales de sus respectivas comunidades.

Durante el período de vigencia de la anterior LOPD y su Reglamento de aplicación, una de las misiones principales de la AEPD era el mantenimiento del registro de ficheros con datos personales que tenían que realizar las empresas y administraciones. Con la aprobación del RGPD de la Unión Europea y la nueva Ley Orgánica de protección de datos personales y garantía de los derechos digitales, se suprime el registro de ficheros y la protección se centra en el tratamiento de los datos. Así, en el portal de la AEPD se dispone de toda la información relativa al cumplimiento de la legislación, herramientas de apoyo a la creación de los documentos básicos en tratamientos de escaso riesgo, guías para la realización de análisis de impacto de los tratamientos, etc.

ACTIVIDADES

1. Reflexionar acerca de nuestras políticas domésticas de contraseñas, de copias de seguridad y de actualizaciones del sistema operativo. Identificar defectos en el procedimiento y posibles mejoras. Si no existen, establecerlas.
2. Analizar los aspectos básicos de la configuración de nuestra conexión a Internet y de nuestra Wifi doméstica, si existen. Identificar posibles mejoras y si es posible, implementarlas.
3. Reflexionar acerca de la política de empleo de antivirus/firewall en nuestros equipos de sobremesa, portátiles y móviles. Identificar posibles mejoras. Si es posible, implementarlas.
4. Revisar nuestras opciones de privacidad en todas las redes sociales en las que estemos registrados. Leer atentamente las condiciones de privacidad y uso de los recursos allí depositados. Extraer conclusiones.
5. Identificar la “cadena” de organismos de seguridad a los que se puede acudir en caso de incidente en nuestra organización, o en su caso, de nuestra Universidad.

BIBLIOGRAFÍA

- Aceituno Canal, V. (2004). Seguridad de la información: expectativas, riesgos y técnicas. Madrid. Creaciones Copyright.
- Areitio Bertoln, J. (2008). Seguridad de la información: redes, informática y sistemas de información. Madrid. Paraninfo.
- Gómez López, J. (2010). Guía de campo de Hackers. Aprende a atacar y a defenderte. Madrid. Ra-Ma.
- Harris, S., Harper, A., Eagle, C., Ness, J., Lester, M. (2005). Hacking Ético. Madrid. Anaya Multimedia.
- Mitnick, K. (2006). El arte de la intrusión: la verdadera historia de las hazañas de hackers, intrusos e impostores. Madrid. Ra-Ma.
- Rovira del Canto, E. (2002). Delincuencia informática y fraudes informáticos. Granada. Comares.
- Shinder, D. L. (2003). Prevención y detección de delitos informáticos. Madrid. Anaya Multimedia.
- Tynan, D. (2006). Privacidad informática: problemas y soluciones. Madrid. Anaya Multimedia.

Guías CCN-STIC y recursos del INCIBE

- Guía 450 - Guía de Seguridad de las TIC. Seguridad en dispositivos móviles.
- Guía 453 - Guía de Seguridad de las TIC. Seguridad en Android.
- Guía 454 - Guía de Seguridad de las TIC. Seguridad en iPad.
- Guía 455 - Guía de Seguridad de las TIC. Seguridad en iPhone.
- Guía de seguridad y privacidad en Internet. Oficina de Seguridad del Internauta.
<https://www.osi.es/es/guia-de-privacidad-y-seguridad-en-internet>.

Sitios web de referencia

- Agencia Española de Protección de Datos <https://www.aepd.es>
- Centro Criptológico Nacional (CCN) <https://www.ccn.cni.es>
- Centro Nacional de Inteligencia <https://www.cni.es>
- Centro Nacional de Protección de Infraestructuras Críticas y Ciberseguridad (CNPIC)
<https://www.cnpic.es>
- CERT de CCN (CCN-CERT) <https://www.ccn-cert.cni.es>
- CERT de Incibe (INCIBE-CERT) <https://www.incibe-cert.es>
- ENISA (European Union Agency for Network and Information Security)
<https://enisa.europa.eu>
- Instituto Nacional de Ciberseguridad (INCIBE) <https://www.incibe.es>
- Oficina de Seguridad del Internauta (OSI) <https://www.osi.es>

EJERCICIOS DE AUTOEVALUACIÓN

1. ¿Cuál de estos rangos de direcciones IP no pertenece a una red privada?
 - a. 10.X.X.X
 - b. 192.168.X.X
 - c. 152.126.X.X
 - d. 172.26.X.X
2. Para cifrar las comunicaciones en una red Wifi, se puede usar el protocolo:
 - a. WPA.
 - b. WAP.
 - c. Bluetooth.
 - d. WPE.
3. Una recomendación básica en la configuración de un router doméstico es:
 - a. Permitir el acceso remoto a la pantalla de configuración.
 - b. Desactivar la utilización de comunicaciones cifradas.
 - c. Entregar todas las conexiones entrantes a una “default workstation” o DMZ.
 - d. Cambiar la contraseña de acceso e impedir su configuración desde Internet.
4. Para garantizar la integridad de un mensaje de correo electrónico necesitaremos:
 - a. Cifrarlo.
 - b. Firmarlo.
 - c. Cifrarlo y firmarlo.
 - d. Utilizar un servidor de correo electrónico seguro.
5. Una red privada virtual (VPN)...
 - a. Es un mecanismo de virtualización de redes.
 - b. Es un sistema de comunicaciones virtuales.
 - c. Es un sistema de interconexión o de acceso a redes privadas.
 - d. Es una nueva tecnología de comunicaciones inalámbricas.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	c
2	a
3	d
4	b
5	c

GLOSARIO

ACL: Access Control List. Lista de control de acceso. En general es una lista, blanca o negra, de elementos que pueden acceder a un sistema, por ejemplo, la lista de direcciones MAC que pueden conectar con un servidor Wifi.

Infraestructura crítica: Toda instalación, red o servicio cuya interrupción o destrucción suponga un impacto importante en la salud, la seguridad o el bienestar económico de los ciudadanos o en el eficaz funcionamiento del Estado y de sus administraciones públicas.

Lista negra: Mecanismo de control de identificación que permite diferenciar entre direcciones o servidores, típicamente de correo electrónico, que pueden acceder a un determinado servicio de otros que no. Si aparece en dicha lista, se le denegará el acceso.

Lista blanca: Mecanismo similar al de la *lista negra* pero en este caso, si la dirección o el servidor especificados aparece en la lista, tendrá permitido el acceso.

Network Address Translation (NAT): Mecanismo de traducción automática entre las direcciones IP privadas de una red interna y la dirección pública del router o firewall. Esto proporciona seguridad a la red interna, ya que salvo configuración expresa del router/firewall, ningún equipo interno será directamente accesible desde el exterior.

SSID: Service Set Identifier. Identificador de red Wifi. Equivale al nombre único de la red. Puede ser ocultado, de forma que el router no lo anuncie, como medida de seguridad adicional.

Uniform Resource Locator (URL): Un localizador de recursos uniforme o URL es una cadena de caracteres con la que se asigna una dirección única a cada uno de los recursos de información accesibles en Internet. Típicamente tiene cuatro partes: el protocolo, el anfitrión, el puerto y la ruta al recurso.

UA 5. Instrumentos para la gestión de la seguridad

PRESENTACIÓN

Conocidos los conceptos básicos, las amenazas a los sistemas de información y sus mecanismos de defensa, es el momento de diseñar estrategias y aplicar metodologías que permitan gestionar adecuadamente la seguridad de la información en las organizaciones. Esta gestión llega no sólo como una obligación legal, marcada por la legislación y normativa actuales que se estudian en la siguiente unidad, sino como una necesidad para lograr la eficiencia y la eficacia en la protección de las dimensiones de esta seguridad.

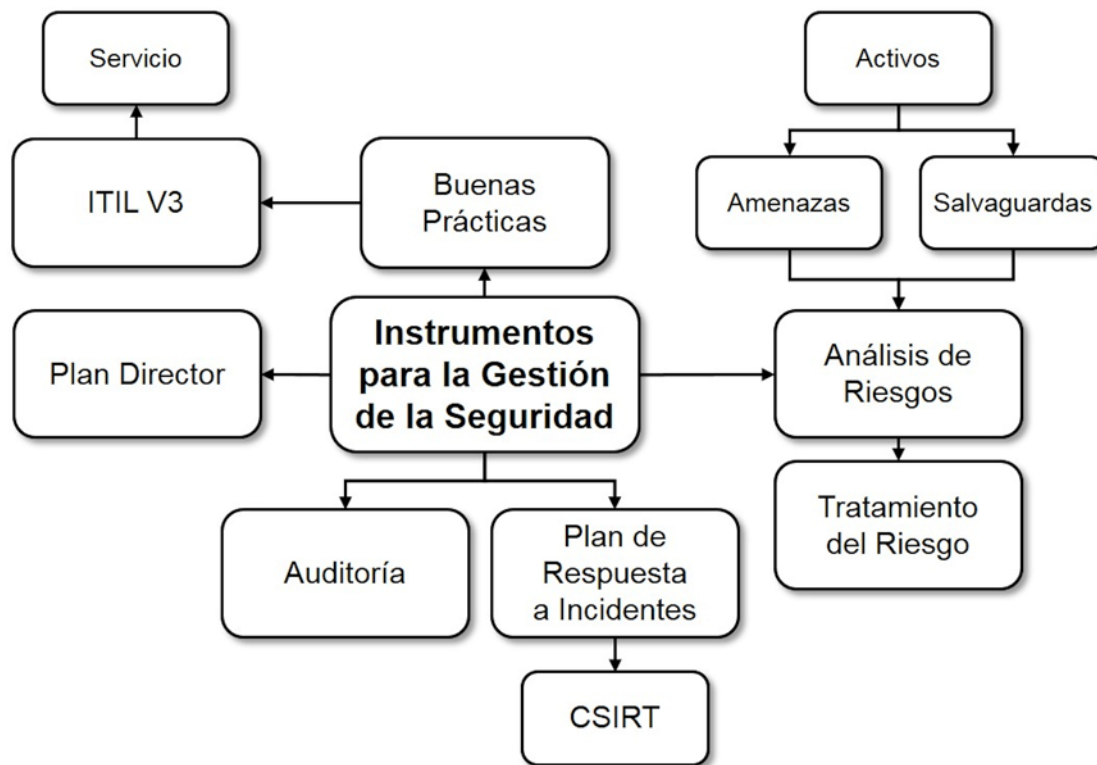
Comienza la unidad explicando el concepto de buenas prácticas en el desarrollo y gestión de sistemas basados en tecnologías de la información, con la biblioteca ITIL como ejemplo más significativo. A continuación se desarrollan una serie de instrumentos que permiten gestionar diferentes aspectos de la seguridad de la información en cualquier organización y que forman parte de los sistemas integrados de gestión de seguridad de la información, que se estudian en la unidad siguiente.

Así se estudia el análisis de riesgos, instrumento básico que permite cuantificar los riesgos inherentes a los diferentes activos de información en la organización, en virtud de las amenazas a las que están expuestos y las salvaguardas o medidas de protección establecidas, así como gestionar estos riesgos mediante la incorporación de planes de tratamiento con incorporación de nuevas salvaguardas. Otro instrumento, como la auditoría de seguridad, permite realizar un seguimiento y control de las medidas y acciones a desarrollar. Se define también la metodología básica para la elaboración de un plan director de seguridad, y finaliza la unidad con los aspectos que conforman un plan de respuesta ante incidentes y un plan de continuidad del negocio.

OBJETIVOS

- Conocer qué son buenas prácticas en la provisión de sistemas de información y los aspectos básicos de la biblioteca ITIL.
- Conocer los diferentes instrumentos para la gestión de la seguridad de la información.
- Conocer los fundamentos y saber aplicar las técnicas básicas para la realización de análisis de riesgos en una organización.
- Conocer los fundamentos y saber aplicar las técnicas básicas para la realización de una auditoría de seguridad, un plan director de seguridad, un plan de respuesta ante incidentes y un plan de continuidad del negocio en una organización.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. BUENAS PRÁCTICAS EN TIs. LA VISIÓN DE ITIL

El concepto de “buenas prácticas” es una constante en el camino hacia la normalización de la gestión de cualquier actividad compleja del ser humano, y suele ser previo al establecimiento de normativa recomendada, que frecuentemente conduce a la aprobación de legislación de obligado cumplimiento. La seguridad de la información no es ajena a este proceso y cuando se habla de *buenas prácticas* en un marco vinculado directa o indirectamente a las Tecnologías de la Información (TIs) es imprescindible hacer referencia a un estándar *de facto* que poco a poco ha ido ganando la confianza de los responsables de TI a nivel internacional. Se trata de la *Information Technologies Infrastructure Library* o biblioteca ITIL. Si bien ITIL no se centra específicamente en la seguridad TI, establece un marco general de buenas prácticas, que facilita la gestión de la seguridad al optimizar el contexto global de gestión de servicio TI.

El origen de ITIL se centra en la búsqueda de la eficiencia en la Gestión de servicios TI. Nació fruto de una gran frustración tecnológica: en la década de los 80, el Reino Unido emprendió un proyecto cuyo objetivo era eliminar el papel en las transacciones de la bolsa de Londres y reducir costes, a la vez que se mejoraba la seguridad en las transacciones. Denominado proyecto TAURUS (*Transfer and Automated Registration of Uncertificated Stock*), este proyecto fue un rotundo fracaso, tras una inversión de más de 20 millones de dólares y una segunda versión del proyecto, denominada TAURUS II.

Como consecuencia de la situación anterior, el Gobierno Británico solicitó a la CCTA (*Computer and Telecommunication Agency*) una investigación con la intención de identificar las mejores prácticas en la gestión de servicios TI, documentando los resultados para que en el

futuro se pudiese minimizar el riesgo de fracaso en proyectos similares. De esta documentación surge la *IT Infrastructure Library*, más conocida como ITIL.

El origen formal de ITIL se sitúa en 1986, basado en el resultado de las investigaciones de la CCTA y con apoyo principalmente de IBM. Actualmente la CCTA forma parte del Ministerio de Comercio Británico, OGC (*Office of Government Commerce*) quien ha patentado y posee todos los derechos sobre ITIL.

En un principio ITIL se enfocó al ámbito de la administración pública, convirtiéndose posteriormente en un estándar de la gestión de servicios TI, tanto en el ámbito público como privado.

A partir de 2014, se creó un consorcio entre el Gobierno del Reino Unido y Capita, denominado AXELOS, para el desarrollo de ITIL, además de otras metodologías y buenas prácticas.

1.1. La biblioteca ITIL

Originalmente se publicaron más de 50 libros recogiendo las buenas prácticas de la gestión del servicio TI, pasando a concentrarse en un primer bloque de 34 libros que cubrían todos los aspectos de la provisión de servicios TI. Esta versión inicial fue revisada y reemplazada por un bloque de 7 libros, más coherentes y mejor relacionados entre sí. Esta colección se denominó ITIL v2 y supuso la madurez de este conjunto de buenas prácticas. **ITIL v2** se utiliza actualmente en multitud de organizaciones, pertenecientes a diferentes países, como una base para la gestión eficiente de sus servicios TI.

En 2008 se formalizó la versión **ITIL v3**, que simplifica y aporta mayor coherencia entre los distintos procesos.

La nueva versión 3 tiene como objetivo facilitar la comprensión del nuevo papel de las TI considerando su complejidad y dinamismo. Para ello se parte de un nuevo método de gestión de servicios centrado en lo que se ha denominado “Ciclo de vida del servicio” que trata de abarcar las distintas etapas por las que pasa un nuevo “servicio”, desde que surge la idea hasta que se plasma en una realidad que se ofrece a los clientes y que requiere de un mantenimiento y actualización permanente. Algunos años más tarde, en 2011, se publicó una actualización de ITIL v3, denominada **ITIL v3 2011 edition**.

Recientemente se ha comenzado a publicar una nueva versión de ITIL, denominada **ITIL v4**, donde hay una considerable y profunda reestructuración del modelo de buenas prácticas propuesto por ITIL. Hasta la fecha solo se ha publicado la guía ITIL 4 Foundation. El objetivo de esta nueva versión es adaptarlo a los nuevos retos de la industria y convertirlo en el Modelo Operativo de TI para la *cuarta revolución industrial*.

1.2. Terminología básica

Para poder entender las propuestas de ITIL (pues al ser una guía de buenas prácticas, no tienen carácter obligatorio) es necesario entender primero algunos conceptos fundamentales que exponemos a continuación:

- **Buena práctica:** un enfoque o método que ha demostrado su validez y eficacia en la práctica.
- **Servicio:** es un medio para entregar valor al cliente, facilitando los resultados que los clientes quieren conseguir sin asumir costes o riesgos específicos.
- **Valor:** desde el punto de vista del cliente supone la conjunción de dos componentes fundamentales: funcionalidad (lo que recibe el cliente) y garantía (la forma en cómo se proporciona)

- **Gestión de Servicio:** es un conjunto de capacidades organizativas especializadas cuyo fin es generar valor para los clientes en forma de servicios.
- **Función:** subdivisión de una organización (unidad organizativa) especializada en realizar un trabajo específico y que tiene la responsabilidad de obtener resultados concretos.
- **Proceso:** es un conjunto estructurado de actividades diseñado para cumplir con un objetivo concreto.

1.3. El enfoque de ITIL v3 2011. El ciclo de vida del servicio

Si bien se están publicando las primeras guías de ITIL V4, la versión actual sigue siendo ITIL v3 2011 edition, por lo que a continuación haremos un resumen esquemático del enfoque de esta versión, terminando con un apartado que refleja el cambio de filosofía que propone la futura versión 4.

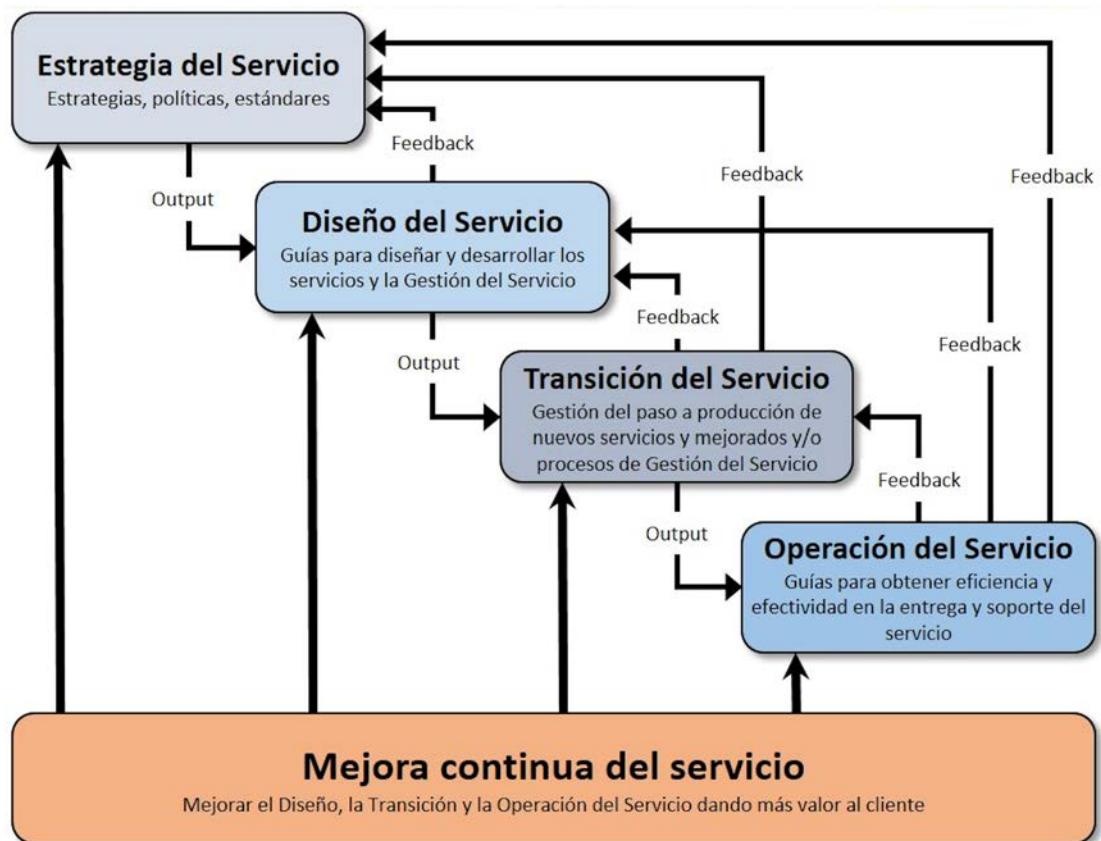


Figura 5.1. Etapas del Ciclo de Vida de los servicios en ITIL V3

En ITIL v3 2011, el eje de gestión gira en torno al **ciclo de vida del servicio**.

Este ciclo de vida del servicio consiste en un modelo de organización que aporta información sobre tres aspectos críticos:

- La forma en que está estructurada la gestión del servicio.
- La forma en que los distintos componentes del ciclo de vida están relacionados entre sí.
- El efecto que los cambios en un componente tendrán sobre otros componentes y, sobre todo, en el sistema del ciclo de vida.

En ITIL v.3 tal y como se observa en la Figura 5.1, se plantea un **ciclo de vida de cinco fases**, detallada en cada uno de los libros que conforman esta versión.

- **Estrategia** del Servicio.
- **Diseño** del Servicio.
- **Transición** del Servicio.
- **Operación** del Servicio.
- **Mejora** continua.



Figura 5.2. Procesos de ITIL v3 2011 edition

El objetivo de cada fase es generar valor para el negocio, entendiendo como tal aquello en lo que la Organización tiene su enfoque principal.

Cada fase o etapa posee dos elementos cruciales para entender el modelo del ciclo de vida:

- **Actividades:** relación de las tareas más importantes a realizar para lograr los objetivos en cada fase.
- **Procesos:** conjunto de actividades con un objetivo específico.

Finalmente, en la figura 5.2 se resume la relación de procesos en cada etapa del ciclo de vida del servicio, destacando en **negrita** los que se han añadido o modificado en la revisión de 2011.

1.4. ITIL v4 y la Industria 4.0

La evolución tecnológica y los cambios que ésta ha implicado en la industria hacían necesaria una profunda revisión del modelo de ITIL. Conceptos tan familiares a día de hoy como el *Cloud Computing* o la computación en la nube se citaban ocasionalmente en la revisión de 2011. Sin embargo, a día de hoy es algo inherente a la mayoría de los servicios de TI. Este y otros muchos cambios en los modelos de gestión en la industria han llevado a acuñar el modelo “Industria 4.0” del que hablamos en la primera unidad de este manual. De ahí que ITIL haya decidido adaptarse y alinearse con este nuevo contexto sociotecnológico.

Así, ITIL v4 define cuatro dimensiones que se consideran críticas para alcanzar con éxito la creación de valor para los clientes y resto de partes interesadas en el negocio:

1. Organización y personas.
2. Información y tecnología.
3. Socios y proveedores.
4. Flujos de valor y procesos.

Se resumen a continuación las características esenciales de esta nueva versión:

- a. Aproximación holística: ITIL v4 define cuatro dimensiones para la gestión del servicio que se consideran especialmente críticas para facilitar la creación de valor tanto para los clientes como para los implicados en forma de productos y servicios.
- b. Sistema de valor de servicio (SVS): como evolución del anterior concepto de ciclo de vida del servicio, el SVS describe la manera en que todos los componentes y actividades de una organización trabajan juntos para permitir la creación de valor. Su objetivo es que la organización cree valor de forma continua y cooperativa.
- c. Cadena de valor del servicio: consiste en un modelo operativo que aglutina las actividades clave necesarias para dar respuesta a la demanda y facilitar valor de negocio a través de la creación y gestión de productos y servicios. Aporta una visión más flexible que el ciclo de vida del servicio.
- d. Prácticas ITIL: En lugar de hablar de procesos, en ITIL v4 se utiliza el concepto de práctica, que se define como un grupo de recursos de organización diseñados para realizar el trabajo o cumplir un objetivo.
- e. Integración con otras mejoras prácticas: esta nueva versión aporta la posibilidad de integrarse con otras metodologías, como Agile, DevOps, Lean, Gobierno TI, etc.

2. ANÁLISIS DE RIESGOS

Vista la importancia de las buenas prácticas en la provisión de servicios de TIs, nos centraremos a continuación en los instrumentos para la gestión de la seguridad, comenzando por la **herramienta básica e imprescindible** en cualquier actuación encaminada a mejorar objetivamente la seguridad de un sistema de información, como es el **análisis de riesgos**.

La progresión de la cantidad de incidentes que comprometen la seguridad de los sistemas de información es actualmente imparable. La información está sometida a multitud de situaciones que, de forma intencionada o accidental, comprometen su seguridad en todas sus dimensiones: disponibilidad, integridad, confidencialidad, no repudio y autenticación. Situaciones y hechos que hasta hace poco eran infrecuentes, pertenecen hoy en día a lo cotidiano y no es raro ver en las noticias ataques de considerable relevancia a empresas, organismos públicos y gobiernos. Según el Centro Criptológico Nacional, cada día tres infraestructuras críticas de nuestro país

sufren un ciberataque de peligrosidad alta o muy alta. Sin embargo, no sólo las grandes organizaciones están expuestas a estos riesgos. El phishing, tanto genérico como dirigido, y las infecciones de ransomware, por citar sólo dos ejemplos, están ocasionando verdaderos estragos, tanto a nivel doméstico como en todo tipo de pequeñas y grandes organizaciones.

Por tanto, que la información está *bajo amenaza* es un hecho. Amenazas no sólo externas a personas y organizaciones sino provenientes de las debilidades inherentes a la propia infraestructura, los sistemas que sobre ella se apoyan y muy especialmente al personal que las mantiene y utiliza en el desempeño de sus funciones.

Ante esta situación, es necesario escoger entre dos planteamientos posibles: reactivo o proactivo. Obviamente, la multiplicidad de amenazas y de formas en las que éstas se pueden materializar exige un enfoque más allá de la mera capacidad de reacción. Es necesario anticiparse a la materialización de las distintas amenazas y considerar las repercusiones del daño sufrido por cualquier componente del sistema de información en los restantes. Así, **el proceso de análisis de riesgos formaliza de manera estandarizada los pasos a seguir para identificar, cuantificar, medir y gestionar las situaciones que ponen en peligro la seguridad de la información**. En los próximos apartados realizaremos una introducción progresiva a esta útil y eficaz herramienta que, además, es requisito indispensable para el cumplimiento de la mayor parte de las normas y leyes relativas a la seguridad de la información.

2.1. Terminología básica

Antes de entrar a describir en qué consiste y las pautas a seguir en un análisis de riesgos, veremos los conceptos básicos que se emplean en este proceso. Si bien algunos conceptos ya se han visto en las primeras unidades, se repiten aquí con el enfoque específico orientado al riesgo, para facilitar la comprensión del capítulo.

- **Activo:** cualquier recurso de software, hardware, de personal, administrativo, etc. requerido para el adecuado funcionamiento de un servicio.
- **Vulnerabilidad:** es una debilidad del sistema que puede ser utilizada accidental o intencionadamente.
- **Amenaza:** la posibilidad de que se produzca una determinada vulnerabilidad con éxito.
- **Impacto:** supone la materialización de un riesgo. Nos proporciona un medible del grado de **daño** que se ha producido sobre un activo.

Llegados a este punto definiremos el concepto fundamental de este capítulo, como es el riesgo.

2.2. Definición de riesgo

Riesgo: La probabilidad de que un evento adverso ocurra y que supone un impacto negativo si llegase a ocurrir.

En el ámbito que nos ocupa destacan tres aspectos fundamentales para entender el concepto de riesgo:

- **Acontecimientos futuros:** Sólo se pueden estimar y reducir a un nivel razonable los riesgos conocidos, por tanto, es necesario vigilar la *sustanciación* de amenazas que no habían sido consideradas previamente, es decir, la aparición de *nuevos riesgos*. Esto conlleva que el análisis de riesgos es un proceso cíclico que se ha de revisar y mantener a lo largo del tiempo.
- **Cambios:** ya que la detección y análisis de los riesgos lleva consigo el estudio de qué cambios se pueden implementar en la organización para reducirlos.

- **Elección:** en cuanto que se han tomar decisiones, muchas veces alternativas, para gestionar los riesgos.

En base a lo que acabamos de exponer, podemos decir que el análisis de riesgos es un proceso que consiste, por una parte, en identificar los problemas de seguridad que evidencian **vulnerabilidades**, las cuales pueden ser posteriormente explotadas por las **amenazas**, generando un **impacto en la organización**. Así, se identifican los **riesgos** a los que están expuestos los **activos** de la organización.

Un análisis de riesgos generalmente comporta dos etapas principales: identificar el nivel de riesgo existente en la organización y aplicar medidas que disminuyan los riesgos encontrados:

1. Identificar las **amenazas** y las medidas de defensa o **salvaguardas** ya implantadas sobre cada activo, evaluando el nivel de riesgo sobre ese activo y posteriormente, de la organización en su conjunto.
2. Si el nivel de riesgo está por encima de lo recomendable (que será el caso más usual), proponer las mejoras en las defensas o nuevas salvaguardas que pueden implementarse para minimizar las amenazas y, en consecuencia, disminuir el nivel de riesgo. A su vez, resultado de esta etapa será el desarrollo de un plan de tratamiento de los riesgos.

2.3. Tipos de riesgos

- **Riesgos conocidos:** son aquellos que pueden ser identificados y gestionados, adoptando las medidas oportunas.
- **Riesgos desconocidos:** se trata de situaciones imprevistas que no permiten tomar medidas “a priori”. Como se ha dicho, a lo largo del tiempo, la revisión de un análisis de riesgos conlleva la incorporación de riesgos inicialmente desconocidos a los conocidos, así como su tratamiento.

2.4. ¿Qué esperamos del análisis de riesgos?

Los objetivos principales de un análisis de riesgos son:

- Identificar cualquier riesgo significativo en todos los activos de información, dentro de su contexto de uso.
- Obtener un informe claro y entendible por la Dirección.
- Establecer una clasificación de riesgos en función de su impacto potencial en la organización y en los clientes internos y externos.
- Identificar la posibilidad de lograr una eliminación de riesgo inmediata.
- Identificar soluciones alternativas, con sus ventajas y desventajas.

2.5. Desarrollo

Aunque existen diversas metodologías para realizar un análisis de riesgos, todas conducen al desarrollo de una serie de etapas o fases esenciales, como las indicadas en la figura 5.3 y que describiremos a continuación.

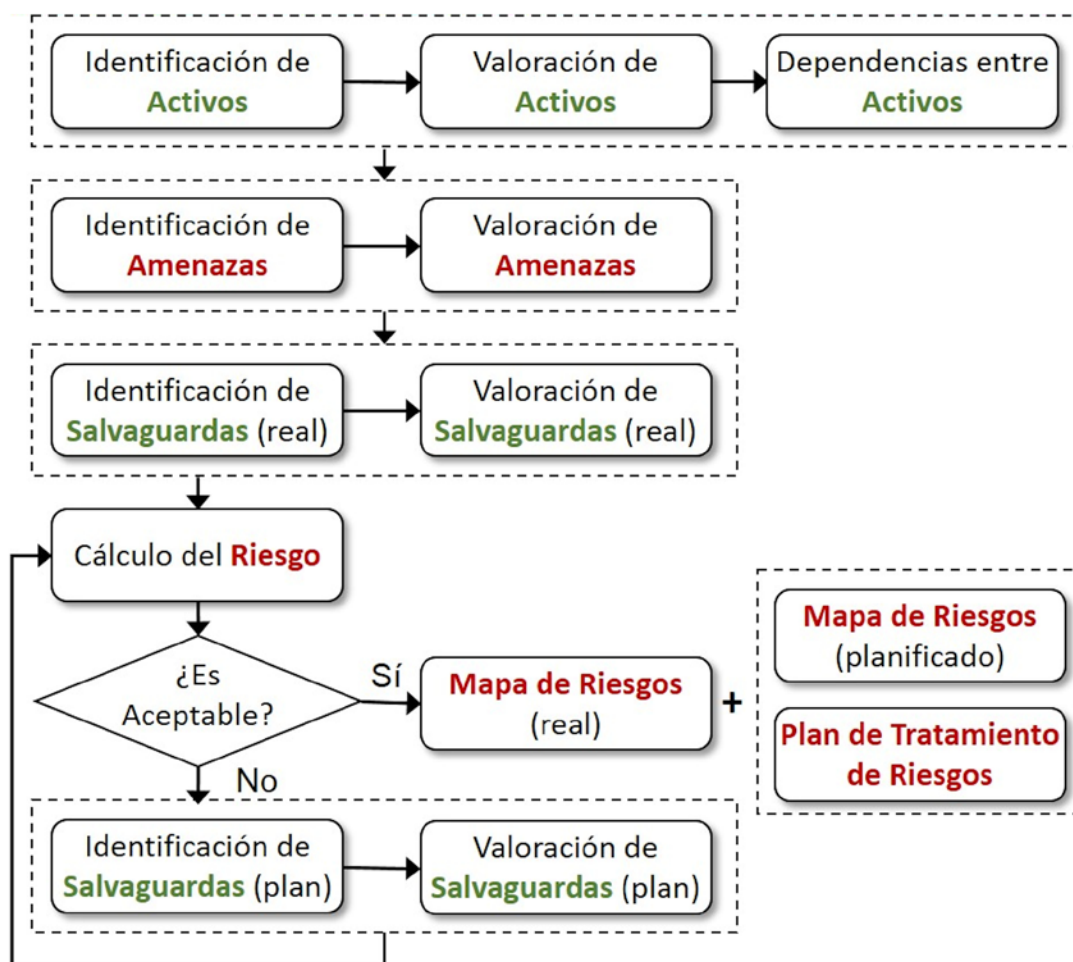


Figura 5.3.- Etapas en el análisis de riesgos

Fase 1. Gestión de activos: identificación, valoración y análisis de dependencias

La primera etapa, de la que dependerá en buena medida el éxito o fracaso del proceso de análisis de riesgos, consiste **en identificar los activos vinculados al ámbito del análisis de riesgos**. Es decir, es necesario tener una relación completa de aquellos elementos que conforman los servicios de información. En este apartado se pueden incluir:

- Infraestructuras básicas (desde la eléctrica hasta el aire acondicionado del CPD)
- Hardware y software de comunicaciones.
- Hardware de sistemas (servidores, equipos de usuario, etc.)
- Software (sistemas operativos, aplicaciones)
- Sistemas de almacenamiento.
- Bases de datos.
- Informes.
- Expedientes.
- Contratos de mantenimiento y servicios.
- Personal.

En definitiva, todo lo que es necesario para que la información esté disponible.

A continuación se realiza la **valoración de los activos**, es decir: se asigna una medida del **impacto** que provoca en la organización el hecho de que el activo se vea dañado. Este proceso se puede realizar globalmente o para cada una de las dimensiones básicas de la seguridad: **disponibilidad, integridad, confidencialidad y autenticación**.

Una vez identificados y valorados los activos, es necesario **conocer sus relaciones y dependencias**. Un activo A (se denomina activo hijo) puede depender de otro B (activo padre). Por tanto, un ataque sobre B provocará una acción indirecta sobre A. Por norma general se asigna un porcentaje a esta dependencia.

El valor de un activo y el impacto cuando sufre un daño podrán ser directos o acumulados, de tal forma que un activo padre acumula el valor de sus activos hijos, de acuerdo a su grado de dependencia:

Valor acumulado (B) = valor (B) + valor (A) * grado de dependencia

Mientras que el impacto o daño sufrido por un activo hijo acumulará el daño sufrido por sus activos padre, en función del grado de dependencia:

Impacto acumulado (A) = impacto (A) + impacto (B) * grado de dependencia

Fase 2. Detección de amenazas: identificación y valoración de las amenazas

En esta fase se identifican, para cada activo, las amenazas cuya materialización supondrían un impacto sobre dicho activo. Por ejemplo, si el activo es el hardware de un servidor, se pueden considerar amenazas como la avería física, el robo o vandalismo, etc.

Para valorar el efecto de cada amenaza, se trata de realizar una estimación sobre la vulnerabilidad del activo en dos vertientes:

- **Degradación:** medible que estima cuánto puede verse afectado el activo por esa amenaza. Suele expresarse en tanto por ciento.
- **Frecuencia:** medible sobre cada cuánto se produce la amenaza. Se suele utilizar una escala numérica asignada a cada período (diario, mensual, anual, etc.)

Fase 3: Identificación y valoración de salvaguardas

Tras conocer las posibles amenazas de cada activo, se alinearán con las salvaguardas o mecanismos de defensa ya existentes, que impiden o mitigan la materialización de cada amenaza. Así, en el ejemplo anterior, la amenaza de avería física de la parte hardware de un servidor podrá estar salvaguardada por la existencia de un equipo de reemplazo o con un sistema tolerante a fallos; el robo o vandalismo, con la seguridad física, etc.

Tanto para la identificación de amenazas como de salvaguardas, se dispone de repositorios y catálogos en normas y metodologías nacionales e internacionales, como:

- Libro II de la metodología MAGERIT.
- Normas ISO (ISO/IEC 27002 y siguientes)
- Anexos del Esquema Nacional de Seguridad.
- Norma UNE 71504 – Metodología de análisis y gestión de riesgos para los sistemas de información.

En el proceso de valoración de las salvaguardas, el objetivo es asignar un medible que indique el grado de eficacia ante la amenaza en cuestión, típicamente en valores porcentuales.

Fase 4. Gestión del riesgo

Esta fase comienza con el cálculo del riesgo en virtud de los activos identificados, las amenazas identificadas para cada activo y las salvaguardas para cada una de estas amenazas ya establecidas en la organización. Si alguno de los riesgos estimados es demasiado alto, procederá la gestión de los riesgos.

Gestionar el riesgo consiste en identificar y desplegar las medidas técnicas y organizativas, es decir, **nuevas salvaguardas**, requeridas para evitar, minimizar o controlar los riesgos identificados, de manera que se elimine o se reduzca en lo posible el daño que pueden ocasionar.

Se pueden adoptar cuatro acciones diferentes:

- **Mitigar el riesgo:** reducirlo hasta llevarlo a un nivel aceptable.
- **Asumir el riesgo:** Corresponde a la dirección asumir el riesgo en los casos en que esté por encima de un valor de riesgo aceptable y su mitigación sea demasiado costosa.
- **Transferir el riesgo a un tercero:** esto se puede realizar subcontratando el servicio, contratando un seguro, etc.
- **Eliminar el riesgo:** aunque es la opción deseable, normalmente los condicionantes económicos o el grado de complejidad requerido la convierten en la opción menos viable.

Como se indica en la figura 5.3, el proceso de cálculo del riesgo, estimación de nuevas salvaguardas y nuevo recálculo se podrá efectuar cíclicamente, hasta llegar a un nivel de riesgo aceptable. En ese momento se elaborará el **plan de tratamiento de riesgos** que implantará las nuevas salvaguardas establecidas. Tengamos en cuenta que existen salvaguardas de todo tipo: desde la adquisición e incorporación de nuevos sistemas hasta la implantación de planes de formación para todo el personal de una gran organización; y por tanto, el correcto despliegue de las salvaguardas puede tardar meses o incluso años en realizarse de forma completa.

2.6. Metodologías para la implementación

Existen varias metodologías que aportan las pautas específicas para realizar un análisis de riesgos. A continuación realizaremos un breve resumen de las más reconocidas.

CRAMM

Se trata de una metodología desarrollada por la *Central Agency of Data Processing and Telecommunications* del Gobierno del Reino Unido. Tiene su origen en las mejores prácticas de la administración pública británica y dada su complejidad, requiere del apoyo de una herramienta específica, por lo que no se recomienda para pequeñas organizaciones. CRAMM se desarrolla en tres fases:

- **Fase 1:** Establecimiento de objetivos de seguridad.
- **Fase 2:** Análisis de riesgos.
- **Fase 3:** Identificación y selección de salvaguardas.

Actualmente es la metodología de análisis de riesgos empleada por la OTAN, el ejército holandés y multitud de empresas a nivel internacional.

EBIOS

Consiste en un juego de guías dirigidas a la gestión del riesgo en entornos TI y dispone también de una herramienta gratuita de código libre. Su desarrollo y adopción por el gobierno

francés ha motivado una amplia difusión tanto en el sector público como privado de ese país y su entorno. La metodología EBIOS consta de cinco fases:

- **Fase 1:** Análisis del contexto.
- **Fase 2 y 3:** Análisis de los requisitos de seguridad y de las amenazas.
- **Fases 4 y 5:** Establecimiento de los objetivos de seguridad, asegurando su cumplimiento e identificando los riesgos residuales.

MAGERIT V3

Se trata de la metodología de análisis y gestión de riesgos elaborada por el Consejo Superior de Administración electrónica y su utilización no requiere autorización previa. Se centra en el estudio de los riesgos propios de los sistemas de información para recomendar las medidas a tomar para controlar su impacto. Se publicó en su primera versión en 1.997 y actualmente cuenta ya con una versión 3, estructurada en tres libros:

- **Libro 1: El método.** Contiene la secuencia de acciones y tareas a realizar para realizar un proceso de gestión de riesgos, dando una visión práctica que se apoya en:
 - Acciones para tomar una “instantánea” del estado de los riesgos y poder gestionar su mitigación.
 - Relación de tareas básicas para sacar adelante el proyecto de análisis de riesgos, concretando las pautas para definir roles, actividades y documentación necesaria.
 - Aplicación práctica de la metodología indicada.
 - En los apéndices se engloba el material de referencia, tal como marco normativo, ejemplos, referencias bibliográficas, etc.
- **Libro 2: Catálogo de Elementos.** Este libro se centra en los activos, como fuente principal del estudio de riesgos, considerando su tipología, valoración, amenazas habituales y salvaguardas.
- **Libro 3: Guías técnicas.** Se trata de un manual de referencia para conocer algunas técnicas utilizadas en el desarrollo de proyectos de análisis de riesgos.

Norma ISO/IEC 27005

Se basa en el modelo PDCA (Plan, Do, Check, Act), característico de la familia de normas ISO 27000, dedicadas a la gestión de la seguridad de la información, que se estudian en la siguiente unidad, y plantea un modelo genérico de gestión de riesgos.

2.7. Tipología de los análisis de riesgos

Con independencia de la metodología utilizada, se distinguen dos clasificaciones para un análisis de riesgos: atendiendo a su nivel de detalle en cuánto a la identificación de activos y atendiendo a su formalidad o unidad de medida (cualitativos o cuantitativos).

Atendiendo a su **nivel de detalle**, un análisis de riesgos de cualquier organización comenzará por la identificación de activos, agrupados en categorías más o menos amplias. Por ejemplo, cada servidor puede constituir un solo activo, varios activos (hardware, software, unidades de almacenamiento, etc.) o incluso formar parte de un solo activo (servidores corporativos). Evidentemente, los resultados del análisis en cada caso mostrarán riesgos detallados o agrupados en mayor o menor medida, con diferente capacidad de respuesta en cada caso.

Atendiendo a la unidad de medida (**formalidad**):

- **Análisis de riesgo cualitativo:** se basará en identificar los diferentes niveles de riesgo en una escala de valores discretos: muy bajo, bajo, medio, alto, muy alto y similares. Los resultados por tanto serán orientativos y las decisiones resultantes del análisis tendrán que ser justificadas por separado. La mayoría de las organizaciones emplea esta técnica, apoyándose en el empleo de herramientas informáticas como versiones más o menos potentes de la herramienta Pilar, que permiten también el análisis cuantitativo.
- **Análisis de riesgo cuantitativo:** En este caso se hace una estimación económica real (en euros, dólares, etc.) de los niveles de riesgo, empleando técnicas similares a las que realizan los actuarios en los cálculos de las primas de los seguros. Esto requiere análisis muy formales de los activos y las dependencias entre ellos, la estimación muy exacta de los porcentajes de afectación de las amenazas, del grado de protección de las amenazas, etc. Estos análisis de riesgo la dedicación casi exclusiva de personal con muy alta cualificación. Sólo las grandes organizaciones pueden afrontar estos desarrollos, cuya mayor ventaja es que permiten estimar el retorno de la inversión efectuada en la mejora de las salvaguardas, a partir de la estimación numérica de los niveles de riesgo anteriores y posteriores. En resumen, permiten identificar con precisión una de las preguntas clave formuladas en la primera unidad de este manual: hasta dónde proteger los activos.

Normalmente, los análisis de riesgos se comienzan a un nivel de detalle medio (por ejemplo, un servidor físico se estudiará como uno, dos o tres activos) y de tipo cualitativo, y en organizaciones de tamaño medio o grande, evolucionan hacia estudios cuantitativos, que siempre podrán ser mostrados en modo cualitativo para la realización de informes ejecutivos, resúmenes, etc.

3. AUDITORÍA DE SEGURIDAD

El segundo de los instrumentos empleados en la gestión de la seguridad de la información que estudiaremos es la auditoría de seguridad. Se trata de un proceso mediante el cual se describen los pasos realizados en la gestión de un problema complejo, de forma que se pueda evaluar la corrección de los supuestos efectuados, de las acciones realizadas, etc. Históricamente el trabajo de los primeros auditores consistía en escuchar a la persona que era sometida a su acción para determinar si sus argumentos eran ciertos o falsos. Por ello, etimológicamente la palabra auditoría proviene del verbo latino “Audire” (oír).

Hoy en día la auditoría es un instrumento empleado en multitud de entornos de gestión. Posiblemente la más conocida sea la auditoría financiera, donde un experto o panel de expertos revisa los libros y registros contables de una organización para determinar el cumplimiento de la normativa y la validez de los resultados. Nos centraremos aquí en las **auditorías relativas a la seguridad de la información**.

Aunque en ocasiones se utiliza el mismo término de auditoría de seguridad para indicar el proceso de identificación de vulnerabilidades de los sistemas de información, es más correcto hablar en ese caso de **análisis de seguridad**, realizados mediante técnicas de hacking ético y pruebas de vulnerabilidad y de penetración, como los indicados en la unidad anterior. No olvidemos que la seguridad de la información es un concepto que va más allá de la ciberseguridad e integra el factor humano y la información de todo tipo, no solo en formato digital.

3.1. Definición

La auditoría de seguridad es el proceso de recoger, agrupar y evaluar evidencias para determinar si un sistema de información protege el activo empresarial, mantiene la integridad de los datos, realiza de forma eficaz los fines de la organización y utiliza eficientemente los recursos.

Realizar una auditoría a un sistema de información consistirá por tanto en analizar los mecanismos de control implantados, verificando si son adecuados y cumplen los objetivos establecidos. Como resultado del proceso de auditoría se podrán obtener a su vez los cambios que deben realizarse para lograr los objetivos marcados por la organización.

En este apartado tomaremos como referencia la guía 802 del CCN-CERT para la ejecución de auditoría del Esquema Nacional de Seguridad, la cual es extrapolable a cualquier ámbito en el contexto de la ciberseguridad.

3.2. Alcance

El alcance de una auditoría incluirá, a nivel general:

- Descripción de las ubicaciones de los elementos y sedes de la organización.
- Estructura orgánica de la organización.
- Actividades y procesos.
- Período de tiempo abarcado.

A nivel específico en el ámbito que nos ocupa, incluirá:

- Sistemas afectos por la revisión.
- Organismo responsable.
- Activos que conforman la estructura tecnológica.
- Personal vinculado a los activos analizados.
- Períodos de tiempo.

3.3. Objetivos

En un contexto específico de seguridad de la información, la auditoría tiene por objeto verificar que se garantiza tanto la protección de la información como el cumplimiento de la normativa. Es decir, verifica que:

- La disponibilidad de los sistemas de TI está razonablemente asegurada.
- Los controles necesarios para garantizar la integridad, la confidencialidad y la autenticación de la información están implantados.
- Existen controles para asegurar la trazabilidad de las actuaciones en el contexto TI.
- Se cumplen las normativas, leyes, reglamentos y buenas prácticas que son de aplicación en el ámbito de la seguridad de la información.

3.4. Tipos de auditoría

Cuando se plantea la realización de una auditoría de seguridad, se puede enfocar desde dos puntos de vista:

- **Centrada en la operativa específica** de los sistemas TI. Auditorías específicas de ciberseguridad, de sistemas SCADA de control industrial, de aseguramiento de la ciberresiliencia, etc.
- Como **complemento a otras auditorías** de cumplimiento normativo.

3.5. Desarrollo y ejecución

Siguiendo las directrices de las guías publicadas por el CCN-CERT en relación al Esquema Nacional de Seguridad, en el proceso de ejecución de una auditoría de seguridad tendremos que llevar a cabo las siguientes fases o hitos:

- **Definición y alcance de la auditoría:** primer paso a realizar entre el equipo auditor y la organización, a través del cual se determina el ámbito de actuación de la auditoría y el nivel de detalle de la misma.
- **Configuración del equipo auditor:** puede tratarse de un equipo interno (auditorías internas) o externo, pero siempre debe garantizar los conocimientos suficientes en relación al alcance establecido. El equipo auditor no debe limitarse a la simple revisión documental, sino que debe verificar por sí mismo aquello que es objeto de la auditoría. Puede estar apoyado por expertos en temas específicos.
- **Planificación:** En esta etapa se planifica la ejecución de la auditoría, estableciendo los requisitos de información y documentación necesarios para llevar a cabo el proceso de auditoría. En concreto, en este punto se debe:
 - Establecer y desarrollar el propio plan de auditoría.
 - Especificar y concretar los conocimientos requeridos al equipo de auditoría.
 - Definir el calendario de revisiones, reuniones de trabajo y entrevistas al personal, así como el personal objeto de las mismas.
 - Definir las revisiones y pruebas que serán efectuadas.
 - Asignar las tareas a los distintos miembros del equipo auditor, así como a los posibles expertos externos que apoyen al equipo auditor.
 - Concretar los criterios de auditoría.
- **Recogida de evidencias** como resultado de las revisiones y pruebas realizadas.
- **Presentación de hallazgos** de la auditoría: se trata aquí de confirmar los hechos y situaciones que se han detectado en las pruebas realizadas.
- **Informe de auditoría:** realizado de acuerdo al nivel de detalle definido de antemano.
- **Dictamen final:** donde se indican las conclusiones y el resultado de la auditoría.

4. PLAN DIRECTOR DE SEGURIDAD

Otro instrumento de gran utilidad en la gestión de la seguridad de la información en cualquier organización es la definición de un plan director de seguridad. Un plan director define la estrategia en seguridad TIC de la organización durante un período de tiempo acotado, identificando y detallando las actuaciones a realizar durante ese período y alineando todas las áreas de la organización con dicha estrategia.

A través de su desarrollo y posterior implantación se logran evitar algunos de los problemas más habituales en los entornos TI: iniciativas disparejas y tomadas de forma aislada en cada área de la organización, sistemas e infraestructuras heterogéneos, diferentes requisitos de seguridad dentro de la misma organización, etc.

Por definición, debe cubrir todos los dominios de seguridad:

- Seguridad física.
- Control de accesos.

- Gestión de redes y equipos informáticos.
- Mantenimiento y desarrollo de sistemas.
- Adecuación a la legislación vigente (especialmente en protección de datos)
- Organización de la seguridad.
- Política de seguridad.
- Seguridad del personal.
- Continuidad del negocio.
- Control de inventario.

Una de las normas de referencia para la elaboración de un plan de este tipo es la norma ISO 27002 que estudiaremos en la próxima unidad, dentro del marco de la normativa en gestión de la seguridad de la información.

4.1. Objetivos

Los objetivos principales de un plan director de seguridad son:

- Establecer de forma clara el compromiso con la seguridad de la información.
- Definir objetivos y criterios en seguridad.
- Definir las bases del marco normativo de seguridad y alinearlas con la legislación vigente.
- Definir la estructura organizativa que gestionará y velará por el cumplimiento de las normas establecidas.
- Conocer y planificar las inversiones y costes asociados a la seguridad de la información.
- Aportar confianza sobre los servicios ofrecidos.

4.2. Factores clave para el éxito

Desde el momento en que se plantea un plan director de seguridad, es fundamental asegurar algunos aspectos clave para llevarlo a buen término:

- **Compromiso de la dirección.** Al igual que en los sistemas de calidad, si la alta dirección de la organización no comparte los objetivos de trabajo, difícilmente podrá realizarse un trabajo de estas características.
- Designar un **responsable** del plan. Entre sus funciones estarán: conocer la metodología a aplicar, presentar y difundir el trabajo a los actores implicados, participar y coordinar las distintas actividades, revisar documentos, etc.
- Determinar un **marco metodológico**. Puede basarse en las recomendaciones de la ISO 27000, del Esquema Nacional de Seguridad o de cualquier otra normativa específica de referencia.
- Asignar **recursos y medios**, manteniéndolos durante todo el proceso de elaboración del plan.
- Realizar un **seguimiento permanente** de todas las acciones y sus resultados.

4.3. Desarrollo y resultados

De forma general, en el proceso de realización de un plan director de seguridad se han de tener en cuenta las siguientes fases de actuación, similares y complementarias a las que hemos visto en los apartados anteriores:

1. Identificar las necesidades en cuanto a organización de la seguridad.
2. Realizar un inventario de activos y realizar una valoración de su criticidad.
3. Realizar un análisis de riesgos.
4. Alinear e incluso integrar la seguridad con la estrategia de negocio.
5. Gestionar los riesgos y realizar un seguimiento permanente.

Como resultado del plan se debe obtener información sobre aspectos fundamentales para salvaguardar la seguridad de la información. En particular, sobre:

1. Estado de las medidas de seguridad actuales y sus puntos débiles.
2. Hasta dónde queremos llegar: nivel de seguridad deseado.
3. Relación de necesidades vinculadas a la seguridad de la información.
4. Proyecto de implantación y hoja de ruta de las acciones a desplegar.
5. Estudio económico de la inversión requerida en función de los proyectos incluidos en el plan director.
6. Análisis de costes y recursos.

5. PLAN DE RESPUESTA ANTE INCIDENTES

Se denomina incidente a cualquier situación o evento que pueda ocasionar la pérdida total de un servicio o su degradación, o que afecte a las dimensiones de la seguridad. La causa de un incidente podrá ser fortuita o intencionada, pero, en cualquier caso, requerirá de una respuesta, formada por un conjunto de acciones que restauren el servicio lo antes posible y minimicen los tiempos de parada. En este apartado se indican las pautas básicas para definir un plan de respuesta ante incidentes, siguiendo las directrices marcadas tanto por las buenas prácticas en gestión de la Seguridad como por la legalidad vigente.

Un plan de respuesta ante incidentes supone plasmar documentalmente una relación de actividades y tareas destinadas a dar respuesta a cualquier incidente genérico que afecte a la seguridad de la información en una organización determinada.

A modo de orientación, se muestra a continuación una relación de estas posibles actividades y tareas, sin que suponga una limitación para que cada organización adecúe a sus especificidades las propuestas a continuación:

1. **Definición del “Equipo de Respuesta ante Incidentes” o CSIRT** (*Computer Security Incident Response Team*). Supone el eje de control ante un incidente de seguridad y debe estar formado por personal no sólo cualificado sino con responsabilidad para cubrir todas las posibles áreas expuestas.
2. **Recopilación de procedimientos de actuación:** es necesario disponer de un conjunto de protocolos de actuación claros y concisos sobre la restauración de los servicios y de los datos que pudiesen resultar dañados o destruidos. Incluirá tanto las acciones técnicas como las derivadas de la legislación vigente.

3. **Detección y análisis de incidentes:** por una parte implica rastrear posibles síntomas de un ataque en base a la información proporcionada por los sistemas. Por otra, documentar las pautas de actuación para identificar el tipo de ataque, valorar la gravedad del peligro y poder actuar en consecuencia.
4. **Contención del daño y reducción de riesgos:** relación de acciones a tomar para minimizar el impacto del ataque y de los daños que éste pueda ocasionar, al tiempo que se evita destruir pruebas necesarias a posteriori para la identificación y rastreo del atacante.
5. **Recuperación de servicios:** una vez neutralizado el ataque es necesario recuperar los sistemas, recuperando la información dañada en base a las políticas de Copias de Seguridad.
6. **Plan de comunicación:** es fundamental definir a priori la gestión de la información que la organización debe comunicar a terceros como consecuencia del incidente sufrido, tanto a efectos de comunicación a los clientes como la posible necesidad de comunicación a los Cuerpos y fuerzas de Seguridad del Estado. Una mala gestión en este apartado puede generar más daño que la pérdida de la información ocasionada por el ataque.
7. **Valoración de daños y estimación económica:** este paso será fundamental para cuantificar el alcance del incidente y la repercusión económica para la organización.
8. **Revisión del proceso y actualización de políticas internas:** terminadas las tareas de neutralización del ataque y recuperación de servicios, procede realizar un análisis crítico de los sistemas y la revisión de las políticas de la organización para prevenir situaciones similares en el futuro.

6. PLAN DE CONTINUIDAD DEL NEGOCIO

Aunque existen otros mecanismos o instrumentos vinculados a la gestión de la seguridad, finalizaremos esta unidad con un conjunto de documentos que resulta básico en la sistematización de la **resiliencia** de las organizaciones, entendida ésta como la “capacidad de la organización de recuperarse frente a la adversidad y seguir proyectando el futuro”: Se trata del denominado PCN o **plan de continuidad del negocio**, que aglutina diversos planes para facilitar a las organizaciones la prevención, protección y reacción ante incidentes de seguridad. Para ello, un PCN establece la continuidad en las operaciones de la organización desde múltiples perspectivas: logística, infraestructuras físicas, sistemas de comunicación, infraestructura TI, seguridad, etc.

6.1. Objetivos

El objetivo principal de un plan de este tipo es la reanudación de las operaciones de la organización, en el menor tiempo posible, ante cualquier contingencia.

Así, los objetivos desde una perspectiva general serán:

- Evitar todo tipo de pérdidas (vidas humanas, información, recursos, etc.)
- Mantener la confianza en la empresa.
- Garantizar la comunicación con los clientes y proveedores esenciales.
- Proteger el medio ambiente.

Y más concretamente, definir una serie de objetivos específicos:

- Mantener el nivel de servicio en ciertos umbrales predefinidos.

- Evitar que las actividades de la organización se vean interrumpidas.
- Recuperar la situación inicial ante un incidente de seguridad.
- Definir los tiempos mínimos de recuperación.

6.2. Fases para el desarrollo de un PCN

El trabajo de elaboración del PCN implica el análisis de todos aquellos factores que favorecen la continuidad de los servicios ante una contingencia. Para ello han de desarrollarse las siguientes etapas:

Fase 1: Definición del alcance. Al igual que lo comentado en apartados anteriores, lo principal es concretar y acotar *hasta dónde* se va a llegar. De hecho, es más efectivo comenzar con un alcance modesto y en los departamentos más asequibles, que tratar de abarcar toda la organización en el primer intento.

Fase 2: Análisis de la organización. En este punto se recogerá toda la información requerida para identificar los procesos de negocio críticos, sus activos y recursos asociados. Se trata de una de las fases más críticas y extensas ya que conlleva diversas actuaciones:

- Reuniones con el personal afectado por el alcance definido en la fase anterior.
- Análisis del impacto sobre el negocio: se debe estudiar para cada proceso de negocio crítico identificado, considerando los siguientes parámetros:
 - RTO o Tiempo de recuperación: tiempo que transcurre desde la parada de un proceso hasta que se logra recuperar su funcionamiento.
 - Recursos implicados en el proceso: análisis de las dependencias que cada proceso tiene de la infraestructura TI (software, sistemas, almacenamiento, etc.)
 - MTD o Tiempo máximo tolerable de caída: El tiempo máximo que un proceso puede permanecer inactivo antes de que las consecuencias para la organización sean dramáticas. El MTD ha de ser superior al RTO.
 - ROL o niveles mínimos de recuperación de servicio: Se trata del nivel mínimo de funcionamiento que debe tener un proceso para darlo por recuperado. No se requiere que llegue a su estado óptimo.
 - RPO o grado de dependencia de la actualidad de los datos. Este valor mide el impacto sobre la actividad que tiene la pérdida de datos y condicionará muy especialmente la política de copias de seguridad.
 - Dependencias de otros procesos internos o proveedores externos.
- Análisis de riesgos: es preceptivo, pero típicamente, un PCN forma parte de un sistema de gestión de la seguridad de la información, como los estudiados en la siguiente unidad, y por tanto, la organización ya estará inmersa en el desarrollo de un análisis de riesgos, según alguna metodología reconocida.

Fase 3: Definir la estrategia de continuidad. Ante una adversidad se ha de saber si se podrán recuperar los activos asociados a procesos críticos en el tiempo requerido o, por el contrario, será necesario establecer estrategias de recuperación alternativas.

Fase 4: Respuesta. En base a la información recopilada en la fase anterior, se identificarán las actuaciones necesarias, documentándolas en el plan de crisis, incluyendo los protocolos para la recuperación de cada entorno.

Fase 5: Pruebas, mantenimiento y supervisión. Se elaborará un plan de pruebas que recogerá la relación de acciones y su periodicidad.

Fase 6: Concienciación. Se trata de trasladar a todo el personal no solo el contenido del PCN, sino el papel específico que cada uno de ellos juega dentro del mismo y las actuaciones concretas en caso de contingencia.

La principal referencia nacional en la elaboración de este tipo de planes es la documentación aportada por el Instituto Nacional de Ciberseguridad (Incibe), en su portal web, aunque existe diversa documentación específica, como la norma ISO 22301, relativa a la continuidad del negocio en las organizaciones.

ACTIVIDADES

1. Identificar los activos vinculados a un servicio de gestión de llamadas de emergencias. A efectos de considerar activos se tendrán en cuenta sólo los vinculados a la gestión telefónica de las llamadas. Realizar una tabla de valoración de dichos activos en función de la criticidad para la organización.
2. Clasificar las posibles amenazas según su tipología e identificar dentro de cada tipología las más importantes. Identificar las posibles salvaguardas asociadas a los activos anteriores.
3. Realizar un pequeño análisis de riesgos de carácter cualitativo, en base a la información recopilada en los apartados anteriores, sobre el servicio de atención de llamadas de emergencias.
4. Establecer los elementos básicos de una auditoría de seguridad y de un plan director de seguridad del servicio de gestión de llamadas de emergencias descrito anteriormente.
5. Establecer los elementos básicos de un plan de respuesta ante incidentes y de un plan de continuidad del negocio para el servicio de gestión de llamadas de emergencias descrito anteriormente.

BIBLIOGRAFÍA

Martínez, Juan Gaspar. (2006). Plan de Continuidad de Negocio. Guía Práctica para su Elaboración. Madrid. Díaz de Santos.

Ministerio de Administraciones Públicas (2012). MAGERIT V3 – versión 3. Madrid.

Piattini, Mario; Del Peso, Mario y Del Peso, Mar (2008). Auditoría de Tecnologías y Sistemas de información. Madrid. Ra-Ma.

Guías CCN-STIC

Guía 802- Guía de Seguridad de las TIC. Auditoría ENS.

Guía 817- Guía de Seguridad de las TIC. Gestión de Ciberincidentes.

Recursos en Internet

Catálogo general de publicaciones oficiales: <https://publicaciones.administracion.es>

Centro Criptológico Nacional (CCN-CERT): <https://www.ccn-cert.cni.es/>

Instituto Nacional de Ciberseguridad: <https://www.incibe.es>

Plan Director de Seguridad. Incibe.

https://www.incibe.es/sites/default/files/contenidos/dosieres/metad_plan-director-seguridad.pdf

Portal de Administración Electrónica: <https://administracionelectronica.gob.es>

Repositorio de Guías CCN-STIC: <https://www.ccn-cert.cni.es/guias/indice-de-guias.html>

EJERCICIOS DE AUTOEVALUACIÓN

1. ITIL es:
 - a. Una normativa en seguridad de la información.
 - b. Una metodología para la realización de análisis de riesgos.
 - c. Una biblioteca de buenas prácticas en la provisión de TI.
 - d. Una biblioteca de apoyo a la realización de auditorías de seguridad.
2. Definimos el riesgo como:
 - a. La probabilidad de que ocurra un evento que puede tener un impacto positivo o negativo en la organización.
 - b. La probabilidad de que ocurra un evento adverso que supone un impacto negativo en caso de ocurrir.
 - c. La probabilidad de que una amenaza nunca ocurra.
 - d. La posibilidad de que un evento adverso no se produzca.
- 3.Cuál de las siguientes no es una metodología reconocida de análisis de riesgos:
 - a. MAGERIT.
 - b. EBIOS.
 - c. ITIL.
 - d. CRAMM.
- 4.Cuál de las siguientes tareas no corresponde a la realización de una auditoría informática:
 - a. Recoger, agrupar y evaluar evidencias para determinar si un sistema de información protege el activo empresarial.
 - b. Verificar que se mantiene la integridad de los datos.
 - c. Verificar que el sistema realiza de forma eficaz los fines de la organización y utiliza eficientemente los recursos.
 - d. Identificar las amenazas y proponer salvaguardas para proteger a la organización.
- 5.Cuál de los siguientes no es factor crítico de éxito en un plan director de seguridad:
 - a. Realizar un análisis de riesgos.
 - b. Compromiso de la dirección.
 - c. Designar un responsable del plan.
 - d. Establecer el marco metodológico.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	c
2	b
3	c
4	d
5	a

GLOSARIO

AENOR: Antigua Asociación Española de Normalización y Certificación. A partir de 2017, AENOR Internacional, S.A.U. se ocupa de las operaciones mercantiles de la UNE, como evaluación de conformidad y formación.

Agile: Metodología para el desarrollo de software basada en el trabajo colaborativo, la autoorganización y la responsabilidad, alineando el trabajo con las necesidades del cliente en todo momento.

Cloud Computing: En español “computación en la nube”, consiste en disponer de servicios que tradicionalmente se han ofrecido en modo local, a través de un acceso a Internet, abstrayendo las necesidades de hardware al cliente y facilitando la escalabilidad de forma ágil y efectiva.

DevOps: Metodología para el desarrollo de software basada en coordinar el trabajo de los desarrolladores de software con los técnicos de sistemas, con el objetivo de generar productos de software de manera más eficiente y eficaz.

IEC: International Electrotechnical Commission. Comisión electrotécnica internacional. Organización internacional de normalización en los campos eléctrico, electrónico y tecnologías relacionadas.

ISO: International Standards Organization. Organización Internacional de Estándares. Organismo internacional independiente y no gubernamental formado por las organizaciones de estandarización de sus 163 países miembros.

Lean: metodología originalmente desarrollada por Toyota, destinada a la mejora de procesos basada en un ciclo de mejora continua, simplificando las actividades implicadas en los procesos, eliminando las que no aportan beneficio o mejoras en la calidad para el cliente final.

MAGERIT: Metodología para el análisis y gestión de riesgos de los sistemas de información, desarrollada por el Consejo superior de administración electrónica en España.

PILAR: Herramienta promovida por el CCN-CERT para realizar el análisis de riesgos de sistemas de información según la metodología MAGERIT.

SCADA: Acrónimo de “*Supervisory Control and Data Acquisition*” (Supervisión, control y adquisición de datos) es un tipo de software dedicado al control y supervisión de procesos industriales.

UNE: Asociación Española de Normalización. Entidad privada sin fines lucrativos. UNE también hace referencia tanto al conjunto de normas y estándares creados por la antigua AENOR, como a las nuevas que desarrolla esta asociación. UNE representa en España a ISO, IEC y otros organismos internacionales.

UA 6. Legislación y normativa en seguridad de la información

PRESENTACIÓN

Para cerrar la visión del mosaico que configura los distintos aspectos de la seguridad de la información se estudian en esta unidad la legislación, de obligado cumplimiento, y la normativa recomendada, basada en estándares internacionales.

Se comienza así con una breve revisión de la legislación europea y española, relacionada directa o indirectamente con la gestión de la Seguridad, agrupada en los ámbitos de infraestructuras críticas, protección de datos personales, ciberseguridad y comunicaciones electrónicas.

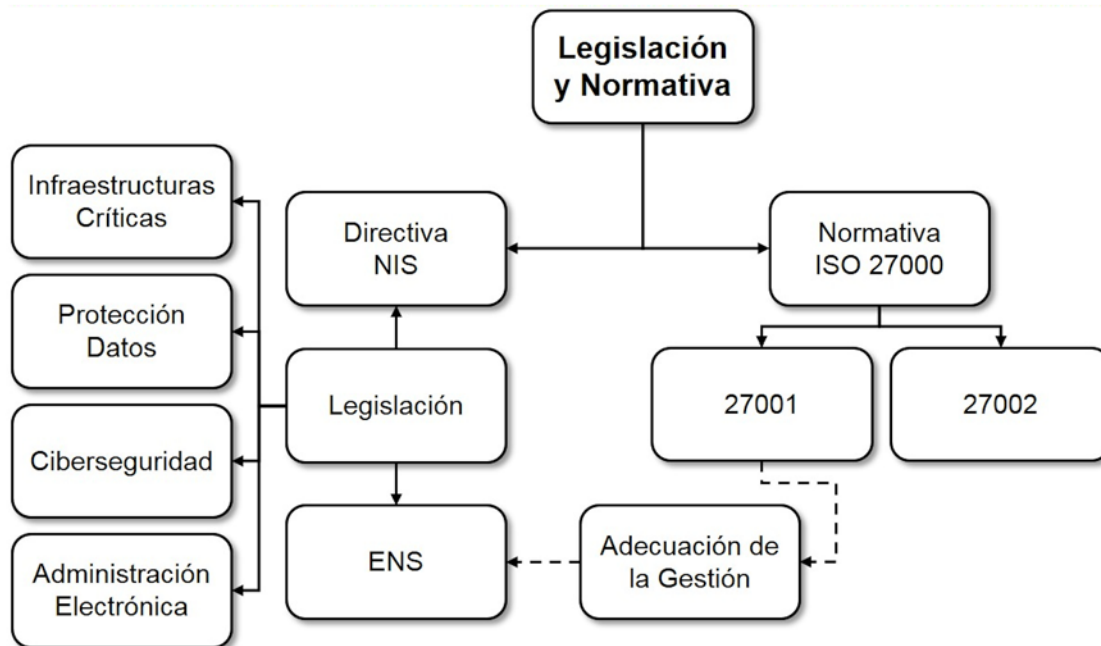
Se desarrollan con más detalle las directrices europeas como el Reglamento General de Protección de Datos o la denominada Directiva NIS y sus respectivas trasposiciones en leyes nacionales. También se estudia el Esquema Nacional de Seguridad (ENS), como una de las leyes más importantes en el sector de la Administración Pública. Sienta las bases de la seguridad en este ámbito y es de obligado cumplimiento en todas las administraciones públicas del territorio nacional. Asimismo, también afecta al sector privado, en tanto en cuanto éste se relaciona con la Administración.

Posteriormente se trata la normativa más reconocida a nivel internacional, como es la familia de normas ISO 27000, relativas al desarrollo y mantenimiento de un SGSI (Sistema de Gestión de la Seguridad de la Información), finalizando con propuestas de adecuación de la gestión según esta normativa al ENS.

OBJETIVOS

- Conocer la legislación española y europea de relevancia en relación con la seguridad de la información.
- Conocer los aspectos básicos de la directiva NIS y su ley de aplicación y del Reglamento General de protección de datos y la ley LOPDyGDD.
- Conocer la legislación de referencia del Esquema Nacional de Seguridad y las guías de su desarrollo publicadas por el Centro Criptológico Nacional.
- Conocer los fundamentos y técnicas básicas asociados al cumplimiento del Esquema Nacional de Seguridad.
- Conocer los fundamentos y técnicas básicas asociados al desarrollo de un sistema de gestión de seguridad de la información, acorde con las normas ISO 27001 y 27002.

ESQUEMA DE CONTENIDOS



EXPOSICIÓN DE LOS CONTENIDOS

1. LEGISLACIÓN

En este apartado veremos el conjunto de directrices, leyes y decretos que conforman el marco legal que, de una manera u otra, afectan a los distintos aspectos de la Seguridad de la Información.

Se ha agrupado este marco legislativo en cuatro grandes bloques: infraestructuras críticas, protección de datos personales, ciberseguridad y por último, comunicaciones y administración electrónica.

Posteriormente, aunque son citados en los bloques anteriores, se desarrollan con más detalle, por sus implicaciones en la legislación española, la directiva europea NIS y el Reglamento europeo de protección de datos personales.

1.1. Infraestructuras críticas

- Ley 8/2011, de 28 de abril, por la que se establecen las medidas para la **protección de las infraestructuras críticas**.
- Real Decreto 704/2011, de 20 de mayo por el que se aprueba el **Reglamento de protección de las infraestructuras críticas**.
- Resolución de 8 de septiembre de 2015, de la secretaría de Estado de seguridad, por la que se aprueban los nuevos contenidos mínimos de los planes de seguridad del operador de infraestructuras críticas y de sus planes de protección específicos.

1.2. Protección de datos personales

Antecedentes:

- Ley Orgánica 5/92 de Regulación del tratamiento automatizado de los datos de carácter personal de 29 de octubre (LORTAD): sustituida posteriormente por la LOPD, supuso la primera ley española que regulaba específicamente los datos de carácter personal.
- Directiva 95/46 CE de 24 de octubre del Parlamento europeo y del Consejo relativa a la protección de las personas físicas en lo referente al tratamiento de datos personales y a la libre circulación de estos datos. Motivó el desarrollo de la LOPD.
- Ley Orgánica 15/1999 de 13 de diciembre de **Protección de datos de carácter personal (LOPD)**: su objetivo es regular el tratamiento de los datos y ficheros de carácter personal, independientemente del soporte en el que son tratados (automatizados y no automatizados), los derechos de los ciudadanos sobre ellos y las obligaciones de quienes los crean o tratan, al tiempo que traspone la Directiva europea 95/46. Reemplazada por la publicación de la Ley Orgánica 3/2018, de 5 de diciembre.
- Real Decreto 1720/2007, de 21 de diciembre, por el que se aprueba el **Reglamento de desarrollo de la LOPD**, de protección de datos de carácter personal. Fuente de referencia fundamental para determinar los requisitos técnicos a implementar en función del nivel de los datos a proteger.

Legislación actual:

- Reglamento (UE) 2016/679 del Parlamento Europeo y del consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos)
- Real Decreto-Ley 5/2018, de 27 de julio, de medidas urgentes para la adaptación del Derecho español a la normativa de la Unión europea en materia de protección de datos. (derogado por la Ley Orgánica 3/2018, de 5 de diciembre)
- Ley Orgánica 3/2018, de 5 de diciembre, de **Protección de datos personales y garantía de los derechos digitales (LOPDyGDD)**. Se adapta al Reglamento (UE) 2016/679 y sustituye a la LOPD. Más adelante desarrollaremos sus principios básicos.

1.3. Ciberseguridad

- **Ley 34/2002 de Servicios de la sociedad de la información y de comercio electrónico (LSSI-CE)**: sienta las bases del régimen jurídico de los servicios de la sociedad de la información y de la contratación por medios electrónicos.
- En relación a esta Ley hay algunos aspectos especialmente destacables:
 - Incluye las obligaciones de los prestadores de servicios, de obligado cumplimiento para los casos en los que se obtiene un beneficio económico como consecuencia de la prestación de dichos servicios.
 - Regula las comunicaciones comerciales por medios electrónicos.
 - Establece un régimen sancionador.
 - Incluye aspectos relativos a la accesibilidad en las webs de las Administraciones públicas.
 - Regula la asignación de nombres de dominio bajo .es

- Real Decreto 3/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Seguridad** en el ámbito de la Administración Electrónica. Dada la importancia de este decreto, se desarrollará de forma más extensa a lo largo de este capítulo, pues define el marco de seguridad de la Administración Pública y con afectación incluso a las empresas que se relacionan con la Administración.
- Real Decreto 951/2015, de 23 de octubre, de modificación del Real Decreto 3/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Seguridad** en el ámbito de la Administración Electrónica.
- Resolución de 13 de octubre de 2016, de la Secretaría de Estado de Administraciones Públicas, por la que se aprueba la **Instrucción técnica de Seguridad de conformidad con el Esquema Nacional de Seguridad**.
- Real Decreto 4/2010, de 8 de enero, por el que se regula el **Esquema Nacional de Interoperabilidad** en el ámbito de la Administración Electrónica.
- Real Decreto 381/2015, de 14 de mayo, por el que se establecen medidas contra el tráfico no permitido y el tráfico irregular con fines fraudulentos en comunicaciones electrónicas.
- **Directiva NIS:** Directiva (UE) 2016/1148 del Parlamento Europeo y del Consejo, de 6 de julio de 2016 relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de información de la Unión Europea. Por su importancia, se desarrolla más adelante.
- **Estrategia Nacional de Ciberseguridad:** Orden PCI/487/2019, de 26 de abril por la que se publica la Estrategia Nacional de Ciberseguridad 2019, aprobada por el Consejo de Seguridad Nacional.
- **Trasposición de la Directiva NIS al ámbito nacional:** Real Decreto-ley 12/2018, de 7 de septiembre, de **seguridad de las redes y sistemas de información**. Se explica más adelante.

1.4. Comunicaciones y administración electrónica

- Ley 30/1992 de **régimen jurídico** de las **administraciones públicas** y del **procedimiento administrativo común**: incluye ya en su contenido la obligación para las Administraciones Públicas para aplicar técnicas y medios electrónicos, informáticos y telemáticos para el desarrollo de su actividad. Establece además la validez de los documentos emitidos por medios electrónicos, informáticos o telemáticos siempre que se asegure su autenticidad, integridad y conservación.
- Real Decreto 263/1996, de 16 de febrero por el que se regula la utilización de técnicas electrónicas, informáticas y telemáticas por la Administración General del Estado: desarrolla el artículo 45 de la Ley 30/92, vinculado al uso de medios telemáticos por parte de la Administración Pública.
- Directiva 1999/93/CE de 13 de diciembre por la que se establece un marco comunitario para la firma electrónica: establece los criterios para el reconocimiento jurídico de la firma digital. Se incluyen nuevos conceptos tales como: firma electrónica, firma electrónica avanzada y certificado reconocido.

- Directiva 2000/31/CE de 8 de junio sobre el comercio electrónico: su objetivo es reforzar la seguridad jurídica del comercio electrónico estableciendo un marco jurídico ajustando los servicios de la sociedad de la información a los principios del mercado interior. Introduce referencias a la contratación en línea y al spam como comunicaciones comerciales no autorizadas.
- Real Decreto 209/2003, de 21 de febrero por el que se regulan los registros y las notificaciones telemáticas, así como la utilización de medios telemáticos para la sustitución de la aportación de certificados por los ciudadanos.
- Ley 59/2003 de 19 de diciembre de Firma Electrónica. En la unidad 1 desarrollamos algunos conceptos de esta ley, como la distinción entre firma electrónica reconocida y avanzada.
- Directiva 2004/18/CE del Parlamento Europeo y del Consejo de 31 de marzo de 2004, sobre coordinación de los procedimientos de adjudicación de los contratos públicos de obras, de suministro y de servicio. Introduce la igualdad entre los medios electrónicos y los tradicionales, así como el concepto de “subasta electrónica”.
- Real Decreto 589/2005 por el que se reestructuran los órganos colegiados responsables de la Administración Electrónica: El antiguo Consejo Superior de Informática pasa a denominarse Consejo Superior de Administración Electrónica (CSAE) y asumen la responsabilidad de definir y aplicar la política y estrategia gubernamental en materia de tecnologías de la información.
- Ley 11/2007, de 22 de junio, de **acceso electrónico de los ciudadanos a los servicios públicos (LAECSP)**: de gran relevancia por sus consecuencias para los ciudadanos, supone un impulso decisivo a la relación de los ciudadanos con las Administraciones Públicas por medios electrónicos.
- Ley 56/2007, de 28 de diciembre, de **Medidas de impulso de la sociedad de la información**: destaca por los aspectos relativos a la **factura electrónica**.
- Ley 25/2007, de 18 de octubre, de conservación de datos relativos a las comunicaciones electrónicas y a las redes públicas de comunicaciones.
- Real Decreto 1671/2009, de 6 de noviembre, por el que se desarrolla parcialmente la Ley 11/2007 de 22 de junio, de acceso electrónico de los ciudadanos a los servicios públicos.
- Orden PRE/878/2010, de 5 de abril, por la que se establece el régimen del sistema de dirección electrónica habilitada previsto en el artículo 38.2 del Real Decreto 1671/2009, de 6 de noviembre. Supone la creación de la **Dirección Electrónica Habilitada (DEH)** para que cualquier persona física o jurídica pueda recibir notificaciones administrativas con carácter legal. Es accesible por todos los ciudadanos con carácter voluntario y es totalmente gratuita. Su página de referencia es: <http://notificaciones.060.es>. En el caso de las empresas, el Real Decreto 1363/2010, de 29 de octubre, establece la obligatoriedad para las empresas de recibir notificaciones de carácter tributario de forma electrónica.
- Ley 9/2014, de 9 de mayo, General de Telecomunicaciones.
- Directiva (UE) 2018/1972 del Parlamento Europeo y del Consejo de 11 de diciembre de 2018 por la que se establece el Código Europeo de las Comunicaciones Electrónicas.

1.5. Directiva NIS

Dada su relevancia como marco general de la ciberseguridad en el contexto europeo y nacional, a través de la trasposición de esta Directiva, trataremos con un poco más de detalle esta norma y las implicaciones para la seguridad que conlleva.

La Directiva fue aprobada el 6 de julio de 2016, entrando en vigor el 9 de agosto de ese mismo año. Incluyó un plazo de 21 meses para que los Estados pudieran adaptar sus estructuras legales y administrativas a las nuevas obligaciones que finalizó el 9 de mayo de 2018.

Además de regular la seguridad de las redes y sistemas de información destinados a proporcionar servicios esenciales y digitales, **establece un sistema de notificación de incidentes obligatorio.**

Se contemplan 4 objetivos principales:

- Gestionar el riesgo.
- Proteger contra los posibles ciberataques.
- Detectar eventos de ciberseguridad.
- Minimizar el impacto de los incidentes.

La Directiva NIS establece 5 medidas principales:

1. Obliga a todos los estados miembros a definir una Estrategia Nacional de Seguridad de las redes y los sistemas de información.
2. Define la creación de un grupo de cooperación para consensuar una estrategia común y para garantizar el intercambio de información entre los estados miembros.
3. Conlleva la creación de una red CSIRT (Equipos de Respuesta a Incidentes de Seguridad Informática). Recordemos que CERT y CSIRT son la misma cosa.
4. Requiere que se establezcan condiciones de seguridad para los operadores de servicios esenciales (entidad pública o privada que preste un servicio de mantenimiento de actividades sociales o económicas y que dependa para ello de redes y sistemas de información) y proveedores de servicios digitales (persona jurídica que preste un servicio digital)
5. Implica obligaciones para las autoridades nacionales en todas las tareas relacionadas con la seguridad de redes y sistemas.

La trasposición de esta Directiva se hizo a través del Real Decreto-Ley 12/2018, de 7 de septiembre, de **seguridad de las redes y sistemas de información**. Entre otros aspectos, este Real Decreto-Ley:

- Identifica los Operadores de Servicios Esenciales y las medidas de seguridad que han de aplicar.
- Las Autoridades competentes.
- Identifica los CSIRT de referencia (CCN-CERT para organismos públicos, INCIBE-CERT para los privados y la red académica y ESPDEF-CERT para los organismos de defensa)
- Asigna al CCN-CERT la coordinación y respuesta técnica en casos de especial gravedad.

1.6. Reglamento Europeo de Protección de Datos

Aprobado en abril de 2016 y de obligado cumplimiento a partir del 25 de mayo de 2018, supone una importante actualización en la normativa de protección de datos personales en la UE y es de aplicación directa, sin necesidad de realizar trasposición a la legislación nacional.

El desarrollo de este reglamento parte de dos conceptos principales:

Dato personal: “toda información sobre una persona física, identificada o identificable”, entendiéndose como *persona física identificable* a toda persona cuya identidad pueda determinarse directa o indirectamente. Esto significa que se consideran datos personales, entre otros: nombre, DNI, datos de localización, dirección IP, fisiología, genética, etc.

Tratamiento: “Cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no automatizados, así como la recogida, organización, estructuración, conservación, adaptación o modificación, extracción, consulta utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo, interconexión, limitación, supresión o destrucción.”

- Además de profundizar en la protección de los derechos de las personas en relación a los datos que las identifican, destacan algunas novedades:
- Creación de la figura del **Delegado de Protección de Datos**, y establecimiento de las condiciones para su obligada designación en determinadas organizaciones.
- El anterior modelo, basado en **ficheros de datos**, evoluciona hacia el **tratamiento de datos**. El enfoque de la nueva normativa cambia radicalmente las funciones de la Agencia de Protección de Datos, ya no se inscriben los ficheros y el enfoque se centra en el “tratamiento”.
- **Obligatoriedad de comunicación de incidentes:** Notificar las violaciones de datos a las autoridades de supervisión y a las personas afectadas dentro de 72 horas después de haber tenido conocimiento de ello.
- El régimen sancionador incorpora **sanciones de hasta 20.000.000 €** o de una cuantía equivalente **al 4 % del volumen de negocio** total anual global del ejercicio financiero anterior, si el infractor es una empresa.
- Incorpora la **obligación a todas las organizaciones de analizar las vulnerabilidades informáticas** y posibles brechas de seguridad lógica con el objeto de seleccionar e implementar las soluciones tecnológicas más óptimas para impedir, bloquear o neutralizar los ataques.
- Establece las condiciones por las que las organizaciones deberán efectuar una **evaluación del impacto** que los tratamientos de datos que realizan tienen sobre la protección de datos personales.

Aunque este Reglamento es de aplicación directa en todos los países miembros, en España ha obligado a actualizar la LOPD, publicándose en diciembre de 2018 la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de datos personales y garantía de los derechos digitales (LOPDyGDD), que incorpora las directrices del RGPD, aplicando el enfoque hacia el “tratamiento de datos” y modificando como hemos dicho una de las misiones principales de la Agencia Española de Protección de Datos.

2. ESQUEMA NACIONAL DE SEGURIDAD

2.1. Introducción

El 29 de enero de 2010 se publicó en el Boletín Oficial del Estado el real Decreto 3/2010 de 8 de enero a través del cual se regula el Esquema Nacional de Seguridad (ENS) dentro del ámbito de la Administración Electrónica. Aunque lo hemos considerado en el ámbito de la legislación en materia de ciberseguridad, ya que ha sido promulgado mediante decretos-ley, se considera una normativa de carácter obligatorio en materia de seguridad de la información y por ello lo estudiaremos con más detalle.

El ENS define la política de seguridad que debe aplicarse en el uso de los medios electrónicos, conteniendo los principios básicos y requisitos mínimos para garantizar una adecuada protección de la información, asegurando el acceso, integridad, disponibilidad, autenticidad, confidencialidad, trazabilidad y conservación de los datos.

Partiendo de una visión integral de la seguridad, que engloba todos los elementos técnicos, humanos, materiales y organizativos relacionados con el sistema, el ENS tiene como objetivos principales:

- Aportar confianza a los ciudadanos en el ejercicio de sus derechos y deberes con la Administración pública por medios telemáticos.
- Establecer la política de seguridad en la utilización de medios electrónicos.
- Crear un marco común para la actuación de las Administraciones Públicas en materia de seguridad de las tecnologías de la información.
- Definir un lenguaje homogéneo para facilitar la interacción entre las distintas administraciones y la comunicación de los requisitos de seguridad de la información a la industria.

Dentro del Esquema Nacional de Seguridad se identifica la “seguridad” como *“la capacidad de las redes y sistemas de información de resistir con un determinado nivel de confianza aquellos accidentes o acciones que comprometen la disponibilidad, autenticidad, integridad y confidencialidad de la información que es almacenada o transmitida, así como de los servicios de dichas redes o sistemas”*.

A través del Real Decreto que concreta el ENS, se establecen los requisitos básicos y requisitos mínimos para dar una protección adecuada a la información y servicios, sentando las bases de una regulación homogénea del marco normativo de la seguridad en redes y sistemas de las Administraciones Públicas.

2.2. Ámbito Legal y de Aplicación

El Esquema Nacional de Seguridad es de obligada aplicación en la Administración General del Estado. Esto incluye a:

- Las administraciones de las comunidades autónomas.
- Las entidades que integran la administración local.
- Las entidades de derecho público con personalidad jurídica propia vinculadas o dependientes de las administraciones públicas.

En concreto, también se incluyen las **universidades** como organismos autónomos con vinculación a las Comunidades autónomas.

Únicamente quedan **excluidos** los sistemas que tratan **información clasificada**, regulada por la Ley 9/1968 de 5 de abril de Secretos Oficiales y normas de desarrollo.

Es importante destacar que, aunque el ENS no es, por defecto, de obligado cumplimiento para el sector privado, en la Guía CCN-STIC 830 se especifica que: “**las soluciones tecnológicas o los servicios** comprendidos dentro del ámbito objetivo de aplicación del Esquema Nacional de Seguridad, cuando sean suministrados o prestados por **organizaciones privadas, habrán de satisfacer las exigencias legales establecidas en el mismo**”. Por tanto, en la práctica cualquier empresa privada que se relacione con el ámbito de la Administración Pública tendrá la necesidad de adecuarse al Esquema Nacional de Seguridad.

2.3. Elementos Básicos del ENS

Los elementos básicos del Esquema Nacional de Seguridad son:

- Principios básicos a tener en cuenta a la hora de la toma de decisiones.
- Requisitos mínimos para garantizar la adecuada protección de la información.
- Adopción de medidas proporcionadas en función de la naturaleza y tipología de los servicios a proteger.
- Las comunicaciones electrónicas.
- La Auditoría de Seguridad.
- La Respuesta ante Incidentes de seguridad.
- La Certificación de Seguridad.
- La Conformidad.

Tras la publicación de este Real Decreto, el desarrollo del Esquema Nacional de Seguridad se completa con la redacción de numerosas guías CCN-STIC (guías publicadas por el Centro Criptológico Nacional). El CCN mantiene un repositorio de Guías STIC en el siguiente enlace: <https://www.ccn-cert.cni.es/guias/indice-de-guias.html>.

2.4. Esquema general de implantación

A nivel global, un proceso de implantación del Esquema Nacional de Seguridad consta del ciclo de actuaciones descrito en la figura 6.1.

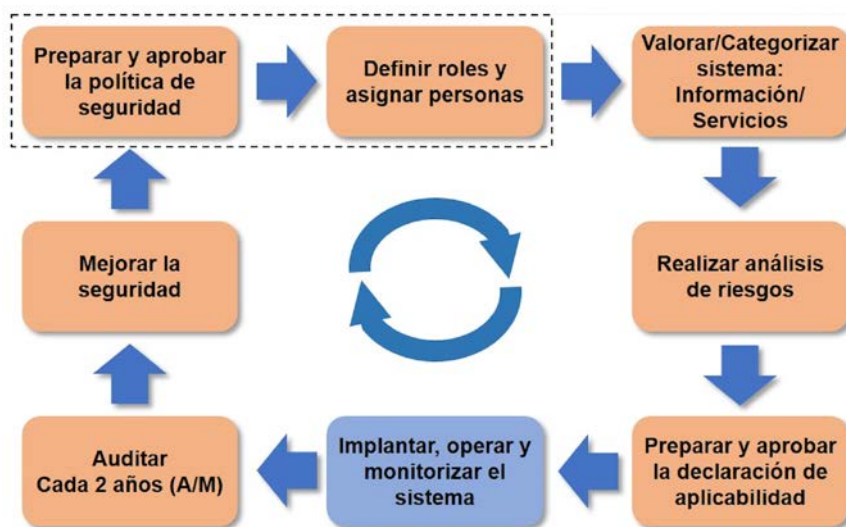


Figura 6.1.- Ciclo de actuaciones del ENS

Como apoyo a este proceso de implantación, el CCN-CERT ha publicado numerosas guías de apoyo. A continuación, se muestra un resumen de las etapas de implantación y la guía o guías que servirán de referencia en cada punto:

- a. Preparar y aprobar la Política de Seguridad: Guía CCN-STIC 805 - Política de seguridad de la información.
- b. Asignación de roles y personas: Guía CCN-STIC 801 - Seguridad de las TIC.
- c. Categorización de los sistemas: Guía CCN-STIC 803: - Valoración de sistemas en el ENS. Podrán categorizarse con la clasificación Básica, Media o Alta.
- d. Análisis de Riesgos: Magerit V3, con apoyo de la herramienta PILAR.
- e. Declaración de aplicabilidad: Guía CCN-STIC 804 - Medidas e implantación del ENS.
- f. Fase de implantación y monitorización.
- g. Auditoría: Guía CCN-STIC 802 - Auditoría del ENS y CCN-STIC 808 - Verificación del cumplimiento de las medidas del ENS.
- h. Mejorar la seguridad: Guías CCN-STIC 800 y Guía CCN-STIC 815: Indicadores y métricas en el ENS.

2.5. Declaración de conformidad

La conformidad con el ENS consiste en:

- La aplicación de las medidas requeridas en base a la categoría de los sistemas.
- Garantizar su mantenimiento durante el ciclo de vida del sistema, realizando las auditorías periódicas pertinentes.
- Reflejar en un informe el resultado de la auditoría:
 - El nivel de cumplimiento de las medidas de seguridad.
 - Deficiencias, medidas correctoras y propuestas de mejora.
 - Criterios utilizados.
 - Alcance y objetivo de la auditoría.
 - Hechos y evidencias.
 - Conclusiones.

En función de la categorización de los sistemas se establecen los siguientes requisitos para dar conformidad formal al ENS:

- **Categoría Básica:** únicamente se requiere una autoevaluación que verificará el cumplimiento de los requisitos contemplados en el esquema y tendrá una periodicidad de 2 años. La autoevaluación se podrá realizar por el mismo personal que administra los sistemas o delegarla en un tercero.

- **Categorías Media y Alta:** La conformidad en este ámbito requiere obligatoriamente un procedimiento de auditoría formal y se realizará, al menos, cada dos años. El resultado de la auditoría es un documento denominado “Certificación de Conformidad” que contendrá un distintivo de Certificación de Conformidad emitido por una entidad acreditada por la Entidad Nacional de Acreditación (ENAC). El Centro Criptológico Nacional mantiene en su sede electrónica una relación actualizada de las Entidades de Certificación acreditadas para expedir Certificaciones de Conformidad con el Esquema Nacional de Seguridad.

3. NORMATIVA ISO 27000 EN EL ÁMBITO DE LA SEGURIDAD DE LA INFORMACIÓN

3.1. Introducción

Además de la legislación de obligado cumplimiento, existe una amplia variedad de normas y estándares de cumplimiento voluntario que abarcan todos los ámbitos de la seguridad de la información, como las que estudiaremos a continuación.

Dentro de los estándares ISO/IEC se ha asignado el rango 27.000 para el ámbito de la seguridad de la información. Así pues, ISO 27.000 aglutina un conjunto de estándares internacionales vinculados a la seguridad de la información, incorporando un conjunto de buenas prácticas reconocidas para el establecimiento, implementación, mantenimiento y mejora de lo que se denomina SGSI o Sistema de Gestión de la Seguridad de la Información.

De todas las normas incorporadas en la familia ISO 27.000, la norma 27.001 es la más conocida, además de ser certificable, junto con la 27.002 que supone un código de buenas prácticas y no es certificable. De hecho, en la literatura relativa a la norma 27.001 se encuentra siempre una relación muy estrecha con la norma 27.002, ya que ambas son complementarias.

3.2. La norma ISO 27.001

La norma ISO 27001 es un estándar internacional de Sistemas de Gestión de Seguridad de la Información (SGSI), siendo la norma de referencia en este ámbito que permite a una organización evaluar su riesgo e implementar controles apropiados para preservar la confidencialidad, la integridad y la disponibilidad del valor de la información.

El estándar ISO/IEC 27.001 fue aprobado y publicado como estándar internacional en octubre de 2005 por la ISO (Organización Internacional de Normalización) y por la IEC (Comisión Electrotécnica Internacional) que conforman el sistema para la normalización internacional. Esta norma tiene su origen en la norma BS 7799-2:2002 desarrollada por el organismo de normalización británica (*British Standards Institution* o BSI)

En relación a su desarrollo en España, en el año 2004 se publicó la UNE 71502, adaptación de la norma británica BS 7799-2:2002. Posteriormente, con la publicación de la traducción de la ISO/IEC 27.001 (denominada UNE-ISO/IEC 27.001), la UNE 71502 dejó de estar vigente. La versión vigente en el momento de la redacción de este manual es la: UNE-EN ISO/IEC 27001:2017.

La base de la ISO 27001 consiste en la **implantación de un Sistema de Gestión de Seguridad de la Información (en adelante SGSI)**. Según la Norma UNE –ISO/IEC 27001, un SGSI una parte del sistema de gestión general, basada en un enfoque de riesgo empresarial, que se establece para: crear, implementar, operar, supervisar revisar, mantener y mejorar la seguridad de la información.

En una visión más cercana, diríamos que se trata de eliminar los elementos subjetivos en la gestión de la seguridad y desplegar una serie de **medibles** que permitan obtener información

objetiva sobre qué ocurre en los sistemas de información, pasando así a tener control sobre ellos y sobre la información almacenada.

Un SGSI es un sistema de gestión que comprende los siguientes elementos:

- Los modelos organizativos.
- Las políticas.
- La planificación.
- Las responsabilidades.
- Los procedimientos.
- Los procesos.
- Los recursos.

Para desarrollar un sistema de gestión de la seguridad de la información se emplea el denominado **ciclo PDCA**: Plan, Do, Check, Act, también llamado ciclo de Deming, ilustrado en la figura 6.4.

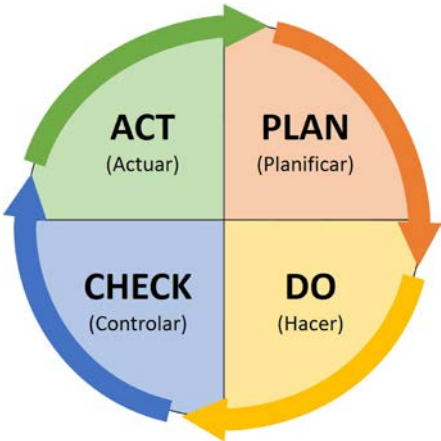


Figura 6.4. Ciclo de Deming

Este modelo PDCA plantea una serie de fases o etapas, resumidas en la tabla 6.1, con el objetivo de obtener indicadores y métricas para cuantificar el progreso de mejora en la organización.

Tabla 6.1. Etapas del Ciclo de Deming o PDCA.

Planificación: Crear el SGSI	Ejecución: Implementación SGSI
Identificar el proceso que se quiere mejorar. Recopilar datos para profundizar en el conocimiento del proceso. Análisis e interpretación de los datos. Establecer los objetivos de mejora. Detallar las especificaciones de los resultados esperados. Definir los procesos necesarios para conseguir estos objetivos, verificando las especificaciones.	Ejecutar los procesos definidos en el paso anterior. Documentar las acciones realizadas.

Seguimiento: Supervisar el SGSI	Mejora: Mantener y Mejorar
Pasado un periodo de tiempo previsto de antemano, volver a recopilar datos de control y analizarlos, comparándolos con los objetivos y especificaciones iniciales, para evaluar si se ha producido la mejora esperada. Documentar las conclusiones.	Modificar los procesos según las conclusiones del paso anterior para alcanzar los objetivos con las especificaciones iniciales, si fuese necesario. Aplicar nuevas mejoras, si se han detectado en el paso anterior. Documentar el proceso.

En el ámbito de la norma UNE-ISO/IEC 27001, se concibe la seguridad como un proceso en sí mismo. Por tanto, el grado de seguridad que se pretenda conseguir dependerá de cómo este proceso funcione y progrese.

3.3. La norma ISO 27002

Como hemos indicado, la norma ISO 27002 es un compendio de buenas prácticas y documentación de apoyo para la realización de un Sistema de gestión de seguridad de la información en aplicación de lo indicado en la norma ISO 27001.

La norma 27.002 se organiza en 11 capítulos que identifican otras tantas áreas de seguridad a tener en cuenta, con un total de 39 categorías de seguridad con sus correspondientes objetivos y controles asociados. Se incluye además un capítulo dedicado a la valoración y tratamiento del riesgo. En total se establecen 133 controles. En su anexo A se establece una relación detallada de controles a implementar para determinar las medidas de seguridad necesarias en aplicación de la norma ISO 27001.

En la figura 6.3 se muestra un esquema general de la estructuración de los contenidos de la norma 27.002.

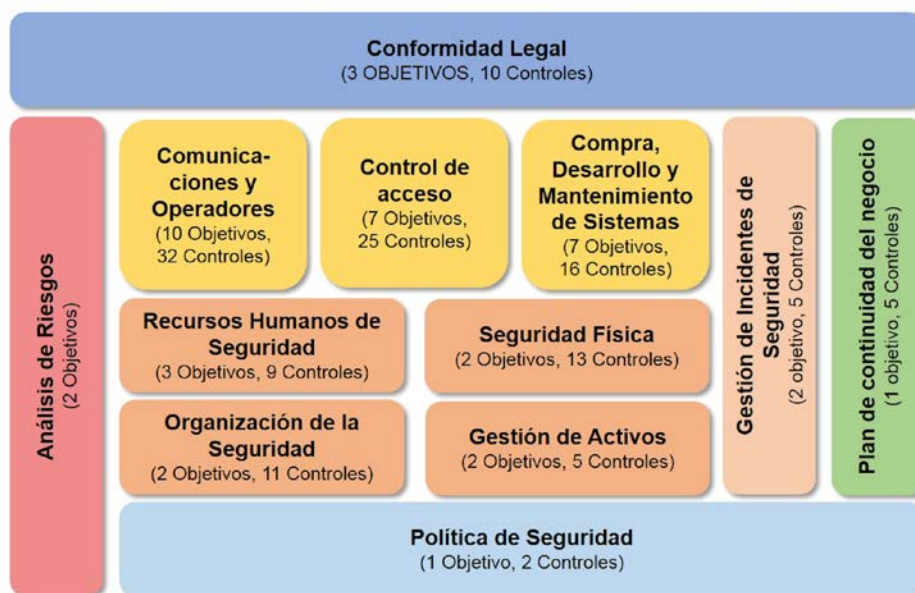


Figura 6.3.- Contenido de la Norma ISO 27002

3.4. El SGSI como eje del proceso de implantación de la ISO 27001

En el momento en que una organización comienza la implantación de un SGSI, debe tenerse en cuenta que el éxito o el fracaso vendrán dados principalmente en función de que se hayan logrado los siguientes prerequisites:

- **Compromiso de la dirección:** esto es fundamental en el despliegue de cualquier norma de calidad. Si la alta dirección no transmite a todos los estamentos la necesidad de implicarse y la priorización del trabajo asociado, será casi imposible la consecución de los objetivos deseados.
- **Planteamientos realistas:** el desarrollo de un SGSI es una tarea ardua y compleja. Por tanto, una adecuada gestión de los recursos será un elemento crucial para la implantación con éxito del SGSI

Además de lo anterior, es fundamental contar con:

- Sistema de Gestión Documental.
- Inventario de Activos.
- Sistema de Gestión de Incidentes de Seguridad.
- Garantizar el cumplimiento de la normativa aplicable.

3.4.1. Documentación relativa a un SGSI

Respecto a la documentación que será necesario realizar, ésta se organiza en varios niveles cuyo significado se detalla a continuación:

- **Políticas:** marcan las líneas generales de actuación estableciendo por escrito los objetivos generales y las implantaciones que ha llevado a cabo cada organización. Deben ser conocidas por todo el personal de la organización.
- **Procedimientos:** marcan las instrucciones para realizar las tareas programadas. Desarrollan los objetivos marcados por las Políticas y contienen detalles técnicos. Su difusión debe realizarse a aquellas personas que los necesitan para llevar a cabo sus funciones.
- **Instrucciones:** suponen el desarrollo a bajo nivel de los procedimientos, concretando todos los pasos a realizar para llevar a cabo una tarea.
- **Registros:** suponen la evidencia de que se han realizado las acciones previstas.

3.4.2. Etapas o fases para el establecimiento de un SGSI

La implantación de un SGSI conlleva siete etapas o fases, indicadas en la Figura 6.5.

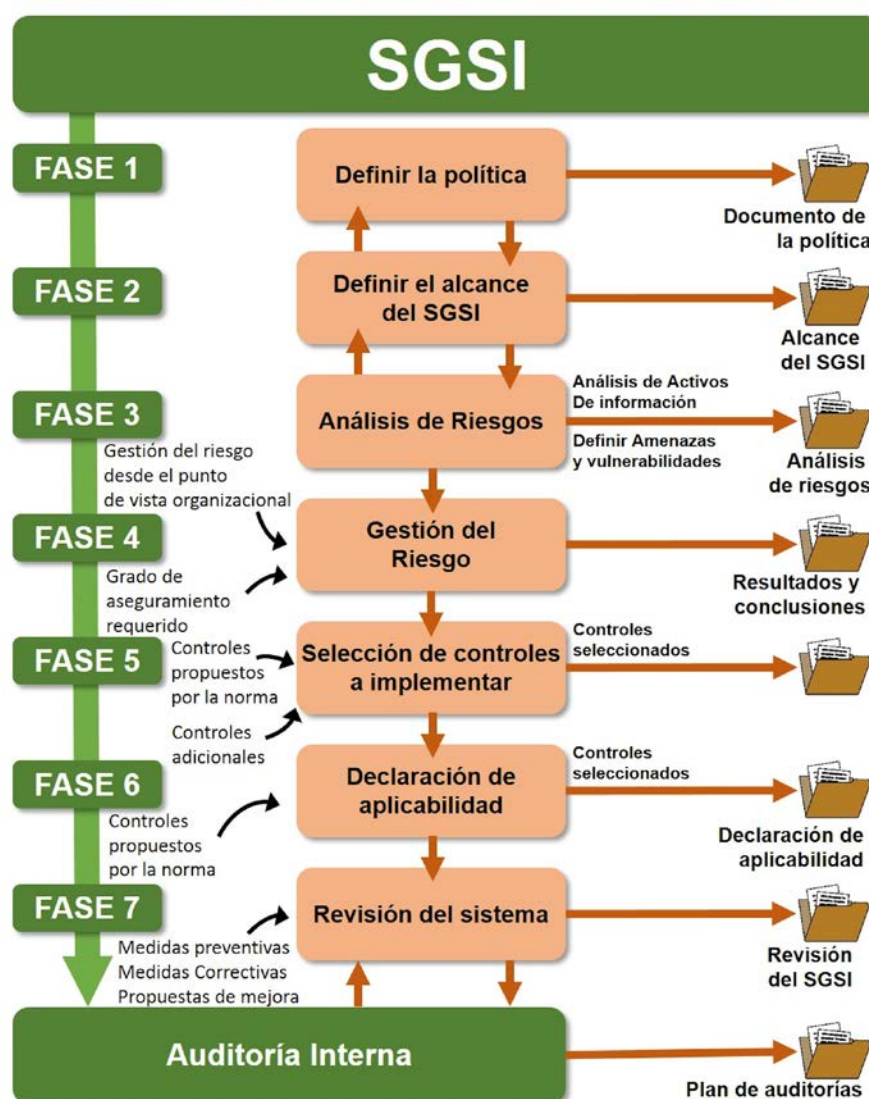


Figura 6.5. Etapas o Fases en el desarrollo de un SGSI

Fase 1: Definir la Política de Seguridad

En el capítulo 4 se trató en detalle el concepto de “Política de Seguridad”. Recordando su definición, entenderemos como tal aquella que tiene por objeto informar a todos los miembros de la organización (usuarios, trabajadores, directivos) de los requisitos para proteger la información.

Dado que la política forma parte de la organización en sí, debemos tener en cuenta los siguientes aspectos:

- Requisitos del negocio.
- Aspectos contractuales.
- Legislación aplicable.
- Legislación/normas internas relacionadas.

Una vez establecida la política de Seguridad, ésta debe ser transmitida a todo el personal, formalizando incluso su adhesión.

Fase 2: Definir el alcance del SGSI

En esta etapa la organización toma la decisión de qué proceso o procesos internos serán el objetivo de la aplicación del SGSI.

A pesar de ser una decisión aparentemente sencilla, siempre se corre el riesgo de querer abarcarlo todo, dando un ámbito al SGSI tan amplio que su implementación se convierte en un trabajo sin fin. Por ello, es fundamental concretar con claridad un ámbito de trabajo asumible por la organización, cuya visibilidad sea óptima (tanto dentro de la organización como fuera de ella)

Un ejemplo de alcance de un SGSI podría ser la “Atención de llamadas” dentro de una empresa cuyo negocio principal sea la gestión de *Call Centers*.

Fase 3: Análisis de Riesgos

Para llevar a cabo esta fase es necesario llevar a cabo las siguientes tareas, ya detalladas en la Unidad 5, donde se explicó en detalle un proceso genérico de análisis de riesgos. No olvidemos que la información es el activo más importante, que aporta valor añadido a la organización y, en consecuencia, debe estar adecuadamente protegida.

a. Identificar los activos relacionados con el alcance definido

Se trata no sólo de identificar todos los activos vinculados al proceso o procesos objeto del SGSI sino también a sus responsables.

Tras la identificación de los activos se procede a categorizarlos en función del valor que asociemos a cada uno. Este valor determina la importancia de dicho activo para el negocio de nuestra organización.

b. Definir el enfoque de análisis de riesgos

Antes de iniciar el Análisis de Riesgos, es necesario definir el enfoque que daremos al estudio. Para ello se deben concretar dos aspectos fundamentales:

- Nivel de detalle: mínimo o detallado.
- Grado de formalidad: cualitativo o cuantitativo.

c. Identificar los riesgos

Se trata de determinar los peligros a los que se enfrenta nuestra organización o, lo que es lo mismo, identificar los puntos débiles para poder priorizar de forma efectiva los recursos.

d. Análisis de los riesgos

El análisis de riesgos es el proceso que nos permitirá detectar los riesgos a los que están sometidos los activos de la organización, determinando la probabilidad de que las amenazas se conviertan en realidad.

En este proceso hay 3 conceptos clave:

- **Amenazas:** posibilidad de que se produzca una determinada vulnerabilidad con éxito.
- **Incidentes:** son los hechos que deben evitarse en la organización pues causan impacto en el negocio.
- **Impacto:** supone el nivel de afectación que provocan los incidentes en la organización en función de su amplitud y gravedad.

De la relación entre amenaza – incidente – impacto se obtendrá la prioridad de las acciones de seguridad que deben llevar a cabo relativas a la corrección de los activos que se desean proteger.

Ejemplos de la relación incidente-impacto:

1. Incidente: fallo en el suministro eléctrico a la central de compras. Como incidente en sí mismo es de gran relevancia, sin embargo, si se dispone de UPS y grupo electrógeno que proporcionan la estabilidad y suministro eléctrico permanente, el impacto en la organización es imperceptible.
2. Incidente: un único PC de toda la central de compras presenta una avería en la fuente de alimentación. En este caso el incidente es muy pequeño, pero si la infraestructura eléctrica no es la adecuada, esa avería podría provocar una derivación de corriente eléctrica y podría dejar sin electricidad a todos los PCs de la planta del edificio, generando un gran **impacto** en la organización.

Fase 4: Gestión del Riesgo

En esta fase, ya se dispone de un mapa de niveles de riesgo relativo al ámbito de actuación. Es momento, por tanto, de separar aquellos riesgos que se consideran aceptables por la organización de aquellos otros que no son aceptables y que requieren en consecuencia, actuaciones específicas.

No olvidemos las cuatro opciones posibles a la hora de tratar los riesgos:

- **Mitigar el riesgo:** supone reducirlo implementando controles que hacen disminuir el nivel de riesgo hasta umbrales aceptables.
- **Asumir el riesgo:** esta circunstancia se puede dar por varios motivos. Bien porque el nivel de riesgo se sitúa por debajo del umbral de criticidad previamente establecido o bien porque las medidas necesarias para mitigarlo o eliminarlo son inasumibles desde el punto de vista técnico o económico.
- **Transferir el riesgo:** a través de Outsourcing, contratando un seguro, etc.
- **Eliminar el riesgo.**

Habitualmente se produce una combinación de varias de las opciones anteriores.

Fase 5: Selección de controles

Como hemos indicado, la norma de apoyo ISO/IEC 27002 aporta en su anexo A una relación detallada de controles a implementar para determinar las medidas de seguridad necesarias para el SGSI. Se trata de una relación no excluyente, por lo que si fuese necesario se pueden ampliar los controles más allá de los indicados en este anexo.

Fase 6: Declaración de Aplicabilidad

También llamada SOA (*Statement of Applicability*), se trata de un documento que ha de contener:

- Una lista de todos los controles seleccionados incluyendo los motivos que han llevado a su elección.
- La relación de controles actualmente implementados y la justificación de los mismos.
- La relación de controles que han sido excluidos de los existentes en el ANEXO A de la norma.

A través de este requisito, se resumen las decisiones tomadas en relación al tratamiento del riesgo.

Una vez finalizadas las etapas anteriores, se procede con el proceso de implementación.

Una vez que la organización da el visto bueno a la documentación generada en las etapas anteriores, se procederá a realizar de manera efectiva la implementación del SGSI. Durante este proceso se deben asignar dos roles de gran importancia para el éxito del despliegue:

- Un **responsable de seguridad**: coordinará el trabajo y será el punto de encuentro de todos los aspectos relacionados con la seguridad de la organización
- Un **comité de seguridad**: será el órgano encargado de buscar soluciones a problemas de seguridad, así como de aprobar directrices y normas

Para llevar a cabo la implementación se realizarán una serie de acciones que resumimos a continuación:

1. Definición del plan de tratamiento de riesgos: contendrá acciones de gestión, recursos, responsabilidades y prioridades para la gestión de riesgos de seguridad de la información.
2. Implantación del plan de tratamiento de riesgos.
3. Implementación de controles.
4. Formación y concienciación: La organización debe garantizar que todo el personal bajo el alcance del SGSI dispone de responsabilidades claras y definidas que les permiten ser competentes en las tareas asignadas.
5. Desarrollo del marco normativo necesario: incluirá normas, manuales, instrucciones y procedimientos.
6. Gestión de las operaciones del SGSI y de los recursos asignados.
7. Implantación de procedimientos y controles de detección y respuesta ante incidentes de seguridad.

Fase 7: Seguimiento y proceso de Mejora Continua

a. Seguimiento

La etapa de control y seguimiento del SGSI debe aportar información sobre el estado del despliegue y las posibles acciones correctoras necesarias.

En particular, debe contemplar las siguientes acciones:

1. **Ejecutar procedimiento y controles de monitorización y revisión**: nos permitirá detectar errores, identificar problemas e incidentes de seguridad, detectar si las actividades se están desarrollando según lo previsto, así como detectar y prevenir incidentes a través del uso de indicadores.
2. **Medir la eficacia del SGSI**: en base a auditorías de seguridad, medibles establecidos y *feedback* de los implicados.
3. **Medir la eficacia de los controles**: garantizando que se cumple con los requisitos de seguridad.
4. **Revisar la evaluación de riesgos**: la organización es un elemento dinámico y sus cambios tanto internos (tecnología, procesos, objetivos de negocio, etc.) como externos (nuevas amenazas, cambios en el contexto de negocio, etc.) pueden suponer una variación importante en los riesgos previamente evaluados.

5. **Realizar auditorías internas:** tienen el objetivo, entre otros, de comprobar si los controles, procesos y procedimientos del SGSI siguen alineados con los requisitos de la norma ISO 27001.

Estas auditorías deben caracterizarse por:

- Incluir procedimientos para su ejecución.
 - Tener carácter periódico.
 - Establecer requisitos específicos y medibles.
6. **Revisar periódicamente** el SGSI por la Dirección
 7. **Actualizar los planes de seguridad:** en base a la monitorización y las revisiones establecidas.
 8. **Registrar acciones** y eventos que afecten a la **eficacia** del SGSI.

b. Mejora continua

Como sistema de gestión, para garantizar su efectividad debe seguir un ciclo de mejora continua que permita su actualización en base a los errores y defectos detectados y las propuestas de mejora derivadas.

Como parte de este proceso de mejora continua, se detallan a continuación las acciones básicas a llevar a cabo:

- **Implantar mejoras:** puesta en marcha de todas aquellas mejoras que surgen del trabajo realizado en el apartado anterior (seguimiento)
- **Realizar acciones correctivas:** dan solución a las no conformidades detectadas. Esto incluye un procedimiento destinado a:
 - Identificar las no conformidades y sus causas.
 - Desplegar las acciones correspondientes.
 - Registrar los resultados.
 - Revisar la eficacia de las acciones.
- **Realizar acciones preventivas:** actuaciones para evitar que se produzca la No Conformidad.
- **Comunicación** de acciones y mejoras: difusión a todos los implicados.

3.5. Adecuación de la gestión según ISO 27000 al ENS

Como hemos visto, la normativa ISO 27000 está orientada al establecimiento de un SGSI, mientras que el ENS está orientado al cumplimiento de unos principios básicos y la implantación de unas medidas de seguridad concretas.

Aunque muchas medidas de seguridad del ENS coinciden con controles ISO 27002, el Esquema Nacional de Seguridad es más preciso y establece unas medidas de protección proporcionales a los bienes protegidos, lo que reduce la discrecionalidad. Además, el ENS contempla aspectos esenciales en la administración pública, por ejemplo, relativos a la firma electrónica, no recogidos en las normas ISO 27000.

Tabla 6.1. Adecuación de la gestión según ISO 27000 al ENS

Gestión en base a ISO/IEC 27000	Gestión en base al ENS
Tiene como objetivo el establecimiento de un sistema de gestión de la seguridad de la información.	Regula los principios básicos y define los requisitos mínimos.
El alcance del SGSI viene definido por la organización.	Afecta específicamente a los medios electrónicos utilizados por la Administración para relacionarse con los ciudadanos.
Se enfoca hacia los recursos de forma general, sin limitarse a los sistemas de información.	Se enfoca al sistema de información como conjunto organizado de recursos.
No obliga a la implantación de medidas de seguridad concretas.	Obliga a implantar un conjunto determinado de medidas de seguridad, en base a la categoría del sistema.
Obliga a la realización de auditorías periódicas.	Obliga a una auditoría cada 2 años de conformidad con el ENS, en los casos de sistemas de categoría media y alta.

Por otra parte, el ENS establece que en sistemas de categoría alta debería aplicarse un SGSI para poder satisfacer ciertos principios básicos, pero no exige que sea de tipo ISO 27000, si bien éste es aplicable.

Para finalizar, se muestra en la Tabla 6.1 un breve resumen de las principales diferencias entre la gestión de la seguridad de la información en base a la normativa ISO 27000 o basándose en los principios del ENS, de importancia para las organizaciones que tengan implantado un SGSI según la norma ISO 27001 y deban adecuarse al ENS, por ejemplo, por colaborar estrechamente con la administración pública española.

ACTIVIDADES

1. Realizar una búsqueda en Internet de las diferencias principales entre la antigua LOPD y la actual LOPDyGDD. Elaborar un informe original, basado en un mínimo de tres fuentes documentales y con extensión mínima de 5 páginas de texto.
2. Realizar una búsqueda en Internet de las principales diferencias y similitudes entre el cumplimiento del ENS y de la ISO 27001. Elaborar un informe original, basado en un mínimo de tres fuentes documentales, con extensión mínima de 3 páginas de texto.
3. Realizar un informe de la legislación indicada en esta unidad que es de aplicación en una empresa privada que gestiona un servicio de alojamiento web para clientes de ámbito privado y empresarial.
4. Realizar un informe de la legislación indicada en esta unidad que es de aplicación en una empresa pública que gestiona un servicio de soporte informático a usuarios de las universidades públicas de una comunidad autónoma.
5. De acuerdo con la Guía CCN-STIC 803 de categorización de sistemas del ENS, establecer la categorización de los servidores del Campus Virtual de la ULPGC.

BIBLIOGRAFÍA

Aceituno Canal, V. (2004). Seguridad de la información: expectativas, riesgos y técnicas. Madrid. Creaciones Copyright.

Areitio Bertolín, J. (2008). Seguridad de la información: redes, informática y sistemas de información. Madrid. Paraninfo.

Costas Santos, J. (2011). Seguridad y alta disponibilidad. Madrid. Ra-Ma.

Díaz Orueta, G., Mur Pérez, F. Sancristobal Ruiz, E. Castro Gil, M. Peire Arroba, J. (2004). Seguridad en las comunicaciones y en la información. Madrid. Universidad Nacional de Educación a Distancia.

Recursos en Internet

Centro Criptológico Nacional (CCN-CERT): <https://www.ccn-cert.cni.es/>

El portal de ISO 27001 en español: <http://www.iso27000.es>

Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.

Repositorio de Guías CCN-STIC: <https://www.ccn-cert.cni.es/guias/indice-de-guias.html>

Web oficial ITIL: <http://www.ital-officialsite.com/>

EJERCICIOS DE AUTOEVALUACIÓN

1. Qué ley española reemplaza actualmente a la antigua LORTAD:
 - a. Ley de firma electrónica.
 - b. Ley Orgánica de protección de datos personales.
 - c. Ley Orgánica de protección de datos personales y garantía de los derechos digitales.
 - d. Reglamento general europeo de protección de datos personales.
2. En qué niveles se categorizan los sistemas en el ENS:
 - a. Básica, Media y Alta.
 - b. Media, Alta y Muy Alta.
 - c. Básica, Media, Alta y Muy Alta.
 - d. En el ENS no se categorizan los sistemas, eso se hace en la ISO 27000.
3. ¿Qué es lo que ayuda a desarrollar la ISO 27001?
 - a. Un sistema de monitorización de redes.
 - b. Un sistema de gestión de seguridad de la información.
 - c. Un plan director de seguridad de la información.
 - d. Un sistema general de seguridad de la información.
4. El Esquema Nacional de Seguridad está regulado por...
 - a. La Constitución Española.
 - b. La Ley General de Telecomunicación.
 - c. La LOPDyGDD.
 - d. El Real Decreto 3/2010 de 8 de enero.
5. Qué carácter tienen las normas ISO 27001 y 27002:
 - a. Ambas son obligatorias y ambas son certificables.
 - b. Ambas son voluntarias y ambas son certificables.
 - c. Ambas son voluntarias y sólo la ISO 27001 es certificable.
 - d. Ambas son voluntarias y ninguna es certificable.

SOLUCIONES A LOS EJERCICIOS DE AUTOEVALUACIÓN

Pregunta de los Ejercicios de Autoevaluación	Respuesta Correcta
1	c
2	a
3	b
4	d
5	c

GLOSARIO

Directiva europea: disposición normativa de derecho comunitario que vincula a los estados de la Unión a la consecución de resultados u objetivos concretos en un plazo determinado, típicamente, su trasposición, es decir, la promulgación de una ley o decreto que recoja dichos objetivos.

Ley Orgánica: En el sistema jurídico español, las leyes orgánicas desarrollan derechos fundamentales y libertades públicas de la Constitución, su propio desarrollo y modificación, así como de los estatutos de autonomía y el régimen electoral. A diferencia de las leyes ordinarias, requieren mayorías cualificadas para su aprobación

IEC: International Electrotechnical Commission. Comisión electrotécnica internacional. Organización internacional de normalización en los campos eléctrico, electrónico y tecnologías relacionadas

ISO: International Standards Organization. Organización Internacional de Estándares. Organismo internacional independiente y no gubernamental formado por las organizaciones de estandarización de sus 163 países miembros)

Operador de servicios esenciales: entidad pública o privada que se identifique considerando los factores establecidos en el artículo 6 de este real decreto-ley, que preste dichos servicios en alguno de los sectores estratégicos definidos en el anexo de la Ley 8/2011, de 28 de abril. (Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

Servicio digital: servicio de la sociedad de la información, entendido en el sentido recogido en la letra a) del anexo de la Ley 34/2002, de 11 de julio, de servicios de la sociedad de la información y de comercio electrónico. (Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

PILAR: Herramienta promovida por el CCN-CERT para realizar el análisis de riesgos de sistemas de información según la metodología MAGERIT.

Real decreto: En el sistema jurídico español, es una norma jurídica que emana del poder ejecutivo (Gobierno) y tiene menor prelación que las normas con rango de Ley, que emanan del poder legislativo.

Servicio esencial: necesario para el mantenimiento de las funciones sociales básicas, la salud, la seguridad, el bienestar social y económico de los ciudadanos, o el eficaz funcionamiento de las Instituciones del Estado y las Administraciones Públicas, que dependa para su provisión de redes y sistemas de información. (Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.

UNE: Asociación Española de Normalización. Entidad privada sin fines lucrativos. UNE también hace referencia tanto al conjunto de normas y estándares creados por la antigua AENOR, como a las nuevas que desarrolla esta asociación. UNE representa en España a ISO, IEC y otros organismos internacionales.